

Metodologia ORION.
Formalny model oceny ryzyka informatycznego
w organizacjach nadzorowanych

Bartosz Lewandowski ¹¹

¹Department of Clinical Engineering, Academy of Silesia in Katowice

¹ORCID: 0009-0004-1158-0693

Spis treści

1	Preambuła	4
2	Wstęp	5
2.1	Postulat: Ocena Ryzyka Nadzorowanych Systemów Informatycznych . . .	6
3	Krajobraz regulacyjny	8
3.1	Krajowe ramy prawne cyberbezpieczeństwa i ochrony danych	8
3.1.1	Zakres obowiązków wynikający z ustawy o krajowym systemie cyberbezpieczeństwa z 2018 r.	8
3.1.2	Nowelizacja UKSC z 23 stycznia 2026 roku (implementacja NIS2) .	9
3.1.3	Ustawa o ochronie danych osobowych z 10 maja 2018 r.	10
3.1.4	Ustawa o zwalczaniu nieuczciwej konkurencji (1993)	11
3.1.5	Odpowiedzialność cywilna wg kodeksu cywilnego	11
3.1.6	Odpowiedzialność karna: Kodeks karny	12
3.1.7	Dyrektywa NIS2 jako fundament europejskiego cyberbezpieczeństwa	13
3.1.8	Nadzór i egzekwowanie przepisów	16
3.1.9	Odpowiedzialność zarządcza	17
3.1.10	Rejestracja i samoidentyfikacja	17
3.2	Regulacje związane z rynkiem finansowym	18
3.2.1	Prawo bankowe	18
3.3	Rozporządzenie DORA: cyfrowa odporność operacyjna sektora finansowego	19
3.4	Ochrona danych medycznych, regulacje prawne i nadzór	21
4	Konflikt jurysdykcji i suwerenność danych	23
4.1	Problem CLOUD Act i FISA 702	24
4.2	Suwerenność danych: Gaia-X, suwerenne chmury obliczeniowe i poufne przetwarzanie danych	24
4.3	Schrems I, II i konsekwencje dla transferu danych poza EOG	26
4.3.1	Umowa Safe Harbour (2000–2015)	27
4.3.2	Maximilian Schrems: Tło i strategia prawna	27
4.3.3	Schrems I: Unieważnienie zasad Safe Harbor	27
4.3.4	Schrems II: Tarcza Prywatności	28
4.3.5	Ramy ochrony prywatności danych (2023–obecnie)	28
4.3.6	Implikacje dla struktury ORION	29
4.4	Strategia legislacyjna UE: Data Act, EUCS i CADA	29
4.5	Przykładowe scenariusze konfliktu	32
4.5.1	Mechanizm telemetrii w systemie Windows	33
4.5.2	Scenariusz kumulacji ryzyka: Windows Server na Google Cloud, Microsoft Azure, AWS	33
4.5.3	Trzy warstwy ryzyka	33
4.5.4	Macierz wektorów dostępu	34
4.5.5	Rekomendacje dla środowisk regulowanych (NIS2 / DORA / RODO)	34

4.5.6	Wnioski	35
5	Ryzyka w praktyce: zagrożenia, konsekwencje i dobre praktyki	36
5.1	Shadow IT	37
5.2	Shadow AI	38
5.3	Edukacja jako fundament ochrony danych osobowych	39
5.4	Często występujące ryzyka związane z nieprawidłowym przetwarzaniem danych	41
6	ORION - Ocena Ryzyka Informatycznego Organizacji Nadzorowanych	45
6.1	Luka badawcza	45
6.2	Postulaty i cele ORION	48
6.3	Identyfikacja podmiotu audytowanego	49
6.4	Mechanizm walidacji jakości dowodów i odpowiedzi	50
6.4.1	Struktura pytań	50
6.4.2	Model dowodowy	51
6.4.3	Walidacja odpowiedzi	51
6.4.4	Skala jakości dowodów	51
6.4.5	Wpływ dowodu na wartość odpowiedzi	52
6.4.6	Walidacja krzyżowa oraz definicja konsensusu	53
6.4.7	Interpretacja rozbieżności	54
6.5	Definicje i aktorzy	54
6.5.1	Perspektywa	54
6.5.2	Obiekt	55
6.5.3	Atrybuty obiektów	57
6.5.4	Atrybut: dostępność systemu	57
6.5.5	Atrybut: poziom krytyczności	58
6.5.6	Atrybut: klasyfikacja utrzymania w chmurze	59
6.5.7	Atrybut: klasyfikacja atrybutu typów przetwarzanych danych	60
6.5.8	Atrybut: kraj pochodzenia	60
6.6	Plan ciągłości działania	61
6.7	Exit plan	62
7	Przeprowadzenie audytu ORION	64
7.1	Faza 1: Klasyfikacja podmiotu	64
7.1.1	Krok 1.1: Ustalenie reżimu regulacyjnego	64
7.2	Faza 2: Inwentaryzacja i klasyfikacja obiektów	65
7.2.1	Krok 2.1: Inwentaryzacja systemów	65
7.2.2	Krok 2.2: Identyfikacja bezpośrednich dostawców	66
7.2.3	Krok 2.3: Przypisanie atrybutów klasyfikacyjnych	66
7.2.4	Ankieta klasyfikacji atrybutu dostępności	66
7.2.5	Ankieta klasyfikacji atrybutu poziomu krytyczności	67
7.2.6	Ankieta klasyfikacji atrybutu utrzymania w chmurze	69
7.2.7	Ankieta klasyfikacji typu danych	71
7.3	Faza 3: Kwestionariusz szczegółowy i zbieranie dowodów	72
7.3.1	Warunkowe aktywowanie sekcji pytań	72
7.3.2	Sekcja organizacja	73
7.3.3	Sekcja dane poufne: osobowe, wrażliwe oraz tajemnice przedsiębiorstwa	76

7.3.4	Sekcja bezpieczeństwo techniczne	77
7.3.5	Sekcja bezpieczeństwo fizyczne	79
7.3.6	Sekcja system informatyczny	82
7.3.7	Sekcja usługi w chmurze	85
7.3.8	Sekcja Transfer Impact Assessment (TIA)	87
7.3.9	Sekcja dostawcy ICT	90
7.3.10	Sekcja exit plan	92
7.3.11	Sekcja plan ciągłości działania (BCP)	94
7.3.12	Sekcja koncentracja ryzyka	96
7.4	Faza 4: Obliczenie scoringu i propagacja ryzyka	97
7.4.1	Poziom 1: Wynik pytania	97
7.4.2	Poziom 2: Wynik sekcji	98
7.4.3	Poziom 3: Wynik obiektu	98
7.4.4	Poziom 4: Wynik podmiotu z propagacją ryzyka	99
7.4.5	Identyfikacja dostawców kluczowych	100
7.5	Faza 5: Raport końcowy i rekomendacje	101
7.5.1	Macierz zgodności	101
7.5.2	Graf ICT z oznaczeniami	102
7.5.3	Lista rekomendacji z priorytetami	104
7.5.4	Karta dostawców kluczowych	106
7.6	Wyniki audytu	107
7.6.1	Klasyfikacja podmiotu	107
7.6.2	Klasyfikacja atrybutu ekspozycji sieciowej	107
7.6.3	Klasyfikacja atrybutu poziomu krytyczności	108
7.6.4	Klasyfikacja atrybutu utrzymania w chmurze	109
7.6.5	Klasyfikacja atrybutu typów przetwarzanych danych	110
7.6.6	Klasyfikacja atrybutu kraju pochodzenia	110
7.6.7	Analiza aktywowanych sekcji pytań	110
7.6.8	Wyniki sekcji organizacja	112
7.6.9	Wyniki sekcji bezpieczeństwo techniczne	113
7.6.10	Wyniki sekcji bezpieczeństwo fizyczne	114
7.6.11	Wyniki sekcji system informatyczny	116
7.6.12	Wyniki sekcji usługi chmurowe	117
7.6.13	Wyniki sekcji dane poufne	118
7.6.14	Wyniki sekcji dostawcy ICT	119
7.6.15	Wyniki sekcji plan wyjścia z usługi (exit plan)	120
7.6.16	Wyniki sekcji plan ciągłości działania (BCP)	122
7.6.17	Podsumowanie wyników audytu i obliczenie S_{total}	123
8	Zakończenie	128
9	Słownik pojęć	130

1. Preambuła

Ocena Ryzyka Informatycznego Podmiotów Nadzorowanych, w skrócie zwana ORION, jest nową, wieloperspektywną metodą oceny zgodności systemów informatycznych, odpowiadającą na ograniczenia tradycyjnych podejść audytowych. Klasyczne audyty ICT opierają się na deklaracjach i samoocenie, pomijają perspektywę prawną lub traktują ją rozłącznie od technicznej, a w efekcie nie wykrywają rzeczywistych luk w zarządzaniu łańcuchem dostaw i zgodności z wymogami regulacyjnymi. ORION adresuje te luki przez integrację trzech niezależnych perspektyw oceny: prawnej, biznesowej i technicznej, połączoną z rygiem dowodowym i modelowaniem propagacji ryzyka. Metoda adresowana jest przede wszystkim do podmiotów objętych nadzorem regulacyjnym, instytucji finansowych, operatorów usług kluczowych oraz dostawców usług cyfrowych, dla których zgodność z wymogami DORA, NIS2 i RODO stanowi obowiązek prawny, a nie dobrowolny standard. Warto jednak wykorzystać metodę ORION również w pozostałych przedsiębiorstwach, traktując podnoszone przez metodologię wyzwania wynikające z implementacji DORA oraz NIS2 jako zestaw dobrych praktyk, równocześnie upewniając się, że działania podmiotu są zgodne z obowiązującymi przepisami np. w zakresie RODO.

Luka kompetencyjna na styku ocen rozwiązań informatycznych przez zespoły prawne oraz techniczne jest przyczyną nieprawidłowej klasyfikacji systemów informatycznych. Co więcej, organizacje nieprawidłowo zarządzają łańcuchem dostawców i poddostawców, nawet gdy są do tego zobowiązane przez rozporządzenie DORA (*Digital Operational Resilience Act*) oraz dyrektywę NIS2 (*Network and Information Security Directive 2*). Szczególnie jest to widoczne w relacjach z hiperskalerami objętymi jurysdykcją *Cloud Act* (*Clarifying Lawful Overseas Use of Data Act*), gdzie bardzo często pomija się ryzyka transferu danych do USA, co stoi w sprzeczności z RODO (Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679, ogólne rozporządzenie o ochronie danych).

Niniejsza publikacja przedstawia założenia teoretyczne metody ORION, opisuje jej strukturę klasyfikacyjną oraz ilustruje jej zastosowanie praktyczne na przykładzie wybranej organizacji.

2. Wstęp

Transformacja cyfrowa przedsiębiorstw i instytucji publicznych, postępująca intensywnie od końca XX wiek, zmieniła charakter ryzyk i wyzwań stawianych przed organizacjami. Systemy informatyczne przestały być wyłącznie narzędziami wspierającymi codzienną pracę, stały się jej elementem strategii przedsiębiorstw, bez którego realizacja procesów jest praktycznie niemożliwa. Dotyczy to w równym stopniu banku przetwarzającego miliony transakcji konsumentów, szpitala prowadzącego elektroniczną dokumentację medyczną pacjentów, operatora infrastruktury energetycznej zarządzającego siecią dystrybucyjną, uczelni i szkoły prowadzącej cyfrowe ewidencje postępów podopiecznych, firm produkcyjnych opierających ciągłość działania na cyfrowych algorytmach. We wszystkich tych przypadkach niedostępność systemu informatycznego awarią o ograniczonych skutkach, jest zdarzeniem operacyjnym, prawnym często niosącym negatywne skutki finansowe.

Ustawodawca zdefiniował standardy bezpieczeństwa opisane w przepisach prawa. Do kluczowych aktów prawnych, które wymagają prowadzenia szczegółowej analizy ryzyka, należą przede wszystkim Ustawa o Krajowym Systemie Cyberbezpieczeństwa¹ oraz Rozporządzenie w sprawie operacyjnej odporności cyfrowej sektora finansowego, potocznie zwane DORA.² Choć powyższe dokumenty jasno określają, kogo dotyczą ich zapisy, warto potraktować te publikacje jako uniwersalne źródło wiedzy. Wskazane w nich procedury oraz opisane wektory zagrożeń mogą pomóc zabezpieczyć każdą organizację przed skutkami cyberataków.

Równoległe z rosnącym uzależnieniem organizacji od technologii informatycznych rozwinął się złożony rynek dostawców, poddostawców i partnerów technologicznych, tworzący łańcuchy zależności ICT (*Information and Communications Technology*). Pojedyncza aplikacja biznesowa może dziś opierać się na wielu elementach dostarczanych przez szereg dostawców: platformach chmurowych, bibliotekach oprogramowania, usługach uwierzytelniania, systemach płatności, zewnętrznych centrach przetwarzania danych czy dostawcach łączności. Każde z tych elementów jest potencjalnym źródłem ryzyka, technicznego (awarii), prawnego (brak zgodności z obowiązującym prawem) i operacyjnego. To organizacja ponosi odpowiedzialność regulacyjną za skutki zdarzeń w całym tym łańcuchu, niezależnie od tego, czy posiada nad nim bezpośrednią kontrolę. Złożoność łańcuchów dostaw ICT sprawia, że ich pełna inwentaryzacja, ocena i nadzór są zadaniem, z którym większość organizacji radzi sobie niewystarczająco, nie z braku dobrej woli, lecz z braku odpowiednich narzędzi metodycznych.

Problem ten nabiera szczególnego wymiaru w kontekście intensywnej aktywności legislacyjnej europejskiego prawodawcy ostatniej dekady. Ochrona danych stanowi jeden z fundamentalnych elementów współczesnego porządku prawnego Unii Europejskiej. Dynamiczny rozwój technologii, w szczególności sztucznej inteligencji oraz gromadzenia in-

¹ Ustawa z dnia 5 lipca 2018 r. o krajowym systemie cyberbezpieczeństwa. Weszła w życie 28 sierpnia 2018 r. 2018 (dalej jako UKSC).

² Parlament Europejski i Rada Unii Europejskiej. Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA). Dz.Urz. UE L 333/1. Grudzień 2022. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX%3A32022R2554>.

formacji, a co za tym idzie szeroka cyfryzacja usług publicznych i prywatnych oraz rosnąca skala międzynarodowego przetwarzania danych osobowych sprawiły, że zagadnienie ochrony danych stało się przedmiotem prac legislacyjnych zarówno na poziomie unijnym, jak i krajowym. Unia Europejska oraz jej państwa członkowskie zwracają szczególną uwagę na jakość ochrony danych, uznając ją za istotny element ochrony praw jednostki, zaufania do gospodarki oraz bezpiecznego funkcjonowania społeczeństwa informacyjnego. Regulacje te, omówione szczegółowo w rozdziale *Krajobraz regulacyjny*, tworzą środowisko, w którym zgodność z prawem stała się warunkiem koniecznym prowadzenia działalności w sektorach takich jak finanse, ochrona zdrowia, energetyka czy transport. Niespełnienie wymogów wiąże się z sankcjami finansowymi wobec przedsiębiorstw, a odpowiedzialność za naruszenia spoczywa bezpośrednio na organach zarządczych podmiotów nadzorowanych.

W tym kontekście szczególnego znaczenia nabiera pytanie badawcze niniejszej monografii: w jaki sposób organizacja może w sposób wiarygodny, powtarzalny i oparty na obiektywnych dowodach ocenić rzeczywisty stan zgodności swoich systemów informatycznych i ich łańcucha dostawców z obowiązującymi wymogami prawnymi? Jest to teoretycznie proste pytanie. Praktyka audytowa i badawcza pokazuje bowiem, że istniejące metodyki, choć wartościowe w swoich dziedzinach, nie dają na nie zadowalającej odpowiedzi. Powstała więc luka, której wymiary nie były do tej pory szacowane, jednak luka jest realna, dotychczas nieadresowana, jednocześnie wskazuje na braki prawidłowej oceny zgodności zarządzania systemami informatycznymi. Deklarowana zgodność z wymagami regulatorów rynku często rozmija się z weryfikowalnym stanem faktycznym. Organizacja posiadają certyfikaty i polityki bezpieczeństwa, lecz nie potrafią wskazać, które konkretne systemy przetwarzają dane szczególnej kategorii, kto jest faktycznym poddostawcą kluczowej platformy chmurowej ani czy dostawca zewnętrzny kiedykolwiek był przedmiotem oceny zgodności. Zjawisko to, opisywane w literaturze anglojęzycznej jako *compliance theater*, wynika ze słabości systemów oceny opartych wyłącznie na deklaracjach i samoocenie. Jest ono równie szkodliwe, jak jawna niezgodność: daje organizacji fałszywe poczucie bezpieczeństwa.

2.1 Postulat: Ocena Ryzyka Nadzorowanych Systemów Informatycznych

Prezentowana praca opisuje metodologię Oceny Ryzyka Informatycznego Organizacji Nadzorowanych (ORION), oryginalny framework metodyczny zaprojektowany w celu wypełnienia opisanej luki. ORION nie jest kolejną implementacją istniejących standardów, nie zastępuje audytów ISO (*International Organization for Standardization*) czy NIST (*National Institute of Standards and Technology*), nie jest też systemem informatycznym w technicznym sensie tego słowa. Jest formalnie zdefiniowaną metodyką oceny zgodności systemów ICT i ich łańcucha dostaw, opartą na trzech innowacjach konceptualnych.

Fundamentem metodyki jest wieloperspektywiczność, którą można wytłumaczyć jako segmentację kompetencyjną. Celem jest rozdzielenie procesu oceny na płaszczyzny: prawną, biznesową (użytkową) oraz techniczną. Zapewnia to, że odpowiedzi udzielają wyłącznie osoby posiadające realne kompetencje w danej dziedzinie.

Kolejny istotny element to rygor dowodowy. Kluczem jest zastąpienie deklaratywności ocen weryfikacją artefaktów (logi, certyfikaty). System wprowadza mechanizm penalizacji scoringowej za brak materialnych dowodów, co eliminuje zjawisko fasadowej zgodności

(compliance theater).

Finalnie wynik mapowany do jako sieć powiązań w modelu grafowym. Dzięki algorytmom propagacji ryzyka, ORION pozwala wyliczyć, jak błędy poddostawcy wpływają na bezpieczeństwo i ciągłość działania podmiotu nadrzędnego.

DRAFT

3. Krajobraz regulacyjny

3.1 Krajobraz ramy prawne cyberbezpieczeństwa i ochrony danych

Polska, jako państwo członkowskie Unii Europejskiej, od lat aktywnie uczestniczy w budowaniu europejskiego systemu ochrony danych i cyberbezpieczeństwa. Punktem wyjścia dla krajowych regulacji w tym zakresie stało się wdrożenie unijnej dyrektywy NIS z 2016 roku,¹ która zobowiązała państwa członkowskie do ustanowienia krajowych norm cyberbezpieczeństwa. W odpowiedzi na te wymagania, Polska uchwaliła ustawę o krajowym systemie cyberbezpieczeństwa, przyjętą przez Sejm RP dnia 5 lipca 2018 roku i podpisaną przez Prezydenta RP dnia 1 sierpnia 2018 r., która weszła w życie 28 sierpnia 2018 r..²

3.1.1 Zakres obowiązków wynikający z ustawy o krajowym systemie cyberbezpieczeństwa z 2018 r.

Ustawa o krajowym systemie cyberbezpieczeństwa³ nakłada kompleksowe obowiązki przede wszystkim na operatorów usług kluczowych (*OUK*) oraz dostawców usług cyfrowych (*DUC*), działających w sektorach takich jak energetyka, transport, bankowość, ochrona zdrowia czy infrastruktura cyfrowa.

¹ *Dyrektywa Parlamentu Europejskiego i Rady (UE) 2016/1148 z dnia 6 lipca 2016 r. w sprawie środków na rzecz wysokiego wspólnego poziomu bezpieczeństwa sieci i systemów informatycznych na terytorium Unii*. 19 lipca 2016 (dalej jako Dyrektywa NIS).

²UKSC.

³UKSC.

Tabela 3.1: Główne obowiązki nałożone ustawą o KSC z 2018 r.

Obszar obowiązku	Opis
Zarządzanie ryzykiem	Regularna identyfikacja i ocena ryzyk cyberbezpieczeństwa; opracowanie i wdrożenie strategii ochrony adekwatnej do specyfiki działalności.
Środki techniczne i org.	Zapewnienie bezpiecznej eksploatacji systemów, w tym bezpieczeństwa fizycznego, kontroli dostępu oraz ciągłości świadczenia usług.
Monitorowanie i zgłaszanie incydentów	Bieżące monitorowanie systemów informatycznych; raportowanie incydentów do właściwych zesp. CSIRT (Zespół reagowania na incydenty bezpieczeństwa komputerowego) (CSIRT GOV, CSIRT NASK, CSIRT MON).
Dokumentacja	Opracowanie i przechowywanie przez co najmniej 2 lata dokumentacji dotyczącej cyberbezpieczeństwa systemu informacyjnego.
Audyty	Przeprowadzanie regularnych audytów bezpieczeństwa oraz szkoleń dla pracowników.
Współpraca z organami	Koordinacja działań z organami właściwymi ds. cyberbezpieczeństwa; udostępnianie wyników audytów w razie kontroli.

3.1.2 Nowelizacja UKSC z 23 stycznia 2026 roku (implementacja NIS2)

W dniu 23 stycznia 2026 r. Sejm uchwalił nowelizację ustawy o krajowym systemie cyberbezpieczeństwa,⁴ stanowiącą implementację unijnej dyrektywy NIS2⁵ do polskiego porządku prawnego. Ustawa została następnie podpisana przez Prezydenta RP, który jednocześnie skierował ją do Trybunału Konstytucyjnego, podnosząc wątpliwości dotyczące m.in. obowiązku wymiany sprzętu bez odszkodowania oraz sposobu podejmowania decyzji przez organy nadzorcze.

⁴Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw. 2026.

⁵Dyrektywa Parlamentu Europejskiego i Rady (UE) 2022/2555 z dnia 14 grudnia 2022 r. w sprawie środków na rzecz wysokiego wspólnego poziomu cyberbezpieczeństwa na terytorium Unii (NIS2). 27 grudnia 2022 (dalej jako Dyrektywa NIS2).

Tabela 3.2: Kluczowe zmiany wprowadzone nowelizacją UKSC z 2026 r.

Zmiana	Opis
Rozszerzenie zakresu podmiotowego	Poszerzenie katalogu branż i obniżenie progu wejścia do systemu
Obowiązek samoidentyfikacji	Organizacja samodzielnie ma obowiązek ustalić swój status, dokonać kwalifikacji i złożyć wniosków o wpis do właściwego wykazu.
Odpowiedzialność zarządcza	Odpowiedzialność przestaje być wyłącznie operacyjna i staje się elementem ładu korporacyjnego oraz osobistej odpowiedzialności członków zarządu.
Kary finansowe	Podmioty kluczowe: do 10 mln EUR lub 2% rocznego światowego obrotu; podmioty ważne: do 7 mln EUR lub 1,4% obrotu.
Odroczenie kar	Kary pieniężne za naruszenia mogą być nakładane dopiero po upływie 2 lat od wejścia w życie ustawy.
Modyfikacje definicji	Zawężenie definicji organizacji badawczej i doprecyzowanie zakresu podmiotowego wobec środowisk naukowych.

3.1.3 Ustawa o ochronie danych osobowych z 10 maja 2018 r.

Z punktu widzenia bezpieczeństwa, istotną ustawą w krajowym prawodawstwie jest Ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych,⁶ która stanowi akt wykonawczy wobec rozporządzenia RODO⁷ i reguluje m.in. zasady działania Prezesa Urzędu Ochrony Danych Osobowych (PUODO) jako krajowego organu nadzorczego, tryb postępowania przed tym organem, szczegółowe zasady przetwarzania danych oraz krajowe przepisy uzupełniające RODO tam, gdzie rozporządzenie pozostawia swobodę regulacyjną państwom członkowskim.

Odpowiedzialność administracyjna na gruncie RODO

Rozporządzenie RODO⁸ przewiduje dwustopniowy system administracyjnych kar pieniężnych (art. 83 RODO).

⁶ Ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych. Weszła w życie 25 maja 2018 r. 2018.

⁷ Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (ogólne rozporządzenie o ochronie danych). Stosowane od 25 maja 2018 r. 4 maja 2016 (dalej jako RODO).

⁸ RODO.

Tabela 3.3: Administracyjne kary pieniężne na mocy art. 83 RODO

Wysokość kary	Przykładowe naruszenia
Do 10 mln EUR lub 2% rocznego obrotu	Brak rejestru czynności przetwarzania; brak wyznaczenia inspektora ochrony danych w wymaganych przypadkach; brak współpracy z organem nadzorczym.
Do 20 mln EUR lub 4% rocznego obrotu	Złamanie podstawowych zasad przetwarzania danych; naruszenie praw osób, których dane dotyczą; nielegalny transfer danych do państw trzecich.

Organ nadzorczy dysponuje również wachlarzem środków nacisku (art. 58 RODO): ostrzeżenia i upomnienia, nakazanie spełnienia żądań osoby, której dane dotyczą, nakazanie dostosowania operacji przetwarzania do przepisów RODO, a w najpoważniejszych przypadkach, czasowe lub całkowite ograniczenie przetwarzania, w tym zakaz przetwarzania danych oraz nakaz ich usunięcia lub powiadomienia o naruszeniu.

3.1.4 Ustawa o zwalczaniu nieuczciwej konkurencji (1993)

Ustawa z dnia 16 kwietnia 1993 r. o zwalczaniu nieuczciwej konkurencji⁹ stanowi istotne uzupełnienie systemu ochrony danych, zwłaszcza w zakresie ochrony tajemnicy przedsiębiorstwa. Zgodnie z art. 11 u.z.n.k., czynem nieuczciwej konkurencji jest ujawnienie, wykorzystanie lub pozyskanie cudzych informacji stanowiących tajemnicę przedsiębiorstwa. Za tajemnicę przedsiębiorstwa uznaje się informacje techniczne, technologiczne, organizacyjne lub inne posiadające wartość gospodarczą, które nie są powszechnie znane i co do których przedsiębiorca podjął należyte środki w celu zachowania ich poufności.

W kontekście naruszeń danych i cyberbezpieczeństwa ustawa ta nabiera szczególnego znaczenia: wyciek danych stanowiących tajemnicę przedsiębiorstwa (np. w wynik ataku hakerskiego, działania niełojalnego pracownika lub wadliwego zabezpieczenia systemów) może jednocześnie stanowić naruszenie RODO oraz czyn nieuczciwej konkurencji z u.z.n.k. Ustawa przewiduje cywilnoprawne środki ochrony, w tym roszczenia o zaniechanie, usunięcie skutków, naprawienie szkody i wydanie bezpodstawnie uzyskanych korzyści.¹⁰

3.1.5 Odpowiedzialność cywilna wg kodeksu cywilnego

Odpowiedzialności z tytułu naruszenia przepisów o ochronie danych nie można rozpatrywać wyłącznie przez pryzmat RODO, kluczową rolę odgrywa tu również Kodeks cywilny.¹¹

⁹ Ustawa z dnia 16 kwietnia 1993 r. o zwalczaniu nieuczciwej konkurencji. Tekst jednolity: Dz.U. z 2003 r. Nr 153, poz. 1503 z późn. zm. 1993 (dalej jako u.z.n.k.).

¹⁰ u.z.n.k.

¹¹ Ustawa z dnia 23 kwietnia 1964 r. – Kodeks cywilny. Tekst jednolity: Dz.U. z 2023 r. poz. 1610 z późn. zm. 1964 (dalej jako k.c.).

Tabela 3.4: Reżimy odpowiedzialności cywilnej w obszarze ochrony danych

Podstawa prawna	Opis
Art. 415 k.c.: odpowiedzialność deliktowa	Administrator lub podmiot przetwarzający, który ze swojej winy wyrządził szkodę osobie fizycznej poprzez naruszenie zasad ochrony danych, zobowiązany jest do jej naprawienia. Przesłankami są: bezprawne działanie lub zaniechanie, wina, szkoda oraz związek przyczynowo-skutkowy.
Art. 23, 24 i 448 k.c.: dobra osobiste	Prywatność jest traktowana jako dobro osobiste. W razie jego naruszenia pokrzywdzony może żądać zaniechania naruszeń i zasądzenia zadośćuczynienia (sądy orzekają w zbiegu z art. 82 RODO).
Art. 82 ust. 4 RODO w zw. z k.c.: solidarność	Jeżeli w tym samym przetwarzaniu uczestniczy więcej niż jeden podmiot, odpowiadają oni solidarnie za całą szkodę, co zapewnia poszkodowanemu rzeczywiste uzyskanie odszkodowania.
Zbieg podstaw odpowiedzialności	Nałożenie kary przez PUODO nie zwalnia administratora z równoległej odpowiedzialności cywilnej wobec osób poszkodowanych.

3.1.6 Odpowiedzialność karna: Kodeks karny

Odrębnym, lecz komplementarnym reżimem jest odpowiedzialność karna przewidziana w Kodeksie karnym,¹² w szczególności w rozdziale XXXIII „Przestępstwa przeciwko ochronie informacji” (art. 265–269b k.k.).

¹² *Ustawa z dnia 6 czerwca 1997 r. – Kodeks karny*. Tekst jednolity: Dz.U. z 2024 r. poz. 17 z późn. zm. 1997 (dalej jako k.k.).

Tabela 3.5: Przestępstwa z zakresu ochrony informacji (art. 265–269b k.k.)

Przepis	Opis
Art. 267 k.k. hacking	Kara grzywny, ograniczenia wolności albo pozbawienia wolności do 2 lat za bezprawne uzyskanie dostępu do informacji poprzez przełamanie zabezpieczeń elektronicznych, podpięcie do sieci lub stosowanie oprogramowania szpiegującego; penalizowane również ujawnianie tak pozyskanych informacji.
Art. 268 i 268a k.k.	Niszczenie lub uszkodzanie danych informatycznych i udaremnianie osobie uprawnionej zapoznania się z informacją; kara do 3 lat pozbawienia wolności, a przy znacznej szkodzie majątkowej od 3 miesięcy do 5 lat.
Art. 269 k.k.: sabotaż komputerowy	Uszkodzenie danych informatycznych lub oprogramowania o szczególnym znaczeniu dla obronności lub bezpieczeństwa państwa; kara pozbawienia wolności od 6 miesięcy do 8 lat.
Art. 269a k.k.: zakłócenie systemu	Istotne zakłócenie pracy systemu komputerowego lub sieci teleinformatycznej przez transmisję, usunięcie lub zmianę danych; kara pozbawienia wolności od 3 miesięcy do 5 lat.
Art. 269b k.k.: narzędzia ataków	Wytwarzanie, pozyskiwanie lub udostępnianie narzędzi informatycznych przeznaczonych do popełnienia powyższych przestępstw.
Art. 23 u.z.n.k. (uzupełniająco)	Ujawnienie tajemnicy przedsiębiorstwa przez osobę zobowiązaną do jej zachowania, jeżeli wyrządza to poważną szkodę; kara grzywny, ograniczenia wolności albo pozbawienia wolności do 2 lat.

Warto podkreślić, że reżim karny funkcjonuje równolegle do odpowiedzialności administracyjnej (kary RODO/UKSC) i cywilnej, skazanie sprawcy nie eliminuje roszczeń odszkodowawczych poszkodowanych ani nie uchyla administracyjnych kar nałożonych na administratora danych^{13, 14}.

3.1.7 Dyrektywa NIS2 jako fundament europejskiego cyberbezpieczeństwa

Dyrektywa Parlamentu Europejskiego i Rady (UE) 2022/2555 z dnia 14 grudnia 2022 r., znana jako NIS2,¹⁵ reformuje unijny system cyberbezpieczeństwa. NIS2 uchyliła i zastąpiła dyrektywę NIS z 2016 r.,¹⁶ która okazała się niewystarczająca wobec wzrostu zagrożeń cybernetycznych oraz rosnącej zależności gospodarki i administracji od systemów informatycznych. Dyrektywa NIS2 weszła w życie 16 stycznia 2023 r., zaś państwa członkowskie zobowiązane były do dokonania jej transpozycji do krajowych porządków prawnych do 17 października 2024 r. W Polsce implementacji dyrektywy dokonała nowelizacja ustawy

¹³k.k.

¹⁴RODO.

¹⁵Dyrektywa NIS2.

¹⁶Dyrektywa NIS.

o Krajowym Systemie Cyberbezpieczeństwa z dnia 23 stycznia 2026 r..¹⁷

Zakres podmiotowy: podmioty kluczowe i ważne

Dyrektywa NIS2 odchodzi od dotychczasowego podziału na operatorów usług kluczowych i dostawców usług cyfrowych, dyrektywa definiuje nowe kategorie: podmioty kluczowe (ang. *essential entities*) oraz podmioty ważne (ang. *important entities*). Dyrektywą objęte są podmioty będące co najmniej średnim przedsiębiorstwem wg definicji MŚP¹⁸ (tj. zatrudniające min. 50 osób i osiągające obrót roczny powyżej 10 mln EUR), działające w sektorach wskazanych w załącznikach I i II do dyrektywy. Jednocześnie przewidziano szereg wyjątków, na mocy których dyrektywa stosuje się niezależnie od wielkości podmiotu.

Tabela 3.6: Sektory objęte dyrektywą NIS2 według kategorii podmiotów

Kategoria	Sektory (wybrane)
Podmioty kluczowe (załącznik I)	Energetyka (energia elektryczna, gaz, ropa, wodór); transport (lotniczy, kolejowy, wodny, drogowy); bankowość i infrastruktura rynków finansowych; ochrona zdrowia; woda pitna i ścieki; infrastruktura cyfrowa (IXP, DNS, usługi chmurowe, centra danych, sieci CDN); zarządzanie usługami ICT (B2B); administracja publiczna; przestrzeń kosmiczna.
Podmioty ważne (załącznik II)	Usługi pocztowe i kurierskie; gospodarka odpadami; produkcja i dystrybucja chemikaliów; produkcja i dystrybucja żywności; produkcja (wyroby medyczne, sprzęt elektroniczny, pojazdy); dostawcy usług cyfrowych (platformy handlowe, wyszukiwarki, serwisy społecznościowe); organizacje badawcze.

Zakresem dyrektywy nie są objęte podmioty administracji publicznej prowadzące działalność w dziedzinie bezpieczeństwa narodowego, obronności lub ścigania przestępstw, podmioty wyłączone ze stosowania rozporządzenia DORA¹⁹ (stosownie do art. 2 ust. 4 DORA), a także dostawcy świadczący usługi wyłącznie na rzecz zwolnionych organów administracji publicznej. Z obowiązku zwolnienia nie można jednak skorzystać wobec dostawców usług zaufania.

Obowiązki podmiotów kluczowych i ważnych

Dyrektywa NIS2 wprowadza identyczne obowiązki dla obu kategorii podmiotów (kluczowe oraz ważne), rozróżniając jedynie intensywność nadzoru i poziom kar. Obowiązki te mają

¹⁷ Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.

¹⁸ Ustawa z dnia 6 marca 2018 r. – Prawo przedsiębiorców. Dz.U. 2018 poz. 646. art. 7; ELI: <https://eli.gov.pl/eli/DU/2018/646/ogl.2018>. URL: <https://eli.gov.pl/eli/DU/2018/646/ogl.2018>.

¹⁹ Parlament Europejski i Rada Unii Europejskiej, Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).

być stosowane w sposób proporcjonalny do specyfiki, wielkości i poziomu narażenia danego podmiotu na ryzyko.

Podmioty muszą zaimplementować *System Zarządzania Bezpieczeństwem Informacji*, w tym zarządzania ryzykiem. Wymaga do opracowania, wdrożenia i testowania planów ciągłości działania (*BCP*) oraz politykę bezpieczeństwa łańcucha dostaw, polegającą na szacowaniu ryzyk współpracy w dostawcami oraz poddostawcami.

Każdy podmiot kluczowy i ważny zobowiązany jest do wdrożenia odpowiednich i proporcjonalnych środków technicznych, operacyjnych i organizacyjnych, obejmujących co najmniej:

Tabela 3.7: Minimalne środki zarządzania ryzykiem wymagane przez art. 21 NIS2

Obszar	Wymagania minimalne
Polityki bezpieczeństwa i analizy ryzyka	Opracowanie i wdrożenie polityk bezpieczeństwa systemów informatycznych; regularna ocena ryzyka uwzględniająca zagrożenia, prawdopodobieństwo i dotkliwość incydentów oraz skutki społeczne i gospodarcze.
Obsługa incydentów	Ustanowienie procedur wykrywania, analizy, reakcji i odtwarzania po incydentach bezpieczeństwa.
Ciągłość działania	Wdrożenie planów ciągłości działania (<i>BCP</i>) i odtwarzania po awarii (<i>DRP</i>), w tym zarządzanie kopiami zapasowymi i zarządzanie kryzysowe.
Bezpieczeństwo łańcucha dostaw	Ocena i zarządzanie ryzykiem ze strony dostawców i usługodawców ICT; stosowanie klauzul bezpieczeństwa w umowach z dostawcami.
Bezpieczeństwo sieci i systemów	Środki kontroli dostępu, uwierzytelnianie wieloskładnikowe (<i>MFA</i>), szyfrowanie danych w spoczynku i w transzycie, segmentacja sieci, zarządzanie podatnościami i aktualizacjami.
Szkolenia i świadomość	Regularne szkolenia dla zarządu i pracowników; organy zarządzające obowiązane do zatwierdzania środków zarządzania ryzykiem i odbycia wymaganych szkoleń.
Kryptografia i szyfrowanie	Wdrożenie polityk stosowania kryptografii i szyfrowania w odniesieniu do przetwarzanych danych i komunikacji.
Bezpieczeństwo zasobów ludzkich	Procedury zarządzania dostępem i polityki kontroli dostępu oparte na zasadzie najmniejszych uprawnień; bezpieczeństwo personelu.

Środki zarządzania ryzykiem muszą być zatwierdzone przez organ zarządzający podmiotu. W przypadku stwierdzenia niezgodności z wymaganiami dyrektywy, podmiot zobowiązany jest do bezzwłocznego wdrożenia środków naprawczych.

Zgłaszanie incydentów (art. 23 NIS2)

Podmioty kluczowe i ważne zobowiązane są do zgłaszania *poważnych incydentów* do właściwego zespołu CSIRT lub organu nadzorczego. Za poważny incydent uznaje się zdarzenie, które powoduje lub może spowodować znaczne zakłócenia operacyjne lub straty finansowe, albo wpływa na inne osoby lub organizacje powodując znaczne szkody.

Tabela 3.8: Harmonogram obowiązkowego raportowania incydentów na mocy art. 23 NIS2

Termin	Zakres informacji
Max. 24 h: wczesne ostrzeżenie	Niezwłoczne poinformowanie o poważnym incydencie z wskazaniem: czy incydent mógł być wywołany działaniem bezprawnym lub złym zamiarem; czy mógł wywrzeć wpływ transgraniczny.
Max. 72 h: zgłoszenie incyduentu	Pełna aktualizacja wczesnego ostrzeżenia z wstępną oceną incyduentu, jego dotkliwości i skutków oraz wskaźnikami integralności systemu. Dostawcy usług zaufania dokonują zgłoszenia w ciągu 24 h.
Na wniosek organu: sprawozdanie okresowe	Aktualizacje statusu w trakcie obsługi incyduentu, stosownie do żądań CSIRT lub właściwego organu.
Max. 1 miesiąc: sprawozdanie końcowe	Szczegółowy opis incyduentu, rodzaj zagrożenia i pierwotna przyczyna, zastosowane środki ograniczające ryzyko, transgraniczne skutki incyduentu. Jeżeli incydent trwa - w terminie miesiąca od jego zakończenia.

Podmioty mają również obowiązek poinformowania odbiorców usług o poważnych incydentach mogących negatywnie wpłynąć na świadczone usługi, a także o poważnych cyberzagrożeniach i środkach zaradczych, jakie mogą podjąć. Samo zgłoszenie incyduentu nie nakłada na podmiot zgłaszający zwiększonej odpowiedzialności prawnej.

3.1.8 Nadzór i egzekwowanie przepisów

Dyrektywa NIS2 wprowadza wyraźne rozróżnienie reżimów nadzoru w zależności od kategorii podmiotu.

Tabela 3.9: Różnice w nadzorze nad podmiotami kluczowymi i ważnymi

Aspekt	Podmioty kluczowe	Podmioty ważne
Charakter nadzoru	Nadzór ex ante (prewencyjny, ciągły) i ex post	Nadzór ex post (reaktywny, po incydencie lub sygnale)
Inspekcje i audyty	Regularne inspekcje na miejscu, zdalne audyty, testy	Inspekcje na żądanie, po stwierdzeniu naruszeń
Maks. kara administracyjna	Do 10 mln EUR lub 2% rocznego światowego obrotu	Do 7 mln EUR lub 1,4% rocznego światowego obrotu
Odpowiedzialność osobista	Możliwy zakaz pełnienia funkcji kierowniczych przez osoby fizyczne	Możliwy zakaz pełnienia funkcji kierowniczych przez osoby fizyczne

3.1.9 Odpowiedzialność zarządcza

Jedną z najistotniejszych zmian wprowadzanych dyrektywą NIS2 jest *bezpośrednia odpowiedzialność organów zarządzających* za przestrzeganie wymogów cyberbezpieczeństwa. Oznacza to, że członkowie zarządu i inne osoby pełniące funkcje kierownicze mogą być osobiście pociągnięci do odpowiedzialności za poważne naruszenia przepisów dyrektywy. Organy zarządzające podmiotów zobowiązane są do:

- (i) zatwierdzania środków zarządzania ryzykiem,
- (ii) nadzoru nad ich wdrożeniem,
- (iii) odbywania regularnych szkoleń z zakresu cyberbezpieczeństwa.

W skrajnych przypadkach właściwy organ może zwrócić się do właściwego sądu o tymczasowe zawieszenie osoby fizycznej w pełnieniu funkcji kierowniczej w danym podmiocie.

3.1.10 Rejestracja i samoidentyfikacja

Dyrektywa NIS2 wprowadza mechanizm *samoidentyfikacji*: to sam podmiot, a nie organ nadzorczy, ma obowiązek ustalić, czy mieści się w zakresie stosowania dyrektywy, a następnie dokonać rejestracji u właściwego organu, przekazując dane adresowe, kontaktowe, sektor i podsektor oraz wykaz państw członkowskich, w których świadczy usługi. O każdej zmianie tych danych podmiot zobowiązany jest do powiadomienia organu w terminie dwóch tygodni. W polskiej implementacji dokonanej Krajową Ustawą o Cyberbezpieczeństwie²⁰ termin na zgłoszenie przedsiębiorstwa do wykazu podmiotów kluczowych i ważnych wynosi 6 miesięcy od wejścia w życie ustawy, zaś na wdrożenie środków zarządzania ryzykiem 12 miesięcy.

²⁰ Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.

3.2 Regulacje związane z rynkiem finansowym

Rynek finansowy w Polsce podlega nadzorowi Komisji Nadzoru Finansowego (KNF). Do stycznia 2025 roku w kontekście bezpieczeństwa i odporności cyfrowej, podstawowym dokumentem obowiązującym banki była *Rekomendacja D KNF*.²¹ KNF wydaje rekomendacje na podstawie art. 137 pkt 5 ustawy Prawo bankowe z dnia 29 sierpnia 1997 roku, Rekomendacje to dokumenty o charakterze nadzorczym, działające na zasadzie „zastosuj albo wyjaśnij”, które definiuje i opisują oczekiwania KNF wobec instytucji finansowych w zakresie zarządzania ryzykiem, bezpieczeństwa IT oraz ochrony danych klientów. Formalnie nie są aktami prawnymi, w praktyce traktowane są przez nadzorowane podmioty jako wymogi, ponieważ ich niestosowanie skutkuje negatywną oceną w ramach Badania i Oceny Nadzorczej (BION).²²

Rekomendacja D została przyjęta uchwałą KNF nr 7/2013 z dnia 8 stycznia 2013 roku, następnie uchylona z dniem 17 stycznia 2025 r. i zastąpiona bezpośrednio stosowanym *Rozporządzeniem Parlamentu Europejskiego i Rady (UE) 2022/2554 z dnia 14 grudnia 2022 r. w sprawie operacyjnej odporności cyfrowej sektora finansowego i zmieniającym rozporządzenia (WE) nr 1060/2009, (UE) nr 648/2012, (UE) nr 600/2014, (UE) nr 909/2014 oraz (UE) 2016/1011*, powszechnie zwanym DORA (*Digital Operational Resilience Act*).²³

Wytyczne i dobre praktyki zawarte w Rekomendacji D zostały w większości zachowane i przeniesione do DORA oraz towarzyszących jej regulacyjnych standardów technicznych (RTS) i wykonawczych standardów technicznych (ITS) opracowanych przez Europejski Urząd Nadzoru Bankowego (EBA).

3.2.1 Prawo bankowe

Ustawa z dnia 29 sierpnia 1997 r. - *Prawo bankowe* to akt prawny uchwalony przez Sejm RP 29 sierpnia 1997 r., opublikowana w Dzienniku Ustaw 1997 nr 140 poz. 939, weszła w życie 1 stycznia 1998 roku. Od tamtej pory była wielokrotnie nowelizowana, aktualny tekst jednolity obejmuje zmiany wprowadzone m.in. przez przepisy implementujące dyrektywy unijne (CRD IV, PSD2, AML).

Art. 104 ustawy Prawo bankowe nakłada na bank, jego pracowników oraz wszystkich pośredników wykonujących czynności bankowe bezwzględny obowiązek zachowania tajemnicy bankowej, obejmuje ona wszelkie informacje o czynnościach bankowych uzyskane podczas negocjacji, zawierania i realizacji umowy z klientem, a więc m.in. salda rachunków, historię transakcji, dane o kredytach, zabezpieczeniach czy zdolności kredytowej. Ujawnienie tych informacji osobom trzecim jest dopuszczalne wyłącznie za pisemną zgodą klienta lub w ściśle określonych przypadkach przewidzianych przez prawo (np. na żądanie prokuratury lub organów podatkowych). W praktyce oznacza to, że każdy pod-

²¹Komisja Nadzoru Finansowego. *Rekomendacja D dotycząca zarządzania obszarami technologii informacyjnej i bezpieczeństwa środowiska teleinformatycznego w bankach*. Załącznik do uchwały nr 7/2013 Komisji Nadzoru Finansowego z dnia 8 stycznia 2013 r., Dz. Urz. KNF z 2013 r. poz. 5. Ogłoszona 27 lutego 2013 r. 2013. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/rekomendacja_d_8_01_13_uchwala_7_33016.pdf.

²²Urząd Komisji Nadzoru Finansowego. *Metodyka badania i oceny nadzorczej banków komercyjnych, zrzeszających oraz spółdzielczych (Metodyka BION)*. Urząd Komisji Nadzoru Finansowego, Warszawa, 12 lutego 2024 r. Dokument opisujący proces BION stosowany przez KNF. 2024. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/Metodyka_BION_2024.pdf.

²³Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

miot zewnętrzny, w tym dostawca chmury czy firma technologiczna któremu bank powierza przetwarzanie danych, przejmuje obowiązek zachowania tajemnicy bankowej i musi gwarantować jej nienaruszalność kontraktowo oraz technicznie.

3.3 Rozporządzenie DORA: cyfrowa odporność operacyjna sektora finansowego

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2022/2554, znane jako **DORA** (*Digital Operational Resilience Act*), weszło w życie 16 stycznia 2023 roku, a jego stosowanie stało się obowiązkowe od 17 stycznia 2025 roku. Rozporządzenie stanowi odpowiedź na rosnącą zależność sektora finansowego od technologii informacyjno-komunikacyjnych (ICT) oraz systematyczny wzrost liczby cyberincydentów dotyczących instytucje finansowe w całej Unii Europejskiej.²⁴

Rozporządzenie strukturyzuje obowiązki wokół pięciu wzajemnie powiązanych filarów, opisanych szczegółowo poniżej.

Filar I, Zarządzanie ryzykiem ICT

Pierwszy filar zobowiązuje instytucje finansowe do ustanowienia kompleksowych i udokumentowanych ram zarządzania ryzykiem ICT, za które odpowiedzialność ponosi bezpośrednio kierownictwo wyższego szczebla.²⁵ Ramy te muszą obejmować szczegółowy rejestr wszystkich aktywów ICT wspierających funkcje krytyczne, polityki bezpieczeństwa informacji, mechanizmy ciągłego monitorowania anomalii oraz plany ciągłości działania i odtwarzania po awarii. Podmiot finansowy zobowiązany jest do regularnego przeglądu i aktualizacji tych ram, a organ nadzoru może w każdej chwili zażądać ich udostępnienia.²⁶

Filar II, Zarządzanie incydentami ICT i ich raportowanie

Drugi filar wprowadza ujednolicone, rygorystyczne reguły klasyfikowania, rejestrowania i zgłaszania incydentów związanych z ICT. W przypadku wykrycia poważnego incydentu podmiot finansowy zobowiązany jest do przekazania wstępnego powiadomienia właściwemu organowi nadzorczemu w ciągu 4 godzin, raportu pośredniego w ciągu 72 godzin oraz raportu końcowego w ciągu miesiąca. Naruszenie bezpieczeństwa ICT prowadzące do wycieku danych osobowych podlega równolegle obowiązkowi zgłoszenia do UODO na podstawie art. 33 RODO, co czyni z DORA i RODO komplementarne reżimy sprawozdawcze.

²⁴Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

²⁵Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

²⁶*Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2022/2554 z dnia 14 grudnia 2022 r. w sprawie operacyjnej odporności cyfrowej sektora finansowego i zmieniające rozporządzenia (WE) nr 1060/2009, (UE) nr 648/2012, (UE) nr 600/2014, (UE) nr 909/2014 oraz (UE) 2016/1011 (DORA)*. 27 grudnia 2022. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32022R2554>.

Filar III, Testowanie cyfrowej odporności operacyjnej

Trzeci filar nakłada obowiązek regularnego, ustrukturyzowanego testowania odporności systemów ICT na zagrożenia. Co najmniej raz w roku podmioty finansowe muszą przeprowadzać testy obejmujące m.in. oceny podatności, testy scenariuszowe i testy penetracyjne. Duże, systemowo istotne instytucje zobowiązane są do wykonywania zaawansowanych testów penetracyjnych sterowanych zagrożeniami (*Threat-Led Penetration Testing, TLPT*) z udziałem zewnętrznych certyfikowanych podmiotów, przy czym zewnętrzny dostawca ICT musi w pełni współpracować przy ich przeprowadzaniu.

Filar IV, Zarządzanie ryzykiem zewnętrznych dostawców ICT

Czwarty filar stanowi najbardziej przełomowy element rozporządzenia. DORA nakłada bezpośrednie obowiązki na zewnętrznych dostawców ICT, w tym hiperscalerów chmurowych takich jak Google Cloud, Microsoft Azure czy Amazon Web Services, obejmując ich nadzorem jako *Critical ICT Third-Party Providers (CTPP)*. Instytucje finansowe muszą przeprowadzać ocenę ryzyka przed zawarciem każdej umowy z dostawcą ICT, a sama umowa musi zawierać postanowienia o prawie do audytu, lokalizacji przetwarzania danych, planach wyjścia (*exit strategy*) oraz minimalnych okresach przejściowych przy zmianie dostawcy.²⁷ Korzystanie z niezatwierdzonych narzędzi chmurowych (*shadow IT*) stanowi naruszenie tego filaru, a jednocześnie naruszenie zasady rozliczalności z art. 5 ust. 2 RODO.

Filar V, Wymiana informacji o cyberzagrożeniach

Piąty filar zachęca, a w określonych przypadkach zobowiązuje, podmioty finansowe do uczestnictwa w schematach wymiany informacji o zagrożeniach cybernetycznych, podatnościach i technikach ataku w ramach zaufanych społeczności sektorowych.²⁸ Celem jest budowanie zbiorowej odporności sektora: wczesne ostrzeżenie jednej instytucji o nowym wektorze ataku pozwala innym podmiotom na podjęcie środków zapobiegawczych zanim incydent zdąży się rozprzestrzenić. Uczestnictwo w takich schematach musi jednak odbywać się zgodnie z przepisami o ochronie danych osobowych oraz z zachowaniem tajemnicy zawodowej.²⁹

Sankcje

Za naruszenie rozporządzenia Wiodący Organ Nadzorczy może nakładać na krytycznych dostawców ICT kary w wysokości do 1% średniego dziennego światowego obrotu za każdy dzień naruszenia, przez okres do sześciu miesięcy. Dla podmiotów finansowych nadzorowanych przez KNF sankcje określa prawo krajowe wdrażające uprawnienia nadzorcze wynikające z rozporządzenia.³⁰

²⁷European Insurance and Occupational Pensions Authority (EIOPA). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna EIOPA. Informacje dotyczące wymogów DORA w zakresie zarządzania ryzykiem ICT, raportowania incydentów oraz wymiany informacji o zagrożeniach cybernetycznych. 2024. URL: https://www.eiopa.europa.eu/digital-operational-resilience-act-dora_en (dostęp 10.03.2025).

²⁸European Insurance and Occupational Pensions Authority (EIOPA), *Digital Operational Resilience Act (DORA)*.

²⁹Rozporządzenie DORA.

³⁰Komisja Nadzoru Finansowego (KNF). *Rozporządzenie DORA – strona tematyczna*. Serwis instytucjonalny KNF. Zbiór materiałów nadzorczych KNF dotyczących wdrożenia rozporządzenia (UE)

3.4 Ochrona danych medycznych, regulacje prawne i nadzór

Dane dotyczące zdrowia należą do szczególnej kategorii danych osobowych w rozumieniu art. 9 rozporządzenia (UE) 2016/679 (RODO),³¹ co oznacza, że ich przetwarzanie jest co do zasady zakazane, a wyjątki od tego zakazu są ściśle i enumeratywnie określone w przepisach.³² Do kategorii tej zalicza się wszelkie informacje o stanie zdrowia fizycznego lub psychicznego osoby, dane genetyczne i biometryczne, a także informacje pośrednie (takie jak numer recepty, historia wizyt lekarskich czy przynależność do grupy ubezpieczenia zdrowotnego) jeżeli pozwalają one na wyciągnięcie wniosków o stanie zdrowia danej osoby. Podwyższony reżim ochrony danych zdrowotnych uzasadniony jest ich szczególną wrażliwością: ujawnienie informacji o chorobie, leczeniu psychiatrycznym czy uzależnieniu może prowadzić do dyskryminacji w zatrudnieniu, wykluczenia z rynku ubezpieczeń lub stygmatyzacji społecznej.

Krajowe ramy prawne i wielość nadzorców

Ochrona danych medycznych w Polsce regulowana jest przez trzy nakładające się warstwy prawa, za których egzekwowanie odpowiadają odrębne organy nadzorcze.

- (i) Pierwszą warstwę stanowi RODO wraz z krajową ustawą o ochronie danych osobowych z 2018 roku. Nadzór nad jej przestrzeganiem sprawuje *Prezes Urzędu Ochrony Danych Osobowych (UODO)*, uprawniony do przeprowadzania kontroli w placówkach medycznych, wydawania decyzji nakazowych i nakładania kar administracyjnych sięgających 20 milionów euro lub 4% rocznego obrotu. Każda placówka medyczna przetwarzająca dane zdrowotne na dużą skalę, zobowiązana jest do wyznaczenia *Inspektora Ochrony Danych (IOD)*, który monitoruje zgodność przetwarzania z RODO, szkoli personel i pełni rolę punktu kontaktowego dla pacjentów oraz organu nadzoru.³³
- (ii) Drugą warstwę tworzy ustawa z dnia 6 listopada 2008 roku o prawach pacjenta i Rzeczniku Praw Pacjenta. Nadzór nad prawem pacjenta do dostępu do dokumentacji medycznej (art. 23–29 ustawy) sprawuje *Rzecznik Praw Pacjenta*, który rozpatruje skargi pacjentów i może kierować zalecenia do podmiotów leczniczych. Ustawa nakłada na każdy podmiot udzielający świadczeń zdrowotnych obowiązek prowadzenia, przechowywania i udostępniania dokumentacji medycznej w ściśle określony

2022/2554 (DORA). 2024. URL: https://www.knf.gov.pl/dla_ryнку/dora (dostęp 10.03.2025).

³¹RODO.

³² *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (Ogólne rozporządzenie o ochronie danych, RODO)*. W szczególności art. 9 dotyczący szczególnych kategorii danych osobowych (w tym danych zdrowotnych). 27 kwietnia 2016. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679>.

³³ *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. (RODO)*. W szczególności art. 37–39 RODO regulujące obowiązek wyznaczenia, zadania i pozycję Inspektora Ochrony Danych (IOD). 27 kwietnia 2016. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679>.

sposób, a dokumentacja ta podlega ochronie zarówno na podstawie ustawy, jak i RODO.³⁴

- (iii) Trzecią warstwę stanowi system akredytacji i nadzoru nad podmiotami leczniczymi, który sprawuje *Ministerstwo Zdrowia* we współpracy z *Narodowym Funduszem Zdrowia* oraz, w zakresie standardów informatycznych, *Centrum e-Zdrowia*, odpowiadające za systemy P1. Systemy P1 to centralny system e-zdrowia w Polsce, formalnie określany jako *Elektroniczna Platforma Gromadzenia, Analizy i Udostępniania Zasobów Cyfrowych o Zdarzeniach Medycznych*. Jest to państwowa platforma teleinformatyczna rozwijana przez Centrum e-Zdrowia, służąca do gromadzenia, przetwarzania i udostępniania danych o zdarzeniach medycznych oraz do obsługi usług takich jak e-recepta, e-skierowanie i wymiana EDM.³⁵

Europejska Przestrzeń Danych Zdrowotnych (EHDS)

Nową regulacją jest *Europejska Przestrzeń Danych Zdrowotnych* (*European Health Data Space, EHDS*), której rozporządzenie weszło w życie 26 marca 2025 roku.³⁶ EHDS tworzy ogólnounijne ramy pierwotnego i wtórnego wykorzystania elektronicznych danych zdrowotnych: pacjent uzyskuje prawo dostępu do swoich danych w standardowym europejskim formacie (*EEHRxF*), możliwość kontrolowania kto ma do nich wgląd oraz prawo do ograniczenia dostępu do wybranych części dokumentacji.³⁷ Pełne wdrożenie systemu przewidziane jest do 26 marca 2027 roku.³⁸

EHDS działa równolegle do RODO, nie zastępując go, lecz nadając sektorowi zdrowotnemu dodatkowy, sektorowy wymiar regulacyjny. Oznacza to, że placówki medyczne będą podlegać jednocześnie: RODO (nadzór UODO), ustawie o prawach pacjenta (nadzór Rzecznika Praw Pacjenta) oraz EHDS (nadzór krajowego organu ds. elektronicznych danych zdrowotnych, który Polska wyznaczy do 2027 roku). Naruszenie bezpieczeństwa systemu ICT przechowującego dane medyczne będzie tym samym incydentem, który należy raportować do wielu organów jednocześnie, analogicznie do zbieżności DORA i RODO w sektorze finansowym.

³⁴ Ustawa z dnia 6 listopada 2008 r. o prawach pacjenta i Rzeczniku Praw Pacjenta. W szczególności art. 23–29 regulujące prawo pacjenta do dokumentacji medycznej oraz obowiązki podmiotów leczniczych w zakresie jej prowadzenia, przechowywania i udostępniania. 6 listopada 2008. URL: <https://isap.sejm.gov.pl/isap.nsf/download.xsp/WDU20240000581/0/D20240581.pdf>.

³⁵ Centrum e-Zdrowia. *Systemy informacyjne w ochronie zdrowia – P1 (e-recepta, e-skierowanie) i krajowa infrastruktura elektronicznej dokumentacji medycznej*. Serwis instytucjonalny Centrum e-Zdrowia. Informacje o systemach P1, P2 oraz standardach informatycznych elektronicznej dokumentacji medycznej zarządzanych przez Centrum e-Zdrowia. 2024. URL: <https://www.cez.gov.pl> (dostęp 10.03.2025).

³⁶ Rozporządzenia EHDS (UE) 2025/327, daty wejścia w życie (26.03.2025 r.) oraz harmonogramu wdrożenia do 26.03.2027 r. Parlament Europejski. 2025. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/PDF/?uri=OJ:L_202500327 (dostęp 10.03.2025).

³⁷ Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2025/327 z dnia 11 lutego 2025 r. w sprawie Europejskiej Przestrzeni Danych Dotyczących Zdrowia i zmieniające rozporządzenie (UE) 2018/1724 i dyrektywę 2011/24/UE. Weszło w życie 26 marca 2025 r.; ustanawia EHDS jako ogólnounijne ramy pierwotnego i wtórnego wykorzystania elektronicznych danych zdrowotnych. 5 marca 2025. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32025R0327>.

³⁸ Rozporządzenia EHDS (UE) 2025/327, daty wejścia w życie (26.03.2025 r.) oraz harmonogramu wdrożenia do 26.03.2027 r.

4. Konflikt jurysdykcji i suwerenność danych

Informacja jest współczesną walutą, jest to bardzo popularne, jednocześnie prawdziwe stwierdzenie. Dane, które posiadają przedsiębiorstwa, uczelnie oraz rządy stanowią o sile gospodarczej i przewadze technologicznej. Nic więc dziwnego w działaniach, które mają na celu ochronę informacji przed nieautoryzowanym dostępem. Do szpiegostwa gospodarczego ze strony takich państw jak Rosja czy Chiny dochodziło od wielu lat,¹ ale nowością jest wykorzystywanie informacji i technologii przeciwko sojusznikom, gdy decyzje podejmowane nie podobają się jednej ze stron.

Flagowym przykładem była sytuacja związana z działaniami administracji amerykańskiej w stosunku do Międzynarodowego Trybunału Karnego w Hadze, a źródłem ich była decyzja sądu, której treść nie była zgodna z oczekiwaniami administracji Donalda Trumpa.

Sankcje USA wobec MTK przełożyły się na odcięcie dostępu do niektórych usług amerykańskich, w szczególności do usług Microsoft w odniesieniu do prokuratora Karima Khana, a także do ograniczeń finansowych i wizowych. Podstawę tych działań stanowił nakaz (*executive order*) USA z 5 lutego 2025 roku, przewidujący m.in. blokowanie majątku i aktywów oraz restrykcje wizowe wobec urzędników MTK i ich rodzin.²

Jednocześnie sankcje zostały rozszerzone w czerwcu 2025 na kolejne osoby, Reine Adelaide Sophie Alapini Gansou, sędzia MTK i druga wiceprezes MTK, oraz sędziowe Solomy Balungi Bossa, Luz del Carmen Ibáñez Carranza oraz Beti Hohler, sędzia MTK.

Decyzja zaostrza napięcie między USA a państwami popierającymi porządek oparty na prawie międzynarodowym. Najważniejszy efekt polityczny to osłabienie niezależności Trybunału przez pokazanie. Ta decyzja buduje precedens, że państwo może używać sankcji nie tylko wobec przeciwników geopolitycznych, lecz także wobec międzynarodowego sądu i osób współpracujących z nim. Taki precedens może zachęcać inne rządy do podobnych działań wobec instytucji międzynarodowych, gdy ich decyzje staną się politycznie niewygodne.

Incydent związany z odcięciem amerykańskich usług cyfrowych dla osób objętych sankcjami USA nie wydaje się stanowić jedynej przyczyny działań UE w obszarze suwerenności danych, lecz stał się katalizatorem politycznym wzmacniającym unijną debatę o ryzykach wynikających z zależności od dostawców podlegających jurysdykcji Stanów Zjednoczonych.

¹Johan Putter i Sascha-Dominik Bachmann. „Russia and China Expected to Renew Their Espionage Vigour”. W: *Journal on Baltic Security* 9.1 (2023), s. 1–31. DOI: 10.2478/jobs-2023-0001. URL: <https://journalonbalticsecurity.com/journal/JOBS/article/113/text>.

²The White House. *Imposing Sanctions on the International Criminal Court*. Luty 2025. URL: <https://www.whitehouse.gov/presidential-actions/2025/02/imposing-sanctions-on-the-international-criminal-court/> (dostęp 7.03.2026).

4.1 Problem CLOUD Act i FISA 702

Podstawą konfliktu prawnego w zakresie przetwarzania i wykorzystywania danych w chmurze oraz dostępu do nich przez władze Stanów Zjednoczonych są dwie amerykańskie ustawy: pierwsza to *Clarifying Lawful Overseas Use of Data Act* (CLOUD Act, 2018),³ druga to sekcja 702 ustawy *Foreign Intelligence Surveillance Act* (FISA 702).⁴ Obie regulacje pozwalają władzom amerykańskim na żądanie dostępu do danych przechowywanych przez przedsiębiorstwa podlegające pod amerykańską jurysdykcję, bez względu na to, gdzie dane te się znajdują.

Amerykański ustawodawca zdefiniował jurysdykcję w CLOUD Act, określając, że dotyczy ona podmiotu, a nie danych. Oznacza to, że Amazon, Microsoft i Google, które łącznie kontrolują około 70 procent europejskiego rynku usług w chmurze,⁵ mogą zostać zobowiązane nakazem sądowym do ujawnienia danych swoich klientów, nawet jeśli serwery znajdują się na terytorium Unii Europejskiej.⁶ Co istotne, ani osoba, której dane dotyczą, ani też żaden europejski organ nadzoru nie muszą być powiadamiani. Ustawa FISA 702 działa równolegle, upoważniając agencje wywiadowcze, bez nakazu, do gromadzenia komunikacji osób spoza Stanów Zjednoczonych.

4.2 Suwerenność danych: Gaia-X, suwerenne chmury obliczeniowe i poufne przetwarzanie danych

Europejską odpowiedzią na strukturalną zależność od dostawców spoza Unii Europejskiej jest opracowanie koncepcji **suwerenności danych cyfrowych**. Składa się ona z trzech wymiarów: rezydencja danych (*data residency*), suwerenność prawna (*data sovereignty*) oraz suwerenność operacyjna (*operational sovereignty*). Kluczowym problemem jest fakt, że fizyczna lokalizacja serwerów na terytorium Unii Europejskiej nie przesądza o jurysdykcji prawnej. Stąd UE podjęła szereg inicjatyw: inicjatywę GAIA-X, suwerenne chmury, poufne przetwarzanie.

Gaia-X

Inicjatywa Gaia-X, ogłoszona przez Niemcy i Francję w 2019 r. i formalnie zainicjowana przez Komisję Europejską w 2020 roku, ma na celu stworzenie interoperacyjnej, zdecentralizowanej infrastruktury danych zgodnej z europejskimi normami prawnymi i war-

³United States Congress. *Clarifying Lawful Overseas Use of Data Act (CLOUD Act)*. Pub. L. No. 115-141, div. V, 132 Stat. 348. 2018. URL: <https://www.congress.gov/115/plaws/publ141/PLAW-115publ141.pdf>.

⁴United States Congress. *Foreign Intelligence Surveillance Act, Section 702*. 50 U.S.C. §1881a; re-authorized most recently by the FISA Reform and Reauthorization Act of 2024. 1978. URL: <https://www.govinfo.gov/content/pkg/STATUTE-92/pdf/STATUTE-92-Pg1783.pdf>.

⁵Synergy Research Group. *European Cloud Providers' Local Market Share Holds Steady at 15%*. Market Report. 2023. URL: <https://www.srgresearch.com/articles/european-cloud-providers-local-market-share-now-holds-steady-at-15>.

⁶European Data Protection Board i European Data Protection Supervisor. *Initial Legal Assessment of the Impact of the US CLOUD Act on the European Union Legal Framework for Personal Data Protection*. Joint Response Annex. 2019. URL: https://www.edpb.europa.eu/sites/default/files/files/file2/edpb_edps_joint_response_us_cloudact_annex.pdf.

tościami.⁷ Jego główne cele to: zapewnienie użytkownikom pełnej kontroli nad swoimi danymi i ich wykorzystaniem, standaryzacja usług chmurowych w oparciu o otwarte standardy oraz stworzenie alternatywy dla dominujących trzech amerykańskich hiperskalerów: Amazon, Google oraz Microsoft.⁸

Realizacja projektu jest kontrowersyjna. Krytycy zauważają, że do konsorcjum Gaia-X dołączyli sami hiperskalerzy, Amazon, Google i Microsoft, co rodzi pytania i wątpliwości o faktyczną suwerenność usług w ramach inicjatywy.

Operator Chmury Krajowej (OChK)

Polska inicjatywa, czyli Operator Chmury Krajowej (OChK), jest poddawana podobnej krytyce jak Gaia-X. OChK jest spółką z ograniczoną odpowiedzialnością, w której po 50% udziałów posiadają PKO Bank Polski oraz Polski Fundusz Rozwoju (PFR), oba podmioty z dominującym udziałem Skarbu Państwa. Spółka została powołana w celu utworzenia suwerennego, krajowego środowiska chmurowego dla polskiego sektora publicznego i finansowego.

W roku 2019 OChK zawarł strategiczne partnerstwo z Google Cloud. W jego ramach OChK stał się certyfikowanym sprzedawcą usług Google w Polsce, a Google otworzył region chmurowy w Warszawie. Partnerstwo jest analogiczne do krytykowanego wejścia amerykańskich hiperskalerów do Gaia-X: OChK, który miał stanowić polską alternatywę dla dostawców spoza UE, stał się pośrednikiem sprzedaży ich usług.

OChK w październiku 2025 roku ogłosiło, że platforma „osiągnęła pełną suwerenność cyfrową zgodnie z definicją Cloud Sovereignty Framework Komisji Europejskiej” i że usługi podlegają „całkowitej kontroli podmiotów z UE oraz unijnemu prawu, bez krytycznych zależności od dostawców spoza Europy”.⁹ Twierdzenie to wymaga jednak zastrzeżenia: dotyczy ono własnej warstwy platformowej OChK, natomiast nie eliminuje faktu, że klienci korzystający za pośrednictwem OChK z usług Google Cloud w dalszym ciągu korzystają z infrastruktury podmiotu podlegającego prawu USA, w tym CLOUD Act i FISA 702. W praktyce OChK umożliwia dwa różne modele, usługi własne (suwerenne) oraz usługi Google dystrybuowane przez OChK, które są niesuwerenne w sensie prawnym, i to od odbiorcy usługi i wybranej przez niego konfiguracji zamówienia oraz świadomości użytkownika zależy, z którego modelu faktycznie korzysta.

Suwerenne chmury

Koncepcja suwerennej chmury odnosi się do oferty usług chmurowych, która gwarantuje, że dane pozostają pod prawną kontrolą jurysdykcji europejskiej. Jedyną drogą do prawdziwej suwerenności danych jest wybór dostawcy, który nie ma żadnych prawnych powiązań z jurysdykcją USA, czyli europejskich dostawców usług chmurowych całkowicie niezależnych od amerykańskich korporacji.

⁷Tristan Braud i in. „Scaling the Gaia-X Lighthouse: An Analysis of European Data Infrastructure”. W: *Proceedings of the 2021 IEEE International Conference on Cloud Engineering (IC2E)*. IEEE, 2021. URL: <https://publikationen.bibliothek.kit.edu/1000139020>.

⁸Braud i in., „Scaling the Gaia-X Lighthouse: An Analysis of European Data Infrastructure”.

⁹Operator Chmury Krajowej. *OChK osiągnął pełną suwerenność cyfrową zgodnie z Cloud Sovereignty Framework Komisji Europejskiej*. Komunikat prasowy. Październik 2025. URL: <https://chmura.gov.pl>.

Przetwarzanie poufne

Szyfrowanie danych w spoczynku i podczas przesyłania to wymóg stawiany przed przetwarzaniem poufnym *confidential computing*. Jego bazę stanowią *Zaufane Środowiska Wykonawcze* (TEE), sprzętowo izolowane środowiska, w których dane pozostają zaszyfrowane w czasie aktywnego przetwarzania, niedostępne ani dla hiperwizora, ani systemu operacyjnego, ani tym bardziej dla personelu dostawcy chmury.¹⁰

TEE chronią przed nieautoryzowanym i pozajurysdykcyjnym dostępem do danych podczas ich przechowywania, transmisji oraz podczas obliczeń.¹¹

Warto podkreślić, że takie podejście wpisuje się bezpośrednio w oczekiwania polskiego i europejskiego nadzoru finansowego. Komisja Nadzoru Finansowego już w Komunikacie Chmurowym z 2020 roku wymagała od podmiotów nadzorowanych, by informacje prawnie chronione były szyfrowane zawsze *at rest* oraz *in transit*,¹² a kontrola nad kluczami kryptograficznymi pozostawała po stronie instytucji finansowej, nie dostawcy chmury. Obowiązujące od stycznia 2025 r. rozporządzenie DORA idzie o krok dalej, nakładając wymóg kompleksowej polityki szyfrowania obejmującej dane *at rest*, *in transit*, a także *in use*, co jest bezpośrednim odniesieniem do scenariusza, w którym przetwarzanie poufne staje się nie tyle opcją, ile techniczną odpowiedzią na regulacyjne oczekiwania.^{13, 14}

Z perspektywy jurysdykcyjnej, szczególnie wynikającej z ryzyk CLOUD Act, poufne obliczenia umożliwiają techniczne egzekwowanie reguł dotyczących lokalizacji przetwarzania, operacje mogą być wykonywane wyłącznie w autoryzowanych geograficznie lokalizacjach (*powinowactwo lokalizacji*) i na dedykowanych hostach (*powinowactwo hosta*).¹⁵ Co ważne, choć sama technologia nie uchyla prawnych obowiązków dostawcy wynikających z amerykańskiej ustawy CLOUD Act, to utrudnia realizację ewentualnych nakazów dostępu, a przede wszystkim eliminuje ryzyko cichego dostępu operacyjnego ze strony dostawcy.

4.3 Schrems I, II i konsekwencje dla transferu danych poza EOG

Rozwiązania prawne regulujące zakres transferu danych osobowych między Unią Europejską, a Stanami Zjednoczonymi stanowią jeden z najważniejszych punktów w historii prawa o ochronie danych. Z perspektywy oceny ryzyka łańcuchów dostaw ICT, stanowi ona również przykład tego, jak strukturalna luka prawna może podważyć zgodność z przepisami tysięcy organizacji jednocześnie. Sekwencja zdarzeń zainicjowana przez jednego

¹⁰Sulaiman Almutairi i in., „Confidential Computing Using Trusted Execution Environments”. W: *International Journal of Advances in Internet of Big Data and Cloud Management System* 3.1 (2024). URL: <https://ijaibdcms.org/index.php/ijaibdcms/article/view/240>.

¹¹Almutairi i in., „Confidential Computing Using Trusted Execution Environments”.

¹²Urząd Komisji Nadzoru Finansowego. *Komunikat UKNF w sprawie przetwarzania przez podmioty nadzorowane informacji w chmurze obliczeniowej publicznej i hybrydowej*. Komunikat UKNF. Styczeń 2020. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/Komunikat_UKNF_Chmura_Obliczeniowa_68669.pdf.

¹³Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

¹⁴Komisja Europejska. *Commission Delegated Regulation (EU) 2024/1532 — RTS on ICT Risk Management Tools, Methods, Processes and Policies (DORA Article 15)*. Dz.Urz. UE. 2024. URL: https://ec.europa.eu/finance/docs/level-2-measures/dora-regulation-rts--2024-1532_en.pdf.

¹⁵Almutairi i in., „Confidential Computing Using Trusted Execution Environments”.

austriackiego studenta prawa doskonale ilustruje kategorię ryzyka, którą system ORION ma wykrywać i mierzyć.

4.3.1 Umowa Safe Harbour (2000–2015)

Podstawowym instrumentem regulującym transfer danych osobowych między UE a USA była decyzja Komisji 2000/520/WE, powszechnie znana jako *Umowa Safe Harbour*. Przyjęta 26 lipca 2000 roku ustawa ustanowiła mechanizm autocertyfikacji, w ramach którego amerykańskie firmy mogły dobrowolnie zobowiązać się do przestrzegania siedmiu zasad ochrony danych: powiadomienia, wyboru, dalszego przekazywania, bezpieczeństwa, integralności danych, dostępu i egzekwowania. Po dokonaniu autocertyfikacji uzyskiwały prawo do otrzymywania danych osobowych z państw członkowskich UE bez dalszego uzasadnienia prawnego.¹⁶

Mechanizm działał na podstawie oświadczeń składanych w Departamencie Handlu USA, a ramy dostępu do danych opierały się wyłącznie na dobrej wierze organizacji uczestniczących i teoretycznej możliwości egzekwowania zasad przez Federalną Komisję Handlu USA. W szczytowym okresie ponad 4500 amerykańskich firm, w tym Facebook, Google, Microsoft i Amazon, działało na podstawie certyfikatu Safe Harbour, który stanowił podstawę prawną dla zdecydowanej większości komercyjnych przepływów danych między UE a USA..¹⁷

4.3.2 Maximilian Schrems: Tło i strategia prawna

Maximilian Schrems, jest austriackim prawnikiem, działaczem na rzecz ochrony prywatności i założycielem organizacji pozarządowej *noyb* (None of Your Business), zajmującej się egzekwowaniem europejskich przepisów o ochronie danych. W wyniku działania Schremsa sprawę do Trybunału Sprawiedliwości Unii Europejskiej (TSUE) z wnioskiem o wydanie orzeczenia w trybie prejudycjalnym.

4.3.3 Schrems I: Unieważnienie zasad Safe Harbor

6 października 2015 roku TSUE wydał wyrok w sprawie C-362/14, *Maximillian Schrems przeciwko Komisarzowi Ochrony Danych*, powszechnie znanej jako *Schrems I*.¹⁸ Trybunał orzekł nieważność decyzji Komisji 2000/520/WE ze skutkiem natychmiastowym. Orzeczenie opierało się na dwóch zasadniczych podstawach. Po pierwsze, Trybunał orzekł, że pierwszeństwo przyznane wymogom bezpieczeństwa narodowego, interesu publicznego i egzekwowania prawa USA nad zasadami Safe Harbor oznaczało, że amerykańskie firmy były systematycznie uprawnione, a w praktyce zmuszone, do odchodzenia od tych zasad,

¹⁶Komisja Europejska. *Decyzja Komisji 2000/520/WE z dnia 26 lipca 2000 r. wydana na podstawie dyrektywy 95/46/WE Parlamentu Europejskiego i Rady w sprawie adekwatności ochrony przewidzianej przez zasady „bezpiecznej przystani” oraz związane z nimi najczęściej zadawane pytania, wydane przez Departament Handlu Stanów Zjednoczonych*. Dz.U. L 215 z 25.08.2000, s. 7–47. 2000.

¹⁷Komisja Europejska, *Decyzja Komisji 2000/520/WE z dnia 26 lipca 2000 r. wydana na podstawie dyrektywy 95/46/WE Parlamentu Europejskiego i Rady w sprawie adekwatności ochrony przewidzianej przez zasady „bezpiecznej przystani” oraz związane z nimi najczęściej zadawane pytania, wydane przez Departament Handlu Stanów Zjednoczonych*.

¹⁸Trybunał Sprawiedliwości Unii Europejskiej. *Wyrok z dnia 6 października 2015 r., Maximillian Schrems przeciwko Data Protection Commissioner, C-362/14*. ECLI: EU:C:2015:650. Schrems I. 2015.

ilekroć wymagało tego prawo amerykańskie. Ramy, które mogą zostać uchylone przez suwerenne prawo państwa odbiorcy, nie mogą stanowić odpowiedniego poziomu ochrony w rozumieniu dyrektywy o ochronie danych.

Po drugie, Trybunał stwierdził, że obywatele UE, których dane zostały przekazane do Stanów Zjednoczonych, nie mieli skutecznego środka odwoławczego ani administracyjnego, aby egzekwować swoje prawa wobec władz USA. Brak jakiegokolwiek mechanizmu umożliwiającego osobom z UE, których dane dotyczą, uzyskanie dostępu, poprawienie lub usunięcie danych przechowywanych przez amerykańskie agencje wywiadowcze, był nie do pogodzenia z podstawowym prawem do skutecznej ochrony sądowej zapisanym w artykule 47 Karty praw podstawowych UE.

4.3.4 Schrems II: Tarcza Prywatności

W odpowiedzi na wyrok w sprawie Schrems I, Komisja Europejska i Departament Handlu USA wynegocjowały nowe ramy prawne, Tarczę Prywatności UE–USA, która weszła w życie 12 lipca 2016 roku.

Schrems natychmiast zakwestionował Tarczę Prywatności, argumentując, że nie rozwiązała ona fundamentalnych braków strukturalnych zidentyfikowanych w sprawie Schrems I. 16 lipca 2020 r. TSUE potwierdził tę ocenę w sprawie C-311/18, *Data Protection Commissioner przeciwko Facebook Ireland Limited i Maximillian Schrems*, zwanej dalej *Schrems II*.¹⁹ Sąd unieważnił Tarczę Prywatności z zasadniczo tych samych powodów, co Safe Harbor: amerykańskie prawo dotyczące nadzoru (w szczególności art. 702 ustawy o nadzorze nad wywiadem zagranicznym (FISA)) oraz rozporządzenie wykonawcze 12333, nadal zezwalały na masowe gromadzenie danych obywateli UE bez odpowiednich ograniczeń, niezależnego nadzoru lub skutecznych mechanizmów dochodzenia roszczeń.

Sprawa Schrems II miała jednak szersze znaczenie niż samo unieważnienie Tarczy Prywatności. Trybunał wydał również niezwykle istotne wytyczne dotyczące standardowych klauzul umownych (SCC), orzekając, że eksporterzy i importerzy danych powołujący się na standardowe klauzule umowne są zobowiązani do oceny, w każdym indywidualnym przypadku, czy prawo kraju przeznaczenia zapewnia odpowiednią ochronę w praktyce, a nie tylko w teorii. Ten obowiązek, Ocena Skutków Przenoszenia (TIA), stał się nowym, obowiązkowym elementem zgodności dla każdej organizacji przekazującej dane osobowe poza EOG i jest on również istotnym aspektem w modelu ORION.

4.3.5 Ramy ochrony prywatności danych (2023–obecnie)

Po trzech latach intensywnych negocjacji Komisja Europejska przyjęła 10 lipca 2023 roku *Ramy ochrony prywatności danych UE–USA (DPF)* w formie *Decyzji wykonawczej Komisji (UE) 2023/1795*.²⁰ DPF wprowadził nowy mechanizm odwoławczy: Sąd ds. Ochrony Danych (DPRC), mający na celu zapewnienie obywatelom UE wiążącego środka odwoławczego w przypadku bezprawnego gromadzenia informacji wywiadowczych.

¹⁹Trybunał Sprawiedliwości Unii Europejskiej. Wyrok z dnia 16 lipca 2020 r., *Data Protection Commissioner przeciwko Facebook Ireland Ltd i Maximillian Schrems*, C-311/18. ECLI: EU:C:2020:559. Schrems II. 2020.

²⁰Komisja Europejska. *Decyzja wykonawcza Komisji (UE) 2023/1795 z dnia 10 lipca 2023 r. wydana na podstawie rozporządzenia (UE) 2016/679 Parlamentu Europejskiego i Rady w sprawie odpowiedniego poziomu ochrony danych osobowych na podstawie ram ochrony danych UE–USA*. Dz.U. UE L 231 z 20.09.2023. dokument C(2023) 4745. 2023.

DPF stanowi obecnie główną podstawę prawną przekazywania danych osobowych między UE a USA. Jednakże już Maximillian Schrems zapowiedział dalsze postępowanie sądowe kwestionujące DPF przed sądami europejskimi, argumentując, że DPRC nie stanowi niezależnego organu sądowego w rozumieniu wymaganym przez orzecznictwo TSUE i że sekcja 702 ustawy FISA pozostaje niezmienną w swoich najbardziej problematycznych aspektach.

4.3.6 Implikacje dla struktury ORION

Wyroki będące skutkiem działań Schremsa niosą bezpośrednie implikacje dla metodologii ORION. Decyzje sądów wskazują, że ryzyko regulacyjne związane z geograficznym pochodzeniem dostawcy ICT jest problemem realnym, który musi być przez dostawców usług ICT brany pod uwagę.

W modelu ORION ryzyko to jest wyliczane. Dostawcy geograficznie lokalizowani poza EOG uruchamiają obowiązkowy zestaw pytań audytowych obejmujących aktualną podstawę prawną transferu danych, istnienia *Oceny Skutków Transferu (TIA)* oraz weryfikacji postanowień umów regulujących wnioski rządowe o dostęp do danych. Historia Safe Harbor, Privacy Shield i ciągła niepewność związana z DPF stanowią zatem empiryczne uzasadnienie dla jednej z kluczowych decyzji projektowych ORION: klasyfikacji pochodzenia geograficznego jako ryzyka kluczowego.

4.4 Strategia legislacyjna UE: Data Act, EUCS i CADA

Europejska odpowiedź na ryzyko jurysdykcyjne ewoluje z poziomu inicjatyw przemysłowych (Gaia-X) w stronę wiążących instrumentów prawnych, tworzących załączek spójnego ekosystemu suwerenności cyfrowej. Trzy wzajemnie uzupełniające się inicjatywy: *EU Data Act*, *EUCS* oraz *Cloud and AI Development Act* adresują kolejno: prawa dostępu do danych i ich przenoszalność, certyfikację bezpieczeństwa dostawców chmury oraz budowę europejskiej infrastruktury obliczeniowej.

EU Data Act (Rozporządzenie 2023/2854)

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2023/2854, powszechnie znane jako *EU Data Act*, zostało opublikowane w Dzienniku Urzędowym UE 22 grudnia 2023 r. i stało się w pełni stosowane od 12 września 2025 r.²¹ Regulacja wprowadza dwa mechanizmy bezpośrednio adresujące ryzyko jurysdykcyjne:

- (i) Po pierwsze, art. 31 Data Act nakłada na dostawców usług przetwarzania danych obowiązek wdrożenia środków technicznych i organizacyjnych uniemożliwiających organom państw spoza Europejskiego Obszaru Gospodarczego dostęp do danych przechowywanych w UE bez ważnej podstawy w prawie międzynarodowym lub w umowie między UE a danym państwem trzecim.²² Przepis ten nie uchyla obowiązków dostawcy wynikających bezpośrednio z prawa państwa jego inkorporacji

²¹Parlament Europejski i Rada Unii Europejskiej. *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2023/2854 z dnia 13 grudnia 2023 r. w sprawie zharmonizowanych przepisów dotyczących sprawiedliwego dostępu do danych i ich wykorzystywania oraz w sprawie ich zmiany*. Stosowane od 12 września 2025 r. 22 grudnia 2023. URL: <https://data.europa.eu/eli/reg/2023/2854/oj> (dostęp 21.03.2026) (dalej jako Data Act).

²²Data Act.

(takich jak CLOUD Act), lecz nakłada na dostawcę obowiązek aktywnego kwestionowania wniosków uznanych za sprzeczne z prawem unijnym i powiadamiania klienta.

- (ii) Po drugie, Data Act zakazuje z dniem 12 stycznia 2027 r. pobierania opłat za przełączenie dostawcy (*switching fees*) i ekstrakcję danych, co bezpośrednio ogranicza ryzyko uzależnienia od jednego hiperskalera (*vendor lock-in*) identyfikowane przez EBA i Parlament Europejski.²³

Europejski Schemat Certyfikacji Bezpieczeństwa Chmury (EUCS)

Europejski Schemat Certyfikacji Bezpieczeństwa Chmury (*European Cybersecurity Certification Scheme for Cloud Services*, EUCS), opracowywany przez Agencję Unii Europejskiej ds. Cyberbezpieczeństwa (ENISA) na podstawie unijnego *Aktu o Cyberbezpieczeństwie* (Rozporządzenie 2019/881), definiuje trzy poziomy zapewnienia: *Basic*, *Substantial* i *High*.²⁴ Projekt przewidywał również poziom *High+*, który wprowadzałby wymogi jurysdykcyjne, rezydencję danych, personel operacyjny z EOG i brak wiążących powiązań korporacyjnych z podmiotami spoza EOG, jako warunek certyfikacji dla usług krytycznych.²⁵

Brak politycznego porozumienia wśród państw członkowskich co do poziomu *High+* jest jednym z głównych czynników blokujących wdrożenie suwerennej oferty chmurowej dla sektora finansowego i publicznego i stanowi potwierdzenie tezy, że samo umieszczenie serwerów na terytorium UE nie przesądza o jurysdykcji prawnej. Z perspektywy zgodności z DORA oznacza to, że instytucje finansowe nie dysponują dotychczas uzgodnionym, zharmonizowanym poziomem odniesienia dla oceny suwerenności dostawcy ICT na poziomie unijnym.

Cloud and AI Development Act (CADA)

W dniu 3 czerwca 2026 r. Komisja Europejska złożyła wniosek legislacyjny dotyczący *Cloud and AI Development Act* (CADA), COM(2026) 502.²⁶ Inicjatywa ta, zapowiadana wcześniej w programie prac Komisji na rok 2026²⁷ i analizowana przez Europejskie Biuro Badań Parlamentarnych (EPRS) już w grudniu 2025 roku,²⁸ stanowi najdalej idące narzędzie prawne w arsenale unijnej suwerenności cyfrowej.

²³Data Act.

²⁴European Union Agency for Cybersecurity (ENISA). *EUCS – Cloud Services Scheme: Draft Candidate Scheme for the European Cybersecurity Certification of Cloud Services*. Draft Candidate Scheme. ENISA, 2022. URL: <https://www.enisa.europa.eu/publications/eucs-cloud-service-scheme> (dostęp 21.03.2026).

²⁵European Union Agency for Cybersecurity (ENISA), *EUCS – Cloud Services Scheme: Draft Candidate Scheme for the European Cybersecurity Certification of Cloud Services*.

²⁶Komisja Europejska. *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*. Czerwiec 2026. URL: <https://digital-strategy.ec.europa.eu/pl/library/proposal-cloud-and-ai-development-act-cada> (dostęp 11.06.2026).

²⁷Komisja Europejska. *Commission Work Programme 2026*. Inicjatywa Cloud and AI Development Act (CADA) zapowiedziana na I kwartał 2026 r.; wniosek złożony 3 czerwca 2026 jako COM(2026) 502; podstawa prawna: art. 114 TFUE. 2025. URL: https://commission.europa.eu/document/09579818-64a6-4dd5-9577-446ab6219113_en (dostęp 21.03.2026).

²⁸European Parliamentary Research Service (EPRS). *Cloud and AI Development Act*. Sprawozdanie techniczne EPRS_BRI(2025)779251. Europejski Parlament – EPRS, grudzień 2025. URL: [https://www.europarl.europa.eu/thinktank/en/document/EPRS_BRI\(2025\)779251](https://www.europarl.europa.eu/thinktank/en/document/EPRS_BRI(2025)779251) (dostęp 21.03.2026).

CADA wyrasta bezpośrednio z rekomendacji raportu Draghiego z 2024 r., który wskazał strukturalną zależność UE od nieeuropejskich dostawców chmury jako ryzyko strategiczne dla konkurencyjności europejskiej gospodarki.²⁹ Wniosek legislacyjny opiera się na trzech filarach:

- (i) rozbudowie europejskiej infrastruktury obliczeniowej, obejmującej tzw. *AI Gigafactories*, czyli dużych centrów superobliczeniowych dedykowanych trenowaniu modeli sztucznej inteligencji,
- (ii) ustanowieniu europejskiego systemu oceny i certyfikacji dostawców chmury i AI, powiązanego z preferencjami w zamówieniach publicznych dla dostawców spełniających kryteria zgodności,
- (iii) wzmocnieniu europejskiej niezależności infrastrukturalnej przez mechanizmy prawne ograniczające ryzyko pozajurysdykcyjnego dostępu do danych.

Podstawą prawną wniosku jest art. 114 Traktatu o Funkcjonowaniu Unii Europejskiej (TFUE), a projekt przewiduje możliwość nałożenia kar finansowych za niezgodność z wymaganiami.³⁰

Definicja suwerenności chmury jako oś konfliktu. Kluczowym nierozstrzygniętym zagadnieniem CADA jest definicja *suwerennej chmury*. Projekt przekształca cyfrową suwerenność z politycznej deklaracji w wiążący wymóg prawny, jednak nie przesądza, jak ściśle mają być kryteria kwalifikacji. Zarysowały się dwa stanowiska. Po pierwsze, **definicja wąska** (popierana m.in. przez Francję i grupę lobby CISPE): suwerenność wymaga pełnej europejskiej kontroli kapitałowej nad dostawcą, co w praktyce wyklucza z zamówień publicznych podmioty kontrolowane przez korporacje spoza EOG. Po drugie, **definicja szeroka**: suwerenność oceniana jest na podstawie faktycznych gwarancji prawno-technicznych (rezydencji danych, szyfrowania i braku dostępu operacyjnego podmiotu macierzystego) niezależnie od struktury właścicielskiej.

Spór ten ma bezpośrednie implikacje rynkowe. Przyjęcie wąskiej definicji oznaczałoby de facto ograniczenie dostępu do rynku zamówień publicznych dla Amazon Web Services, Microsoft Azure i Google Cloud, które łącznie kontrolują około 70% europejskiego rynku chmury.³¹ CADA działałby wówczas jako nieformalna bariera regulacyjna wobec podmiotów objętych jurysdykcją CLOUD Act i FISA 702. Szerokie kryterium pozwoliłoby natomiast hiperskalersom na zachowanie dostępu do rynku publicznego przez joint ventures z europejskimi partnerami lub wdrożenie rozwiązań *confidential computing* jako środka kompensacyjnego.

Status legislacyjny i perspektywa czasowa. Na dzień złożenia niniejszej pracy CADA znajduje się na wczesnym etapie procesu legislacyjnego UE, złożony wniosek Komisji musi przejść przez negocjacje w Parlamencie Europejskim i Radzie UE (trilog). Kluczowe parametry aktu (w tym wiążąca definicja suwerenności oraz zakres sankcji)

²⁹Mario Draghi. *The Future of European Competitiveness. A Competitiveness Strategy for Europe*. Bruksela: Komisja Europejska, wrzesień 2024. URL: https://commission.europa.eu/topics/strengthening-european-competitiveness/eu-competitiveness-looking-ahead_en (dostęp 21.03.2026).

³⁰Komisja Europejska, *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*.

³¹Synergy Research Group, *European Cloud Providers' Local Market Share Holds Steady at 15%*.

pozostają otwarte na etapie prac legislacyjnych.³² Przy typowym dla unijnych regulacji cyfrowych tempie prac, realistyczny termin wejścia w życie CADA to nie wcześniej niż 2028–2029 r., z uwzględnieniem standardowego okresu *vacatio legis*.

Implikacje dla modelu ORION

Trzy omówione inicjatywy, tj. Data Act, EUCS i CADA, tworzą wzajemnie uzupełniający się system regulacyjny. Data Act reguluje prawa dostępu i przenoszenia danych *ex post*, EUCS certyfikuje bezpieczeństwo dostawców, a CADA (jako złożony wniosek legislacyjny) ma budować alternatywną, europejską infrastrukturę *ex ante*. Z perspektywy metodologii ORION istotne jest jednak, że żadna z tych regulacji nie eliminuje jeszcze w całości konfliktu jurysdykcyjnego wynikającego z CLOUD Act: Data Act nie uchyla prawnych obowiązków dostawcy wynikających z prawa USA, EUCS pozostaje nieukończony na poziomie wymaganym dla usług krytycznych, a CADA jest na wczesnym etapie procesu legislacyjnego.

Stanowi to empiryczne uzasadnienie dla jednej z kluczowych decyzji projektowych ORION: traktowania jurysdykcji geograficznej dostawcy jako **czynnika ryzyka, którego nie można się pozbyć** w drodze samej konfiguracji usługi, wymagającego wymiany dostawcy lub zastosowania poufnego przetwarzania jako warstwy kompensacyjnej.

4.5 Przykładowe scenariusze konfliktu

Konflikt wynikający z Cloud Act pojawia się na wielu płaszczyznach. Ogólny ogłód na przechowywanie danych w chmurze należy uszczegółowić, by wskazać, jakie informacje i w jakich sytuacjach mogą opuszczać EOG. Po pierwsze należy zwrócić uwagę, w jaki sposób dane są przechowywane.

Przekazywane mogą być całe kopie maszyn wirtualnych, bez względu na jakim systemie operacyjnym działają. W takiej sytuacji nie ma znaczenia czy podmiot korzysta z rozwiązań Open Source (Linux vs Windows), nie ma również znaczenia jakie oprogramowanie jest na danym systemie zainstalowane oraz kto jest jego producentem, np. komercyjny silnik bazy danych Oracle, Microsoft SQL, etc. vs PostgreSQL, MySQL. Ryzyko związane z CLOUD Act zależy nie od silnika bazy danych (MySQL, Oracle, PostgreSQL), lecz od lokalizacji infrastruktury i jej operatora. Sama zmiana silnika bazy danych nic nie zmienia, decydująca jest jurysdykcja nad infrastrukturą hostingową.

W przypadku systemów operacyjnych użytkownik narażony jest na dodatkowy kanał ryzyka, równoległy do przesłania danych z maszyn wirtualnych, czyli informacji zebranych przez system, przykładowo mechanizm telemetryi dostępny nie tylko w systemie Windows,³³ ale również macOS³⁴ oraz zostanie dołączona do dystrybucji Linux Fedora,³⁵ rozwijanej przez RedHat / IBM.

³²Komisja Europejska, *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*.

³³Microsoft Corporation. *Configure Windows diagnostic data in your organization*. Microsoft Learn. Dostęp: 2026-04-07. URL: <https://learn.microsoft.com/en-us/windows/privacy/configure-windows-diagnostic-data-in-your-organization>.

³⁴Privacy Guides. *macOS Overview — Privacy and Telemetry*. Privacy Guides. Dostęp: 2026-04-07. 2025. URL: <https://www.privacyguides.org/en/os/macos-overview/>.

³⁵Fedora Project. *Changes/Telemetry — Fedora Project Wiki*. Fedora Project Wiki. Dostęp: 2026-04-07. 2024. URL: <https://fedoraproject.org/wiki/Changes/Telemetry>.

Telemetria Windows nie przesyła wprost zawartości baz danych, jednak może przekazywać informacje takie jak nazwy procesów i ścieżki plików, zdarzenia audytu logowania (np. SQL Server Audit), czy błędy połączeń bazodanowych. W kontekście postępowania informacje te mogą być wystarczające do ukierunkowania żądania CLOUD Act wobec Google (jak i każdego innego hiperscalera podlegającego pod CLOUD Act) o wydanie pełnych danych z dysku VM.

4.5.1 Mechanizm telemetrii w systemie Windows

Systemy operacyjne z rodziny Windows zbierają dane diagnostyczne i behawioralne tzw. *telemetrię*, obejmujące informacje o:

- używanych aplikacjach i ich awariach,
- aktywności sieciowej i połączeniach,
- konfiguracji sprzętu,
- zdarzeniach systemowych rejestrowanych w Event Viewer,
- lokalizacji użytkownika (przy odpowiednim poziomie uprawnień).

Kluczową usługą odpowiedzialną za transmisję telemetrii jest **DiagTrack** (*Connected User Experiences and Telemetry*), która regularnie przesyła dane do serwerów Microsoft zlokalizowanych w USA. Dane te, trafiając do infrastruktury podmiotu objętego jurysdykcją amerykańską, wchodzi automatycznie w zakres CLOUD Act.

4.5.2 Scenariusz kumulacji ryzyk: Windows Server na Google Cloud, Microsoft Azure, AWS

Warto przeprowadzić eksperyment myślowy ze scenariuszem, w który uruchamiono system operacyjny na maszynie wirtualnej w centrum danych. Szczególnie wysokim profilem ryzyka charakteryzuje się konfiguracja polegająca na uruchomieniu Windows Server jako maszyny wirtualnej w Google Cloud Platform (lub innej podległej pod jurysdykcję CLOUD Act) z zainstalowanym silnikiem bazy danych. Wskazanie Google Cloud Platform oraz Microsoft Windows są wizualizacją przykładu i wynikają z popularności usług. Scenariusz ten łączy jednocześnie trzy warstwy ryzyka.

4.5.3 Trzy warstwy ryzyka

Warstwa 1, Chmura a CLOUD Act. Hostującą firmą jest podmiot amerykański, z tego wynika, że każda maszyna wirtualna w tym centrum danych, niezależnie od regionu (w tym `europa-central2` w Warszawie), podlega CLOUD Act. Organy USA mogą żądać danych od dostawcy bezpośrednio, bez informowania właściciela.

Warstwa 2, Windows Server a telemetria. Windows Server uruchomiony jako VM na chmurze generuje telemetrię przesyłaną do serwerów Microsoft. Oznacza to **dwa niezależne podmioty objęte CLOUD Act**: Google (infrastruktura VM) oraz Microsoft (telemetria systemowa). Możliwe jest równoległe żądanie skierowane do obu firm.

Warstwa 3, Dostęp Google do danych bazy danych. Google jako hypervisor ma techniczną możliwość dostępu do dysków Persistent Disk przypisanych do maszyny wirtualnej. Przy domyślnym szyfrowaniu zarządzanym przez Google KMS, firma może odczytać zawartość dysku w tym pliki danych bazy snapshoty, logi i backupy.

4.5.4 Macierz wektorów dostępu

Tabela 4.1: Wektory dostępu do danych bazy przy konfiguracji Windows Server / GCP

Wektor dostępu	Podmiot	Co może być ujawnione
Nakaz CLOUD Act do Google	Google LLC	Pliki danych bazy, snapshoty dysków, logi, backupy GCS
Telemetria Windows	Microsoft Corp	Metadane systemu, Event Log, ścieżki plików
Cloud SQL (jeśli użyte)	Google LLC	Bezpośredni dostęp do tabel przez DBaaS API
Klucze Google KMS (domyślne)	Google LLC	Możliwość odszyfrowania dysków VM

4.5.5 Rekomendacje dla środowisk regulowanych (NIS2 / DORA / RODO)

Na podstawie przeprowadzonej analizy formułuje się następujące rekomendacje dla organizacji przetwarzających dane wrażliwe lub dane operacyjne podlegające dyrektywie NIS2 i rozporządzeniu DORA:

1. **CMEK z zewnętrznym HSM** (*Customer-Managed Encryption Keys*), klucze do dysków VM przechowywane poza infrastrukturą dostawcy chmury eliminują techniczną możliwość odszyfrowania przez Google lub AWS.
2. **BYOK dla baz danych** (*Bring Your Own Key*), niezależne szyfrowanie danych w bazie (np. TDE *Transparent Data Encryption*) z kluczem zarządzanym przez klienta, poza środowiskiem chmurowym.
3. **Wyłączenie telemetrii Windows** na poziomie GPO (*Security level*) oraz zablokowanie ruchu do endpointów telemetrycznych na poziomie firewalla egress.
4. **Wybór europejskiego dostawcy infrastruktury w usłudze** spoza jurysdykcji USA (w pełni zlokalizowane w EOG) jako infrastruktury dla systemów krytycznych.
5. **Uwzględnienie CLOUD Act w rejestrze ryzyk IT**, jako ryzyko regulacyjne kategorii *prawne / compliance*, z przypisaniem prawdopodobieństwa i wpływu zgodnie z metodologią przyjętą w organizacji.
6. **Audyt umów z dostawcami chmurowymi** pod kątem klauzul dotyczących żądań rządowych oraz regularny monitoring *Government Request Transparency Reports* publikowanych przez Google, Microsoft i Amazon.

4.5.6 Wnioski

CLOUD Act stanowi realne i wielowarstwowe zagrożenie dla suwerenności danych europejskich organizacji. Zagrożenie to nie ogranicza się do danych przechowywanych bezpośrednio w usługach chmurowych (DBaaS, SaaS), lecz obejmuje również metadane generowane przez systemy operacyjne (telemetria Windows) oraz dane na dyskach wirtualnych maszyn IaaS zarządzanych przez podmioty podlegające prawu USA.

Konfiguracja łącząca Windows Server z Google Cloud Platform jako infrastrukturą hostingową bazy danych tworzy najwyższy profil ryzyka, dwa niezależne podmioty objęte CLOUD Act uzyskują potencjalny dostęp do danych przez różne kanały techniczne.

Skuteczna mitigacja tego ryzyka wymaga działań na poziomie infrastrukturalnym (wybór dostawcy spoza jurysdykcji USA), kryptograficznym (CMEK, BYOK) oraz operacyjnym (wyłączenie telemetrii, audyt umów). Środki te powinny być traktowane jako elementy systemu zarządzania ryzykiem IT, spójne z wymogami dyrektywy NIS2 i rozporządzenia DORA.

5. Ryzyka w praktyce: zagrożenia, konsekwencje i dobre praktyki

Zrozumienie architektury środowiska organizacji oraz pełna inwentaryzacja usług jest kluczem do prawidłowego zarządzania ryzykiem ICT. Badania przeprowadzone przez firmę *Swimlane* wykazały, że 71% organizacji nie jest w stanie całościowo dokonać audytu wszystkich systemów zgodnie z wewnętrznymi i zewnętrznymi standardami.¹ Badani wskazują jako przyczyny:

- *Fragmentację narzędzi*: 92% respondentów korzysta z co najmniej trzech różnych narzędzi do zbierania dowodów audytowych, co powoduje powielanie pracy i nie-spójność danych;
- *Uzależnienie od procesów manualnych*: średnio jedynie 39% procesu zbierania dowodów jest zautomatyzowane; ponad połowa organizacji (54%) poświęca ponad 5 godzin tygodniowo na ręczne zadania compliance;
- *Podatność na błędy w danych*: 62% organizacji przyznaje, że proces zbierania dowodów audytowych jest przynajmniej sporadycznie obciążony błędem;
- *Brak współpracy między zespołami*: 90% organizacji wskazuje, że słaba koordynacja między zespołami podważa gotowość do audytu;
- *Rosnącą złożoność regulacyjną*: 96% organizacji twierdzi, że dotrzymanie kroku rosnącej liczbie regulacji branżowych stanowi istotne wyzwanie.

Jakość prowadzonych audytów bywa podważana przez samych badanych. Brak kompetencji osób wypełniających kwestionariusze audytowe nie gwarantuje poprawności udzielanych odpowiedzi. Badanie *The Next Generation Cybersecurity Auditor* przeprowadzone na próbie 151 tys. audytorów IT z firm Big Four (*Deloitte, Ernst & Young, KPMG, PricewaterhouseCoopers*) wykazało, że poziom wiedzy proceduralnej (praktycznej) audytorów był o 17% niższy niż poziom ich wiedzy teoretycznej, a poziom pewności siebie respondentów nie był skorelowany z ich rzeczywistymi wynikami, co wskazuje na efekt Dunninga-Krugera w środowisku audytorskim.²

Dodatkowym problemem obniżającym jakość audytów jest zjawisko nierzetelnego wypełniania kwestionariuszy przez respondentów. Badania z zakresu ekonomii behawioralnej wskazują, że nieuczciwość w systemach samoraportowania jest powszechna, Friesen

¹Swimlane. *GRC Chaos: The High Price of Audits and Non-Compliance*. Sprawozdanie techniczne. Survey conducted by Sapio Research among 500 IT and cybersecurity decision-makers in the US and UK, March 2025. Swimlane, Inc., kwiecień 2025. URL: <https://swimlane.com/news/grc-audit-research/> (dostęp 10.03.2026).

²Brandon Henry. „The Next Generation Cybersecurity Auditor: Technical Competency Gaps in 151,000 IT Auditors in the Audit Industry”. W: *Security Magazine* (październik 2022). Dotyczy luki kompetencyjnej między wiedzą deklaratywną a proceduralną u audytorów IT w firmach Big Four; wykazano 17% spadek poziomu wiedzy praktycznej względem teoretycznej. URL: <https://www.securitymagazine.com/articles/98555-technical-competency-gaps-in-151-000-it-auditors-in-the-audit-industry> (dostęp 10.03.2026).

i Gangadharan wykazali eksperymentalnie, że respondenci częściej podają prawdziwe informacje w reżimach raportowania obowiązkowego niż dobrowolnego, co sugeruje, iż bez odpowiednio zaprojektowanych mechanizmów egzekwowania trudno osiągnąć satysfakcjonujący poziom zgodności odpowiedzi ze stanem faktycznym.³ Potwierdzają to badania Peer i in., którzy wykazali, że zobowiązanie do złożenia przysięgi uczciwości zmniejsza skłonność do nieuczciwości ($OR = 0,79 [0,72; 0,88]$), jednak sama relacja interpersonalna między wypełniającym a audytorem nie wywiera istotnego wpływu na rzetelność odpowiedzi ($OR = 1,08 [0,97; 1,20]$).⁴ Oznacza to, że dowody pozyskane poprzez nieusystematyzowane, dobrowolne kwestionariusze audytowe mogą być obarczone istotną słabością metodologiczną, a ich wartość jako podstawy oceny ryzyka ICT powinna być traktowana z należytą ostrożnością.

5.1 Shadow IT

Trudnym do wykrycia problemów z bezpieczeństwem jest zjawisko zwane jako *Shadow IT*. Definiuje się je, jako wykorzystanie przez pracowników narzędzi informatycznych, aplikacji, urządzeń lub usług bez wiedzy i zgody działu IT organizacji.⁵ W wyniku restrykcyjnych polityk bezpieczeństwa, użytkownicy sięgają po nieautoryzowane rozwiązania informatyczne w celu usprawnienia codziennej pracy, zjawisko to nasilił wzrost popularności modelu pracy zdalnej.⁶

Raport Capterra z 2023 roku wskazuje, że 76% małych i średnich przedsiębiorstw identyfikuje *Shadow IT* jako umiarkowane lub poważne zagrożenie dla cyberbezpieczeństwa.⁷ Badania JumpCloud pokazują, że w 2023 roku 41% pracowników korporacyjnych korzystało z technologii pozostających poza nadzorem działu IT,⁸ a średnio firma dysponuje 975 nieznanych usługami chmurowymi, podczas gdy jedynie 108 jest przez nią oficjalnie monitorowanych.⁹

Niepokojący jest wpływ *Shadow IT* na bezpieczeństwo organizacji. Badanie Kaspersky z 2023 roku wykazało, że 85% firm doświadczyło incydentów cyberbezpieczeństwa, przy czym w co najmniej 11% przypadków rola *Shadow IT* była bezpośrednio udokumentowana.¹⁰ Szacuje się, że prawie połowa wszystkich cyberataków ma swoje źródło właśnie w *Shadow IT*. Wykrycie *Shadow IT* jest szczególnie trudne, ponieważ zasoby te z definicji funkcjonują poza zasięgiem standardowych narzędzi monitorowania sieci i systemów

³Lana Friesen. „Designing Self-Reporting Regimes to Encourage Truth Telling”. W: *Journal of Economic Behavior & Organization* 95 (2013). DOI: 10.1016/j.jebo.2013.08.007. URL: <https://www.sciencedirect.com/science/article/abs/pii/S0167268113002072>.

⁴Eyal Peer, Thomas Vanhoof i in. „Commitment to honesty oaths decreases dishonesty, but commitment to another individual does not”. W: *Communications Psychology* 1.1 (2023). DOI: 10.1038/s44271-023-00028-7. URL: <https://www.nature.com/articles/s44271-023-00028-7>.

⁵IBM. *What Is Shadow IT?* Dostęp: 2026. 2022. URL: <https://www.ibm.com/think/topics/shadow-it>.

⁶JumpCloud. *What Is Shadow IT? 2024 Statistics & Solutions*. Dostęp: 2026. 2024. URL: <https://jumpcloud.com/blog/shadow-it>.

⁷Capterra. *Shadow IT Report 2023*. Cytowane w: Auvik (2024), dostęp: 2026. 2023. URL: <https://www.capterra.com>.

⁸JumpCloud, *What Is Shadow IT? 2024 Statistics & Solutions*.

⁹Josys. *Shadow IT Definition: 2024 Statistics and Solutions*. Dostęp: 2026. 2024. URL: <https://josys.com/article/article-shadow-it-shadow-it-definition-2024-statistics-and-solutions>.

¹⁰Kaspersky. *IT Security Economics Report 2023*. Cytowane w: ISACA Journal (2024), dostęp: 2026. 2023. URL: <https://www.kaspersky.com>.

bezpieczeństwa.¹¹

Istnienie *Shadow IT* w organizacji stanowi sygnał, że istniejące polityki i narzędzia IT nie zaspokajają w pełni potrzeb pracowników. Pracownicy wykorzystujący w swojej pracy nieautoryzowane rozwiązania pokazują, że istnieją luki w oficjalnej ofercie narzędziowej organizacji. Sytuacja ta powinna skłaniać działy IT do weryfikacji swoich polityk oraz systemów szkoleń.¹²

5.2 Shadow AI

Dynamiczny rozwój narzędzi generatywnej sztucznej inteligencji w latach 2022-2025 wytworzył nową kategorię zjawiska *Shadow IT*, określaną jako *Shadow AI*. Definiuje się je jako wykorzystanie przez pracowników systemów sztucznej inteligencji, w szczególności narzędzi generatywnych, bez wiedzy, zgody i oceny bezpieczeństwa ze strony działu IT organizacji.¹³

Shadow AI wyróżnia się od klasycznego *Shadow IT* jedną właściwością istotnie zwiększającą profil ryzyka: użycie narzędzia AI nieodłącznie wiąże się z przesyłaniem danych wejściowych do infrastruktury zewnętrznego dostawcy. Klasyczne *Shadow IT* może działać lokalnie, bez transferu danych poza organizację. *Shadow AI* natomiast z definicji eksportuje dane wejściowe każdorazowo, gdy pracownik sformułuje zapytanie do modelu.

Skala zjawiska jest znaczna. Raport LayerX Security wykazał, że 50% pracowników przyznało się do wklejania wrażliwych danych firmowych do narzędzi generatywnej AI, z czego 18% deklarowało udostępnianie danych szczególnie wrażliwych.¹⁴ Analiza Cyberhaven Labs, obejmująca 1,6 mln pracowników, wykazała, że 11% danych wklejanych do ChatGPT stanowią informacje poufne, a przeciętna firma notuje kilkadziesiąt takich zdarzeń tygodniowo.¹⁵ Raport Microsoft *Work Trend Index 2024* wskazał, że 78% pracowników korzystających z AI w pracy robi to za pomocą własnych, prywatnych kont w narzędziach niezatwierdzonych przez pracodawcę.¹⁶

Shadow AI generuje trzy odrębne kategorie ryzyka regulacyjnego.

- *Ryzyko naruszenia RODO*. Dane przesyłane do modeli generatywnej AI trafiają na serwery dostawców zlokalizowane poza Europejskim Obszarem Gospodarczym. Stanowi to transfer danych osobowych wymagający ważnej podstawy prawnej w rozumieniu rozdziału V RODO, takiej jak standardowe klauzule umowne (SCC) lub

¹¹ISACA. „Risk in the Shadows”. W: *ISACA Journal* 6 (2024). Dostęp: 2026. URL: <https://www.isaca.org/resources/isaca-journal/issues/2024/volume-6/risk-in-the-shadows>.

¹²Grip Security. *How to Detect and Manage Shadow IT in 5 Steps*. Dostęp: 2026. 2025. URL: <https://www.grip.security/blog/5-steps-to-detect-and-control-shadow-it>.

¹³Gartner, Inc. *Gartner Predicts Forty Percent of AI Data Breaches Will Arise from Cross-Border GenAI Misuse by 2027*. Gartner Newsroom Press Release. Accessed: June 2026. Luty 2025. URL: <https://www.gartner.com/en/newsroom/press-releases/2025-02-17-gartner-predicts-forty-percent-of-ai-data-breaches-will-arise-from-cross-border-genai-misuse-by-2027>.

¹⁴LayerX Security. *Enterprise AI and SaaS Data Security Report 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. LayerX Security Ltd., 2025. URL: <https://www.cybersecurity-insiders.com/research-says-over-77-percent-of-data-is-shared-to-chatgpt-by-employees/>.

¹⁵Cyberhaven Labs. *11% of data employees paste into ChatGPT is confidential*. Dostęp: 10 marca 2026. 2023. URL: <https://www.cyberhaven.com/blog/4-2-of-workers-have-pasted-company-data-into-chatgpt>.

¹⁶Microsoft i LinkedIn. *2024 Work Trend Index Annual Report: AI at Work Is Here. Now Comes the Hard Part*. Sprawozdanie techniczne. Based on a survey of 31,000 professionals across 31 countries. Accessed: June 2026. Microsoft Corporation, maj 2024. URL: <https://www.microsoft.com/en-us/worklab/work-trend-index/ai-at-work-is-here-now-comes-the-hard-part>.

przynależność dostawcy do Ram Ochrony Prywatności Danych (DPF). W przypadku Shadow AI transfer ten odbywa się bez wiedzy administratora, co wyklucza spełnienie wymogu rozliczalności z art. 5 ust. 2 RODO: pracownik, bez stosownego umocowania, dokonuje transferu danych, za który organizacja ponosi pełną odpowiedzialność.

- *Ryzyko na gruncie AI Act.* Rozporządzenie (UE) 2024/1689, zwane *AI Act*, które weszło w życie 1 sierpnia 2024 roku, nakłada na podmioty *stosujące* systemy AI obowiązki uzależnione od poziomu ryzyka danego systemu.¹⁷ Korzystanie przez pracownika z niezatwierdzonego modelu AI do wspomagania decyzji kredytowych, rekrutacyjnych lub diagnostyki medycznej może oznaczać, że organizacja faktycznie stosuje system AI wysokiego ryzyka w rozumieniu art. 6 i załącznika III AI Act bez przeprowadzenia wymaganej oceny zgodności i bez zapewnienia nadzoru ludzkiego. Odpowiedzialność spoczywa na organizacji niezależnie od tego, że wdrożenie nastąpiło bez wiedzy zarządu.
- *Ryzyko jakości i wiarygodności.* Modele generatywnej AI mogą generować błędne informacje, określane jako *halucynacje modelu*. Wbudowanie wyników działania niezwyfikowanego modelu w procesy decyzyjne, na przykład w analizy prawne, rekomendacje medyczne lub wyceny finansowe, bez procedury weryfikacji tworzy ryzyko operacyjne, za które odpowiada organizacja. Warunki korzystania z większości narzędzi generatywnej AI wprost wyłączają odpowiedzialność dostawcy za skutki biznesowe zastosowania generowanych treści.

Podobnie jak Shadow IT, Shadow AI jest diagnozą organizacyjną: pracownicy sięgają po niezatwierdzone modele AI, ponieważ zatwierdzone rozwiązania nie spełniają ich potrzeb lub procedura akceptacji jest zbyt długa. Odpowiedzią nie jest wyłącznie zakaz, lecz wdrożenie zatwierdzonego środowiska AI uzupełnionego polityką dopuszczalnego użycia, która definiuje, jakich danych nie wolno wprowadzać do żadnego zewnętrznego modelu.

5.3 Edukacja jako fundament ochrony danych osobowych

Problem *shadow IT* oraz niewłaściwego posługiwania się danymi osobowymi jest w znacznej mierze wynikiem niewystarczającego poziomu świadomości i wiedzy pracowników. Badania przeprowadzone przez Stanford University i firmę Tessian wskazują, że **88% naruszeń** bezpieczeństwa informacji wynika z błędu ludzkiego, a nie z działania cyberprzestępców.¹⁸ Raport *Verizon Data Breach Investigations Report 2024* wskazuje, że czynnik ludzki, zdefiniowany jako nieświadome błędy lub brak kompetencji, pozostaje głów-

¹⁷European Parliament i Council of the European Union. *Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act)*. Entered into force: 1 August 2024. Accessed: June 2026. Lipiec 2024. URL: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689>.

¹⁸ISOQAR CEE. *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. ISOQAR CEE Sp. z o.o., 2024. URL: <https://www.isoqar.pl/pl/aktualnosci/bezpieczenstwo-informacji/blad-ludzki-cichy-sprawca-naruszen-bezpieczenstwa-informacji>.

nym źródłem naruszeń bezpieczeństwa danych.¹⁹ Raport *Cyberportret polskiego biznesu* z 2024 roku przedstawił dane dla Polski: ponad połowa pracowników w polskich firmach nie przeszła żadnego szkolenia z zakresu cyberbezpieczeństwa i ochrony danych w ciągu ostatnich pięciu lat.²⁰

Skala i charakter najczęstszych incydentów potwierdzają diagnozę. W 2024 roku zespół CERT Polska odnotował wzrost liczby cyberzagrożeń, liczba zgłoszeń w jednym roku przekroczyła 600 tysięcy, najczęstszym incydem były ataki phishingowe, czyli uzyskanie korzyści przez przestępców poprzez manipulacje zachowania ofiary, a nie na przełamaniu zabezpieczeń technicznych.²¹ W badaniu przeprowadzonym przez Keepnet Labs w 2026 roku 45% pracowników przyznało, że ich organizacja nie zapewniła szkoleń z zakresu bezpieczeństwa.²²

W kontekście polskiego rynku sygnałem pozytywnym jest fakt, że cyberbezpieczeństwo stało się najszybciej rosnącym segmentem rynku IT w Polsce, a w latach 2024-2025 niemal dwie trzecie respondentów wskazało je na pierwszym miejscu wśród inwestycji IT, 43% badanych uznało je za najważniejszy pojedynczy obszar.²³ Wzrost wydatków koncentruje się na rozwiązaniach technicznych, a nie na edukacji pracowników, co przy dominacji błędu ludzkiego jako źródła incydentów stanowi strategiczną asymetrię w alokacji zasobów.²⁴

Wymiar regulacyjny obowiązku szkolenia

Edukacja pracowników nie jest jedynie kwestią dobrej praktyki lub woli pracodawcy. Aktualnie jest obowiązkiem, wynikającym aktów prawnych. RODO nakłada na administratora obowiązek zapewnienia, by osoby upoważnione do przetwarzania danych osobowych były odpowiednio przeszkolone (art. 32 ust. 4 RODO), a brak szkoleń jako środka techniczno-organizacyjnego stanowi podstawę do nałożenia kary przez UODO.²⁵ Rozporządzenie DORA zobowiązuje instytucje finansowe do prowadzenia programów podnoszenia świadomości w zakresie ryzyka ICT, w tym kadry zarządzającej.²⁶ Norma ISO/IEC 27001 wprost wymaga wdrożenia udokumentowanych programów szkoleń i uświadamiania jako kontroli organizacyjnej.²⁷ Brak lub niewystarczający program szkoleniowy staje się zatem

¹⁹Verizon Business. *2024 Data Breach Investigations Report*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Verizon Communications Inc., 2024. URL: <https://www.verizon.com/business/resources/reports/dbir/>.

²⁰BrandsIT. *Im mniej szkoleń, tym więcej ataków. Jak brak edukacji wpływa na cyberbezpieczeństwo firm*. Dostęp: 10 marca 2026. 2025. URL: <https://brandsit.pl/im-mniej-szkolen-tym-wiecej-atakow-jak-brak-edukacji-wplywa-na-cyberbezpieczenstwo-firm/>.

²¹CERT Polska / NASK. *Analiza bezpieczeństwa polskiego internetu w 2024 roku*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Ministerstwo Cyfryzacji / NASK PIB, 2025. URL: <https://www.gov.pl/web/baza-wiedzy/analiza-bezpieczenstwa-polskiego-internetu-w-2024-roku>.

²²Keepnet Labs. *Security Awareness Training Statistics [Updated 2026]*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Keepnet Labs Ltd., 2026. URL: <https://keepnetlabs.com/blog/security-awareness-training-statistics>.

²³PAP Biznes. *Cyberbezpieczeństwo najszybciej rosnącym segmentem rynku IT w Polsce*. Dostęp: 10 marca 2026. 2026. URL: <https://biznes.pap.pl/wiadomosci/gry-i-technologie/cyberbezpieczenstwo-najszybciej-rosnacym-segmemtem-ryнку-it-w-polsce-w>.

²⁴BrandsIT, *Im mniej szkoleń, tym więcej ataków. Jak brak edukacji wpływa na cyberbezpieczeństwo firm*.

²⁵ISOQAR CEE, *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*.

²⁶Autoriteit Financiële Markten (AFM). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna AFM. Informacje nt. wymogów DORA, w tym zarządzania ryzykiem ICT i obowiązków raportowania incydentów dla podmiotów finansowych. 2025. URL: <https://www.afm.nl/en/sector/themas/digitalisering/dora> (dostęp 10.03.2025).

²⁷ISOQAR CEE, *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*.

nie tylko źródłem ryzyka operacyjnego, lecz również jest przyczyną i źródłem niezgodności z obowiązującym prawem.

5.4 Często występujące ryzyka związane z nieprawidłowym przetwarzaniem danych

Niewłaściwe i ryzykowne zachowania pracowników można zidentyfikować i wskazać główne ich źródła. Poniżej przedstawiono najistotniejsze kategorie zachowań, udokumentowane przez raporty branżowe, organy nadzoru oraz literaturę naukową.

- *Przekazywanie danych do narzędzi generatywnej AI.* Pracownicy przekazują dane wrażliwe, treści umów, numery PESEL, historię transakcji, do narzędzi takich jak ChatGPT, Copilot czy Gemini, w celu ich podsumowania lub analizy. Dane te trafiają bezpośrednio na serwery dostawców zlokalizowane w Stanach Zjednoczonych, poza kontrolą organizacji. Raport LayerX Security *Enterprise AI and SaaS Data Security Report 2025* wykazał, że 50% pracowników przyznało się do wklejania wrażliwych danych firmowych do narzędzi generatywnej AI, przy czym 18% z nich deklaroowało udostępnianie danych szczególnie wrażliwych, w tym danych produkcyjnych i zastrzeżonych.²⁸ Równolegle analiza Cyberhaven Labs, obejmująca 1,6 mln pracowników, wykazała, że 11% danych wklejanych przez pracowników do ChatGPT stanowią informacje poufne, a przeciętna firma notuje kilkaset takich zdarzeń tygodniowo.²⁹
- *Używanie prywatnych kont w usługach chmurowych do transferu dokumentów służbowych.* Pracownicy przesyłają dokumenty zawierające dane osobowe na prywatne konta Google Drive, Dropbox czy Microsoft OneDrive, omijając firmowe procedury DLP (*Data Loss Prevention*). Według raportu WifiTalents *Shadow IT Statistics 2025*, 58% pracowników korzysta z prywatnych rozwiązań do przechowywania plików bez zgody działu IT, a 47% omija kontrole bezpieczeństwa przy użyciu narzędzi shadow IT.³⁰ Dane te, gdy zostaną umieszczone poza infrastrukturą organizacji, stają się niedostępne w celach nadzorczych, co uniemożliwia wykazanie zgodności z zasadą rozliczalności wynikającą z art. 5 ust. 2 RODO.
- *Przesyłanie danych przez niezatwierdzone komunikatory i dyski chmurowe.* Pracownicy korzystają z komunikatorów takich jak WhatsApp lub Messenger. Choć komunikacja w aplikacjach takich jak WhatsApp jest szyfrowana *end-to-end*, czyli wyłącznie między urządzeniami uczestników, nie gwarantuje to zgodności z RODO, ponieważ metadane, kopie zapasowe i historia czatów mogą być przechowywane przez dostawcę poza EOG.³¹ Badanie WifiTalents wykazało, że 37% pracowników używa niezatwierdzonych komunikatorów do komunikacji służbowej.³²

²⁸LayerX Security, *Enterprise AI and SaaS Data Security Report 2025*.

²⁹Cyberhaven Labs, *11% of data employees paste into ChatGPT is confidential*.

³⁰WifiTalents. *Shadow IT Statistics: Reports 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. WifiTalents, 2025. URL: <https://wifitalents.com/shadow-it-statistics/>.

³¹Data Protection People. *GDPR Data Breaches & Human Error: How Bad Is It?* Dostęp: 10 marca 2026. 2026. URL: <https://dataprotectionpeople.com/resource-centre/gdpr-data-breaches-human-error-how-bad-is-it/>.

³²WifiTalents, *Shadow IT Statistics: Reports 2025*.

- *Błędne utożsamianie pseudonimizacji z anonimizacją.* W dokumentach przekazywanych do analizy lub testów pozostają inicjały, numery PESEL lub numery rachunków bankowych, które pracownicy nierzadko traktują jako wystarczające zanonimizowanie danych. Dane pseudonimowe nadal identyfikują osobę fizyczną w rozumieniu art. 4 pkt 1 RODO i nie wyłączają stosowania przepisów rozporządzenia.³³ Preuveneers i in. wykazali, że modele głębokiego uczenia są w stanie z dokładnością 73,4% zidentyfikować gospodarstwa domowe na podstawie pozornie pseudonimowych danych pomiarowych w zbiorze liczącym ponad 5000 podmiotów.³⁴
- *Używanie narzędzi do transkrypcji spotkań bez oceny ryzyka.* Narzędzia takie jak Otter.ai, Fireflies.ai czy rozszerzenia oparte na ChatGPT automatycznie dołączają do posiedzeń, nagrywają rozmowy i przesyłają transkrypty na serwery zewnętrznych dostawców, często zlokalizowane w USA.³⁵ Uczestnicy spotkań mogą nie być świadomi obecności utomatu nagrywającego, co stanowi naruszenie zasady przejrzystości z art. 5 ust. 1 lit. a RODO. Co istotne, warunki korzystania wielu narzędzi transkrypcyjnych, zezwalają na wykorzystanie nagrań i transkrypcji do trenowania modeli AI, co oznacza, że treści posiedzeń z danymi klientów mogą zasilać bazy treningowe dostawcy bez podstawy prawnej.³⁶
- *Przesyłanie danych wrażliwych mailem.* Przekazywane danych wrażliwych pocztą elektroniczną do zewnętrznych adresatów bez uprzedniego zawarcia umowy powierzenia przetwarzania danych (DPA) oraz odpowiedniego zabezpieczenia załącznika (bezpiecznym hasłem), wymaganej przez art. 28 RODO. Badanie MailIntelligence wykazało, że 65% incydentów utraty danych jest powodowanych przez wiadomości e-mail skierowane do niewłaściwego adresata lub przesłane bez odpowiednich zabezpieczeń.³⁷ Takie przekazanie danych stanowi naruszenie RODO, niezależnie od tego, czy doszło do faktycznego wycieku.
- *Kopiowanie danych produkcyjnych do środowisk testowych bez anonimizacji.* Dane wrażliwe z systemów produkcyjnych są przenoszone do środowisk deweloperskich lub testowych w niezmienionej formie, co narusza art. 25 RODO (zasada *privacy by design and by default*) oraz zasady minimalizacji i ograniczenia celu.³⁸ Agencja ochrony danych Hiszpanii (AEPD) wprost wskazuje, że używanie rzeczywistych danych osobowych w środowiskach testowych jest dopuszczalne jedynie gdy jest

³³Agencia Española de Protección de Datos (AEPD). *Personal Data Breaches: Development and Pre-Production Environments*. Dostęp: 10 marca 2026. 2022. URL: <https://www.aepd.es/en/prensa-y-comunicacion/blog/data-breaches-development-and-pre-production-environments>.

³⁴Davy Preuveneers i in. „Re-pseudonymization Strategies for Smart Meter Data Are Not Robust to Deep Learning Profiling Attacks”. W: *arXiv preprint* (2024). DOI: 10.48550/arXiv.2404.03948. URL: <https://arxiv.org/abs/2404.03948>.

³⁵Legal.io / Bloomberg Law. *AI Meeting Tools Raise Privacy, Privilege, and Discovery Risks for Employers*. Dostęp: 10 marca 2026. 2025. URL: <https://www.legal.io/articles/5767845/AI-Meeting-Tools-Raise-Privacy-Privilege-And-Discovery-Risks-For-Employers>.

³⁶Privacy Partnership. *Why AI Transcription Bots Pose a Data Privacy Risk*. Dostęp: 10 marca 2026. 2025. URL: https://www.linkedin.com/posts/privacy-partnership_ai-bots-gdpr-activity-7387443108201787396-3dRL.

³⁷MailIntelligence. *Human Error Cases in Enterprise Email Security 2024*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. MailIntelligence AI, 2024. URL: <https://mailintelligence.ai/reports/human-error-cases-2024>.

³⁸Agencia Española de Protección de Datos (AEPD), *Personal Data Breaches: Development and Pre-Production Environments*.

bezwzględnie konieczne i zabezpieczone zgodnie z art. 32 RODO.³⁹ W praktyce konieczność ta rzadko zachodzi, dostępne są narzędzia do generowania danych syntetycznych, a rezygnacja z ich stosowania wynika z wygody, nie z merytorycznej potrzeby.

- *Przekazywanie danych pacjentów firmom IT bez podstawy prawnej.* Podczas zgłaszania usterek w oprogramowaniu medycznym pracownicy przekazują firmom serwisowym fragmenty dokumentacji pacjentów lub całe zrzuty baz danych. Najwyższa Izba Kontroli w raporcie *RODO w szpitalu* z 2019 roku wykryła ten proceder w 11 z kontrolowanych szpitali, gdzie udostępniono dane podmiotom zewnętrznym bez umowy powierzenia ani innej podstawy prawnej.⁴⁰
- *Przechowywanie dokumentów tożsamości klientów bez podstawy prawnej.* Instytucje finansowe i inne podmioty skanują i przechowują kopie dokumentów tożsamości w celach, mimo że przepisy prawa nie nakładają takiego obowiązku i wystarczająca jest jedynie weryfikacja tożsamości bez utrwalania kopii dokumentu. Prezes UODO nałożył na *ING Bank Śląski* karę w wysokości 18,4 mln zł za masowe i niezasadnione skanowanie oraz przechowywanie dokumentów tożsamości klientów, co było najwyższą karą w historii polskiego organu nadzorczego w roku 2025.⁴¹
- *Wysyłanie dokumentów kadrowych do niewłaściwych adresatów.* Świadczenia pracy, paski płac, aneksy do umów i inne dokumenty HR zawierające dane osobowe kierowane są pocztą elektroniczną lub tradycyjną do błędnych odbiorców wskutek pomyłek przy wpisywaniu adresu lub autouzupełniania skrzynki pocztowej. Błędne skierowanie korespondencji jest jednym z najczęściej zgłaszanych naruszeń do UODO, stanowi 18% wszystkich raportowanych incydentów bezpieczeństwa danych.⁴² Każde takie zdarzenie wymaga oceny ryzyka i potencjalnego zgłoszenia do organu nadzoru w ciągu 72 godzin od wykrycia.
- *Ignorowanie alertów DLP i poszukiwanie obejść.* Pracownicy traktują ostrzeżenia systemów DLP jako fałszywe alarmy i aktywnie szukają sposobów ich ominięcia, kopiując dane na prywatne pendrive'y, wysyłając pliki przez prywatne konto e-mail lub korzystając z platform wymiany plików (WeTransfer, Smash). Badanie WifiTalents wykazało, że 47% pracowników omija kontrole bezpieczeństwa, a organizacje dysponują średnio 975 nieznanymi usługami chmurowymi, z których monitorują jedynie ok. 108.⁴³ Gartner szacuje, że na typowego pracownika korporacyjnego przypada

³⁹Agencia Española de Protección de Datos (AEPD), *Personal Data Breaches: Development and Pre-Production Environments*.

⁴⁰Najwyższa Izba Kontroli. *RODO w szpitalu – wyniki kontroli*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Najwyższa Izba Kontroli, 2019. URL: <https://www.nik.gov.pl/najnowsze-informacje-o-wynikach-kontroli/rodo-w-szpitalu.html>.

⁴¹Gazeta Prawna. „Raport: w 2025 r. padły rekordowe kary za naruszenia RODO – najwyższa dla Poczty Polskiej”. W: *Gazeta Prawna* (2026). Dostęp: 10 marca 2026. URL: <https://www.gazetaprawna.pl/firma-i-prawo/artykuly/10648769,raport-w-2025-r-padly-rekordowe-kary-za-naruszenia-rodo-najwyzsza-.html>.

⁴²Data Protection People, *GDPR Data Breaches & Human Error: How Bad Is It?*; ODO 24. *Naruszenia ochrony danych – jakie są zgłaszane najczęściej i jak można im zapobiegać*. Dostęp: 10 marca 2026. 2020. URL: <https://odo24.pl/blog-post.naruszenia-ochrony-danych-jakie-sa-zgłaszane-najczesciej-i-w-jaki-sposob-mozna-im-zapobiegac>.

⁴³WifiTalents, *Shadow IT Statistics: Reports 2025*; Fidelis Security. *Shadow IT Risks, Examples, and Detection*. Dostęp: 10 marca 2026. 2026. URL: <https://fidelissecurity.com/cybersecurity-101/cloud-security/shadow-it-risks-examples-and-detection/>.

średnio 13 aplikacji shadow IT używanych równolegle.⁴⁴

DRAFT

⁴⁴WifiTalents, *Shadow IT Statistics: Reports 2025*.

6. ORION - Ocena Ryzyka Informatycznego Organizacji Nadzorowanych

6.1 Luka badawcza

Istniejące metodologie obejmują zarządzanie bezpieczeństwem, zarządzanie ryzykiem i kontrole organizacyjne w znacznym stopniu w kierunku analizy systemów informatycznych. Są to standardy rynkowe, takie jak metodologie zdefiniowane w ISO/IEC 27001, NIST Cybersecurity Framework, COBIT. Jednak żadna z nich nie spełnia jednocześnie zasadniczych wymagań stawianych przez współczesne środowiska regulacyjne. Po pierwsze, brakuje im wielostronnej perspektywy obejmującej cały łańcuch dostaw ICT, od nadzorowanego podmiotu, poprzez jego bezpośrednich dostawców, po podprocesory działające na wielu poziomach. Po drugie, nie zawierają one opartego na dowodach mechanizmu punktacji, który rozróżniałby zweryfikowaną zgodność od zwykłego zapewnienia deklaratywnego rozróżnienia, które jest fundamentalne dla przeciwdziałania dobrze udokumentowanemu zjawisku *teatru zgodności*. Po trzecie, nie zapewniają one wieloaspektowej struktury analitycznej, która formalnie przypisuje pytania audytowe do odpowiedniego podmiotu w organizacji, tj. radcy prawnego, biznesu, architekta oprogramowania lub administratora infrastruktury, w oparciu o charakter pytania, a nie wygodę organizacji. Po czwarte, nie oferują modułowej rozszerzalności sektorowej, która zachowuje uniwersalny rdzeń metodologiczny, jednocześnie aktywując perspektywy i zestawy pytań specyficzne dla danej dziedziny dla regulowanych branż, takich jak finanse czy opieka zdrowotna.

Tabela 6.1: Analiza porównawcza frameworków stosowanych w polskiej praktyce audytowej względem wymagań ORION

Wymaganie	ISO/IEC 27001	NIST CSF	COBIT 2019	Narzędzia GRC	ORION
Pokrycie całego łańcucha dostaw ICT	Częściowe (tylko załącznik dot. dostawców)	Częściowe (profil łańcucha dostaw)	Częściowe (zarządzanie dostawcami)	Częściowe (zależne od narzędzia)	Pełne
Ocena oparta na dowodach	Nie	Nie	Nie	Częściowe (zależne od konfiguracji)	Tak

Kontynuacja na następnej stronie...

Tabela 6.1 – kontynuacja z poprzedniej strony

Wymaganie	ISO/IEC 27001	NIST CSF	COBIT 2019	Narzędzia GRC	ORION
Wieloperspektywiczne przypisanie pytań (prawna / biznesowa / techniczna)	Nie	Nie	Częściowe (tylko macierz RACI)	Nie	Tak
Formalny model grafowy zależności ICT	Nie	Nie	Nie	Nie	Tak
Propagacja ryzyka przez warstwy łańcucha dostaw	Nie	Nie	Nie	Nie	Tak
Scoring zgodności z regulacjami (DORA / NIS2 / RODO)	Częściowe (istnieją mapowania)	Częściowe (istnieją mapowania)	Częściowe (istnieją mapowania)	Częściowe (zależne od konfiguracji)	Tak
Rozróżnienie wymogów obowiązkowych od dobrych praktyk	Nie	Nie	Nie	Częściowe	Tak
Modułowa rozszerzalność sektorowa (finanse, zdrowie, energetyka)	Nie	Częściowe (profile branżowe)	Nie	Częściowe (płatne moduły)	Tak
Penalizacja niezwyfikowanych deklaracji	Nie	Nie	Nie	Nie	Tak
Identyfikacja dostawców kluczowych	Częściowe	Częściowe	Częściowe	Częściowe	Tak
Ocena planu wyjścia (exit plan)	Nie	Nie	Częściowe	Częściowe	Tak
Transparentna, replikowalna metodologia	Tak	Tak	Tak	Nie (metodyka zastrzeżona)	Tak
Formalny model matematyczny	Nie	Nie	Nie	Nie	Tak

Kontynuacja na następnej stronie...

Tabela 6.1 – kontynuacja z poprzedniej strony

Wymaganie	ISO/IEC 27001	NIST CSF	COBIT 2019	Narzędzia GRC	ORION
Klasyfikacja ryzyka wg pochodzenia geograficznego (EOG / USA / pozostałe)	Nie	Nie	Nie	Nie	Tak

Legenda: **Tak** - wymaganie w pełni adresowane; **Częściowe** - wymaganie adresowane w ograniczonym zakresie lub wymagające dodatkowej konfiguracji; **Nie** - wymaganie nieadresowane.

Uwaga: Porównanie obejmuje frameworki powszechnie stosowane w polskiej praktyce audytowej i compliance. Frameworki NIST SP 800-161 oraz ISACA CMMI, choć obecne w literaturze akademickiej, nie są szeroko stosowane jako samodzielne metodyki przez polskie organizacje i zostały pominięte w niniejszym zestawieniu.

Skróty: CSF - *Cybersecurity Framework*; GRC - *Governance, Risk and Compliance* (ład, ryzyko i zgodność).

Mimo intensywności regulacyjnej prowadzonej przez regulatorów krajowych oraz międzynarodowych, brakuje usystematyzowanej metodyki, która pozwoliłaby organizacjom w sposób transparentny, co bardzo istotne powtarzalny i oparty na obiektywnych dowodach ocenić stan zgodności wdrożonych systemów informatycznych wraz z ich łańcuchem dostawców. Dobrze przeprowadzony audyt systemów tworzy raport czytelny i zrozumiały dla wszystkich interesariuszy i faktycznie wskazuje na niezgodności. Istniejące narzędzia i frameworki, norma ISO/IEC 27001, NIST Cybersecurity Framework, model COBIT czy metodyki ISACA, dostarczają wskazówek w zakresie zarządzania bezpieczeństwem informacji, jednak żaden z nich nie adresuje jednocześnie:

- perspektywy wielopodmiotowej obejmującej cały łańcuch ICT,
- oceny opartej na weryfikowalnych dowodach jako mechanizmu przeciwdziałającego deklaratywnej zgodności,
- wieloperspektywicznej analizy uwzględniającej punkt widzenia prawnika, menedżera biznesowego i inżyniera IT,
- rozszerzalności sektorowej pozwalającej na adaptację do specyfiki regulacyjnej różnych branż przy zachowaniu wspólnego rdzenia metodycznego.

Rezultatem jest rozdrobniona praktyka, w której oceny prawne, techniczne i biznesowe są przeprowadzane w izolacji, podwykonawcy pozostają niesprawdzani, a wnioski z audytu opierają się na deklaracjach, a nie na weryfikowalnych dowodach. Audyty przeprowadzane według istniejących metodyk często kończą się certyfikatami potwierdzającymi zgodność procesową, które nie odzwierciedlają faktycznego stanu bezpieczeństwa wdrożeń. Zjawisko to, zwane *compliance theater*, wynika ze słabości systemów oceny opartych na deklaracjach. Organizacja może, z pełną znajomością swoich procedur oświadczyć, że wdrożyła wymagane środki ochrony, podczas gdy stan faktyczny jest odmienny, dokumentacja jest nieaktualna, mechanizmy kontrolne nieskuteczne, a dostawcy zewnątrz nie podlegają żadnej weryfikacji.

6.2 Postulaty i cele ORION

Metodologia ORION (*Ocena Ryzyka Nadzorowanych Systemów Informatycznych*) nie ma na celu zastępowania metodologii audytowania zgodnych z ISO czy NIST. Wypełnia istotną lukę w analizie wdrożeń systemów informatycznych z punktu widzenia zgodności z regulacjami. Jest to system oparty na dowodach, ponieważ, jak wykazują badania przytoczone w rozdziale poświęconym walidacji odpowiedzi, organizacje nagminnie deklarują zgodność, której nie są w stanie udokumentować, a ta funkcja jest kluczowa.

Audyt prowadzony w ORION jest wykonywany ogólnie dla przedsiębiorstwa jako całości, analizując jego zgodność prawną z wymogami regulacyjnymi, a następnie, zgodnie z przejściem grafu ICT, przeprowadzany jest na wszystkich systemach i ich dostawcach. Identyfikowani są wszyscy poddostawcy w łańcuchu ICT i wszyscy podlegają badaniu. Wynikiem działania systemu jest określenie, który dostawca jest kluczowy, oraz wyznaczenie poziomu zgodności z prawem i rekomendacji naprawczych z przypisanymi priorytetami.

ORION wprowadza cztery kluczowe innowacje metodyczne względem istniejących frameworków.

Pierwszą z nich jest zasada wieloperspektywiczności. ORION przyjmuje, że każdy element składowy infrastruktury ICT (system informatyczny, dostawca, wymóg, etc), jest rozumiany odmiennie przez prawnika, menedżera biznesowego, architekta oprogramowania czy administratora infrastruktury. Odmiennosc ta nie jest wadą, którą należy eliminować, jest naturalną cechą wynikającą z różnych wyzwań i zadań na poszczególnych stanowiskach, którą metodyka musi uwzględniać. Perspektywa nie jest wyłącznie kategorią opisową, determinuje, kto w organizacji jest właściwą osobą do udzielenia odpowiedzi na konkretne pytanie audytowe, co eliminuje jeden z fundamentalnych błędów istniejącej praktyki: odpowiadanie na pytania prawne przez inżynierów i na pytania techniczne przez prawników.

Drugą innowacją jest ocena oparta na dowodach. Każda odpowiedź na pytanie audytowe podlega weryfikacji przez pryzmat dostarczonego dowodu materialnego. Metodyka rozróżnia trzy poziomy jakości dowodu: brak dowodu, deklarację pisemną oraz dowód potwierdzony materialnie: log systemowy, certyfikat, wynik testu penetracyjnego, protokół z próby odtworzenia systemu. Dodatkowo, dowód pisemny jest traktowany w zależności od jego sporządzenia, inaczej system bierze pod uwagę oświadczenie pisemne czytelnie podpisane, inaczej oświadczenie pisemne będące wynikiem anonimowego dokumentu. Brak dowodu nie zmienia odpowiedzi twierdzącej na przeczącą, lecz obniża jej efektywną wartość w modelu scoringowym w sposób kontrolowany i konfigurowalny. Mechanizm ten precyzyjnie odzwierciedla rzeczywistość audytu: organizacja może stosować właściwe praktyki bez ich pełnej dokumentacji, ale twierdzenie bez weryfikacji ma mniejszą wartość poznawczą niż twierdzenie udokumentowane. Jednoczenie konieczność przygotowania dowodu, co więcej, osobistego podpisania się pod dowodem, skutkuje wysoką rzetelnością odpowiedzi. Jest to bezpośrednia odpowiedź na compliance theater.

Trzecią innowacją jest grafowe modelowanie łańcucha ICT z propagacją ryzyka. Audyt w ORION nie jest przeprowadzany wyłącznie dla podmiotu nadzorowanego traktowanego jako niepodzielna całość, obejmuje wszystkich dostawców i poddostawców ICT, reprezentowanych jako wierzchołki skierowanego grafu zależności. Mechanizm systematycznego przejścia grafu zapewnia pełną identyfikację podmiotów w łańcuchu dostaw, które w tradycyjnych audytach pozostają poza polem widzenia. Algorytm propagacji ryzyka umożliwia z kolei obliczenie skumulowanego wpływu niezgodności na poziomie poddostawcy na ryzyko całego podmiotu nadzorowanego ,co odpowiada na pytanie, które organizacje

zadają coraz częściej: czy mój dostawca jest bezpieczny, a jeśli nie, jak bardzo to mnie dotyczy?

Czwartą innowacją jest modułowa rozszerzalność sektorowa. System ORION jest zaprojektowany jako uniwersalne narzędzie z możliwością rozszerzenia na kolejne sektory. Rdzeń metodyczny, ontologia pojęć, model grafowy, formuły scoringu, struktura pytań i raportowania, jest niezależny od branży i może być stosowany wobec dowolnego podmiotu przetwarzającego dane w systemach ICT. Rozszerzenia domenowe, aktywowane w zależności od sektora audytowanego podmiotu, wprowadzają dodatkowe perspektywy, grupy pytań i wymogi regulacyjne specyficzne dla danej branży. Oznacza to w praktyce, że ten system ORION może obsłużyć audyt banku, szpitala i operatora energetycznego, różniąc się zestawem aktywnych pytań i perspektyw, lecz zachowując identyczny model matematyczny, ontologię i strukturę raportu. Ta cecha ORION ma istotne znaczenie nie tylko praktyczne, lecz także naukowe: pozwala na prowadzenie badań porównawczych między sektorami z użyciem jednolitej metodyki.

6.3 Identyfikacja podmiotu audytowanego

Przed przystąpieniem do właściwego audytu systemów informatycznych metodologia ORION wymaga przeprowadzenia wstępnej klasyfikacji podmiotu audytowanego. Celem tej fazy jest ustalenie, jakim reżimem regulacyjnym podlega organizacja, w szczególności, czy jest ona podmiotem kluczowym lub ważnym w rozumieniu dyrektywy NIS2,¹ podmiotem objętym zakresem stosowania rozporządzenia DORA,² czy też jednostką podlegającą wyłącznie wymogom ogólnym, takim jak RODO.³ Wynik tej klasyfikacji determinuje, które moduły pytań zostaną aktywowane w dalszych etapach audytu, jakie mnożniki wagowe zostaną przypisane do poszczególnych wymogów oraz które elementy, takie jak plan ciągłości działania czy exit plan, mają charakter obowiązkowy, a które stanowią dobrowolne zalecenie.

Klasyfikacja podmiotu jest przeprowadzana metodą walidacji krzyżowej, gdzie zagadnienie analizowane jest niezależnie w perspektywie zgodności, perspektywie użytkownika oraz perspektywie technicznej, a wynik jest ustalany na podstawie konsensusu odpowiedzi. Wynikiem klasyfikacji jest przypisanie podmiotu do jednej z czterech kategorii regulacyjnych: **FINANSOWY** (podmioty objęte rozporządzeniem DORA), **KLUCZOWY** (podmioty kluczowe w rozumieniu dyrektywy NIS2 i ustawy KSC), **WAŻNY** (podmioty ważne w rozumieniu NIS2 i KSC) lub **POZOSTAŁE** (podmioty podlegające wyłącznie wymogom ogólnym, w szczególności RODO). Kategoria determinuje zakres obowiązkowych elementów audytu oraz wartość mnożnika regulacyjnego w_{reg} , których szczegółową charakterystykę przedstawia tabela 7.1.

¹Dyrektywa NIS2.

²Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

³RODO.

6.4 Mechanizm walidacji jakości dowodów i odpowiedzi

6.4.1 Struktura pytań

Pytania stawiane w audycie mają z definicji wartość binarną. Oznacza to, że ankietowany może odpowiedzieć na pytanie tylko i wyłącznie TAK lub NIE. Każdemu pytaniu przypisana jest ODPOWIEDŹ OCZEKIWANA, rozumiana jako wartość wskazująca na stan zgodności z wymaganiem zgodne z semantyką treści pytania.

Działanie wartości oczekiwanej idealnie zilustruje przykład dwóch pytań:

Czy dwa plus dwa jest cztery?

Oraz pytanie drugie:

Czy dwa plus dwa różne od czterech?

W przypadku pierwszym odpowiedzią oczekiwaną jest TAK, w przypadku drugim NIE. Współczynnik wagowy przypisywany jest wyłącznie wtedy, gdy odpowiedź jest zgodna z ODPOWIEDZIĄ OCZEKIWANĄ.

Zrezygowano z opcji NIE WIEM / BRAK DANYCH. W sytuacji braku znajomości odpowiedzi oczekuje się, że ankietowany podejmie wysiłek uzyskania informacji. Brak pewności w odpowiedzi powinien być rozstrzygany na niekorzyść audytu i wynika to z konieczności ochrony organizacji.

Decyzja o rezygnacji z opcji NIE WIEM / BRAK DANYCH jest uzasadniona zarówno metodologicznie, jak i z perspektywy zarządzania ryzykiem. Badania nad konstrukcją kwestionariuszy wykazują, że obecność opcji neutralnej skłania respondentów do udzielania odpowiedzi zastępczych zamiast podejmowania wysiłku poznawczego niezbędnego do udzielenia odpowiedzi merytorycznej, zjawisko to określane jest w literaturze jako *satisficing*.⁴ Kwestionariusze z wymuszonym wyborem binarnym generują dane wyższej jakości i lepiej różnicują rzeczywiste stany wiedzy respondentów niż skale z opcją neutralną.⁵ W kontekście audytu bezpieczeństwa informatycznego brak wiedzy o stanie systemu jest sam w sobie wskaźnikiem ryzyka. Organizacja, która nie jest w stanie potwierdzić zgodności z wymaganiem, nie spełnia go z punktu widzenia ochrony.⁶ Przyjęcie zasady rozstrzygania wątpliwości na niekorzyść audytu odpowiada powszechnie stosowanej w zarządzaniu ryzykiem zasadzie, zgodnie z którą niepewność nie redukuje ryzyka, lecz je potęguje.

Dodatkowo, wprowadzona została opcja flagi blokującej $FLAG_{block}(S) = TRUE$ do pytań, których niespełnienie (odpowiedź inna niż OCZEKIWANA) oznacza przypisanie wartości zerowej dla całej sekcji. Są to pytania kluczowe, które muszą być bezwzględnie spełnione.

⁴Jon A. Krosnick i in. „The Impact of “No Opinion” Response Options on Data Quality: Non-Attitude Reduction or an Invitation to Satisfice?” W: *Public Opinion Quarterly* 66.3 (2002), s. 371–403. DOI: 10.1086/341394.

⁵Sara Dolnicar, Bettina Grün i Friedrich Leisch. „Quick, simple and reliable: forced binary survey questions”. W: *International Journal of Market Research* 53.2 (2011), s. 231–252. DOI: 10.2501/IJMR-53-2-231-252.

⁶Erika A. Waters i in. „Dismissing “don’t know” responses to perceived risk survey questions”. W: *Sage Journals* (2021). DOI: 10.1177/17456916211017860.

6.4.2 Model dowodowy

Każda odpowiedź na pytanie audytowe w ORION musi być opatrzona dowodem. Dowód nie zmienia wartości odpowiedzi z TAK na NIE ani odwrotnie, lecz modyfikuje wagę odpowiedzi w modelu scoringowym. Logika ta odzwierciedla cel audytu, organizacja może faktycznie stosować właściwe praktyki bez ich pełnej i faktycznej dokumentacji istniejącego ryzyka, że dowód jest wadliwy.

Równie istotny jest aspekt behawioralny: badania z zakresu psychologii decyzji wskazują, że osoby podpisujące oświadczenia własnym imieniem i nazwiskiem kłamią istotnie rzadziej niż autorzy anonimowych dokumentów.⁷ Wymóg osobistego podpisania dowodu jest zatem nie tylko formalny, lecz pełni funkcję mechanizmu antydefraudacyjnego wbudowanego w strukturę audytu.

6.4.3 Walidacja odpowiedzi

Walidacja odpowiedzi jest kluczowa, do prawidłowego przeprowadzenia procesu audytowania. Wskazują na to wyniki badań, które wskazują, że awersja do kłamstwa pojawia się głównie przy obowiązkowym raportowaniu.⁸

Osoby wypełniające dane ograniczają kłamstwo w wypełnianych ankietach, gdy są zobligowane do złożenia oświadczenia imiennego, potwierdzającego zgodne z prawdą wypełnienie ankiety. Badania wskazują, że współczynnik nieprawdziwych odpowiedzi wynosi $g = 0.24$.⁹ Współczynnik g (zwany *Hedges' g*) to standaryzowana miara wielkości efektu, wyraża jak duża jest różnica między grupami w jednostkach odchylenia standardowego.

6.4.4 Skala jakości dowodów

Metodologia ORION wymaga przeprowadzenia odpowiedniej walidacji dowodu i jakości dowodu, co bezpośrednio wpływa na wagę odpowiedzi. ORION wyróżnia cztery poziomy jakości dowodu, zdefiniowane w tabeli 6.2. oznaczane symbolem $d \in \{0; 0,5; 0,8; 1,0\}$.

⁷Friesen, „Designing Self-Reporting Regimes to Encourage Truth Telling”.

⁸Friesen, „Designing Self-Reporting Regimes to Encourage Truth Telling”.

⁹Peer, Vanhoof i in., „Commitment to honesty oaths decreases dishonesty, but commitment to another individual does not”.

Tabela 6.2: Skala jakości dowodów w metodologii ORION

Poziom	Symbol d	Definicja	Przykłady
Brak dowodu	$d = 0$	Odpowiedź udzielona wyłącznie ustnie lub pisemnie bez jakiegokolwiek dokumentu potwierdzającego; nie-możliwa do weryfikacji przez audytora.	Oświadczenie słowne podczas wywiadu, odpowiedź wpisana bezpośrednio w formularz bez załącznika
Dowód słaby	$d = 0,4$	Dokument pisemny bez wskazania autora lub anonimowy; dokument ogólny niepowiązany wprost z audytowanym systemem.	Regulamin ogólny dostawcy, polityka bezpieczeństwa bez daty i podpisu, screen z systemu bez kontekstu
Dowód średni	$d = 0,7$	Oświadczenie pisemne z czytelnym podpisem osoby fizycznej i datą; dokument wskazujący jednoznacznie na audytowany system.	Podpisana deklaracja zgodności, umowa powierzenia z klauzulą TIA, certyfikat ISO z numerem seryjnym
Dowód silny	$d = 1,0$	Dowód materialny niemożliwy do sfalszowania bez pozostawienia śladu technicznego; log systemowy, wynik testu automatycznego, lub oświadczenie podpisane z poświadczeniem tożsamości wskazujące na pytanie audytowe.	Log z systemu SIEM, wynik testu penetracyjnego, protokół z próby odtworzenia z BCP, oświadczenie potwierdzone podpisem osobistym.

6.4.5 Wpływ dowodu na wartość odpowiedzi

Efektywna wartość odpowiedzi na pytanie audytowe jest iloczynem odpowiedzi binarnej i jakości dowodu:

$$V_{eff}(q_j, \pi_i) = a_{ij} \cdot d_{ij} \quad (6.1)$$

gdzie $a_{ij} \in \{0, 1\}$ jest odpowiedzią perspektywy π_i na pytanie q_j , a $d_{ij} \in \{0; 0,4; 0,7; 1,0\}$ jest jakością dostarczonego dowodu.

Konsekwencje praktyczne wzoru (6.1) są następujące:

- odpowiedź TAK bez dowodu ($a = 1, d = 0$) daje $V_{eff} = 0$ jest traktowana identycznie jak odpowiedź NIE,
- odpowiedź TAK z dowodem silnym ($a = 1, d = 1,0$) daje $V_{eff} = 1,0$ pełna wartość,
- odpowiedź NIE z dowodem silnym ($a = 0, d = 1,0$) daje $V_{eff} = 0$ wskazuje na niezgodność między odpowiedzią, a dowodem.

Mechanizm ten precyzyjnie odzwierciedla cel audytu: nie interesuje nas, co organizacja mówi, że robi, interesuje nas, co jest w stanie udowodnić.

6.4.6 Walidacja krzyżowa oraz definicja konsensusu

Walidacja krzyżowa (*cross-validation*) jest kluczowym mechanizmem metodologii ORION, zapewniającym rzetelność klasyfikacji atrybutów i odpowiedzi na pytania audytowe. To samo zagadnienie przedstawione jest użytkownikom z co najmniej dwóch perspektyw z trzech, a wynik jest ustalany na podstawie porównania odpowiedzi. Mechanizm ten realizuje dwa cele jednocześnie: po pierwsze, wykrywa rozbieżności między perspektywami, które są same w sobie wartościowymi sygnałami audytowymi; po drugie, zwiększa odporność systemu na celowe lub niecelowe podawanie nieprawdziwych informacji przez jeden z aktorów.

Definicja 6.1 (Formalna definicja konsensusu). *Niech Q będzie zagadnieniem audytowym zadany perspektywom ze zbioru $\Pi_Q \subseteq \Pi$, gdzie $|\Pi_Q| \geq 2$. Każda perspektywa $\pi_i \in \Pi_Q$ udziela odpowiedzi $a_i \in \{0,1\}$ (NIE / TAK). Wynik cross-validation zagadnienia Q definiuje się jako:*

$$CV(Q) = \begin{cases} 1 & \text{jeśli } |\{i : a_i = 1\}| > |\{i : a_i = 0\}| \\ 0 & \text{jeśli } |\{i : a_i = 0\}| > |\{i : a_i = 1\}| \\ \emptyset & \text{jeśli remis lub brak odpowiedzi} \end{cases} \quad (6.2)$$

Gdy $CV(Q) = \emptyset$, zagadnienie jest oznaczane flagą ROZBIEŻNOŚĆ i nie może zostać zatwierdzone bez interwencji audytora. W takim przypadku efektywna wartość zagadnienia jest penalizowana:

$$V_{eff}(Q) = \min_i(a_i) \cdot \beta_{cv} \quad (6.3)$$

gdzie $\beta_{cv} \in [0,1]$ jest konfigurowalnym współczynnikiem kary za brak konsensusu (wartość domyślna: $\beta_{cv} = 0,5$).

Innymi słowy: brak zgody między perspektywami jest traktowany jako połowicznie negatywna odpowiedź, nawet jeśli jeden z aktorów odpowiedział twierdząco.

Gdy konsensus jest osiągnięty i wszystkie perspektywy dostarczyły dowody najwyższej jakości, efektywna wartość jest dodatkowo premiuwana:

$$V_{eff}(Q) = CV(Q) \cdot \left(1 + \gamma \cdot \mathbb{K}[\forall i : d_i = d_{max}]\right) \quad (6.4)$$

gdzie $\gamma = 0,1$ jest premią za pełny konsensus z kompletem dowodów najwyższej jakości, a d_{max} jest najwyższym poziomem dowodu w skali opisanej w sekcji 6.4.2.

6.4.7 Interpretacja rozbieżności

Rozbieżność między perspektywami nie jest błędem procesu audytowego, jest wartościową informacją merytoryczną. Tabela 6.3 przedstawia najczęstsze wzorce rozbieżności i ich standardową interpretację w ORION.

Tabela 6.3: Wzorce rozbieżności cross-validation i ich interpretacja audytowa

Wzorzec rozbieżności	Typowa przy- czynna	Interpretacja i zalecane działanie
Zgodność: TAK Użytkownik: NIE Techniczna: NIE	Wymóg zdefiniowany w przepisach, lecz nieimplementowany	Compliance theater: organizacja deklaruje zgodność formalną bez rzeczywistego wdrożenia. Flaga P1.
Zgodność: NIE Użytkownik: TAK Techniczna: TAK	Praktyka wdrożona bez formalnej podstawy prawnej	Brak świadomości regulacyjnej. Ryzyko braku dokumentacji wymaganej przez regulatora. Rekomendacja formalizacji.
Zgodność: TAK Użytkownik: TAK Techniczna: NIE	Wymaganie znane, polityka istnieje, wdrożenie niezrealizowane	Luka techniczna. Wymóg zdefiniowany lecz nieimplementowany na poziomie systemów. Flaga P2.
Zgodność: NIE Użytkownik: NIE Techniczna: TAK	System techniczny bez świadomości biznesowej i prawnej	Shadow IT lub wdrożenie bez akceptacji zarządczej. Wymaga formalnej inwentaryzacji i decyzji.

6.5 Definicje i aktorzy

6.5.1 Perspektywa

Perspektywa punktu widzenia systemu określa interesariuszy uczestniczących w ocenie oraz sposób ich rozumienia analizowanych zagadnień. Każde pytanie ankietowe jest przypisane do co najmniej dwóch perspektyw, o ile jest to możliwe, do wszystkich trzech. Umożliwia to prowadzenie analizy porównawczej odpowiedzi na to samo kryterium, udzielonych niezależnie przez różnych interesariuszy. Rozbieżności między perspektywami stanowią sygnał do dalszego wyjaśnienia i są równie wartościowe analitycznie jak odpowiedzi zgodne.

Zdefiniowane są trzy perspektywy:

- (i) *Perspektywa zgodności*, reprezentuje punkt widzenia osób odpowiedzialnych za przestrzeganie regulacji, takich jak prawnik, inspektor ochrony danych osobowych (IOD/DPO) czy specjalista ds. compliance. Celem tej perspektywy jest ocena kryterium pod kątem zgodności z obowiązującymi przepisami prawa, regulacjami rynkowymi oraz wewnętrznymi politykami organizacji (np. RODO, NIS2, DORA).

- (ii) *Perspektywa użytkownika*, reprezentuje jednostki organizacyjne firmy aktywnie korzystające z systemu w codziennej pracy, takie jak właściciel biznesowy systemu, kierownik działu lub kluczowy użytkownik końcowy. Celem tej perspektywy jest uzyskanie odpowiedzi odzwierciedlającej rzeczywisty sposób wykorzystania systemu, nie jego założenia projektowe, lecz faktyczny stan i pola eksploatacji.
- (iii) *Perspektywa techniczna*, reprezentuje punkt widzenia osób odpowiedzialnych za budowę, utrzymanie i bezpieczeństwo systemu, takich jak architekt systemów, administrator lub inżynier. Celem tej perspektywy jest ocena, czy implementacja i wdrożenie systemu zostały przeprowadzone zgodnie z obowiązującymi standardami technicznymi i najlepszymi praktykami branżowymi.

Przyjęte perspektywy determinują strukturę pytań ankietowych, w których pojedyncze kryterium analizowane jest przez pryzmat trzech różnych ujęć oraz wpływają na sposób definiowania obiektów. Ilustrując to podejście przykładem, zadajmy sobie pytanie:

Jaka jest definicja systemu CRM?

Na tak postawione pytanie zostaną udzielone trzy komplementarne odpowiedzi:

- (i) Z punktu widzenia *użytkownika*, system CRM służy do rejestrowania wszystkich kontaktów z klientami oraz realizacji procesów sprzedażowych.
- (ii) Z punktu widzenia *zgodności*, system oraz jego fizyczna lokalizacja muszą gwarantować zgodność z polityką RODO, zapewniając organizacji pełną wiedzę o miejscu przetwarzania danych osobowych.
- (iii) Z punktu widzenia *technicznego*, jest to rozwiązanie informatyczne, które ma zapewniać dostępność zasobów dla uprawnionych użytkowników poprzez określone kanały komunikacyjne.

6.5.2 Obiekt

Centralnym pojęciem metodyki ORION jest **obiekt**, reprezentujący byt w systemie ICT organizacji, który może być przedmiotem oceny zgodności regulacyjnej. Pojęcie obiektu jest szerokie: obejmuje zarówno systemy informatyczne działające na infrastrukturze własnej organizacji, jak i zewnętrznych dostawców usług, platformy chmurowe oraz poddostawców odkrytych w toku rozszerzania grafu ICT.

Definicja 6.2 (Obiekt). *Obiekt jest formalną jednostką audytową systemu ORION, reprezentującą byt w ekosystemie ICT organizacji, który:*

- (i) *posiada tożsamość możliwą do jednoznacznej identyfikacji w grafie zależności ICT,*
- (ii) *może być przypisany do co najmniej jednego właściciela lub podmiotu odpowiedzialnego,*
- (iii) *podlega co najmniej jednemu wymogowi regulacyjnemu wynikającemu z obowiązujących przepisów prawa,*
- (iv) *może być oceniany z co najmniej dwóch perspektyw audytowych zdefiniowanych w zbiorze II.*

Formalnie, obiekt jest wierzchołkiem $v \in V$ grafu $ICT\ G = (V, E, W)$, posiadającym zbiór atrybutów klasyfikacyjnych $\mathcal{A}(v)$ determinujących zakres i intensywność przeprowadzanego audytu.

W ORION obiektem jest zarówno aplikacja webowa obsługująca klientów banku, dostawca chmury publicznej, na której ta aplikacja działa, jak i usługi firmy świadczącej usługi zarządzania kluczami kryptograficznymi na rzecz tego dostawcy chmury. Każdy z tych bytów jest odrębnym wierzchołkiem grafu, odrębnym podmiotem audytu i odrębnym źródłem ryzyka, choć wszystkie wymienione podmioty uczestniczą w tym samym łańcuchu przetwarzania danych.

Typy obiektów

ORION wyróżnia cztery typy obiektów, które determinują domyślny zestaw aktywowanych sekcji pytań oraz rolę wierzchołka w grafie ICT. Każdy obiekt posiada właściwości, czyli pola przyjmujące definiowane przez audytora wartości:

Tabela 6.4: Typy obiektów w systemie ORION

Typ	Definicja	Przykłady
PODMIOT Właściwości: nazwa	Korzeń grafu ICT (v_0); audytowana organizacja jako całość. Nie jest bezpośrednio oceniany pytaniami szczegółowymi, jego wynik wynika z agregacji wszystkich pozostałych obiektów.	Bank, szpital, operator infrastruktury krytycznej
SYSTEM_INFORMATYCZNY Właściwości: nazwa, dostawca, właściciel biznesowy	Oprogramowanie służące do gromadzenia, przetwarzania i przesyłania informacji.	System kadrowo-płacowy, baza danych pacjentów, portal intranetowy, API płatności
DOSTAWCA Właściwości: nazwa, kraj pochodzenia, poddostawca	Zewnętrzny podmiot prawny świadczący usługi ICT na rzecz organizacji na podstawie umowy; odkryty na pierwszym poziomie grafu.	Dostawca ERP, operator chmury publicznej, firma hostingowa, integrator systemów
PODDOSTAWCA Właściwości: nazwa, kraj pochodzenia	Zewnętrzny podmiot prawny świadczący usługi ICT na rzecz dostawcy lub innego poddostawcy; odkryty przez mechanizm triggera TIA lub deklarację dostawcy wyższego poziomu.	Google LLC jako operator infrastruktury dostawcy ERP, Cloudflare jako CDN aplikacji webowej, firma zarządzająca kluczami kryptograficznymi

6.5.3 Atrybuty obiektów

Każdy obiektów jest scharakteryzowany przez zbiór atrybutów klasyfikacyjnych $\mathcal{A}(v)$, które pełnią dwie funkcje. Po pierwsze, determinują, które sekcje pytań audytowych zostaną aktywowane dla danego obiektów, na przykład system wewnętrzny działający wyłącznie on-premise nie otrzyma pytań dotyczących transferu danych do chmury. Po drugie, wyznaczają wagi stosowane w modelu scoringowym, decydując o tym, jak mocno wynik danego obiektu wpływa na wynik całego podmiotu.

6.5.4 Atrybut: dostępność systemu

Atrybuty obiektów są ustalane w fazie wstępnej audytu za pomocą pomocniczej ankiety, przed wygenerowaniem kwestionariusza szczegółowego. Widoczność systemu i jego krytyczność, jest wyznaczana przez mechanizm cross-validation z udziałem co najmniej dwóch perspektyw.

Definicja 6.3 (Poziom dostępności systemu). *Poziom dostępności obiektu v jest wartością ze zbioru:*

$$\text{dostępność}(v) \in \{\text{PRYWATNY}, \text{PUBLICZNY}\}$$

wyznaczaną przez mechanizm cross-validation na podstawie odpowiedzi co najmniej dwóch z trzech perspektyw rdzeniowych: ZGODNOŚCI, UŻYTKOWNIKA i TECHNICZNEJ.

Tabela 6.5: Poziomy dostępności obiektu, kryteria klasyfikacji i mnożniki wagowe

Poziom	w_{krit}	Kryteria klasyfikacji	Przykład
PRYWATNY	1,0	System informatyczny działający na infrastrukturze własnej organizacji lub zarządzanej wyłącznie przez nią; bez bezpośredniego dostępu z sieci publicznej.	System kadrowo-płacowy on-premise, baza danych pacjentów, wewnętrzny portal intranetowy
PUBLICZNY	2,5	System informatyczny dostępny z sieci publicznej lub świadczący usługi na rzecz podmiotów zewnętrznych; obejmuje systemy SaaS, API i aplikacje webowe.	Portal klienta banku, system e-rejestracji, API płatności

Klasyfikacja jest przeprowadzana przez cztery kryteria, z których każde jest zadawane wszystkim trzem perspektywom. Logika wynikowa jest progowa: nawet jedna odpowiedź twierdząca z dowolnej perspektywy na dowolne kryterium skutkuje klasyfikacją PUBLICZNY. Uzasadnienie tej asymetrii jest regulacyjne: jedna niepotwierdzona ścieżka dostępu zewnętrznego jest wystarczającym powodem do traktowania systemu jako publicznie dostępnego i stosowania względem niego pełnego zestawu wymogów bezpieczeństwa dla systemów publicznych.

6.5.5 Atrybut: poziom krytyczności

Poziom krytyczności jest atrybutem klasyfikacyjnym obiektu określającym, jak poważne skutki operacyjne, prawne i społeczne pociągnęłaby za sobą niedostępność, naruszenie integralności lub utrata poufności danego systemu lub dostawcy. Atrybut ten jest wyznaczany w fazie wstępnej audytu metodą cross-validation, to samo zagadnienie jest zadawane niezależnie trzem perspektywom audytowym, a wynik klasyfikacji jest ustalany na podstawie konsensusu odpowiedzi.

Definicja 6.4 (Poziom krytyczności obiektu). *Poziom krytyczności obiektu v jest wartością ze zbioru:*

$$\text{krytyczność}(v) \in \{\text{KRYTYCZNY}, \text{WAŻNY}, \text{STANDARDOWY}\}$$

wyznaczaną przez mechanizm cross-validation na podstawie odpowiedzi co najmniej dwóch z trzech perspektyw rdzeniowych: **ZGODNOŚCI**, **UŻYTKOWNIKA** i **TECHNICZNEJ**. Poziom krytyczności determinuje mnożnik wagowy $w_{krit}(v)$ stosowany w równaniu agregacji wyników na poziomie podmiotu (7.9).

Tabela 6.6: Poziomy krytyczności obiektu, kryteria klasyfikacji i mnożniki wagowe

Poziom	w_{krit}	Kryteria klasyfikacji	Podstawa regulacyjna
KRYTYCZNY	2,0	Niedostępność przez ponad 4 h powoduje bezpośrednie straty operacyjne, naruszenie przepisów prawa lub zagrożenie bezpieczeństwa osób; brak możliwości zastąpienia; system wspiera funkcję kluczową w rozumieniu NIS2 lub DORA	NIS2 Art. 3; DORA Art. 2; ustawa o krajowym systemie cyberbezpieczeństwa
WAŻNY	1,5	Niedostępność poważnie utrudnia działalność, lecz jej nie wstrzymuje; istnieje procedura zastępcza; system wspiera funkcję ważną w rozumieniu NIS2	NIS2 Art. 3 ust. 2; ISO/IEC 22301
STANDARDOWY	1,0	Niedostępność powoduje utrudnienia pomocnicze; istnieje możliwość pracy bez systemu przez co najmniej 48 h bez istotnych strat	—

Klasyfikacja krytyczności jest przeprowadzana przez sześć kryteriów (K1–K6) zadawanych wszystkim trzem perspektywom. Wynik końcowy wyznaczany jest progowo: suma wszystkich odpowiedzi twierdzących ze wszystkich perspektyw i wszystkich kryteriów jest normalizowana do skali klasyfikacyjnej zgodnie z ankietą przedstawioną w sekcji 7.2.3.

6.5.6 Atrybut: klasyfikacja utrzymania w chmurze

Lokalizacja miejsca utrzymania usługi ma kluczowy wpływ na warunki jej świadczenia. Oprogramowanie działające *on-premise*, czyli w siedzibie organizacji, nie jest narażone na ryzyko przesyłu danych do zewnętrznych dostawców. Istotna jest również prawna jurysdykcja podmiotu, który hostuje dane. Fakt przechowywania danych w chmurze będzie implikować konieczność dokładnego audytu łańcucha dostawców i wykonania oceny skutków transferu (*TIA*), wymaganej przez RODO w sytuacji, gdy dane przesyłane są z Europejskiego Obszaru Gospodarczego (*EOG*) do tzw. "państwa trzeciego" (np. USA, Indie, Chiny).

Klasyfikacja utrzymania w chmurze

Metodologia ORION definiuje dwa typy lokalizacji danych, a ich atrybut wpływa na aktywację sekcji pytań dotyczących rozwiązań chmurowych oraz transferu danych.

Tabela 6.7: Klasyfikacja utrzymania w chmurze w ORION

Typ utrzymania	Opis
CHMURA_K3	Dane przechowywane są poza organizacją u zewnętrznego podmiotu (SaaS, IaaS/PaaS, model hybrydowy, hosting, kolokacja), którego lokalizacja lub jurysdykcja nie gwarantuje przechowywania danych w EOG. Obejmuje dostawców podlegających prawu państw trzecich, np. Amazon Web Services, Google Cloud, Microsoft Azure.
CHMURA_EOG	Dane przechowywane są poza organizacją u zewnętrznego podmiotu (SaaS, IaaS/PaaS, model hybrydowy, hosting, kolokacja), którego lokalizacja i jurysdykcja gwarantuje przechowywanie danych wyłącznie w EOG, np. NASK SA, Exea Data Center, Beyond.pl, OVH (region PL/EU).
ON_PREMISE	Dane przechowywane są wyłącznie na serwerach i infrastrukturze będącej własnością organizacji, fizycznie zlokalizowanej w jej siedzibie lub własnym centrum danych.

6.5.7 Atrybut: klasyfikacja atrybutu typów przetwarzanych danych

Dotychczasowe modele oceny ryzyka ICT nie uwzględniają charakter przetwarzanych danych jako samodzielny wymiar ryzyka z formalnym przełożeniem na wynik scoringowy. W metodologii ORION charakter danych jest traktowany jako atrybut pierwszorzędny, który wpływa bezpośrednio na wagę artefaktu w agregacji końcowej. Logika jest prosta: naruszenie bezpieczeństwa systemu przetwarzającego tajemnicę lekarską lub dane finansowe klientów pociąga za sobą nieporównywalnie poważniejsze skutki prawne, finansowe i społeczne niż naruszenie systemu obsługującego wyłącznie dane wewnętrzne organizacji.

Klasyfikacja typów danych

Metodologia ORION wyróżnia cztery typy przetwarzanych danych, uporządkowane rosnąco według wrażliwości prawnej i społecznej. Każdemu typowi przypisany jest mnożnik wagowy w_{data} , który modyfikuje wpływ artefaktu na wynik podmiotu zgodnie z równaniem (7.9).

Tabela 6.8: Klasyfikacja typów danych w ORION i odpowiadające mnożniki wagowe

Typ danych	Symbol	w_{data}	Podstawa prawna	Przykłady
BRAK	T_0	1,0	—	Dane konfiguracyjne, logi techniczne bez PII
OSOBOWE	T_1	1,3	RODO Art. 4 ust. 1	Imię, adres, adres e-mail, numer IP
WRAŻLIWE	T_2	1,6	RODO Art. 9 ust. 1	Stan zdrowia, dane biometryczne, przekonania religijne, orientacja seksualna
TAJEMNICA	T_3	2,0	Ustawa sektorowa (bankowa, lekarska, adwokacka)	Tajemnica bankowa, tajemnica lekarska, tajemnica zawodowa, dane niejawne

6.5.8 Atrybut: kraj pochodzenia

Atrybut ten określa kraj pochodzenia podmiotu w celu jednoznacznego ustalenia jego statusu prawnego, tj. czy jest to podmiot mający siedzibę na terenie Europejskiego Obszaru Gospodarczego (EOG), czy też kwalifikuje się on jako podmiot z kraju trzeciego w myśl obowiązujących przepisów prawa (w szczególności w kontekście regulacji dotyczących ochrony danych osobowych RODO oraz cyberbezpieczeństwa).

Wartość tego atrybutu ma kluczowe znaczenie dla logiki warunkowego uruchamiania sekcji pytań podczas procesu audytowego. W przypadku zidentyfikowania podmiotu

pochodzącego z kraju spoza EOG, system automatycznie rozszerza zakres audytu o dodatkowe wymagania. Wynika to z podwyższonego ryzyka operacyjnego i prawnego (np. w obszarze transferu danych lub łańcucha dostaw). W konsekwencji na organizację audytującą nakładany jest obowiązek przeprowadzenia pogłębionej weryfikacji, obejmującej m.in. szczegółowe badanie mechanizmów zabezpieczeń, umów transferowych oraz analizę wpływu na ryzyko (np. TIA).

Tabela 6.9: Dopuszczalne wartości pochodzenia przedsiębiorstw

Kod kraju	Opis i zakres odpowiedzialności
KOD ISO	Kod kraju pochodzenia, np. PL, DE, US

6.6 Plan ciągłości działania

Plan ciągłości działania jest procedurą wymaganą od podmiotów kluczowych zarówno na gruncie ustawy o KSC,¹⁰ jak i rozporządzenia DORA.¹¹

Definicja 6.5 (Plan ciągłości działania (BCP)). *Zbiór udokumentowanych procedur, które określają działania, jakie podmiot musi podjąć w celu odzyskania zdolności do wykonywania operacji oraz zapewnienia ciągłości procesów krytycznych na akceptowalnym poziomie po wystąpieniu incydentu zakłócającego.*

Podstawą planu ciągłości działania jest określenie dwóch wskaźników odporności. Pierwszy, RTO (*Recovery Time Objective*) określa maksymalny dopuszczalny czas, przez jaki system może pozostawać niedostępny po wystąpieniu awarii, im niższy, tym wyższe wymagania wobec infrastruktury. Drugi, RPO (*Recovery Point Objective*) wyznacza maksymalną akceptowalną utratę danych, wyrażoną jako punkt w czasie, do którego dane muszą zostać odtworzone, ilustrując przykładem, RPO wynoszące 15 minut oznacza, że żadna transakcja starsza niż kwadrans nie może zostać bezpowrotnie utracona.

Plan musi przewidywać konkretne scenariusze postępowania na wypadek różnych klas awarii systemów IT, ataku ransomware czy niedostępności kluczowego personelu. Równolegle obowiązują procedury wykrywania, klasyfikacji i eskalacji incydentów, w tym raportowania do organów nadzorczych, takich jak KNF, w ściśle określonych ramach czasowych wynikających z obowiązującego prawa, a ich definicje szczegółowo określa DORA i KSC.

Niezbędne jest opracowanie polityki wytwarzania oraz przywracania kopii zapasowych (DRP). Kopie zapasowe muszą być fizycznie lub logicznie odizolowane od głównej infrastruktury produkcyjnej, co chroni jest przed zaszyfrowaniem w przypadku ataku ransomware. Plan odtwarzania precyzuje harmonogram tworzenia kopii, lokalizację ich przechowywania, odpowiedzialnych za proces oraz procedury testowego odtwarzania danych w kontrolowanych warunkach.

Bardzo ważnym elementem planu ciągłości działania jest strategia komunikacji na czas kryzysu, który określa, kto, kiedy i w jaki sposób informuje klientów, pracowników, kontrahentów oraz nadzór o wystąpieniu awarii i przewidywanym czasie jej usunięcia.

¹⁰ Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.

¹¹ Parlament Europejski i Rada Unii Europejskiej, Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).

Zgodnie z wymogami DORA, instytucja finansowa nie może ograniczyć planowania ciągłości wyłącznie do własnych zasobów, obowiązkiem jest zapewnienie, że dostawcy usług chmurowych i IT również dysponują udokumentowanymi planami ciągłości i są w stanie dotrzymać uzgodnionych poziomów usług (*SLA*) w sytuacji kryzysowej. Wymóg ten powinien być wprost zawarty w umowach z dostawcami, wraz z prawem do audytu.

Plan ciągłości działania podlega obowiązkowym testom ich skuteczności, które obejmują symulacje cyberataków, przełączanie ruchu na ośrodek zapasowy oraz testy odtwarzania danych z kopii zapasowych. Wyniki każdego testu powinny skutkować aktualizacją dokumentacji.

Odpowiedzialność za zatwierdzenie i skuteczność planów ciągłości działania, spoczywa na zarządzie instytucji. Od strony technicznej plan musi eliminować Single Point of Failure (*SPOF*) poprzez zapewnienie redundantnych systemów, łączów komunikacyjnych i zasilania, tak aby awaria pojedynczego komponentu nie prowadziła do niedostępności całej usługi.

W metodologii ORION, plan ciągłości działania jest wymagany dla podmiotów określonych w KSC oraz DORA. Jego brak lub nieprawidłowe zdefiniowanie w organizacjach, gdzie jest on obowiązkowy wskazują binarnie na uchybienia w działaniu organizacji.

Tabela 6.10: Mnożniki wagowe BCP wg typu organizacji

Typ organizacji	Symbol	w_{reg}	Obowiązkowe
FINANSOWY	D_0	1,0	tak
KLUCZOWY	D_1	1,0	tak
WAŻNY	D_2	1,0	tak
POZOSTAŁE	D_3	0,5	nie

6.7 Exit plan

Exit plan (plan wyjścia) to obowiązkowy element zarządzania dostawcami IT w banku, wymagany przez rozporządzenie DORA oraz ustawę KSC.

Definicja 6.6 (Exit plan). *Strategia wyjścia z usługi pozwalająca organizacji wyłączyć system, zakończyć współpracę z dotychczasowym dostawcą oraz ponownie uruchomić usługę u innego dostawcy przy zachowaniu ciągłości działania lub minimalizacji przestoju.*

Plan wyjścia stanowi pisemnie udokumentowaną procedurę umożliwiającą organizacji zakończenie współpracy z dostawcą ICT i przeniesienie usług do alternatywnego środowiska, bez przestoju operacyjnego i bez utraty danych. Definicja ma zagwarantować ciągłości działania, czyli zapewnić minimalny czas niedostępności usługi dla jej użytkowników. Równie istotna jest ochrona przed zjawiskiem *vendor lock-in*, czyli uzależnienia od jednego dostawcy

Według definicji DORA, plan musi identyfikować musi wskazywać rzeczywistego dostawcę zastępczego lub opisywać scenariusz powrotu do infrastruktury własnej. Co istotne, umowa z dostawcą musi zawierać klauzulę zobowiązującą go do udostępnienia wszystkich danych w formacie umożliwiającym ich import do innego systemu

Dostawca ICT jest zobowiązany do świadczenia usług przez określony czas po wypowiedzeniu umowy, tak aby organizacja przeprowadziła migrację danych. Co istotne, wsparcie to nie może mieć charakteru pasywnego, dostawca ma obowiązek aktywnej pomocy technicznej przy przenoszeniu procesów, danych i konfiguracji do nowego środowiska. Tego rodzaju zobowiązania muszą być precyzyjnie zapisane w umowie, z określonymi terminami i zakresem odpowiedzialności.

Exit plan traci swoją wartość, jeśli nie jest regularnie weryfikowany. DORA wymaga przeprowadzania testów planu co najmniej raz w roku lub każdorazowo po istotnych zmianach w architekturze systemu (Art. 28 ust. 4¹²), również ustawa KSC (Art. 8¹³) wymaga opracowania exit planu. Całość procesu musi być zaplanowana tak, aby klient instytucji w ogóle nie odczuł zmiany dostawcy.

Ważna jest forma przygotowania dokumentacji. DORA, w art 28 ust. 4¹⁴ wymaga oddzielnego dokumentu, natomiast KSC wymaga realizuje cele exit planu poprzez klauzule umowne z dostawcą.

W metodologii ORION, exit plan jest wymagany dla podmiotów określonych w KSC oraz DORA. Podobnie jak plan ciągłości działania, brak lub nieprawidłowo zdefiniowany exit plan, gdy jest obowiązkowy, wskazuje binarnie na uchybienia w działaniu organizacji.

Tabela 6.11: Mnożniki wagowe exit plan wg typu organizacji

Typ organizacji	Symbol	w_{reg}	Obowiązkowe
FINANSOWY	D_0	1,0	tak
KLUCZOWY	D_1	1,0	tak
WAŻNY	D_2	1,0	nie
POZOSTAŁE	D_3	0,5	nie

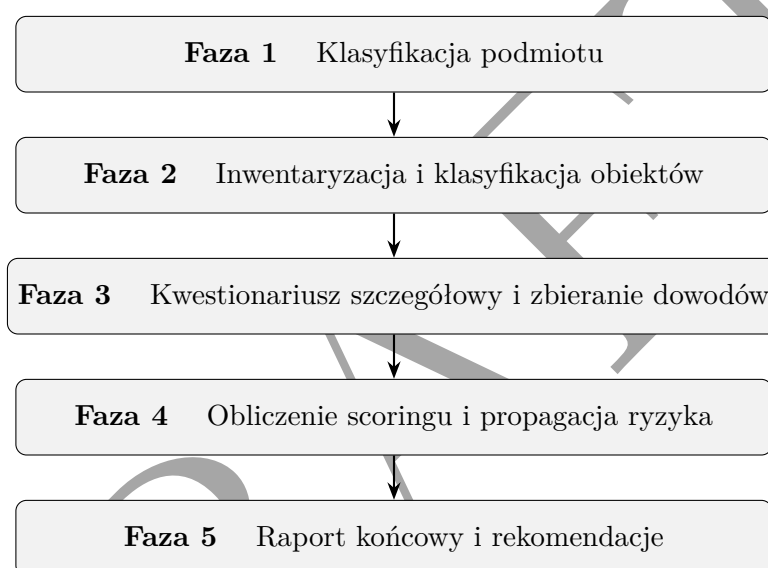
¹²Parlament Europejski i Rada Unii Europejskiej, Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).

¹³Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.

¹⁴Parlament Europejski i Rada Unii Europejskiej, Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).

7. Przeprowadzenie audytu ORION

Niniejszy rozdział opisuje pełny algorytm przeprowadzenia audytu zgodności systemów informatycznych w metodologii ORION. Audyt jest procesem iteracyjnym, co oznacza, że po zakończeniu jednego etapu audytor przechodzi do kolejnego, składającym się z pięciu faz następujących po sobie w ściśle określonej kolejności. Każda faza produkuje dane wejściowe dla fazy następnej, a wynik całości, czyli ocena zgodności podmiotu z aktualnym stanem regulacyjnym z punktu widzenia ITC, jest wynikiem wszystkich odpowiedzi na każdym etapie. Schemat ogólny procesu przedstawia rysunek 7.1.



Rysunek 7.1: Pięć faz audytu ORION

7.1 Faza 1: Klasyfikacja podmiotu

Audyt rozpoczyna się od ustalenia tożsamości regulacyjnej audytowanego podmiotu. Wynik tej fazy determinuje, które zestawy pytań zostaną zaprezentowane w dalszych etapach, jakie wymogi mają charakter obligatoryjny, a jakie fakultatywne oraz jakie progi klasyfikacji dostawców kluczowych będą stosowane. Faza pierwsza składa się z dwóch kroków wykonywanych wyłącznie raz, przed przystąpieniem do analizy jakiegokolwiek obiektu i dotyczy globalnie całej organizacji.

7.1.1 Krok 1.1: Ustalenie reżimu regulacyjnego

Dla każdego kryterium poniżej odpowiedz TAK lub NIE. Klasyfikacja wyznaczana jest na podstawie konsensusu odpowiedzi z co najmniej dwóch perspektyw.

Kryterium R1: Podleganie reżimowi regulacyjnemu

- **Perspektywa zgodności** (DPO / Radca prawny): Czy podmiot prowadzi działalność wymienioną w załączniku I lub II dyrektywy NIS2 albo w art. 2 rozporządzenia DORA i przekracza progi wielkości określone przez te akty?
- **Perspektywa użytkownika** (Zarząd / Właściciel): Czy organizacja świadczy usługi finansowe, prowadzi infrastrukturę krytyczną lub przetwarza dane na zlecenie podmiotów regulowanych?
- **Perspektywa techniczna** (CTO / Architekt): Czy systemy IT organizacji były kiedykolwiek objęte obowiązkowym audytem regulacyjnym lub wymogiem zgłaszania incydentów do organu nadzorczego?

Na podstawie konsensusu odpowiedzi podmiot otrzymuje jedną z następujących klasyfikacji regulacyjnych, które określają obowiązkowość kluczowych elementów audytu:

Tabela 7.1: Klasyfikacja regulacyjna podmiotu i jej wpływ na zakres audytu

Klasyfikacja	Podstawa	BCP	Exit plan	TIA	w_{reg}
FINANSOWY	DORA Art. 2	Tak	Tak	Tak	1,5
KLUCZOWY	NIS2 / KSC Art. 5	Tak	Tak	Tak	1,3
WAŻNY	NIS2 / KSC Art. 6	Tak	Nie	Tak	1,1
POZOSTAŁE	RODO / ogólne	Nie	Nie	Warunkowy	1,0

7.2 Faza 2: Inwentaryzacja i klasyfikacja obiektów

Celem fazy drugiej jest zbudowanie grafu ICT podmiotu, pełnego rejestru wszystkich obiektów podlegających audytowi wraz z ich atrybutami klasyfikacyjnymi. Graf ICT jest strukturą dynamiczną: jego wierzchołki są odkrywane iteracyjnie, a mechanizm triggera TIA opisany w sekcji 7.3.8 może rozszerzać graf o nowe obiekty w trakcie fazy trzeciej. Faza druga stanowi zatem pierwszą, wstępną wersję grafu, która ulega uzupełnieniu w toku audytu szczegółowego.

7.2.1 Krok 2.1: Inwentaryzacja systemów

Audytor przeprowadza inwentaryzację wszystkich systemów informatycznych eksploatowanych przez podmiot. Jako punkt wyjścia służą: rejestr systemów prowadzony przez dział IT, wykaz aplikacji z licencji oprogramowania (pobranych z systemów księgowych oraz archiwów licencji), rejestr umów z dostawcami ICT, wyniki poprzednich audytów lub testów penetracyjnych. Każdy zidentyfikowany system jest rejestrowany jako obiekt w grafie ICT i przypisany do właściciela biznesowego. Należy również przeskanować systemy informatyczne w celu zainwentaryzowania zainstalowanego oprogramowania, na rynku dostępne są do tego narzędzia typu *open source*.

Kluczowe w inwentaryzacji jest podejście wieloperspektywiczne: inwentaryzacja przeprowadzana wyłącznie przez dział IT często pomija systemy zakupione i utrzymywane bezpośrednio przez jednostki biznesowe (*shadow IT*), podczas gdy wywiad z właścicielami biznesowymi i prawnikami ujawnia dodatkowe systemy i usługi SaaS nieprzechodzące przez standardowy proces zakupów IT. Wynikiem operacji indentyfikacji będzie lista obiektów typu `SYSTEM_INFORMATYCZNY`, która będzie dołączona do grafu ITC.

7.2.2 Krok 2.2: Identyfikacja bezpośrednich dostawców

Dla każdego zidentyfikowanego systemu audytor identyfikuje bezpośrednich dostawców ICT: podmioty zewnętrzne świadczące usługi hostingu, utrzymania, wsparcia lub integracji. Każdy dostawca jest rejestrowany jako odrębny obiekt typu `DOSTAWCA` w grafie ICT i połączony krawędzią skierowaną z systemem, który obsługuje. Na tym etapie nie są jeszcze identyfikowani poddostawcy, ich identyfikacja następuje w fazie trzeciej przez mechanizm triggera TIA.

7.2.3 Krok 2.3: Przypisanie atrybutów klasyfikacyjnych

Dla każdego obiektu zidentyfikowanego w kroku 7.2.1 audytor przeprowadza klasyfikację wstępną, ustalając wartości atrybutów: *dostępność(v)*, *krytyczność(v)*, *utrzymanie_chmura(v)*, *typ_danych_wrażliwych(v)*,

Każdy atrybut jest wyznaczany metodą cross-validation opisaną w sekcji 6.4.6.

7.2.4 Ankieta klasyfikacji atrybutu dostępności

Poniższe kryteria służą do określenia, z jaką jest dostępność systemu z punktu widzenia prywatności rozwiązania. Dla każdego kryterium odpowiedz TAK lub NIE. Klasyfikacja jest wyznaczana na ilości odpowiedzi zgodnych z odpowiedzią **oczekiwaną** jako poprawna.

Kryterium D1: Dostęp spoza sieci organizacji

- **Perspektywa zgodności:** Czy umowa lub regulamin systemu przewiduje dostęp dla podmiotów spoza struktury prawnej organizacji?
- **Perspektywa użytkownika:** Czy z systemu korzystają osoby lub firmy spoza naszej organizacji (klienci, partnerzy, dostawcy)?
- **Perspektywa techniczna:** Czy system jest dostępny spoza sieci LAN/VPN organizacji (publiczny IP, internet)?

Kryterium D2: Użytkownicy zewnętrzni

- **Perspektywa zgodności:** Czy system wymaga odrębnych umów powierzenia danych lub regulaminów dla jego użytkowników?
- **Perspektywa użytkownika:** Czy system służy do komunikacji lub wymiany informacji z klientami bądź kontrahentami?
- **Perspektywa techniczna:** Czy system posiada konta lub sesje dla użytkowników spoza domeny organizacji?

Kryterium D3: Integracje zewnętrzne

- **Perspektywa zgodności:** Czy system przesyła dane do podmiotów trzecich na podstawie umów lub przepisów prawa?
- **Perspektywa użytkownika:** Czy system automatycznie wymienia dane z zewnętrznymi dostawcami, bankami lub platformami?
- **Perspektywa techniczna:** Czy system wywołuje zewnętrzne API lub odbiera dane z systemów spoza infrastruktury organizacji?

Kryterium D4: Publiczny adres lub domena

- **Perspektywa zgodności:** Czy system jest zarejestrowany lub dostępny pod adresem publicznie widocznym w internecie?
- **Perspektywa użytkownika:** Czy system ma adres www lub można do niego dorzeć bez łączenia się z siecią wewnętrzną firmy?
- **Perspektywa techniczna:** Czy system posiada publiczny rekord DNS lub publiczny adres IP?

Wynik końcowy:

Suma TAK	Klasyfikacja
Zero odpowiedzi twierdzących	System prywatny
Minimum jedna twierdząca	System publiczny

7.2.5 Ankieta klasyfikacja atrybutu poziomu krytyczności

Poniższe kryteria służą do określenia, z jakim poziomem krytyczności operuje system. Dla każdego kryterium odpowiedz TAK lub NIE. Klasyfikacja jest wyznaczana na ilości odpowiedzi twierdzących.

Kryterium K1: Wpływ finansowy i operacyjny niedostępności systemu

- **Perspektywa zgodności:** Czy niedostępność systemu może powodować roszczenia kontraktowe lub kary umowne?
- **Perspektywa użytkownika:** Czy kilkugodzinny przestój zatrzymuje sprzedaż, obsługę klienta lub kluczowy proces biznesowy?
- **Perspektywa techniczna:** Czy system ma zdefiniowane RTO poniżej 4 godzin lub SLA z karami za niedostępność?

Kryterium K2: Przetwarzanie danych osobowych lub wrażliwych

- **Perspektywa zgodności:** Czy system przetwarza dane osobowe lub szczególne kategorie danych w rozumieniu art. 9 RODO?

- **Perspektywa użytkownika:** Czy w systemie przechowywane są dane klientów, pracowników lub inne informacje poufne?
- **Perspektywa techniczna:** Czy baza danych zawiera pola z danymi PII (np. imię, PESEL, adres, numer konta)?

Kryterium K3: Podleganie regulacjom zewnętrznym

- **Perspektywa zgodności:** Czy system podlega regulacjom sektorowym (np. DORA, NIS2, Rekomendacja D KNF)?
- **Perspektywa użytkownika:** Czy system był przedmiotem pytań audytorów lub regulatorów podczas kontroli?
- **Perspektywa techniczna:** Czy system znajduje się w wykazie systemów objętych audytem zgodności lub testami penetracyjnymi?

Kryterium K4: Zależności innych systemów produkcyjnych

- **Perspektywa zgodności:** Czy awaria systemu może uniemożliwić realizację zobowiązań wobec klientów lub partnerów?
- **Perspektywa użytkownika:** Czy inne działy lub systemy firmy nie mogą działać, gdy system jest niedostępny?
- **Perspektywa techniczna:** Czy inne systemy produkcyjne mają bezpośrednie zależności od tego systemu?

Kryterium K5: Ryzyko wycieku lub utraty danych

- **Perspektywa zgodności:** Czy wyciek danych z systemu wymagałby zgłoszenia incydentu do UODO lub regulatora?
- **Perspektywa użytkownika:** Czy ujawnienie danych mogłoby zaszkodzić reputacji firmy lub spowodować utratę klientów?
- **Perspektywa techniczna:** Czy system przechowuje dane bez szyfrowania lub bez możliwości pseudonimizacji?

Kryterium K6: Obsługa procesów podstawowej działalności (core business)

- **Perspektywa zgodności:** Czy system jest wskazany w dokumentacji BCM/BCP jako niezbędny do kontynuacji działalności?
- **Perspektywa użytkownika:** Czy system obsługuje główny produkt lub usługę firmy?
- **Perspektywa techniczna:** Czy system jest sklasyfikowany jako produkcyjny tier-1 w architekturze IT?

W celu uniknięcia zjawiska sztucznego zawyżania krytyczności (gdzie niemal każdy system przetwarzający dane osobowe stawał się krytyczny), w metodologii ORION zastosowano zasadę dominacji operacyjnej. System nie może zostać uznany za krytyczny tylko na podstawie faktu, że podlega regulacjom (K3) lub przetwarza dane (K2), o ile jego niedostępność nie paraliżuje podstawowej działalności organizacji (K1, K6).

Tabela 7.2: Wynik klasyfikacji krytyczności na podstawie sumy odpowiedzi twierdzących

Suma TAK	Klasyfikacja	Warunek dodatkowy
0–2	System standar- dowy	—
3–4	System ważny	—
5–6	System krytyczny	Wymagane $K1 = TAK$ lub $K6 = TAK$ (zasada domina- cji operacyjnej)

7.2.6 Ankieta klasyfikacji atrybutu utrzymania w chmurze

Poniższe kryteria służą do określenia, czy system jest rozwiązaniem on-premise czy chmurowym. Dla każdego kryterium odpowiedz TAK lub NIE. Klasyfikacja jest wyznaczana na ilości odpowiedzi twierdzących.

Kryterium L1: Model wdrożenia infrastruktury

- **Perspektywa zgodności:** Czy umowa lub dokumentacja systemu wskazuje na dostawcę chmury publicznej, prywatnej lub hybrydowej (np. AWS, Azure, GCP, OVH)?
- **Perspektywa użytkownika:** Czy system działa w internecie lub w środowisku zarządzanym przez zewnętrznego dostawcę, a nie na serwerach w siedzibie firmy?
- **Perspektywa techniczna:** Czy serwery lub maszyny wirtualne systemu są uruchomione poza fizycznym data center organizacji?

Kryterium L2: Odpowiedzialność operacyjna

- **Perspektywa zgodności:** Czy odpowiedzialność za dostępność i utrzymanie infrastruktury systemu spoczywa na zewnętrznym dostawcy zgodnie z umową SLA?
- **Perspektywa użytkownika:** Czy w przypadku awarii serwera zgłaszamy problem do zewnętrznej firmy, a nie do naszego działu IT?
- **Perspektywa techniczna:** Czy organizacja nie ma bezpośredniego dostępu administracyjnego do warstwy sprzętowej lub hiperwizora systemu?

Kryterium L3: Umowa outsourcingowa lub chmurowa

- **Perspektywa zgodności:** Czy z dostawcą systemu lub infrastruktury podpisano umowę outsourcingu IT, umowę SaaS/PaaS/IaaS lub umowę powierzenia przetwarzania danych?
- **Perspektywa użytkownika:** Czy dostęp do systemu lub jego funkcji jest uzależniony od aktywnej subskrypcji lub kontraktu z zewnętrznym dostawcą?

- **Perspektywa techniczna:** Czy system jest wdrożony w modelu usługowym (SaaS, PaaS lub IaaS), w którym zasoby obliczeniowe są rozliczane na podstawie zużycia lub abonamentu?

Kryterium L4: Lokalizacja i kontrola danych

- **Perspektywa zgodności:** Czy dane przetwarzane przez system są przechowywane w lokalizacji określonej przez dostawcę zewnętrznego oraz czy przeprowadzono pełne TIA?
- **Perspektywa użytkownika:** Czy jako użytkownik systemu masz pewności, czy fizycznie dane przechowywane są na serwerach kraju EOG?
- **Perspektywa techniczna:** Czy kopie zapasowe lub dane produkcyjne systemu są składowane na zasobach poza kontrolą administracyjną organizacji?

Kryterium L5: Jurysdykcja podmiotu hostującego

- **Perspektywa zgodności:** Czy dostawca przeprowadził pełne TIA wraz z poddostawcami, z którego wynika, że wszystkie podmioty zaangażowane w przetwarzanie danych są własnością kapitałową przedsiębiorstw z EOG lub nie podlegają jurysdykcji państw trzecich (np. US CLOUD Act, FISA Section 702)?
- **Perspektywa użytkownika:** Czy użytkownik może potwierdzić, że wszystkie usługi i okna logowania systemu należą do podmiotów zarejestrowanych i działających wyłącznie na podstawie prawa europejskiego?
- **Perspektywa techniczna:** Czy certyfikaty SSL/TLS, adresy IP, rekordy DNS oraz dane WHOIS infrastruktury systemu wskazują wyłącznie na podmioty zarejestrowane w EOG, a żaden z komponentów technicznych (CDN, load balancer, usługa uwierzytelniania) nie pochodzi od dostawcy spoza EOG lub podlegającego obcemu prawu dostępu do danych?

Kryterium L6: Wsparcie techniczne

- **Perspektywa zgodności:** Czy umowa z dostawcą systemu jednoznacznie określa, że wsparcie techniczne (helpdesk, administracja, dostęp serwisowy) jest świadczone wyłącznie przez osoby lub podmioty mające siedzibę w EOG?
- **Perspektywa użytkownika:** Czy użytkownik może potwierdzić, że wszystkie punkty kontaktowe wsparcia technicznego (w tym adresy e-mail, domeny helpdesk, numery telefonów oraz profile agentów w systemie zgłoszeń) wskazują na podmioty zarejestrowane w EOG (europejskie domeny, kierunkowe numery telefonów, europejskie dane rejestrowe dostawcy)?
- **Perspektywa techniczna:** Czy narzędzia zdalnego dostępu serwisowego (np. VPN, RDP, sesje administracyjne) są skonfigurowane w sposób uniemożliwiający połączenie spoza EOG, a logi dostępu potwierdzają, że żadna sesja wsparcia technicznego nie była inicjowana z adresów IP spoza Europejskiego Obszaru Gospodarczego?

Wynik końcowy:

Suma TAK	Klasyfikacja
Zero odpowiedzi twierdzących	System on-premise
Minimum jedna odpowiedź twierdząca oraz minimum jedna odpowiedź negatywna na pytania L5, L6	System w chmurze krajów trzecich
Minimum trzy odpowiedzi twierdząca w tym na pytania L5, L6	System w chmurze EOG

7.2.7 Ankieta klasyfikacji typu danych

Poniższe kryteria służą do określenia, z jakim typem danych operuje system. Dla każdego kryterium odpowiedz TAK lub NIE. Klasyfikacja jest wyznaczana na podstawie najwyższej kategorii, dla której udzielono co najmniej jednej odpowiedzi twierdzącej.

Kryterium W: Dane szczególnych kategorii (wrażliwe)

- **Perspektywa zgodności:** Czy system przetwarza dane szczególnych kategorii w rozumieniu art. 9 RODO (np. dane dotyczące zdrowia, wyroków skazujących, przekonań religijnych, orientacji seksualnej, przynależności związkowej)?
- **Perspektywa użytkownika:** Czy system zawiera dokumentację medyczną, orzeczenia, dane HR o niepełnosprawności lub inne informacje uznawane za szczególnie chronione?
- **Perspektywa techniczna:** Czy baza danych zawiera pola klasyfikowane jako dane wrażliwe (np. diagnoza, orzeczenie, wyznanie, dane biometryczne)?

Kryterium O: Dane osobowe (zwykłe)

- **Perspektywa zgodności:** Czy system przetwarza dane osobowe w rozumieniu art. 4 pkt 1 RODO, pozwalające na identyfikację osoby fizycznej (np. imię i nazwisko, PESEL, adres e-mail, numer konta)?
- **Perspektywa użytkownika:** Czy w systemie przechowywane są dane klientów, pracowników lub kontrahentów w jakiegokolwiek formie?
- **Perspektywa techniczna:** Czy baza danych zawiera pola, takie jak imię, adres, identyfikator użytkownika, adres IP lub dane logowania?

Kryterium T: Tajemnice prawnie chronione

- **Perspektywa zgodności:** Czy system przetwarza informacje objęte tajemnicą zawodową, handlową, bankową, skarbową, adwokacką lub inną tajemnicą chronioną przepisami prawa?
- **Perspektywa użytkownika:** Czy ujawnienie danych z systemu mogłoby naruszyć obowiązki zachowania poufności wynikające z umów lub przepisów prawa (np. NDA, tajemnica przedsiębiorstwa)?

- **Perspektywa techniczna:** Czy system posiada oznaczenie klauzulą poufności lub jest objęty restrykcjami dostępu wynikającymi z wymogów regulacyjnych lub umownych?

Tabela 7.3: Wynik klasyfikacji typu danych na podstawie udzielonych odpowiedzi twierdzących

Warunek	Typ danych	Reżim ochrony
Co najmniej jedno TAK w kryterium W	Wrażliwe	art. 9 RODO, DPIA wymagane
Co najmniej jedno TAK w kryterium O (brak TAK w W)	Osobowe	RODO, zgłoszenie do UODO
Co najmniej jedno TAK w kryterium T (brak TAK w W i O)	Tajemnica	przepisy sektorowe, NDA
Wyłącznie NIE we wszystkich kryteriach	Brak	brak szczególnych wymogów

Uwaga: Klasyfikacja ma charakter kaskadowy — wystarczy jedno TAK w kryterium wyższej kategorii, aby przypisać wyższy typ danych. Jeśli system spełnia warunki kilku kryteriów jednocześnie, stosuje się typ danych o najwyższym ryzyku.

7.3 Faza 3: Kwestionariusz szczegółowy i zbieranie dowodów

Na podstawie atrybutów obiektów i wartości im przypisanych w fazie drugiej system ORION generuje dla każdego obiektu indywidualny kwestionariusz szczegółowy, zestaw pytań audytowych pogrupowanych w sekcje tematyczne, aktywowane warunkowo w zależności od wartości atrybutów. Żaden obiekt nie jest pytany o aspekty, które są dla niego nieistotne z powodów technicznych lub regulacyjnych.

7.3.1 Warunkowe aktywowanie sekcji pytań

Zestaw aktywnych sekcji pytań dla obiektu v jest wyznaczany przez funkcję:

$$\mathcal{S}(v) = \bigcup_{\tau \in \mathcal{T}} \mathcal{S}_{\tau} \cdot \mathbb{K}[\text{type}(v) = \tau] \cup \bigcup_k \mathcal{S}_k \cdot \mathbb{K}[\Phi_k(\mathcal{A}(v))] \quad (7.1)$$

gdzie:

- $\mathcal{T} = \{\text{PODMIOT}, \text{SYSTEM_INFORMATYCZNY}, \text{DOSTAWCA}\}$ jest zbiorem typów obiektów w grafie ICT,

- $\mathcal{S}_\tau$ jest zbiorem sekcji aktywowanych wyłącznie dla obiektów danego typu τ (np. sekcje ORGANIZACJA, BEZPIECZENSTWO_TECHNICZNE i BEZPIECZENSTWO_FIZYCZNE są aktywowane gdy $\text{type}(v) = \text{PODMIOT}$, a APLIKACJA gdy $\text{type}(v) = \text{SYSTEM_INFORMATYCZNY}$),
- $\mathcal{S}_k$ jest k -tą sekcją aktywowaną warunkowo na podstawie atrybutów obiektu,
- $\Phi_k(\mathcal{A}(v))$ jest warunkiem logicznym aktywacji sekcji $\mathcal{S}_k$ wyznaczanym na podstawie wektora atrybutów $\mathcal{A}(v)$ obiektu v (np. klasyfikacji utrzymania w chmurze, typu danych, krytyczności).

Pierwszy składnik sumy pokrywa sekcje aktywowane przez *typ* obiektu i jest niezależny od jego atrybutów. Drugi składnik pokrywa sekcje aktywowane przez *atrybuty* obiektu i jest niezależny od jego typu. Oba zbiory mogą być rozłączne lub przecinać się, przy czym wynikowy zbiór aktywnych sekcji $\mathcal{S}(v)$ jest ich sumą teoriomnogościową.

Pytania zostały podzielone na sekcje zgodnie z klasyfikacją przyjętą w rozdziale 6.5.1 *Perspektywa*. Każda pozycja odnosi się do konkretnego obszaru zagadnień, zawiera podstawę prawną, definicję istotności oraz oznaczenie (flagę binarną) pytania blokującego.

7.3.2 Sekcja organizacja

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu.*

Pytania w tej sekcji służą do oceny dojrzałości zarządczej organizacji w zakresie cyberbezpieczeństwa i odporności cyfrowej. Sprawdzają, czy na poziomie strategicznym podmiot jest świadomy ryzyk ICT, czyli czy zarząd formalnie zatwierdził strategię cyberbezpieczeństwa i ponosi za nią odpowiedzialność prawną, czy przeszedł wymagane szkolenia oraz czy wdrożono ramy zarządzania ryzykiem ICT z rejestrem ryzyk, właścicielami i planami. Ocenie podlega również gotowość operacyjna: czy organizacja potrafi klasyfikować incydenty, zgłaszać poważne zdarzenia do organów krajowych w ustawowych terminach oraz informować klientów o incydentach według gotowych procedur.

Pytania w sekcji:

Obszar: **Strategia cyberbezpieczeństwa w organizacji**

Podstawa prawna: **NIS2 art. 20 ust. 1, DORA art. 5**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organ zarządzający formalnie zatwierdził strategię cyberbezpieczeństwa i ponosi za nią odpowiedzialność prawną?
- **Perspektywa użytkownika:** Czy wiesz, że Twoja firma ma strategię cyberbezpieczeństwa i gdzie można ją znaleźć?
- **Perspektywa techniczna:** Strategia cyberbezpieczeństwa, czy organizacja posiada dokumenty potwierdzające jej we wszystkich systemach informatycznych?

Obszar: **Przeprowadzone szkolenia zarządu**

Podstawa prawna: **NIS2 art. 20 ust. 2**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy członkowie zarządu przeszli obowiązkowe szkolenia z cyberbezpieczeństwa?

- **Perspektywa użytkownika:** Czy szef/zarząd Twojej firmy lub działu przechodził kiedykolwiek szkolenie z cyberbezpieczeństwa?
- **Perspektywa techniczna:** Czy szkolenia są dokumentowane z listą uczestników wraz datami oraz zakresem możliwymi do pokazania audytorowi?

Obszar: **Ramy zarządzania ryzykiem ICT**

Podstawa prawna: **NIS2 art. 21 ust. 1 / DORA art. 6**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja wdrożyła udokumentowane ramy zarządzania ryzykiem ICT zatwierdzone przez zarząd?
- **Perspektywa użytkownika:** Czy wiesz, kto w Twojej firmie odpowiada za bezpieczeństwo systemów IT?
- **Perspektywa techniczna:** Czy ramy obejmują rejestr ryzyk z właścicielami i planami mitygacji aktualizowany co najmniej raz w roku?

Obszar: **Ocena ryzyka łańcucha dostaw**

Podstawa prawna: **NIS2 art. 21 ust. 2 lit. d / DORA art. 28**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy przeprowadzana jest regularna ocena ryzyka uwzględniająca łańcuch dostaw i dostawców zewnętrznych?
- **Perspektywa użytkownika:** Czy wiesz, jakie zewnętrzne firmy mają dostęp do systemów lub danych Twojej organizacji?
- **Perspektywa techniczna:** Czy ocena obejmuje wszystkich dostawców ICT z klasyfikacją krytyczności i udokumentowanymi wynikami?

Obszar: **Zgłaszanie poważnych incydentów w 24h**

Podstawa prawna: **NIS2 art. 23 ust. 4 lit. a / DORA art. 19**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja jest w stanie zgłosić poważny incydent do organu krajowego w ciągu 24 godzin od wykrycia?
- **Perspektywa użytkownika:** Czy wiesz, co zrobić i do kogo zadzwonić, gdy zauważysz coś podejrzanego na swoim komputerze?
- **Perspektywa techniczna:** Czy system ticketowy (lub równoważny) wymusza checkpointy 24h/72h z automatycznym przypomnieniem i obowiązkowym polem zgłoszenia do KNF/CSIRT?

Obszar: **Klasyfikacja incydentów**

Podstawa prawna: **NIS2 art. 23 ust. 3 / DORA art. 18**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada procedurę klasyfikacji incydentów pozwalającą ocenić, czy incydent jest poważny/znaczący?

- **Perspektywa użytkownika:** Nie każda awaria to incydent bezpieczeństwa, czy potrafisz odróżnić zwykłą awarię od cyberataku?
- **Perspektywa techniczna:** Czy kryteria klasyfikacji są zaimplementowane w SIEM jako automatyczne reguły eskalacji?

Obszar: **Powiadamianie klientów o incydentach**

Podstawa prawna: **NIS2 art. 23 ust. 4 lit. c / DORA art. 14**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada zatwierdzoną procedurę komunikacji kryzysowej, która w sposób operacyjny (szablony, kanały, progi istotności) wdraża obowiązek niezwłocznego informowania odbiorców usług o poważnych incydentach
- **Perspektywa użytkownika:** Czy masz wiedzę, że istnieje procedura powiadamiania klientów/pracowników o poważnych incydentach?
- **Perspektywa techniczna:** Czy istnieje system komunikacji z klientami / pracownikami z gotowymi szablonami uruchamialny w ciągu minut?

Obszar: **Rejestr czynności przetwarzania (ROPA)**

Podstawa prawna: **RODO art. 30**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja prowadzi aktualny rejestr czynności przetwarzania danych osobowych obejmujący ten system z opisem celów, kategorii danych i odbiorców?
- **Perspektywa użytkownika:** Czy wiesz, że firma musi prowadzić listę wszystkich miejsc, w których przechowuje dane osobowe pracowników i klientów ?
- **Perspektywa techniczna:** Czy rejestr ROPA jest prowadzony w formie elektronicznej, dostępny dla Inspektora Ochrony Danych i aktualizowany przy każdej zmianie systemu lub procesu przetwarzania?

Obszar: **Rejestr kluczowych dostawców ICT**

Podstawa prawna: **DORA art. 28 ust. 2 / art. 29 ust. 1**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja prowadzi aktualny rejestr wszystkich zewnętrznych dostawców ICT z klasyfikacją ich krytyczności i przypisaniem do funkcji krytycznych lub istotnych?
- **Perspektywa użytkownika:** Czy wiesz, ilu zewnętrznych dostawców IT obsługuje Twoją organizację i który z nich świadczy usługi najważniejsze dla ciągłości działania?
- **Perspektywa techniczna:** Czy rejestr jest prowadzony w CMDB lub dedykowanym narzędziu GRC i obejmuje: nazwę dostawcy, zakres usług, dane kontraktowe, klasyfikację krytyczności, sub-procesorów i daty przeglądów?

7.3.3 Sekcja dane poufne: osobowe, wrażliwe oraz tajemnice przedsiębiorstwa

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu.*

Pytania w tej sekcji służą do oceny, czy organizacja prawidłowo zarządza procesem gromadzenia oraz przetwarzania danych poufnych. Weryfikowana jest również gotowość do zgłoszenia naruszenia ochrony danych osobowych, które chroni prawa osób fizycznych i wymaga odrębnej procedury, odrębnej ścieżki eskalacji i odrębnych formularzy. Organizacja nieposiadająca oddzielnej procedury zgłoszeń do UODO nie wykazuje gotowości do wywiązywania się z fundamentalnego obowiązku w zakresie ochrony danych osobowych.

Pytania w sekcji:

Obszar: **Zgłaszanie naruszeń danych osobowych do UODO (72h)**

Podstawa prawna: **RODO art. 33**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada odrębną procedurę zgłaszania naruszeń ochrony danych osobowych do Prezesa UODO w ciągu 72 godzin, niezależną od procedury zgłoszeń NIS2/DORA do CSIRT?
- **Perspektywa użytkownika:** Czy wiesz, że w razie wycieku danych Twoja firma musi powiadomić poszkodowane osoby i czy znasz procedurę takiego powiadomienia?
- **Perspektywa techniczna:** Czy procedura rozróżnia incydent ICT (zgłoszenie do CSIRT/KNF) od naruszenia danych osobowych (zgłoszenie do UODO) i czy istnieją oddzielne ścieżki eskalacji?

Obszar: **Inspektor Ochrony Danych (IOD), powołanie i rejestracja**

Podstawa prawna: **RODO art. 37–39**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja powołała IOD, zarejestrowała go w UODO i udostępniła jego dane kontaktowe osobom, których dane dotyczą?
- **Perspektywa użytkownika:** Czy wiesz, kto w Twojej firmie jest Inspektorem Ochrony Danych i jak możesz się z nim skontaktować?
- **Perspektywa techniczna:** Czy dane kontaktowe IOD są opublikowane na stronie i w klauzulach informacyjnych, a IOD ma bezpośredni dostęp do zarządu bez możliwości wydawania mu instrukcji?

Obszar: **Rejestr Czynności Przetwarzania (RCP)**

Podstawa prawna: **RODO art. 30**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja prowadzi aktualny RCP zawierający: cel, podstawę prawną, kategorie danych, odbiorców, okresy retencji i środki bezpieczeństwa dla każdej czynności przetwarzania?

- **Perspektywa użytkownika:** Czy w Twojej firmie istnieje rejestr wszystkich procesów przetwarzania danych osobowych (tzw. rejestr czynności przetwarzania) wraz z podstawą prawną każdego z nich?
- **Perspektywa techniczna:** Czy RCP jest przechowywany w ustrukturyzowanym, edytowalnym rejestrze powiązany z systemami IT i aktualizowanym automatycznie w ramach procesu change management?

Obszar: **Harmonogram retencji i usuwania danych osobowych**

Podstawa prawna: **RODO art. 5**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada formalny harmonogram retencji (retention schedule) z maksymalnymi okresami przechowywania i mechanizmem automatycznego usuwania danych osobowych po ich upływie?
- **Perspektywa użytkownika:** Czy wiesz, że dane osobowe klientów można przechowywać tylko przez określony czas, a potem firma musi je usunąć lub zanonimizować?
- **Perspektywa techniczna:** Czy systemy IT mają wdrożone automatyczne reguły usuwania/anonimizacji danych osobowych po upływie okresu retencji, bez ręcznej interwencji administratora, i czy proces jest logowany?

7.3.4 Sekcja bezpieczeństwo techniczne

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu.*

Pytania w tej sekcji służą do oceny skuteczności technicznych środków ochrony systemów i infrastruktury ICT organizacji przed zagrożeniami cybernetycznymi. Sprawdzane jest, czy organizacja wdrożyła mechanizmy ciągłego monitorowania i wykrywania anomalii oraz czy przeprowadza regularne testy bezpieczeństwa i testy penetracyjne z udokumentowanymi wynikami i planem naprawy zidentyfikowanych podatności. Ocenie podlega stosowanie zasady minimalnych uprawnień (least privilege) w odniesieniu zarówno do kont użytkowników, jak i kont serwisowych aplikacji dostawców, z kwartalnym przeglądem uprawnień i automatycznym alertowaniem przy próbach eskalacji.

Pytania w sekcji:

Obszar: **Testy bezpieczeństwa i testy penetracyjne**

Podstawa prawna: **NIS2 art. 21 ust. 2 lit. m / DORA art. 24-25**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja przeprowadza regularne testy bezpieczeństwa, testy podatności i testy penetracyjne?
- **Perspektywa użytkownika:** Czy słyszałeś/aś, że ktoś z zewnątrz sprawdzał, czy systemy Twojej firmy da się zhakować?
- **Perspektywa techniczna:** Roczny plan testów z harmonogramem i zakresem, czy wyniki testów są dokumentowane?

Obszar: Monitoring i wykrywanie anomaliiPodstawa prawna: **NIS2 art. 21 ust. 2 lit. b / DORA art. 10**Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja wdrożyła mechanizmy ciągłego monitorowania i wykrywania anomalii w systemach krytycznych?
- **Perspektywa użytkownika:** Czy słyszałeś/aś, że ktoś z zewnątrz sprawdzał, czy systemy Twojej firmy da się zhakować?
- **Perspektywa techniczna:** Czy SIEM/UEBA pokrywa 100

Obszar: Zasada minimalnych uprawnieńPodstawa prawna: **DORA art. 9 / NIS2 art. 21**Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy dostęp do systemów krytycznych jest nadawany zgodnie z zasadą least privilege i regularnie przeglądany?
- **Perspektywa użytkownika:** Czy masz dostęp do systemów lub danych, których nie potrzebujesz do codziennej pracy?
- **Perspektywa techniczna:** Czy stosowany jest PAM z automatycznym przeglądem uprawnień co kwartał i alertowaniem przy próbach eskalacji?

Obszar: Szkolenia i świadomość pracownikówPodstawa prawna: **NIS2 art. 21 ust. 2 lit. g**Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy pracownicy przechodzą regularne szkolenia z cyberbezpieczeństwa?
- **Perspektywa użytkownika:** Czy w ostatnich 12 miesiącach dostałeś/aś podejrzany e-mail, który okazał się testem bezpieczeństwa od działu IT?
- **Perspektywa techniczna:** Czy szkolenia są dostosowane do roli (IT vs. biznes vs. zarząd) i czy mierzona jest ich skuteczność np. przez symulowane ataki phishingowe?

Obszar: Offboarding (usuwanie dostępu)Podstawa prawna: **DORA art. 9**Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy istnieje udokumentowany proces dezaktywacji kont przy odejściu pracownika?
- **Perspektywa użytkownika:** Czy wiesz, że gdy pracownik odchodzi z firmy, jego dostęp do wszystkich systemów powinien być zablokowany tego samego dnia?
- **Perspektywa techniczna:** Czy offboarding jest zautomatyzowany i dezaktywuje wszystkie konta w dniu odejścia pracownika bez konieczności ręcznej akcji administratora w poszczególnych systemach?

Obszar: **Bezpieczeństwo e-mail i załączników**

Podstawa prawna: **RODO art. 32 / NIS2 art. 21**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada politykę regulującą wysyłanie danych wrażliwych przez e-mail i wymóg szyfrowania załączników?
- **Perspektywa użytkownika:** Czy zdarzyło Ci się wysłać e-mailem plik z danymi klientów np. plik Word z umową bez dodatkowego szyfrowania (hasło do archiwum)?
- **Perspektywa techniczna:** Czy system pocztowy stosuje DLP automatycznie wykrywający i blokujący wysyłkę wiadomości z danymi wrażliwymi bez szyfrowania? Jeśli brak DLP lub równoważnego zaznacz nie.

Obszar: **Segmentacja sieci i kontrola ruchu bocznego**

Podstawa prawna: **DORA art. 9 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy systemy krytyczne są logicznie odizolowane od reszty sieci przez segmentację uniemożliwiającą boczne przemieszczanie się atakującego (lateral movement)?
- **Perspektywa użytkownika:** Czy wiesz, że systemy, z których korzystasz, są odizolowane od reszty sieci firmowej tak, by atak na jeden komputer nie mógł automatycznie objąć wszystkich systemów?
- **Perspektywa techniczna:** Czy stosowane są VLAN, mikrosegmentacja lub Zero Trust Network Access dla systemów krytycznych i czy firewall wymusza polityki east-west między segmentami?

Obszar: **Zarządzanie certyfikatami TLS**

Podstawa prawna: **DORA art. 9 / NIS2 art. 21 lit. h**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada inwentarz certyfikatów TLS z datami wygasania i procesem automatycznego odnawiania eliminującym ryzyko niedostępności usług z powodu wygasłego certyfikatu?
- **Perspektywa użytkownika:** Czy zdarzyło Ci się zobaczyć ostrzeżenie przeglądarki o wygasłym certyfikacie na firmowej stronie lub systemie i czy zgłosiłeś/aś to do IT?
- **Perspektywa techniczna:** Czy stosowane jest narzędzie do monitorowania certyfikatów (np. Cert Manager, Venafi, DigiCert) z alertowaniem co najmniej 30 dni przed wygaśnięciem i automatycznym odnowieniem dla certyfikatów Let's Encrypt?

7.3.5 Sekcja bezpieczeństwo fizyczne

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu.*

Pytania w tej sekcji służą do oceny środków ochrony fizycznej stosowanych w obiektach, w których zlokalizowana jest infrastruktura ICT organizacji lub jej kluczowych dostawców. Sprawdzane jest, czy dostęp do stref krytycznych (serwerowni i pomieszczeń technicznych) jest kontrolowany przez elektroniczne systemy uwierzytelnienia (karty dostępu,

biometria) z automatycznym logowaniem każdego wejścia, eliminującym możliwość nie-autoryzowanego wejścia bez śladu w rejestrze. Ocenie podlega podział obiektu na strefy bezpieczeństwa o różnych poziomach dostępu, monitoring wizyjny CCTV z retencją nagrań zgodną z RODO, redundancja zasilania testowana pod rzeczywistym obciążeniem (UPS i agregat prądotwórczy) oraz procedury dotyczące urządzeń przenośnych: szyfrowanie całego dysku, rejestr wynoszenia i zdalna możliwość wyczyszczenia. Weryfikowane jest ponadto, czy nośniki danych przy utylizacji są niszczone fizycznie lub nadpisywane certyfikowaną metodą, a serwisanci zewnętrzni w strefach krytycznych są przez cały czas eskortowani i ich działania są logowane. Pytania blokujące obejmują brak formalnej polityki bezpieczeństwa fizycznego oraz brak elektronicznej kontroli dostępu do serwerowni.

Pytania w sekcji:

Obszar: **Bezpieczeństwo fizyczne centrów danych**

Podstawa prawna: **DORA art. 9 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy polityki bezpieczeństwa fizycznego centrów danych spełniają wymogi poufności, integralności danych, bezpieczeństwa dostępu fizycznego oraz ochronę przez zagrożeniami naturalnymi?
- **Perspektywa użytkownika:** Czy wejście do serwerowni wymaga zgody administratora i jest każdorazowo rejestrowane?
- **Perspektywa techniczna:** Czy stosowana jest kontrola dostępu fizycznego (karty, biometria), CCTV i monitoring środowiskowy z alertowaniem 24/7?

Obszar: **Kontrola dostępu fizycznego do obiektów**

Podstawa prawna: **DORA art. 9 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada formalną politykę kontroli dostępu fizycznego do obiektów przetwarzających dane?
- **Perspektywa użytkownika:** Czy aby wejść do serwerowni, musisz użyć karty/kłucza lub przejść weryfikację?
- **Perspektywa techniczna:** Czy dostęp do serwerowni jest kontrolowany z logowaniem każdego wejścia - czy wystarczy klucz mechaniczny bez rejestracji?

Obszar: **Strefy bezpieczeństwa i segmentacja fizyczna**

Podstawa prawna: **NIS2 art. 21 / ISO 27001 A.11**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy obiekty są podzielone na strefy bezpieczeństwa z różnymi poziomami dostępu: strefa publiczna, biurowa, techniczna, krytyczna?
- **Perspektywa użytkownika:** Czy gość lub dostawca, który przyszedł do biura nie może swobodnie chodzić po budynku (jest zawsze asystowany)?

- **Perspektywa techniczna:** Czy przejście między strefami wymaga oddzielnej autoryzacji co oznacza, że osoba z dostępem do biura nie ma dostępu do serwerowni lub innych pomieszczeń krytycznych?

Obszar: **Monitoring CCTV i rejestracja wideo**

Podstawa prawna: **RODO art. 5 ust. 1 lit. e / NIS2 art. 21**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy obiekty krytyczne są objęte monitoringiem CCTV z retencją nagrań zgodną z polityką bezpieczeństwa i RODO?
- **Perspektywa użytkownika:** Czy obszary w przedsiębiorstwie, krytyczne dla działania Twojej firmy, są monitorowane kamerami?
- **Perspektywa techniczna:** Czy kamery obejmują wszystkie punkty wejścia do stref krytycznych, a nagrania są chronione przed modyfikacją?

Obszar: **Zasilanie i redundancja energetyczna**

Podstawa prawna: **DORA art. 11 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy obiekty krytyczne posiadają redundantne zasilanie z co najmniej dwóch niezależnych źródeł oraz UPS?
- **Perspektywa użytkownika:** Czy podczas awarii zasilania system działał wystarczająco długo, żebyś mógł/mogła zapisać swoją pracę?
- **Perspektywa techniczna:** Czy UPS i generator są regularnie testowane pod obciążeniem - nie tylko w trybie symulacji?

Obszar: **Wynoszenie i transport urządzeń**

Podstawa prawna: **RODO art. 32 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada procedurę wynoszenia urządzeń poza siedzibę z rejestrem wydanych urządzeń?
- **Perspektywa użytkownika:** Czy gdybyś zgubił/a służbowego laptopa w pociągu - wiesz, co zrobić w ciągu pierwszych 30 minut i do kogo zadzwonić?
- **Perspektywa techniczna:** Czy wszystkie urządzenia przenośne mają szyfrowanie całego dysku aktywowane przymusowo i możliwość zdalnego wyczyszczenia?

Obszar: **Niszczenie i utylizacja nośników danych**

Podstawa prawna: **RODO art. 5 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada procedurę bezpiecznego niszczenia nośników danych (dysków, pendrive'ów, wydruków)?
- **Perspektywa użytkownika:** Czy przed oddaniem laptopa do IT masz pewność, że Twoje dane zostaną z niego bezpiecznie usunięte?

- **Perspektywa techniczna:** Czy dyski są niszczone fizycznie lub nadpisywane skuteczną metodą przed utylizacją?

Obszar: **Ochrona przed kradzieżą i sabotażem fizycznym**

Podstawa prawna: **NIS2 art. 21 / ISO 27001 A.11**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja wdrożyła środki ochrony przed kradzieżą i fizycznym sabotażem: alarmy, szafy rack zamykane na klucz, kable zabezpieczające?
- **Perspektywa użytkownika:** Czy gdy umieścisz pendrive w komputerze system zabroni odczytu danych bez zgody administratora?
- **Perspektywa techniczna:** Czy serwery są fizycznie zabezpieczone przed podłączeniem zewnętrznych nośników - zablokowane porty USB i zamknięte szafy rack?

7.3.6 Sekcja system informatyczny

Aktywacja: *aktywacja warunkowa, gdy typ obiektu = SYSTEM_INFORMATYCZNY*

Pytania w tej sekcji służą do oceny bezpieczeństwa i zgodności konkretnego systemu informatycznego rozpatrywanego jako samodzielna jednostka. Zakres oceny jest stosowany odrębnie dla każdego audytowanego systemu, co pozwala zidentyfikować różnice w poziomach zabezpieczeń między poszczególnymi aplikacjami w portfolio ICT organizacji. Sprawdzane jest, czy system figuruje w oficjalnym rejestrze zasobów ICT z przypisaną klasyfikacją krytyczności i właścicielem, czy wymusza uwierzytelnianie wieloskładnikowe (MFA) dla wszystkich kont, czy stosuje aktualny protokół szyfrowania komunikacji TLS 1.2 lub nowszy, a logi są centralnie agregowane i przechowywane w niezmiennym storage przez co najmniej 12 miesięcy. Ocenie podlegają również polityka haseł wymuszana technicznie przez system, zarządzanie podatnościami z udokumentowanymi terminami naprawy oraz, jako kryterium o szczególnym znaczeniu dla ciągłości działania, kopie zapasowe przechowywane w izolowanej, geograficznie odrębnej lokalizacji, z empirycznie weryfikowanymi wskaźnikami RTO i RPO. Pytania blokujące obejmują brak wpisu w rejestrze CMDB, brak MFA oraz brak backupu.

Pytania w sekcji:

Obszar: **Uprawnienia i dostęp aplikacji dostawcy**

Podstawa prawna: **DORA art. 9 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy aplikacje dostawców mają nadane wyłącznie minimalne uprawnienia niezbędne do działania zgodnie z zasadą least privilege?
- **Perspektywa użytkownika:** Czy wiesz, do jakich zasobów firmowych (pliki, e-maile, systemy) ma dostęp oprogramowanie zainstalowane przez zewnętrznych dostawców?
- **Perspektywa techniczna:** Czy konta serwisowe aplikacji dostawcy mają ograniczony zakres uprawnień w AD/IAM bez dostępu do niezwiązanych systemów i są regularnie przeglądane?

Obszar: **Dostęp zdalny dostawcy (remote access)**

Podstawa prawna: **DORA art. 28**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy zdalny dostęp dostawcy do tej aplikacji jest kontrolowany, logowany i ograniczony czasowo?
- **Perspektywa użytkownika:** Czy przy każdym serwisie aplikacji przez zewnętrznego dostawcę nadajesz mu jednorazowy dostęp i odbierasz go po zakończeniu prac (wyrażasz zgodę na zalogowanie do systemu, przejęcie sesji, etc)?
- **Perspektywa techniczna:** Czy stosowany jest mechanizm JIT wymagający jawnej akceptacji każdej sesji zdalnej więc dostawca nie ma stałego dostępu do systemu?

Obszar: **Rejestr zasobów ICT (CMDB)**

Podstawa prawna: **DORA art. 8**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy aplikacja figuruje w oficjalnym rejestrze zasobów ICT z przypisaną klasyfikacją krytyczności i właścicielem?
- **Perspektywa użytkownika:** Czy wiesz, kto jest właścicielem tej aplikacji w organizacji, czyli kto odpowiada za jej bezpieczeństwo i aktualizacje?
- **Perspektywa techniczna:** Czy posiadasz rejestrze zasobów ICT, w którym jest załączony raport klasyfikujący system jako krytyczny?

Obszar: **Retencja i ochrona logów aplikacji**

Podstawa prawna: **DORA art. 10 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy logi aplikacji są centralnie agregowane i przechowywane przez wymagany okres, chronione przed modyfikacją?
- **Perspektywa użytkownika:** Czy jeśli poprosisz IT/administradora o historię Twojej aktywności w systemie to czy taką historię otrzymasz za ostatnie 12 miesięcy?
- **Perspektywa techniczna:** Czy logi są w immutable storage (WORM) przez co najmniej 12 miesięcy i agregowane w SIEM (lub równoważnym)?

Obszar: **Szyfrowanie komunikacji (TLS)**

Podstawa prawna: **DORA art. 9 / NIS2 art. 21 lit. h / RODO art. 32**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy komunikacja aplikacji jest szyfrowana przy użyciu TLS 1.2 lub nowszego? Jeśli nie dotyczy zaznacz tak.
- **Perspektywa użytkownika:** Czy gdy logujesz się do tej aplikacji przez przeglądarkę, adres zaczyna się od https:// w przeglądarce? Jeśli nie dotyczy (czyli nie jest to aplikacja uruchamiana przez przeglądarkę), zaznacz tak.

- **Perspektywa techniczna:** Czy skanowanie konfiguracji potwierdza brak przestarzałych protokołów (TLS 1.0/1.1, SSL) i poprawność certyfikatów? Jeśli nie dotyczy zaznacz tak.

Obszar: **MFA dla wszystkich użytkowników**

Podstawa prawna: **DORA art. 9 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy MFA jest obowiązkowe dla wszystkich kont (w szczególności uprzywilejowanych i zdalnego dostępu)?
- **Perspektywa użytkownika:** Czy za każdym razem logując się do tej aplikacji musisz wpisując dodatkowy kod (z sms, email) lub potwierdzenia w telefonie?
- **Perspektywa techniczna:** Czy MFA jest obowiązkowe dla wszystkich kont (w szczególności uprzywilejowanych i zdalnego dostępu)?

Obszar: **Zarządzanie hasłami i polityką hasel**

Podstawa prawna: **NIS2 art. 21 / DORA art. 9**

Typ pytania: **obowiązkowe**, blokujące:

- **Perspektywa zgodności:** Czy organizacja stosuje formalną politykę hasel (minimalna długość, złożoność, zakaz ponownego użycia)?
- **Perspektywa użytkownika:** Czy system zmusza Cię do zmiany hasła po określonym czasie i blokuje użycie poprzednich hasel?
- **Perspektywa techniczna:** Czy polityka hasel jest wymuszana technicznie przez IdP/AD - niemożliwa do obejścia przez użytkownika?

Obszar: **Backup**

Podstawa prawna: **DORA art. 12 / NIS2 art. 21 ust. 2 lit. c**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy kopie zapasowe są przechowywane w geograficznie oddzielnej lokalizacji, retencja spełnia wymogi regulacyjne, a procedura odtwarzania jest regularnie testowana z dokumentacją wyników?
- **Perspektywa użytkownika:** Czy wiesz, jak szybko Twoja firma mogłaby przywrócić ten system po awarii i czy było to kiedykolwiek sprawdzane w praktyce?
- **Perspektywa techniczna:** Czy backup jest immutable (WORM), izolowany od sieci produkcyjnej (air-gap), RTO/RPO zdefiniowane i weryfikowane empirycznie?

Obszar: **Zarządzanie podatnościami**

Podstawa prawna: **NIS2 art. 21 ust. 2 lit. m / DORA art. 9**

Typ pytania: **obowiązkowe**, blokujące:

- **Perspektywa zgodności:** Czy organizacja posiada formalny proces skanowania podatności CVE i patch managementu z udokumentowanymi terminami?
- **Perspektywa użytkownika:** Czy Twój komputer i oprogramowanie są regularnie aktualizowane automatycznie?
- **Perspektywa techniczna:** Czy skaner podatności (Qualys, Tenable, Nessus) jest uruchamiany co najmniej miesięcznie na systemach krytycznych i czy wyniki są przypisane do właściciela z terminem naprawy?

7.3.7 Sekcja usługi w chmurze

Aktywacja: *aktywacja warunkowa, gdy utrzymanie_chmura(v) ∈ {CHMURA_K3, CHMURA_EOG}*

Pytania w tej sekcji służą do oceny zgodności wynikającej ze specyfiki przetwarzania danych w środowisku chmurowym, gdzie organizacja powierza przetwarzanie zewnętrznemu dostawcy usług (CSP). Sprawdzane jest, czy przed uruchomieniem systemu przeprowadzono i udokumentowano Ocenę Skutków dla Ochrony Danych (DPIA) oraz czy jest ona aktualizowana przy każdej istotnej zmianie systemu lub dostawcy. Ocenie podlega model zarządzania kluczami kryptograficznymi, uniemożliwiając dostawcy samodzielny dostęp do przechowywanych danych. Weryfikowane jest również, czy umowa z dostawcą chmury zapewnia prawo do audytu, bezpieczną i pełną izolację danych między klientami (multi-tenancy).

Pytania w sekcji:

Obszar: **Dokumentacja DPIA dla przetwarzania w chmurze**

Podstawa prawna: **RODO art. 35**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy przed uruchomieniem tego systemu chmurowego przeprowadzono i udokumentowano ocenę skutków dla ochrony danych (DPIA), a dokument ten jest aktualny (aktualizowany przy każdej istotnej zmianie systemu lub dostawcy)?
- **Perspektywa użytkownika:** Czy przed uruchomieniem systemu, ktoś w firmie sprawdził i zapisał na papierze, jakie dane osobowe/poufne są w nim przechowywane i czy są odpowiednio chronione?
- **Perspektywa techniczna:** Czy w repozytorium dokumentacji (np. Confluence, SharePoint) istnieje aktualny dokument DPIA dla tego systemu (zawierający opis przepływów danych osobowych, zidentyfikowane ryzyka i zastosowane środki techniczne) oraz czy dokument był aktualizowany po ostatniej istotnej zmianie infrastruktury lub dostawcy?

Obszar: **Szyfrowanie at-rest poza natywnymi funkcjami dostawcy**

Podstawa prawna: **DORA art. 9 / RODO art. 32**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy dane organizacji przechowywane w systemie są szyfrowane w sposób, który uniemożliwia dostawcy chmurowemu samodzielne odszyfrowanie tych danych, tzn. czy klucze szyfrujące są kontrolowane wyłącznie przez organizację, a nie przez dostawcę?
- **Perspektywa użytkownika:** Czy „sejf z kluczami” do zaszyfrowanych danych firmowych należy wyłącznie do Twojej firmy i jest poza zasięgiem dostawcy chmury?
- **Perspektywa techniczna:** Czy szyfrowanie at-rest dla tego systemu jest realizowane w modelu HYOK (klucz generowany i przechowywany wyłącznie w infrastrukturze organizacji: on-premise HSM lub external KMS poza chmurą dostawcy)?

Obszar: **Kary umowne dla dostawcy (NIS2/DORA)**

Podstawa prawna: **NIS2 art. 34 / DORA art. 30**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowa z dostawcą chmury zawiera klauzulę kar umownych na wypadek, gdy incydent po stronie dostawcy doprowadzi do nałożenia sankcji administracyjnych (kar finansowych) na organizację przez organ regulacyjny (KNF, UKNF, UODO) na podstawie przepisów NIS2 lub DORA?
- **Perspektywa użytkownika:** Czy wiesz, że jeśli dostawca systemu spowoduje wyciek danych klientów, to Twoja firma (nie dostawca) może dostać karę od regulatora?
- **Perspektywa techniczna:** Czy w umowie z dostawcą (MSA, DPA lub załączniku bezpieczeństwa) istnieje klauzula odpowiedzialności i regresu, tzn. czy organizacja może dochodzić zwrotu kary zapłaconej KNF/UODO, jeśli jej przyczyną był błąd lub zaniedbanie dostawcy?

Obszar: **Prawo do audytu dostawcy chmury**

Podstawa prawna: **DORA art. 30 ust. 2 lit. f / RODO art. 28 ust. 3 lit. h**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy umowa z dostawcą chmury zapewnia organizacji prawo do przeprowadzenia audytu (samodzielnie lub przez wyznaczonego audytora zewnętrznego) w zakresie spełnienia wymagań bezpieczeństwa i zgodności, w tym audytu na miejscu (onsite)?
- **Perspektywa użytkownika:** Czy wiesz, że Twoja firma ma prawo skontrolować dostawcę chmury i sprawdzić na miejscu, czy Wasze dane są naprawdę bezpieczne?
- **Perspektywa techniczna:** Czy umowa z dostawcą chmury zawiera prawo do przeprowadzenia audytu onsite (samodzielnie lub przez wyznaczonego audytora zewnętrznego) bez możliwości zastąpienia go wyłącznie raportem dostawcy?

Obszar: **Procedura reagowania na incydenty po stronie dostawcy**

Podstawa prawna: **DORA art. 19 ust. 3 / NIS2 art. 23 ust. 4**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowa z dostawcą chmury określa maksymalny czas powiadomienia organizacji o incydencie bezpieczeństwa po stronie dostawcy i czy czas ten umożliwia organizacji dotrzymanie własnego obowiązku zgłoszenia do CSIRT/KNF w ciągu 24 godzin?
- **Perspektywa użytkownika:** Czy wiesz, kto w Twojej firmie odbiera powiadomienia o awariach lub atakach od dostawcy chmury?
- **Perspektywa techniczna:** Czy umowa z dostawcą chmury jednocześnie spełnia wszystkie trzy poniższe warunki: dostawca musi powiadomić organizację o incydencie bezpieczeństwa w ciągu maksymalnie 12 godzin od jego wykrycia, oraz powiadomienie trafia do wyznaczonej osoby lub funkcji (CISO, SOC, punkt kontaktowy ds. bezpieczeństwa) ORAZ powiadomienie zawiera minimalny zakres informacji: opis zdarzenia, wstępną ocenę wpływu na dane organizacji oraz podjęte działania zaradcze?

Obszar: **Izolacja danych między klientami (multi-tenancy)**

Podstawa prawna: **DORA art. 9 / RODO art. 32 / ISO 27017**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy dostawca chmury zapewnia pełną logiczną izolację danych organizacji od danych innych klientów (tenantów) i czy organizacja posiada dokumentację potwierdzającą mechanizmy tej izolacji?
- **Perspektywa użytkownika:** Czy wiesz, że współdzielenie infrastruktury chmurowej z innymi firmami może stanowić ryzyko dla bezpieczeństwa Waszych danych?
- **Perspektywa techniczna:** Czy dostawca chmury zapewnia pełną logiczną izolację danych organizacji od danych innych klientów, tzn. czy dane organizacji są przechowywane w oddzielnej bazie danych, oddzielnym schemacie lub oddzielnej przestrzeni wirtualnej przypisanej wyłącznie do organizacji, a nie współdzielonej tabeli z izolacją wyłącznie na poziomie filtrowania wierszy?

7.3.8 Sekcja Transfer Impact Assessment (TIA)

Aktywacja: *aktywacja warunkowa, gdy utrzymanie_chmura(v) = CHMURA_K3*

Pytania w tej sekcji służą do oceny zgodności transferów danych osobowych realizowanych poza Europejski Obszar Gospodarczy (EOG). Obowiązek przeprowadzenia TIA wynika z wyroku Trybunału Sprawiedliwości UE w sprawie Schrems II z 2020 r., który uchylił mechanizm Privacy Shield i nałożył na administratorów obowiązek indywidualnej weryfikacji, czy prawo i praktyka państwa docelowego nie podważają skuteczności ochrony gwarantowanej przez Standardowe Klauzule Umowne (SCC). Sprawdzane jest, czy dla każdego transferu przeprowadzono TIA uwzględniające ustawodawstwo krajowe państwa odbiorcy (w tym ryzyko eksterytorialnego dostępu wynikające z amerykańskiego CLOUD Act i FISA 702) a także czy transfer jest obsługiwany jako komplet trzech dokumentów: aktualnej umowy DPA zgodnej z art. 28 RODO, klauzul SCC z 2021 r. oraz dokumentacji TIA. Weryfikowane jest ponadto, czy organizacja posiada pisemne oświadczenie dostawcy o nieprzekazywaniu danych poza EOG, obejmujące backupy, logi i metadane, oraz czy oświadczenie to jest technicznie weryfikowalne. Kryterium blokującym jest brak ważnej umowy DPA, bez niej jakkolwiek transfer danych osobowych jest z mocy prawa niedopuszczalny.

Trigger identyfikacji poddostawców i TIA

Jednym z najpoważniejszych i najczęściej pomijanych problemów współczesnej praktyki compliance jest zjawisko *deklaratywnego zatrzymania łańcucha* analizy poddostawców: organizacja lub jej dostawca deklaruje zgodność z wymogami regulacyjnymi dotyczącymi miejsca przetwarzania danych, nie weryfikując jednak, czy deklaracja ta jest prawdziwa w odniesieniu do wszystkich ogniw łańcucha dostaw ICT leżących poniżej.

Klasycznym przykładem jest firma zewnętrzna, która informuje audytowaną organizację: „*Hostujemy Państwa dane wyłącznie na serwerach zlokalizowanych w Unii Europejskiej*” i jako potwierdzenie wskazuje na regulamin usługi amerykańskiego dostawcy chmury, wskazujący region lokalizacji danych w europejskim obszarze gospodarczym. Jeśli serwer w EOG obsługiwany jest przez podmiot podlegający CLOUD Act oznacza to, że władze federalne USA mogą żądać dostępu do przechowywanych na nim danych bez

wiedzy i zgody europejskiego podmiotu danych, a okoliczność ta powinna być objęta procedurą Transfer Impact Assessment (TIA), jednak w praktyce audytowej jest naginanie pomijana.

ORION rozwiązuje ten problem przez formalny mechanizm triggera identyfikacji poddostawców, który jest zaimplementowany w ankiecie w rozdziale 7.2.6 poprzez pytania dotyczące kraju pochodzenia podmiotu hostującego oraz lokalizacji przechowywania danych.

Definicja 7.1 (Trigger identyfikacji poddostawcy). *Trigger identyfikacji poddostawcy jest automatycznym mechanizmem rozszerzania grafu ICT, aktywowanym gdy obiekt v spełnia co najmniej jeden warunek ze zbioru $\mathcal{C}_{TIA}$. Po aktywacji trigger generuje obowiązek audytowy rozszerzenia grafu G o wierzchołki reprezentujące poddostawców obiektu v oraz przeprowadzenia pełnego audytu ORION dla każdego nowo odkrytego wierzchołka.*

Zbiór warunków aktywujących trigger:

$$\mathcal{C}_{TIA}(v) = \left(\text{pochodzenie podmiotu}(v) \neq \text{EOG} \right) \vee \left(\text{lokalizacja danych}(v) \neq \text{EOG} \right) \vee \left(\text{wsparcie systemu}(v) \neq \text{EOG} \right) \quad (7.2)$$

Gdy $\mathcal{C}_{TIA}(v) = \text{TRUE}$, do kwestionariusza obiektu v dodawana jest sekcja TIA, zawierająca pytania dotyczące ryzyka przekazania danych poza EOG.

Pytania w sekcji:

Obszar: **Transfer Impact Assessment (TIA RODO)**

Podstawa prawna: **RODO art. 46 / EDPB 05/2021**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy dla każdego transferu opartego na SCC przeprowadzono TIA oceniający, czy prawo państwa docelowego nie podważa ochrony gwarantowanej przez SCC?
- **Perspektywa użytkownika:** Czy wiesz, że wysyłając dane do systemu w USA, Twoja firma musi sprawdzić, czy amerykańskie prawo nie pozwoli rządowi USA na dostęp do tych danych bez zgody?
- **Perspektywa techniczna:** Czy TIA obejmuje praktykę stosowania prawa - żądania rządowe, Transparency Reports dostawcy, historię ujawnień?

Obszar: **Umowa powierzenia przetwarzania (DPA)**

Podstawa prawna: **RODO art. 28**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy z każdym dostawcą przetwarzającym dane osobowe poza EOG podpisano umowę powierzenia zgodną z RODO art. 28?

- **Perspektywa użytkownika:** Czy wiesz, że zanim firma może przekazać dane klientów zewnętrznemu dostawcy, musi podpisać z nim specjalną umowę określającą, jak te dane będą chronione?
- **Perspektywa techniczna:** Czy DPA jest uzupełniona o aktualne SCC z 2021 r. i TIA - i czy wszystkie trzy dokumenty są traktowane jako pakiet?

Obszar: **Oświadczenia o nieprzekazywaniu danych poza EOG**

Podstawa prawna: **RODO art. 28 ust. 2**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada pisemne oświadczenie od dostawcy o nieprzekazywaniu danych poza EOG - obejmujące backupy, logi i metadane?
- **Perspektywa użytkownika:** Czy wiesz, że Twoja firma powinna być w stanie udowodnić (nie tylko obiecać), że dane klientów nie opuszczają Europy?
- **Perspektywa techniczna:** Czy oświadczenie jest technicznie weryfikowalne - czy organizacja ma narzędzia potwierdzające, że żaden ruch z danymi klientów nie wychodzi poza EOG?

Obszar: **Ryzyko eksterytorialnego dostępu (Cloud Act)**

Podstawa prawna: **RODO art. 48 / Cloud Act 2018 / FISA 702**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy przeprowadzono ocenę ryzyka Cloud Act i czy umowa zobowiązuje dostawcę do kwestionowania takich żądań i powiadamiania organizacji?
- **Perspektywa użytkownika:** Czy wiesz, że jeżeli firma korzysta z chmury amerykańskiej, serwery w Polsce nie chronią przed żądaniem rządu USA o wydanie danych?
- **Perspektywa techniczna:** Czy architektura technicznie uniemożliwia dostawcy dostęp do danych w plaintext - przez HYOK, Confidential Computing lub External KMS?

Obszar: **Koncentracja przetwarzania danych w jednej jurysdykcji**

Podstawa prawna: **RODO art. 44–49 / DORA art. 29 / EDPB 05/2021**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja oceniła ryzyko wynikające z koncentracji przetwarzania danych osobowych w jednej jurysdykcji poza EOG (np. USA) i podjęła środki techniczne i prawne ograniczające to ryzyko?
- **Perspektywa użytkownika:** Czy wiesz, że dane osobowe klientów Waszej firmy nie powinny być przechowywane na serwerach poza Europą bez spełnienia szczególnych warunków prawnych?
- **Perspektywa techniczna:** Czy architektura techniczna gwarantuje, że dane osobowe obywateli UE są przetwarzane wyłącznie w EOG, a wszelki transfer poza EOG jest udokumentowany w TIA i zabezpieczony przez SCC?

Obszar: **Ryzyko regulacyjne kraju dostawcy (Cloud Act / FISA)**

Podstawa prawna: **RODO art. 48 / Cloud Act 2018 / FISA 702 / EDPB 05/2021**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy dla kluczowych dostawców spoza EOG przeprowadzono ocenę ryzyka dostępu eksterytorialnego przez organy państwa dostawcy i czy wyniki TIA uwzględniają przepisy Cloud Act i FISA 702?
- **Perspektywa użytkownika:** Czy wiesz, że rząd USA może zobowiązać amerykańskie firmy cloudowe do wydania danych przechowywanych nawet na serwerach w Polsce, jeśli firma ma siedzibę w USA?
- **Perspektywa techniczna:** Czy zastosowano środki techniczne uniemożliwiające dostawcy dostęp do danych w plaintext (HYOK, Confidential Computing, External KMS) lub potwierdzono przez TIA, że ryzyko Cloud Act jest akceptowalne?

7.3.9 Sekcja dostawcy ICT

Aktywacja: *aktywacja warunkowa, gdy typ obiektu = SYSTEM_INFORMATYCZNY*

Pytania w tej sekcji służą do oceny zarządzania ryzykiem stron trzecich w odniesieniu do zewnętrznych dostawców ICT wspierających oceniany system lub funkcje krytyczne organizacji. Sprawdzane jest, czy przed zawarciem umowy przeprowadzono due diligence obejmujące weryfikację certyfikatów bezpieczeństwa, lokalizacji przetwarzania danych, listy sub-procesorów oraz wyników testów penetracyjnych środowiska dostawcy. Ocenie podlega kompletność wymogów umownych: czy kontrakt zawiera mierzalne wskaźniki SLA z sankcjami za ich niedotrzymanie, prawo do audytu onsite, obowiązek powiadomienia o istotnych zmianach (np. zmianie sub-procesora) z wyprzedzeniem co najmniej 30 dni, klauzulę exit umożliwiającą pełny eksport danych w otwartym formacie bez dodatkowych opłat oraz klauzulę regresu umożliwiającą dochodzenie zwrotu kar regulacyjnych nałożonych z winy dostawcy.

Pytania w sekcji:

Obszar: **Retencja i ochrona logów systemów krytycznych**

Podstawa prawna: **DORA art. 10 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy logi systemów krytycznych są przechowywane przez wymagany okres i chronione przed modyfikacją zgodnie z DORA i NIS2?
- **Perspektywa użytkownika:** Czy system przechowuje historię tego, kto i kiedy miał dostęp do danych przez okres co najmniej 12 miesięcy?
- **Perspektywa techniczna:** Czy logi są przechowywane w immutable storage (WORM) przez co najmniej 12 miesięcy i centralnie agregowane w SIEM?

Obszar: **Due diligence i ocena ryzyka dostawcy**

Podstawa prawna: **DORA art. 28 / EBA/GL/2019/02**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy przed zawarciem umowy z krytycznym dostawcą ICT przeprowadzane jest due diligence zgodne z DORA art. 28?
- **Perspektywa użytkownika:** Czy wiesz, że zanim firma podpisze umowę z nowym dostawcą systemu IT, powinna sprawdzić, czy ten dostawca jest bezpieczny - tak jak sprawdza się referencje nowego pracownika?
- **Perspektywa techniczna:** Czy ocena obejmuje certyfikaty (ISO 27001, SOC 2), lokalizację danych, sub-procesorów, wyniki pen-testów i scenariusze exit?

Obszar: **Prawa audytu dostawcy (również onsite)**

Podstawa prawna: **DORA art. 30 ust. 2 lit. f / EBA/GL/2019/02**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowa z dostawcą zapewnia prawa audytu, również onsite: czy ten zapis jest w umowie?
- **Perspektywa użytkownika:** Czy osoba odpowiedzialna może pokazać ostatni raport z audytu tego dostawcy z datą i potwierdzeniem zaadresowania obserwacji?
- **Perspektywa techniczna:** Czy organizacja ma dostęp do logów infrastrukturalnych, konfiguracji bezpieczeństwa i wyników pen-testów środowiska dostawcy?

Obszar: **Transfer Impact Assessment (TIA)**

Podstawa prawna: **DORA art. 28 / Komunikat UKNF 2020**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy przeprowadzono TIA dla tego węzła łańcucha i czy dokumentacja jest dostępna dla KNF?
- **Perspektywa użytkownika:** Czy wiesz, że firma musi formalnie ocenić, co się stanie, gdy dostawca systemu, z którego korzystasz, ulegnie awarii lub zostanie zaatakowany?
- **Perspektywa techniczna:** Czy TIA obejmuje mapę usług chmurowych, klasyfikację krytyczności, scenariusze awarii kaskadowej i ryzyko koncentracji?

Obszar: **Klauzule SLA i gwarantowana dostępność**

Podstawa prawna: **DORA art. 30 ust. 2**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy umowy z kluczowymi dostawcami ICT zawierają mierzalne i egzekwowalne wskaźniki SLA (dostępność, RTO, RPO) dostosowane do krytyczności obsługiwanych funkcji?
- **Perspektywa użytkownika:** Czy wiesz, że kilka różnych systemów IT Twojej firmy może korzystać z infrastruktury tego samego dostawcy chmury, co oznacza że jedna awaria może je wszystkie wyłączyć jednocześnie?
- **Perspektywa techniczna:** Czy SLA gwarantuje dostępność na poziomie co najmniej 99,9

Obszar: **Klauzule powiadomień o zmianach u dostawcy**

Podstawa prawna: **DORA art. 30 ust. 2 lit. e**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowy zobowiązują dostawcę do z góry informowania organizacji o istotnych zmianach: zmianach w sub-procesorach, lokalizacji danych, architekturze bezpieczeństwa lub strukturze właścicielskiej?
- **Perspektywa użytkownika:** Czy wiesz, że jeśli Twój dostawca IT zdecyduje się przenieść dane do nowego centrum danych lub zmienić podwykonawcę, powinien Cię o tym uprzedzić zanim to zrobi?
- **Perspektywa techniczna:** Czy umowa określa minimalny czas wyprzedzenia powiadomienia (np. 30 dni) i czy brak powiadomienia uprawnia organizację do rozwiązania umowy bez kary?

Obszar: **Klauzule odpowiedzialności i regres od dostawcy**

Podstawa prawna: **DORA art. 30 ust. 2 lit. d / NIS2 art. 34**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowy z dostawcami zawierają klauzule umożliwiające organizacji dochodzenie regresem kosztów kar regulacyjnych nałożonych na organizację z winy dostawcy?
- **Perspektywa użytkownika:** Czy wiesz, że jeśli dostawca IT spowoduje wyciek danych i Twoja firma dostanie karę od regulatora, umowa powinna dawać możliwość odzyskania tych pieniędzy od dostawcy?
- **Perspektywa techniczna:** Czy klauzula odpowiedzialności nie jest ograniczona do wartości ostatniej faktury, lecz obejmuje rzeczywistą szkodę regulacyjną i reputacyjną wynikającą z incydentu po stronie dostawcy?

7.3.10 Sekcja exit plan

Aktywacja: *aktywacja warunkowa, gdy typ obiektu = SYSTEM_INFORMATYCZNY ORAZ klasyfikacja podmiotu ∈ {FINANSOWY, KLUCZOWY}*

Pytania w tej sekcji służą do oceny gotowości organizacji do zakończenia współpracy z dostawcą ICT w sposób kontrolowany, bez utraty danych i bez zakłócenia ciągłości działania obsługiwanych funkcji krytycznych. Exit plan jest traktowany jako dokument żywy, zatwierdzony przez zarząd i aktualizowany przy każdej istotnej zmianie systemu lub dostawcy, zawierający konkretne kroki techniczne migracji, a nie jedynie deklaracyjny opis intencji. Sprawdzane jest, czy możliwy jest pełny eksport danych w otwartym formacie niezależnym od narzędzi własnościowych dostawcy oraz czy eksport był faktycznie przetestowany poza środowiskiem dostawcy. Ocenie podlega empirycznie zmierzony czas pełnej migracji (RTE), zidentyfikowanie alternatywnego dostawcy zdolnego do przejęcia funkcji oraz posiadanie procedury weryfikacji bezpiecznego i certyfikowanego usunięcia wszystkich danych z infrastruktury dostawcy po zakończeniu współpracy.

Pytania w sekcji:

Obszar: **Istnienie i zatwierdzenie exit planu**

Podstawa prawna: **DORA art. 28 ust. 2 lit. f**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy dla systemu istnieje formalny, zatwierdzony przez zarząd exit plan, traktowany jako dokument żywy aktualizowany przy każdej istotnej zmianie?
- **Perspektywa użytkownika:** Czy Twoja firma ma gotowy plan działania na wypadek awarii lub zaprzestania usług przez dostawcę tej aplikacji?
- **Perspektywa techniczna:** Czy exit plan zawiera konkretne kroki techniczne, narzędzia migracyjne i sekwencje wyłączeń?

Obszar: **Kompletność i możliwość eksportu danych**

Podstawa prawna: **DORA art. 30 ust. 2 lit. h**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan gwarantuje pełny eksport danych w otwartym formacie bez uzależnienia od narzędzi własnościowych dostawcy?
- **Perspektywa użytkownika:** Czy dane z systemu można pobrać w całości i otworzyć np. w Excelu lub innym standardowym programie?
- **Perspektywa techniczna:** Czy dla tego systemu zdefiniowano i przetestowano procedurę eksportu pełnego zbioru danych do formatu niezależnego od dostawcy, a czas i kompletność eksportu są udokumentowane w ramach testów ciągłości działania (BCP/DRP)?

Obszar: **Czas i koszty wyjścia (RTE)**

Podstawa prawna: **DORA art. 28**

Typ pytania: **informacyjne**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan zawiera udokumentowany czas pełnej migracji (RTE) i koszty wyjścia zatwierdzone przez zarząd?
- **Perspektywa użytkownika:** Czy wiesz, ile czasu zajęłoby Twojej firmie przejście na inny system, gdyby obecny dostawca przestał działać?
- **Perspektywa techniczna:** Czy istnieje udokumentowana i przetestowana analiza kosztów i czasu wyjścia (exit strategy) obejmująca: czas migracji danych, koszt wdrożenia alternatywnego systemu, koszty równoległego utrzymania obu środowisk oraz ryzyko utraty ciągłości działania?

Obszar: **Alternatywny dostawca i przenośność usługi**

Podstawa prawna: **DORA art. 28**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja zidentyfikowała co najmniej jednego alternatywnego dostawcę mogącego przejąć funkcję i oceniła jego zdolność do onboardingu?

- **Perspektywa użytkownika:** Gdyby firma, od której kupujemy ten system przestała działać czy Twoja organizacja ma już na liście inną firmę, która mogłaby przejąć tę usługę?
- **Perspektywa techniczna:** Czy architektura systemu jest zaprojektowana z myślą o przenośności - otwarte standardy, brak vendor lock-in na poziomie formatu i API?

Obszar: **Bezpieczne usunięcie danych u dostawcy po wyjściu**

Podstawa prawna: **RODO art. 28 ust. 3 lit. g / DORA art. 30**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan zawiera procedurę weryfikacji bezpiecznego usunięcia wszystkich danych organizacji z infrastruktury dostawcy po migracji?
- **Perspektywa użytkownika:** Czy wiesz, że gdy firma kończy współpracę z dostawcą, powinna dostać pisemne potwierdzenie, że wszystkie dane zostały usunięte?
- **Perspektywa techniczna:** Czy umowa zobowiązuje dostawcę do certyfikatu zniszczenia danych obejmującego kopie zapasowe, logi i dane archiwalne?

Obszar: **Testowanie exit planu**

Podstawa prawna: **DORA art. 28**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan jest testowany co najmniej raz w roku z udokumentowanymi wynikami dostępnymi dla audytorów?
- **Perspektywa użytkownika:** Czy możesz poprosić dział IT o zestawienie lub raport z danych systemu i otrzymać go w rozsądnym czasie?
- **Perspektywa techniczna:** Czy exit plan jest testowany obejmując rzeczywistą próbę eksportu i importu danych do środowiska zastępczego?

7.3.11 Sekcja plan ciągłości działania (BCP)

Aktywacja: *aktywacja warunkowa, gdy krytyczność(v) ∈ {KRYTYCZNY, WAŻNY} ORAZ klasyfikacja podmiotu ∈ {FINANSOWY, KLUCZOWY}*

Pytania w tej sekcji służą do oceny zdolności organizacji do utrzymania lub sprawnego odtworzenia funkcji krytycznych w przypadku poważnego incydentu ICT, awarii dostawcy lub katastrofy. Sprawdzane jest, czy organizacja posiada formalne, zatwierdzone przez zarząd plany BCP i DRP zawierające konkretne kroki techniczne i sekwencje przełączeń oraz czy każdy system krytyczny ma zdefiniowane i technicznie weryfikowalne wskaźniki RTO i RPO. Ocenie podlega zakres scenariuszy ujętych w planach: czy obejmują ransomware, utratę centrum danych, niedostępność dostawcy chmury i awarię kaskadową w łańcuchu dostaw, a dla każdego scenariusza zdefiniowano odrębną ścieżkę odtwarzania.

Pytania w sekcji:

Obszar: **Istnienie i zatwierdzenie planów BCP/DRP**

Podstawa prawna: **DORA art. 11 / NIS2 art. 21 ust. 2 lit. c**

Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada formalne, zatwierdzone przez zarząd plany BCP i DRP obejmujące wszystkie funkcje krytyczne ICT?
- **Perspektywa użytkownika:** Czy wiesz, jak pracować, gdy aplikacja jest niedostępna przez kilka godzin?
- **Perspektywa techniczna:** Czy BCP i DRP zawierają konkretne kroki techniczne, sekwencje przełączeń i drzewa decyzyjne - czy są dokumentami ogólnymi bez instrukcji wykonawczych?

Obszar: Scenariusze zagrożeń w BCP/DRP

Podstawa prawna: **DORA art. 11 / NIS2 art. 21**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy BCP/DRP obejmuje scenariusze ransomware, utraty centrum danych, niedostępności dostawcy chmury i ataku na łańcuch dostaw?
- **Perspektywa użytkownika:** Czy wiesz, jak Twoja organizacja zachowa się, jeśli ten system zostanie zaszyfrowany przez ransomware dzisiaj o 14:00?
- **Perspektywa techniczna:** Czy dla każdego scenariusza zdefiniowano oddzielną ścieżkę odtwarzania z konkretnymi krokami technicznymi?

Obszar: Testowanie BCP/DRP

Podstawa prawna: **DORA art. 11 ust. 6**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy plany BCP/DRP są testowane co najmniej raz w roku z udokumentowanymi wynikami dostępnymi dla audytorów?
- **Perspektywa użytkownika:** Czy brałeś/aś udział w ćwiczeniu awaryjnym dotyczącym tego systemu?
- **Perspektywa techniczna:** Czy testy obejmują rzeczywiste przełączenie na środowisko zapasowe z mierzonym RTO/RPO - czy ograniczają się do tabletop exercise?

Obszar: Komunikacja kryzysowa

Podstawa prawna: **NIS2 art. 23 / DORA art. 14**

Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy BCP zawiera plan komunikacji kryzysowej z gotowymi szablonami i upoważnieniami do komunikowania się na zewnątrz?
- **Perspektywa użytkownika:** Czy wiesz, jak skontaktować się z przełożonym i działem IT, gdy wszystkie firmowe systemy komunikacji są niedostępne - masz numer telefonu zapisany poza komputerem?
- **Perspektywa techniczna:** Czy istnieje alternatywny kanał komunikacji działający niezależnie od głównej infrastruktury IT, gdy e-mail i Teams są niedostępne?

Obszar: Scenariusz awarii kaskadowej w łańcuchu dostaw

Podstawa prawna: **DORA art. 11 / art. 29 ust. 1**

Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja opracowała scenariusz awarii kaskadowej, w którym awaria jednego dostawcy wywołuje niedostępność powiązanych usług i czy scenariusz ten był symulowany?
- **Perspektywa użytkownika:** Czy wiesz, że awaria jednego systemu IT może spowodować niedostępność innych systemów firmy, które na nim polegają?
- **Perspektywa techniczna:** Czy analiza ryzyka kaskadowego obejmuje drzewo zależności: który dostawca poziom 1 jest uzależniony od jakiego dostawcy poziom 2/3 i jaki jest potencjalny wpływ na funkcje krytyczne?

7.3.12 Sekcja koncentracja ryzyka

Aktywacja: *aktywacja warunkowa, gdy obiekt obsługuje ≥ 3 systemy podmiotu*

Pytania w tej sekcji służą do oceny narażenia organizacji na ryzyko nadmiernego uzależnienia od ograniczonej liczby zewnętrznych dostawców ICT, grup powiązanych dostawców lub lokalizacji geograficznych, co może skutkować systemowym zakłóceniem funkcji krytycznych w przypadku pojedynczej awarii lub incydentu. Ryzyko koncentracji jest oceniane w czterech wymiarach: podmiotowym: uzależnienie od jednego dostawcy lub grupy kapitałowej; geograficznym: koncentracja przetwarzania w jednej lokalizacji lub jurysdykcji prawnej; technologicznym: vendor lock-in wynikający z zastrzeżonych formatów danych lub interfejsów API uniemożliwiających migrację; oraz systemowym: wspólna infrastruktura bazowa leżąca u podstaw pozornie niezależnych dostawców warstwy aplikacyjnej.

Pytania w sekcji:

Tabela 7.4: Podsumowanie pytań audytowych ORION i warunki aktywacji

Sekcja	Typ	Warunek aktywacji Φ_k
Organizacja	Warunkowa	$typ\ obiektu = \text{PODMIOT}$
Bezpieczeństwo techniczne	Warunkowa	$typ\ obiektu = \text{PODMIOT}$
Bezpieczeństwo fizyczne	Warunkowa	$typ\ obiektu = \text{PODMIOT}$
System informatyczny	Warunkowa	$typ\ obiektu = \text{SYSTEM_INFORMATYCZNY}$
Usługi w chmurze	Warunkowa	$utrzymanie_chmura(v) \in \{\text{CHMURA_K3}, \text{CHMURA_EOG}\}$
Transfer Impact Assessment (TIA)	Warunkowa	$utrzymanie_chmura(v) = \text{CHMURA_K3}$
Dane poufne: osobowe, wrażliwe oraz tajemnice przedsiębiorstwa	Warunkowa	$typ_danych(v) \in \{D_1, D_2, D_3\}$
Dostawcy ICT	Warunkowa	$typ\ obiektu = \text{SYSTEM_INFORMATYCZNY}$
Plan ciągłości działania (BCP)	Warunkowa	$krytyczność(v) \in \{\text{KRYTYCZNY}, \text{WAŻNY}\}$ ORAZ klasyfikacja podmiotu $\in \{\text{FINANSOWY}, \text{KLUCZOWY}\}$
Exit plan	Warunkowa	$typ\ obiektu = \text{SYSTEM_INFORMATYCZNY}$ ORAZ klasyfikacja podmiotu $\in \{\text{FINANSOWY}, \text{KLUCZOWY}\}$
Koncentracja ryzyka	Warunkowa	Obiekt obsługuje ≥ 3 systemy podmiotu

7.4 Faza 4: Obliczenie scoringu i propagacja ryzyka

Po zebraniu wszystkich odpowiedzi i dowodów dla wszystkich obiektów w grafie ICT system ORION oblicza wyniki scoringowe na trzech poziomach agregacji: pytania, obiektu i podmiotu.

7.4.1 Poziom 1: Wynik pytania

Wynik pojedynczego pytania q_j jest wyznaczany jako ważona średnia efektywnych wartości odpowiedzi ze wszystkich perspektyw, które pytanie to otrzymały:

$$S(q_j) = \frac{\sum_{\pi_i \in \Pi_{q_j}} V_{eff}(q_j, \pi_i) \cdot w_{\pi_i}}{\sum_{\pi_i \in \Pi_{q_j}} w_{\pi_i}} \quad (7.3)$$

gdzie Π_{q_j} jest zbiorem perspektyw, którym zadano pytanie q_j , a w_{π_i} jest wagą perspektywy.

W rdzeniu metodycznym wszystkie perspektywy mają równą wagę $w_{\pi_i} = 1$, co upraszcza wzór do średniej arytmetycznej efektywnych wartości odpowiedzi. Wagi perspektyw mogą być różnicowane w rozszerzeniach domenowych, na przykład w module finansowym DORA perspektywa zgodności może otrzymać wyższą wagę w pytaniach dotyczących obowiązków sprawozdawczych.

7.4.2 Poziom 2: Wynik sekcji

Wynik sekcji tematycznej $\mathcal{S}_k$ jest wyznaczany jako ważona średnia wyników wszystkich pytań należących do tej sekcji, z uwzględnieniem obligatoryjności pytania.

Wynik sekcji $\mathcal{S}_k$ jest wyznaczany dwuetapowo. Najpierw sprawdzany jest warunek blokujący: jeśli $\text{FLAG}_{block}(\mathcal{S}_k) = \text{TRUE}$, wynik sekcji wynosi zero niezależnie od pozostałych odpowiedzi:

$$S(\mathcal{S}_k) = 0 \quad \text{jeśli } \text{FLAG}_{block}(\mathcal{S}_k) = \text{TRUE} \quad (7.4)$$

W przeciwnym razie wynik sekcji jest wyznaczany jako ważona średnia wyników pytań:

$$S(\mathcal{S}_k) = \frac{\sum_{q_j \in \mathcal{S}_k} S(q_j) \cdot \omega(q_j)}{\sum_{q_j \in \mathcal{S}_k} \omega(q_j)} \quad (7.5)$$

gdzie $\omega(q_j)$ jest wagą pytania wynikającą z jego obligatoryjności:

$$\omega(q_j) = \begin{cases} 2,0 & \text{jeśli pytanie jest obligatoryjne (OBOWIĄZKOWE)} \\ 1,0 & \text{jeśli pytanie jest zalecane (ZALECANE)} \\ 0,5 & \text{jeśli pytanie jest informacyjne (INFORMACYJNE)} \end{cases} \quad (7.6)$$

Pytania oznaczone jako OBOWIĄZKOWE wynikają bezpośrednio z przepisów prawa i mają podwojoną wagę względem pytań zalecanych. Ich wynik $S(q_j) = 0$, to znaczy brak zgodności bez żadnego dowodu, jest dodatkowo oznaczany flagą audytową niezależnie od agregacji sekcji.

7.4.3 Poziom 3: Wynik obiektu

Wynik obiektu v jest wyznaczany jako *średnia arytmetyczna* wyników wszystkich aktywnych sekcji. Wszystkie sekcje pytań audytowych są traktowane jako równoważne pod względem znaczenia regulacyjnego ($\rho_k = 1,0$ dla każdej sekcji $\mathcal{S}_k$):

$$S_{total}(v) = \frac{1}{|\mathcal{S}(v)|} \sum_{\mathcal{S}_k \in \mathcal{S}(v)} S(\mathcal{S}_k) \quad (7.7)$$

Flaga blokująca przy pytaniu z odpowiedzią NIE ustawia wartość sekcji na zero, co bezpośrednio obniża $S_{total}(v)$ niezależnie od wyników pozostałych sekcji:

$$\text{FLAG}_{block}(\mathcal{S}_k) = \text{TRUE} \iff \exists q_j \in \mathcal{S}_k : \kappa(q_j) = \text{BLOKUJĄCE} \wedge a_j = 0 \quad (7.8)$$

Wynik $S_{total}(v) \in [0, 1]$ jest interpretowany na pięciostopniowej skali zgodności:

Tabela 7.5: Skala interpretacji wyniku obiektu

Wynik S_{total}	Klasyfikacja	Interpretacja
$[0,85; 1,0]$	ZGODNY	Wysoki poziom zgodności; dowody kompletne; brak istotnych niezgodności
$[0,70; 0,85)$	CZEŚCIOWO ZGODNY	Większość wymogów spełniona; luki w dokumentacji lub pojedyncze niezgodności drugorzędne
$[0,50; 0,70)$	WYMAGA POPRAWY	Znaczące luki; wymogi obowiązkowe niespełnione lub spełnione bez wystarczających dowodów
$[0,25; 0,50)$	NIEZGODNY	Poważne naruszenia; wysokie ryzyko sankcji; pilne działania naprawcze
$[0; 0,25)$	KRYTYCZNIE NIEZGODNY	Brak podstawowych mechanizmów zgodności; ryzyko natychmiastowych sankcji regulatora

Uwaga: Aktywacja $FLAG_{block}^{obj}(v)$ lub $FLAG_{TIA}(v)$ nadpisuje klasyfikację do NIEZGODNY niezależnie od wartości S_{total} . Aktywacja flagi BLOKUJĄCY z pytania obligatoryjnego nadpisuje klasyfikację do KRYTYCZNIE NIEZGODNY. Niezależnie od wartości $S_{total}(v)$, aktywacja flagi $FLAG_{TIA}(v) = \text{TRUE}$ nadpisuje klasyfikację do NIEZGODNY, a aktywacja flagi BLOKUJĄCY z pytania obligatoryjnego nadpisuje klasyfikację do KRYTYCZNIE NIEZGODNY. Żadna agregacja arytmetyczna nie może ukryć fundamentalnej niezgodności z przepisem prawa o charakterze bezwzględnie obowiązującym.

7.4.4 Poziom 4: Wynik podmiotu z propagacją ryzyka

Wynik podmiotu-korzenia v_0 jest wyznaczany jako ważona średnia wyników wszystkich obiektów w grafie ICT, z uwzględnieniem łącznej wagi obiektu $w_{total}(v)$ oraz współczynnika deprecjacji głębokości λ :

$$S_{podmiot} = \frac{\sum_{v \in V \setminus \{v_0\}} S_{total}(v) \cdot w_{total}(v) \cdot \lambda^{depth(v)}}{\sum_{v \in V \setminus \{v_0\}} w_{total}(v) \cdot \lambda^{depth(v)}} \quad (7.9)$$

gdzie:

- $w_{total}(v) = w_{krit}(v) \cdot w_{data}(v)$ jest łączną wagą obiektu wynikającą z jego krytyczności i klasyfikacji przetwarzanych danych zgodnie z tabelą 6.6,
- $depth(v)$ jest głębokością wierzchołka v w grafie ICT, czyli odległością od korzenia v_0 mierzoną liczbą krawędzi,

- $\lambda \in (0, 1]$ jest konfigurowalnym współczynnikiem deprecjacji głębokości (wartość domyślna: $\lambda = 0,8$), określającym, jak mocno niezgodności głębszych warstw łańcucha dostaw wpływają na wynik podmiotu.

Interpretacja współczynnika λ jest następująca: przy $\lambda = 1,0$ niezgodności poddostawcy trzeciego poziomu wpływają na wynik podmiotu z taką samą siłą jak niezgodności systemu własnego; przy $\lambda = 0,8$ każdy kolejny poziom głębokości zmniejsza wpływ o 20%. Wartość λ może być konfigurowana przez audytora w zależności od oceny faktycznej ekspozycji podmiotu na ryzyko łańcucha dostaw.

7.4.5 Identyfikacja dostawców kluczowych

Dostawca kluczowy (*critical ICT third-party service provider*) to dostawca, którego niezgodność lub niedostępność stanowi zagrożenie dla stabilności podmiotu lub całego systemu. ORION identyfikuje dostawców kluczowych formalnie na podstawie warunku alternatywnego wystarczającego spełnienie **co najmniej jednego** z poniższych kryteriów:

Definicja 7.2 (Dostawca kluczowy). *Dostawca v jest uznawany za **kluczowego** (KEY-VENDOR), jeżeli spełnia co najmniej jeden z następujących warunków:*

1. *obsługuje co najmniej jeden system o klasyfikacji **KRYTYCZNY**:*

$$\exists u \in V : (v, u) \in E_{svc} \wedge \text{krytyczność}(u) = \text{KRYTYCZNY}$$

2. *obsługuje co najmniej $n_{KV}^* = 3$ systemy podmiotu (niezależnie od ich klasyfikacji krytyczności):*

$$|\{u \in V : (v, u) \in E_{svc}\}| \geq n_{KV}^*$$

Formalnie:

$$\begin{aligned} \text{KEYVENDOR}(v) = \text{TRUE} \iff & \left(\exists u \in V : (v, u) \in E_{svc} \wedge \text{krytyczność}(u) = \text{KRYTYCZNY} \right) \\ & \vee \left(|\{u \in V : (v, u) \in E_{svc}\}| \geq n_{KV}^* \right) \end{aligned} \quad (7.10)$$

gdzie E_{svc} jest zbiorem krawędzi usługowych w grafie ICT, a $n_{KV}^* = 3$ jest minimalną liczbą systemów obsługiwanych przez dostawcę (wartość domyślna, konfigurowalna przez audytora).

Innymi słowy: dostawca jest kluczowy, jeśli obsługuje choćby jeden system krytyczny **niezależnie od liczby obsługiwanych systemów** lub jeśli obsługuje co najmniej trzy systemy podmiotu, niezależnie od ich poziomu krytyczności. Spełnienie wyłącznie jednego warunku **jest wystarczające**.

Sekcja KONCENTRACJA_RYZYKA jest aktywowana **wyłącznie** wtedy, gdy dostawca obsługuje co najmniej $n_{KV}^* = 3$ systemy podmiotu (warunek 2 z definicji powyżej), niezależnie od tego, czy stał się dostawcą kluczowym na podstawie warunku 1 czy 2:

$$\Phi_{\text{KONCENTRACJA_RYZYKA}}(v) = \text{TRUE} \iff |\{u \in V : (v, u) \in E_{svc}\}| \geq n_{KV}^* \quad (7.11)$$

Uzasadnienie tego rozróżnienia jest następujące: ryzyko koncentracji w rozumieniu DORA Art. 29 materializuje się przez uzależnienie od jednego dostawcy obsługującego wiele systemów jednocześnie. Dostawca obsługujący jeden system krytyczny jest kluczowy z uwagi

na wagę tego systemu, lecz nie generuje ryzyka koncentracji w sensie regulacyjnym, stąd sekcja KONCENTRACJA_RYZYKA nie jest dla niego aktywowana.

Wynik sekcji KONCENTRACJA_RYZYKA wchodzi do agregacji wyniku obiektu zgodnie z równaniem (7.7). Karty dostawców kluczowych są bezpośrednio adresowane do zarządu i rady nadzorczej, gdyż to na tych organach spoczywa odpowiedzialność za nadzór nad kluczowymi zależnościami ICT w rozumieniu DORA Art. 5 i KSC Art. 8.

7.5 Faza 5: Raport końcowy i rekomendacje

Wynikiem audytu ORION jest ustrukturyzowany raport zawierający cztery elementy: macierz zgodności, graf ICT z oznaczeniami, listę priorytetyzowanych rekomendacji oraz kartę dostawców kluczowych.

7.5.1 Macierz zgodności

Macierz zgodności przedstawia wyniki $S_{total}(v)$ dla wszystkich obiektów w grafie ICT, pogrupowane według sekcji tematycznych. Umożliwia to audytorowi i zarządowi szybką identyfikację obszarów, w których poziom zgodności jest najniższy, niezależnie od tego, których konkretnych systemów lub dostawców te obszary dotyczą.

Tabela 7.6: Przykładowy fragment macierzy zgodności (ilustracja struktury)

Sekcja / Obiekt	System ERP	CRM SaaS	Dostawca cloud	Poddostawca CDN	Średnia
ORGANIZACJA	0,91	0,85	0,78	0,62	0,79
BEZPIECZENSTWO_TECHNICZNE	—	0,72	0,65	0,41	0,67
TIA	—	0,40	0,38	0,20	0,33
PODDOSTAWCY_TIA	—	0,10	0,15	0,10	0,12
CIĄGŁOŚĆ_DZIAŁANIA	0,80	0,75	0,50	—	0,68
EXIT_PLAN	—	0,30	0,25	—	0,28
Wynik obiektu S_{total}	0,86	0,55	0,48	0,31	
Klasyfikacja	ZGODNY	WYMAGA POPRAWY	NIEZGODNY	NIEZGODNY	

Wiersze sekcji TIA i EXIT_PLAN w powyższej tabeli ilustrują kluczową obserwację metodyczną: najniższe wyniki skupiają się konsekwentnie w sekcjach dotyczących łańcucha dostaw i transferu danych, a nie w obszarach bezpieczeństwa technicznego, które są tradycyjnie najlepiej monitorowane. Jest to bezpośrednie potwierdzenie luki badawczej zidentyfikowanej w sekcji 6.1.

7.5.2 Graf ICT z oznaczeniami

Graf ICT generowany jako element raportu końcowego jest wizualną reprezentacją skierowanego grafu ważonego $G = (V, E, W)$ zbudowanego w toku przeprowadzenia audytu. Wierzchołki V reprezentują obiekty audytowe, tj.: systemy informatyczne typu **SYSTEM_INFORMATYCZNY** oraz dostawców ICT, a krawędzie skierowane $E \subseteq V \times V$ wskazują kierunek zależności usługowej: od systemu do podmiotu zewnętrznego, który go obsługuje. Wagi W krawędzi odzwierciedlają poziom krytyczności obsługiwanego systemu zgodnie z klasyfikacją przyjętą w Sekcji 7.2.3.

Graf spełnia podwójną funkcję audytową. Po pierwsze, jest *narzędziem komunikacji wyników do zarządu*, pozwala w kilka sekund zidentyfikować, na którym poziomie łańcucha dostaw ICT koncentruje się ryzyko regulacyjne. Po drugie, jest *dowodem audytowym* dokumentującym kompletność przeprowadzonej analizy i wszystkie odkryte ogniwa łańcucha, włącznie z poddostawcami ujawnionymi przez mechanizm triggera TIA opisany w Sekcji 7.3.8.

Notacja wierzchołków

Każdy wierzchołek grafu jest identyfikowany przez *kod literowy z indeksem głębokości* $\text{depth}(v)$, rozumianej jako odległość od korzenia v_0 mierzona liczbą krawędzi. Przyjęta konwencja nazewnicza jest następująca:

- v_0 : podmiot-korzeń, czyli audytowana organizacja (głębokość 0);
- $v_1, v_2, \dots, v_n$: systemy informatyczne własne podmiotu, zidentyfikowane w Kroku 2.1 (głębokość 1);
- $d_1, d_2, \dots, d_m$: bezpośredni dostawcy ICT, zidentyfikowani w Kroku 2.2 (głębokość 2);
- $p_1, p_2, \dots, p_k$: poddostawcy odkryci przez trigger TIA w toku Fazy 3 (głębokość 3 i wyżej).

W przypadku rozległych grafów dopuszcza się stosowanie notacji złożonej, np. $d_{1,1}, d_{1,2}$ dla kolejnych dostawców powiązanych z systemem v_1 , co ułatwia czytelność przy dużej liczbie obiektów.

Oznaczenia klasyfikacji zgodności

Biorąc pod uwagę ograniczenia techniczne związane z technologią druku i ograniczonej dostępności druku kolorowego, raport audytowy może być drukowany w wersji czarno-białej, klasyfikacja zgodności obiektu jest kodowana *symbolem wewnątrz wierzchołka*, a nie wyłącznie kolorem. Tabela 7.7 przedstawia kompletny słownik oznaczeń.

Aktywacja flagi **FLAG_TIA** lub flagi **BLOKUJĄCY** z pytania obligatoryjnego nadpisuje klasyfikację obiektu niezależnie od wartości S_{total} , co jest sygnalizowane przez dodanie symbolu **!!** do oznaczenia wierzchołka. Żadna agregacja arytmetyczna nie może ukryć fundamentalnej niezgodności z przepisem prawa o charakterze bezwzględnie obowiązującym.

Tabela 7.7: Słownik oznaczeń wierzchołków w grafie ICT

Symbol	Klasyfikacja	Warunek	Priorytet na- prawczy
[✓]	ZGODNY	$S_{total} \geq 0,85$	brak
[~]	CZEŚCIOWO ZGODNY	$0,70 \leq S_{total} < 0,85$	P3
[!]	WYMAGA PRAWY	PO- $0,50 \leq S_{total} < 0,70$	P2
[×]	NIEZGODNY	$0,25 \leq S_{total} < 0,50$	P1–P2
[×]	KRYTYCZNIE ZGODNY	NIE- $S_{total} < 0,25$	P0
[×!!]	Aktywna FLAG_TIA lub BLOKUJĄCY	flaga niezależnie od S_{total} nadpisuje klasyfikację	P0–P1

Oznaczenia krawędzi

Krawędzie grafu ICT różnicowane są typem linii oraz opcjonalną etykietą:

- **Linia ciągła** ($\rightarrow$) – standardowa zależność usługowa; system korzysta z usług dostawcy na podstawie umowy;
- **Linia przerywana** ($--\rightarrow$) – krawędź odkryta przez trigger TIA; oznacza poddostawcę niewidocznego na etapie Fazy 2, ujawnionego dopiero w toku analizy kwestionariusza szczegółowego;
- **Etykieta [KV]** na krawędzi, dostawca kluczowy (*Key Vendor*), spełniający co najmniej jeden warunek z definicji ??: obsługuje co najmniej jeden system KRYTYCZNY lub obsługuje co najmniej $n_{KV} = 3$ systemy podmiotu.

Przykładowy graf ICT

Poniższy przykład ilustruje strukturę grafu ICT dla przykładowego podmiotu. Podmiot v_0 eksploatuje trzy systemy informatyczne:

- v_1 - system ERP, klasyfikacja KRYTYCZNY, wdrożony on-premise, wynik $S_{total} = 0,91$ ([✓] ZGODNY);
- v_2 - system CRM, klasyfikacja WAŻNY, chmura EOG, wynik $S_{total} = 0,78$ ([~] CZEŚCIOWO ZGODNY);
- v_3 - portal kliencki SaaS, klasyfikacja STANDARDOWY, chmura kraju trzeciego (USA), wynik $S_{total} = 0,48$ ([×] NIEZGODNY).

Systemy v_1 i v_2 obsługiwane są przez dostawcę d_1 (firma cloudowa z EOG, $S_{total} = 0,72$, [~] CZEŚCIOWO ZGODNY). System v_3 obsługiwany jest przez dostawcę d_2 (firma z

USA, $S_{total} = 0,31$, $[\times!!]$ - FLAG_TIA aktywna). Dostawca d_1 obsługuje dwa systemy podmiotu ($n < n_{KV}$), zatem nie spełnia progu dostawcy kluczowego. Trigger TIA aktywowany dla d_2 rozszerza graf o poddostawcę p_1 – sieć CDN zlokalizowaną w USA ($S_{total} = 0,20$, $[\times!]$ KRYTYCZNIE NIEZGODNY), obsługiwana przez dostawcę p_2 (podmiot zarejestrowany poza EOG, S_{total} nieustalony na etapie Fazy 2).

Wynik podmiotu $S_{podmiot}$ obliczany jest zgodnie z równaniem (7.9), przy czym wierzchołki odkryte przez trigger TIA (głębokość 3) są objęte współczynnikiem deprecjacji głębokości $\lambda^{\text{depth}(v)} = 0,8^3 = 0,512$, co oznacza, że niezgodność poddostawcy CDN (p_1) wpływa na wynik podmiotu z siłą ok. 51% siły niezgodności systemu własnego.

Interpretacja grafu przez zarząd

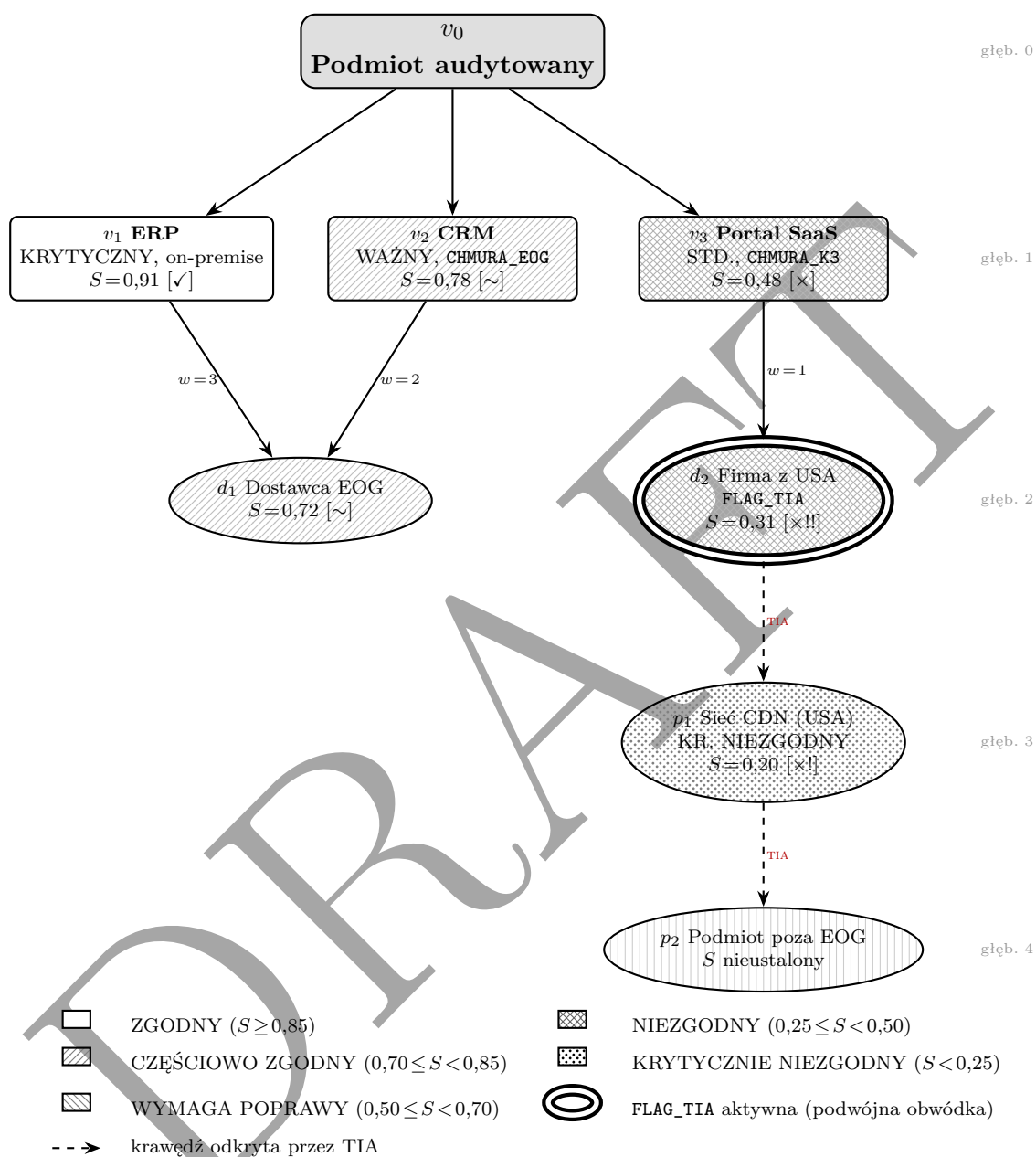
Graf ICT jest jedynym elementem raportu przeznaczonym do odczytania bez uprzedniego zapoznania się z treścią kwestionariuszy. Zarząd i rada nadzorcza powinni być w stanie, wyłącznie na podstawie grafu, odpowiedzieć na trzy pytania operacyjne:

1. **Gdzie skupia się ryzyko?** Wierzchołki oznaczone $[\times]$, $[\times!]$ lub $[\times!!]$ wymagają natychmiastowej uwagi, niezależnie od ich głębokości w grafie.
2. **Który dostawca jest kluczowy?** Krawędzie z etykietą $[KV]$ wskazują podmioty, których awaria lub niezgodność zagraża stabilności całej organizacji.
3. **Jak głęboko sięga łańcuch?** Liczba poziomów grafu ujawnia, czy organizacja jest świadoma pełnej ekspozycji na ryzyko poddostawców, co jest wymogiem art. 28 DORA i art. 6 ust. 2 dyrektywy NIS2.

Brak wierzchołków na poziomie głębokości 3 i wyżej *nie* oznacza braku poddostawców, oznacza brak przeprowadzenia analizy TIA. Audytor jest zobowiązany do odnotowania w raporcie, czy głębokość grafu wynika z faktycznego braku poddostawców podlegających triggerowi, czy też z niewykonania należytej staranności przez audytowany podmiot lub jego dostawców.

7.5.3 Lista rekomendacji z priorytetami

Każda niezgodność zidentyfikowana w toku audytu generuje rekomendację przypisaną do jednego z czterech poziomów priorytetu:



Rysunek 7.2: Przykładowy graf ICT podmiotu z oznaczeniami klasyfikacji zgodności. Prostokąty oznaczają systemy informatyczne (SYSTEM_INFORMATYCZNY), elipsy oznaczają dostawców ICT. Podwójna obwódka sygnalizuje aktywną flagę FLAG_TIA lub kryterium blokujące. Linia przerywana oznacza krawędź odkrytą przez trigger TIA. Wagi krawędzi odzwierciedlają poziom krytyczności obsługiwanego systemu ($w=3$: KRYTYCZNY, $w=2$: WAŻNY, $w=1$: STANDARDOWY).

Tabela 7.8: Priorytety rekomendacji naprawczych w ORION

Priorytet	Definicja	Termin działania	Warunek nadania
P0 KRYTYCZNY	Naruszenie przepisu bezwzględnie obowiązującego grożące natychmiastową sankcją regulatora	Natychmiast (max. 72 h)	Flaga BLOKUJĄCY lub $S_{total}(v) < 0,25$
P1 WYSOKI	Istotna niezgodność z przepisami prawa lub brak TIA przy przetwarzaniu danych osobowych	30 dni	$FLAG_{TIA} = TRUE$ lub pytanie obligatoryjne z $S(q_j) < 0,3$
P2 ŚREDNI	Niezgodność z zaleceniami regulacyjnymi lub luki w dokumentacji	90 dni	$S_{total}(v) \in [0,25; 0,50]$ lub pytanie zalecane z $d < 0,5$
P3 NISKI	Obszar usprawnienia; brak aktualnej dokumentacji lub dowodów słabych	do 180 dni	$S_{total}(v) \in [0,50; 0,70]$ lub odpowiedź z $d = 0,5$

Każda rekomendacja zawiera: identyfikator niezgodności, numer pytania audytowego i sekcji, obiekt którego dotyczy, perspektywę która ujawniła niezgodność, treść niezgodności sformułowaną w języku zrozumiałym dla zarządu, podstawę regulacyjną z numerem artykułu, sugerowane działanie naprawcze oraz termin wynikający z priorytetu.

7.5.4 Karta dostawców kluczowych

Raport końcowy zawiera oddzielną kartę dla każdego dostawcy spełniającego warunek (7.10). Karta zawiera: wynik S_{total} dostawcy, listę systemów podmiotu przez niego obsługiwanych, status TIA i exit planu, klasyfikację zgodności ze wskazaniem priorytetów naprawczych oraz rekomendację dotyczącą zarządzania ryzykiem koncentracji. Karty dostawców kluczowych są bezpośrednio adresowane do zarządu i rady nadzorczej, gdyż to na tych organach spoczywa odpowiedzialność za nadzór nad kluczowymi zależnościami ICT w rozumieniu DORA Art. 5 i KSC Art. 8.

7.6 Wyniki audytu

W celu praktycznej weryfikacji metodologii ORION przeprowadzono audyt technologiczno-prawny w jednym z banków spółdzielczych działających na terenie Polski. Na wniosek instytucji dane identyfikacyjne banku zostały zanonimizowane; wyniki audytu zostały natomiast przedstawione w pełnym zakresie merytorycznym. Audyt objął kompletny cykl klasyfikacyjny przewidziany metodologią: identyfikację reżimu regulacyjnego, klasyfikację ekspozycji sieciowej, ocenę poziomu krytyczności oraz określenie modelu utrzymania infrastruktury i jurysdykcji podmiotu hostującego.

Przedmiotem badania był system Cyfrowego Trwałego Nośnika (CTN), pełniący kluczową funkcję w procesie masowej komunikacji banku z klientami-konsumentami. Podstawowym zadaniem systemu jest dystrybucja dokumentów oraz oświadczeń woli w sposób zgodny z restrykcyjnymi wymogami prawnymi. Architektura systemu realizuje postanowienia Unijnej Dyrektywy o Prawach Konsumenta (Dyrektywa 2011/83/UE) oraz krajowych przepisów implementujących jej założenia, w szczególności Ustawy o prawach konsumenta. Regulacje te nakładają na przedsiębiorców, w tym instytucje sektora finansowego, obowiązek przekazywania konsumentom informacji (takich jak regulaminy, taryfy opłat i prowizji czy formularze informacyjne) na trwałym nośniku, co gwarantuje integralność treści oraz wyklucza możliwość ich jednostronnej modyfikacji przez bank.

7.6.1 Klasyfikacja podmiotu

W pierwszej kolejności zespół audytorski ustalił reżim regulacyjny, jakiemu podlega badana instytucja. Bank spółdzielczy, jako podmiot sektora bankowego, został jednoznacznie zaklasyfikowany jako **podmiot finansowy** w rozumieniu Rozporządzenia DORA (*Digital Operational Resilience Act*). Kwalifikacja ta wynika bezpośrednio z art. 2 ust. 1 lit. a DORA, który na pierwszym miejscu katalogu podmiotów objętych rygiem odporności cyfrowej wymienia instytucje kredytowe.

Klasyfikacja ta determinuje zakres obowiązków banku w obszarze zarządzania ryzykiem ICT: obejmuje wymóg wdrożenia ram zarządzania ryzykiem (art. 5–16 DORA), prowadzenia rejestru umów z dostawcami ICT (art. 28 DORA) oraz przeprowadzania zaawansowanych testów odporności operacyjnej, w tym testów penetracyjnych opartych na analizie zagrożeń: TLPT (*Threat-Led Penetration Testing*).

7.6.2 Klasyfikacja atrybutu ekspozycji sieciowej

Kolejnym krokiem było określenie poziomu ekspozycji sieciowej systemu CTN z zastosowaniem ankiety dostępności metodologii ORION. Analiza architektury systemu wykazała, że dokumenty bankowe oraz interfejs użytkownika są udostępniane masowemu odbiorcy bezpośrednio za pośrednictwem sieci Internet i standardowych przeglądarek internetowych, bez wymogu połączenia VPN ani dostępu do sieci wewnętrznej banku.

Taka architektura wyczerpuje przesłanki *Kryterium D1: Dostęp spoza sieci organizacji* (system jest osiągalny z dowolnego węzła sieci publicznej) oraz *Kryterium D4: Publiczny adres lub domena*, usługa jest opublikowana pod publicznie rozwiązywalną nazwą domenową. Publiczna ekspozycja systemu rozszerza wektor ataku i implikuje konieczność wdrożenia zaawansowanych zabezpieczeń perymetrycznych, w szczególności zapory aplikacyjnej (WAF), mechanizmów mitygacji ataków DDoS oraz inspekcji ruchu TLS.

W rezultacie system CTN został zaklasyfikowany jako **system publiczny**.

7.6.3 Klasyfikacja atrybutu poziomu krytyczności

Ocena krytyczności systemu CTN została przeprowadzona z zastosowaniem sześciokryterialnej ankiety metodologii ORION (Kryteria K1–K6). Poniższa tabela przedstawia wyniki punktacji dla każdego z kryteriów wraz z uzasadnieniem.

Tabela 7.9: Ocena punktowa krytyczności systemu CTN

Kryterium	Opis	Wynik	Uzasadnienie
K1	Wpływ finansowy i operacyjny niedostępności	NIE	Awaria nie zatrzymuje transakcji; BCP przewiduje zastępczy kanał papierowy
K2	Przetwarzanie danych osobowych lub wrażliwych	TAK	Spersonalizowane dokumenty i dane PII klientów (imię, numer umowy, dane adresowe)
K3	Podleganie regulacjom ze-wnątrznym	TAK	Nadzór KNF (Rekomendacja D) i wymogi Prezesa UOKiK dot. trwałego nośnika
K4	Zależności innych systemów produkcyjnych	NIE	Brak systemów operacyjnie uzależnionych od CTN
K5	Ryzyko wycieku lub utraty danych	TAK	Naruszenie poufności rodzi obowiązek zgłoszenia incydentu do UODO i ryzyko reputacyjne
K6	Obsługa procesów podstawowej działalności	NIE	Awaria CTN nie blokuje realizacji transakcji płatniczych ani procesów core-bankingowych
Suma odpowiedzi twierdzących		3 TAK	System ważny

Wynik 3 odpowiedzi twierdzących (K2, K3, K5) plasuje system CTN w kategorii **systemu ważnego** zgodnie z matrycą klasyfikacji metodologii ORION. Kluczowe znaczenie dla ostatecznej kwalifikacji ma zasada dominacji operacyjnej: brak spełnienia kryteriów K1 i K6 (wyznaczników bezpośredniego wpływu na ciągłość podstawowej działalności) wyklucza możliwość uznania systemu za krytyczny, pomimo spełnienia trzech pozostałych kryteriów. Wdrożone plany ciągłości działania (BCP) przewidują procedurę awaryjną polegającą na tymczasowym zastąpieniu kanału cyfrowego klasyczną korespondencją papierową, co pozwala zachować pełną zgodność prawną nawet przy długotrwałej niedostępności systemu informatycznego.

Status systemu ważnego nie zwalnia organizacji z obowiązków nadzorczych. Nakłada on bezwzględny wymóg: ciągłego monitorowania systemu, regularnego przeprowadzania

testów penetracyjnych, audytów zgodności regulacyjnej oraz utrzymania aktualnej dokumentacji przetwarzania danych osobowych zgodnie z art. 30 RODO. Parametry RTO i RPO nie muszą być skalibrowane w reżimie minutowym, jednak powinny zostać formalnie określone i zweryfikowane w ramach ćwiczeń BCP.

7.6.4 Klasyfikacja atrybutu utrzymania w chmurze

Ostatnim krokiem procedury audytowej było ustalenie modelu utrzymania infrastruktury systemu CTN oraz identyfikacja jurysdykcji podmiotu hostującego, z zastosowaniem ankiety klasyfikacji atrybutu utrzymania w chmurze metodologii ORION (Kryteria C1-C6). Wyniki dla każdego kryterium przedstawia poniższa tabela.

Tabela 7.10: Ocena punktowa klasyfikacji modelu utrzymania systemu CTN

Kryterium	Opis	Wynik	Uzasadnienie
C1	Model wdrożenia infrastruktury	TAK	Infrastruktura zaimplementowana u zewnętrznego polskiego dostawcy chmury
C2	Odpowiedzialność operacyjna	TAK	Dostępność zasobów i warstwa sprzętowa w gestii dostawcy na podstawie SLA
C3	Umowa outsourcingowa lub chmurowa	TAK	Umowa SaaS/PaaS i kontrakt outsourcingu IT z dostawcą
C4	Lokalizacja i kontrola danych	TAK	Dane produkcyjne i kopie zapasowe w centrum danych na terytorium RP
C5	Jurysdykcja podmiotu hostującego	TAK	Wyłącznie kapitał europejski; pełne TIA; brak ekspozycji na US CLOUD Act i FISA 702
C6	Wsparcie techniczne	TAK	Helpdesk i administracja świadczone wyłącznie przez zespół z terytorium EOG; geoblocking VPN
Suma odpowiedzi twierdzących		6 TAK	Chmura EOG

Uzyskanie kompletnego zestawu sześciu odpowiedzi twierdzących, w tym pozytywnych wyników dla kryteriów C5 i C6 dotyczących jurysdykcji i wsparcia technicznego, przesądza o klasyfikacji systemu CTN jako **systemu utrzymywanego w chmurze EOG**. Jest to klasyfikacja o najwyższym poziomie bezpieczeństwa jurydycznego: podmiot hostujący oparty wyłącznie na kapitale europejskim i niemający siedziby w państwach objętych re-

gulacjami o ekstraterytorialnym dostępie do danych (takim jak US CLOUD Act czy FISA Section 702) eliminuje ryzyko nieautoryzowanego transferu danych do państw trzecich.

Klasyfikacja ta zapewnia jednocześnie pełną zgodność z wytycznymi i komunikatami chmurowymi Urzędu Komisji Nadzoru Finansowego (UKNF) oraz z wymogami Rozporządzenia DORA w zakresie zarządzania ryzykiem ze strony zewnętrznych dostawców usług ICT (art. 28-30 DORA). Narzędzia zdalnego dostępu serwisowego skonfigurowane z restrykcyjnym geoblockingiem, uniemożliwiające zestawienie sesji administracyjnej spoza obszaru EOG, stanowią dodatkową warstwę zabezpieczenia weryfikowalną przez audytatorów bezpośrednio w logach dostępowych.

7.6.5 Klasyfikacja atrybutu typów przetwarzanych danych

Klasyfikacja typów przetwarzanych danych została przeprowadzona zgodnie z tabelą 6.8 metodologii ORION. System CTN przetwarza spersonalizowane dokumenty bankowe zawierające dane identyfikacyjne klientów (imię i nazwisko, numer umowy, dane adresowe) oraz informacje objęte tajemnicą bankową w rozumieniu art. 104 ustawy Prawo bankowe, a więc dane o rachunkach, historię transakcji i informacje o zobowiązaniach kredytowych. Tajemnica bankowa stanowi informację prawnie chronioną na mocy ustawy sektorowej, co w klasyfikacji ORION odpowiada najwyższej kategorii wrażliwości.

System CTN został zatem sklasyfikowany jako przetwarzający dane kategorii **TAJEMNICA** (symbol D_3 , mnożnik wagowy $w_{data} = 2,0$). Klasyfikacja ta ma bezpośrednie przełożenie na wagę artefaktu w agregacji końcowej oraz aktywuje sekcję pytań dotyczących danych poufnych. Naruszenie bezpieczeństwa systemu przetwarzającego tajemnicę bankową rodzi po stronie instytucji obowiązek zgłoszenia incydentu do organu nadzoru (KNF) oraz potencjalną odpowiedzialność odszkodowawczą wobec klientów, których dane zostały ujawnione osobom nieuprawnionym.

7.6.6 Klasyfikacja atrybutu kraju pochodzenia

Atrybut kraju pochodzenia dostawcy systemu CTN został wyznaczony na podstawie weryfikacji statusu prawnego i kapitałowego podmiotu świadczącego usługę utrzymania oraz przeprowadzającego wdrożenie. Dostawca jest spółką zarejestrowaną i prowadzącą działalność operacyjną wyłącznie na terytorium Rzeczypospolitej Polskiej, bez powiązań kapitałowych z podmiotami spoza Europejskiego Obszaru Gospodarczego. Zarówno wsparcie techniczne, jak i administracja systemu są świadczone przez personel zlokalizowany w Polsce.

Atrybut przyjął wartość **PL**. Konsekwencją tej klasyfikacji jest brak obowiązku przeprowadzenia oceny skutków transferu danych (TIA), ponieważ żaden etap przetwarzania nie wiąże się z przekazaniem danych do państwa trzeciego w rozumieniu RODO. Dostawca nie podlega jurysdykcji przepisów o ekstraterytorialnym dostępie do danych (takich jak US CLOUD Act czy FISA Section 702), co eliminuje ryzyko nieautoryzowanego udostępnienia danych organom obcego państwa.

7.6.7 Analiza aktywowanych sekcji pytań

Zbiór atrybutów wyznaczonych w poprzednich krokach determinuje zakres sekcji pytań aktywowanych przez system ORION dla danego audytu. Poniżej przedstawiono wynik tej aktywacji wraz z uzasadnieniem dla każdej sekcji.

Podmiot audytowany (bank spółdzielczy) został sklasyfikowany jako FINANSOWY, system CTN jako PUBLICZNY o poziomie krytyczności WAŻNY, utrzymywany w trybie CHMURA_EOG, przetwarzający dane kategorii TAJEMNICA (D_3), dostarczany przez podmiot z kraju PL. Zidentyfikowano jednego zewnętrznego dostawcę ICT, działającego w jurysdykcji EOG.

Na podstawie powyższych atrybutów aktywowano następujące sekcje pytań:

- **Organizacja** (aktywacja stała dla obiektów typu PODMIOT): ocena struktury zarządzania ryzykiem ICT, polityk bezpieczeństwa i nadzoru zarządczego nad funkcjami cyfrowymi.
- **Bezpieczeństwo techniczne** (aktywacja stała dla obiektów typu PODMIOT): ocena technicznych środków ochrony infrastruktury, zarządzania podatnościami oraz procedur reagowania na incydenty.
- **Bezpieczeństwo fizyczne** (aktywacja stała dla obiektów typu PODMIOT): weryfikacja zabezpieczeń fizycznych siedziby i pomieszczeń serwerowni podmiotu audytowanego.
- **System informatyczny** (aktywacja warunkowa dla obiektów typu SYSTEM_INFORMATYCZNY): weryfikacja bezpieczeństwa warstwy aplikacyjnej systemu CTN, obejmująca m.in. mechanizmy uwierzytelniania, zarządzanie sesjami i ochronę przed atakami na warstwę aplikacji (OWASP Top 10).
- **Usługi w chmurze** (aktywacja warunkowa: $utrzymanie_chmura \in \{CHMURA_EOG, CHMURA_K3\}$): ocena zgodności wynikającej ze specyfiki przetwarzania w środowisku zewnętrznym, w tym weryfikacja modelu zarządzania kluczami kryptograficznymi, izolacji danych między klientami dostawcy oraz prawa do audytu.
- **Dane poufne** (aktywacja warunkowa: $typ_danych(v) \in \{D_1, D_2, D_3\}$): rozszerzona ocena środków ochrony danych objętych tajemnicą bankową, obejmująca szyfrowanie w spoczynku i podczas transmisji, kontrolę dostępu oraz procedury reagowania na naruszenia ochrony danych.
- **Dostawcy ICT** (aktywacja warunkowa: $utrzymanie_chmura(v) \in \{CHMURA_EOG, CHMURA_K3\}$): ocena zarządzania ryzykiem zewnętrznego dostawcy ICT, w tym due diligence przedkontraktowe, kompletność wymogów umownych (SLA, prawo do audytu, klauzula exit) oraz monitorowanie sub-procesorów.
- **Plan wyjścia z usługi (exit plan)** (aktywacja warunkowa: $typ_obiektu(v) = DOSTAWCA \wedge klasyfikacja_podmiotu(v) = FINANSOWY$): weryfikacja planu wyjścia z relacji z dostawcą, obejmująca zdolność do pełnego eksportu danych w formacie otwartym, zmierzony czas migracji (RTE) oraz identyfikację alternatywnego dostawcy.
- **Plan ciągłości działania (BCP)** (aktywacja warunkowa: $krytyczność(v) \in \{KRYTYCZNY, WAŻNY\}$ oraz klasyfikacja podmiotu FINANSOWY): ocena planów BCP i DRP, wskaźników RTO i RPO, scenariuszy odtwarzania po awarii dostawcy chmury oraz kopii zapasowych izolowanych od infrastruktury produkcyjnej.

Następujące sekcje nie zostały aktywowane z uwagi na niespełnienie warunków progowych:

- **Transfer Impact Assessment (TIA)** (warunek: $utrzymanie_chmura(v) = CHMURA_K3$): sekcja dotycząca oceny skutków transferu danych nie została aktywowana, ponieważ system jest utrzymywany w CHMURA_EOG. Żaden etap przetwarzania nie obejmuje transferu danych do państwa trzeciego, wobec czego obowiązek przeprowadzenia TIA wymagany przez RODO nie powstaje.
- **Koncentracja ryzyka** (warunek: dostawca obsługuje ≥ 3 systemy podmiotu): zidentyfikowano jednego zewnętrznego dostawcę ICT, obsługującego wyłącznie system CTN. Próg koncentracji nie został osiągnięty, wobec czego ryzyko nadmiernego uzależnienia od jednego podmiotu nie wymaga pogłębionej oceny w ramach tego audytu.

7.6.8 Wyniki sekcji organizacja

Sekcja organizacja obejmuje dziewięć obszarów tematycznych wymaganych przez regulacje NIS2 i DORA, dotyczących ładu zarządczego, zarządzania ryzykiem ICT oraz zdolności operacyjnej do obsługi incydentów. Ocena każdego obszaru była przeprowadzana metodą cross-validation, tzn. każde pytanie było zadawane niezależnie trzem perspektywom: prawno-compliance, technicznej (dział IT) oraz użytkownika końcowego. Zgodność odpowiedzi ze wszystkich trzech perspektyw stanowiła warunek udzielenia odpowiedzi twierdzącej bez kary za niepotwierdzenie deklaracji.

Bank spółdzielczy uzyskał kompletne, pozytywne wyniki we wszystkich dziewięciu obszarach, bez żadnych niezgodności i bez rozbieżności między perspektywami. Szczegółowe ustalenia dla każdego obszaru przedstawiono poniżej.

Strategia cyberbezpieczeństwa (NIS2 art. 20 ust. 1, DORA art. 5): zarząd banku formalnie zatwierdził strategię cyberbezpieczeństwa i ponosi za nią odpowiedzialność prawną. Dokument jest dostępny dla pracowników, a jego istnienie zostało potwierdzone niezależnie przez radcę prawnego, dział IT oraz losowo wybranych użytkowników końcowych, co świadczy o realnym wdrożeniu, a nie jedynie formalnym istnieniu dokumentu.

Szkolenia zarządu (NIS2 art. 20 ust. 2): członkowie zarządu odbyli obowiązkowe szkolenia z cyberbezpieczeństwa. Dokumentacja szkoleń (lista uczestników, daty, zakresy tematyczne) była dostępna do wglądu audytorów, co eliminuje ryzyko zakwalifikowania szkolenia jako deklaratywnego.

Ramy zarządzania ryzykiem ICT (NIS2 art. 21 ust. 1, DORA art. 6): organizacja wdrożyła udokumentowane ramy zarządzania ryzykiem ICT zatwierdzone przez zarząd, obejmujące rejestr ryzyk z przypisanymi właścicielami i planami mitygacji. Rejestr jest aktualizowany co najmniej raz w roku. Wszyscy respondenci (compliance, IT, użytkownicy) potrafili wskazać osobę odpowiedzialną za bezpieczeństwo systemów IT, co świadczy o wysokiej świadomości organizacyjnej.

Ocena ryzyka łańcucha dostaw (NIS2 art. 21 ust. 2 lit. d, DORA art. 28): organizacja przeprowadza regularną ocenę ryzyka uwzględniającą łańcuch dostaw ICT i dostawców zewnętrznych. Ocena obejmuje wszystkich dostawców z klasyfikacją krytyczności i udokumentowanymi wynikami. Użytkownicy potwierdzili wiedzę o tym, które zewnętrzne podmioty mają dostęp do systemów lub danych organizacji.

Zgłaszanie poważnych incydentów w ciągu 24 godzin (NIS2 art. 23 ust. 4 lit. a, DORA art. 19): bank posiada udokumentowaną procedurę umożliwiającą zgłoszenie poważnego incydentu do organu krajowego w wymaganym terminie 24 godzin od wykrycia. System ticketowy wymusza checkpointy czasowe z automatycznym przypomnieniem.

Użytkownicy końcowi wykazali się znajomością kroków postępowania w sytuacji podejrzanego zdarzenia, co potwierdza skuteczność szkoleń.

Klasyfikacja incydentów (NIS2 art. 23 ust. 3, DORA art. 18): organizacja dysponuje procedurą klasyfikacji incydentów pozwalającą ocenić, czy dane zdarzenie spełnia kryteria incydentu poważnego lub znaczącego w rozumieniu regulacji. Użytkownicy potrafili odróżnić zwykłą awarię od zdarzenia o charakterze bezpieczeństwa.

Powiadamianie klientów o incydentach (NIS2 art. 23 ust. 4 lit. c, DORA art. 14): bank posiada zatwierdzoną procedurę komunikacji kryzysowej z gotowymi szablonami i zdefiniowanymi kanałami komunikacji z klientami. Procedura jest możliwa do uruchomienia w krótkim czasie. Użytkownicy potwierdzili świadomość istnienia procedury powiadamiania.

Rejestr czynności przetwarzania (RODO art. 30): organizacja prowadzi aktualny rejestr czynności przetwarzania danych osobowych (ROPA) w formie elektronicznej, obejmujący system CTN z opisem celów, kategorii danych, odbiorców i podstaw prawnych. Rejestr jest dostępny dla Inspektora Ochrony Danych i aktualizowany przy zmianach systemu lub procesu przetwarzania.

Rejestr kluczowych dostawców ICT (DORA art. 28 ust. 2, art. 29 ust. 1): organizacja prowadzi aktualny rejestr zewnętrznych dostawców ICT z klasyfikacją ich krytyczności i przypisaniem do funkcji krytycznych lub istotnych. Rejestr obejmuje dane kontraktowe, zakres usług i daty przeglądów. Użytkownicy wykazali świadomość liczby zewnętrznych dostawców IT obsługujących organizację.

Kompletna zgodność we wszystkich dziewięciu obszarach, potwierdzona niezależnie przez trzy perspektywy, wskazuje na wysoki poziom dojrzałości organizacyjnej banku w zakresie ładu zarządzania ryzykiem ICT. Brak rozbieżności między odpowiedziami działu compliance, działu IT i użytkowników końcowych świadczy o tym, że wdrożone procedury i polityki funkcjonują realnie, a nie tylko jako dokumentacja formalna. Jest to wynik szczególnie istotny w kontekście przeciwdziałania zjawisku compliance theater: potwierdzone, weryfikowalne dowody zastępują deklaratywne zapewnienia, co stanowi jeden z kluczowych postulatów metodologii ORION.

7.6.9 Wyniki sekcji bezpieczeństwo techniczne

Sekcja bezpieczeństwo techniczne jest aktywowana dla obiektów typu PODMIOT i w audycie CTN obejmowała ocenę banku jako organizacji. Obejmuje osiem obszarów dotyczących technicznych środków ochrony infrastruktury ICT, zarządzania dostępem, monitorowania oraz ciągłości procesów bezpieczeństwa, wymaganych przez NIS2, DORA i RODO. We wszystkich ośmiu obszarach bank uzyskał wyniki pozytywne, bez żadnych uchybień i bez rozbieżności między perspektywami. Jest to jeden z silniejszych wyników całego audytu, wskazujący na dojrzałość operacyjną działu IT oraz na skuteczność szkoleń i kultury bezpieczeństwa w organizacji.

Testy bezpieczeństwa i testy penetracyjne (NIS2 art. 21 ust. 2 lit. m, DORA art. 24–25): organizacja przeprowadza regularne testy bezpieczeństwa, testy podatności oraz testy penetracyjne zgodnie z rocznym planem obejmującym harmonogram i zakres. Wyniki testów są dokumentowane i powiązane z procesem naprawczym. Użytkownicy potwierdzili wiedzę o tym, że zewnętrzne podmioty cyklicznie weryfikują odporność systemów banku.

Monitoring i wykrywanie anomalii (NIS2 art. 21 ust. 2 lit. b, DORA art. 10): wdrożone mechanizmy ciągłego monitorowania pokrywają systemy krytyczne i generują

alerty w czasie rzeczywistym. Za obsługę alertów odpowiada dedykowany zespół, co zostało potwierdzone przez użytkowników, którzy byli świadomi istnienia takiego zespołu i jego roli.

Zasada minimalnych uprawnień (DORA art. 9, NIS2 art. 21): dostęp do systemów krytycznych jest nadawany zgodnie z zasadą least privilege i regularnie przeglądany. Stosowane jest narzędzie klasy PAM (Privileged Access Management) z automatycznym przeglądem uprawnień i alertowaniem przy próbach eskalacji. Użytkownicy potwierdzili, że nie posiadają dostępu do zasobów wykraczających poza zakres ich obowiązków.

Szkolenia i świadomość pracowników (NIS2 art. 21 ust. 2 lit. g): pracownicy przechodzą regularne szkolenia z cyberbezpieczeństwa dostosowane do roli (odrębne ścieżki dla personelu IT, biznesowego i zarządu). Skuteczność szkoleń jest mierzona przez symulowane kampanie phishingowe. Użytkownicy potwierdzili udział w ćwiczeniach tego rodzaju w ciągu ostatnich 12 miesięcy.

Offboarding i usuwanie dostępu (DORA art. 9): organizacja posiada udokumentowany i zautomatyzowany proces dezaktywacji kont przy odejściu pracownika. Dezaktywacja następuje w dniu odejścia i obejmuje wszystkie systemy bez konieczności ręcznej interwencji administratora w poszczególnych aplikacjach. Użytkownicy wykazali świadomość wymogów w tym zakresie.

Bezpieczeństwo poczty elektronicznej i załączników (RODO art. 32, NIS2 art. 21): organizacja posiada politykę regulującą wysyłanie danych wrażliwych pocztą elektroniczną, z wymogiem szyfrowania załączników zawierających dane klientów. Podczas weryfikacji z perspektywy użytkownika nie odnotowano przypadków wysyłania niezabezpieczonych plików z danymi osobowymi.

Segmentacja sieci i kontrola ruchu bocznego (DORA art. 9, NIS2 art. 21): systemy krytyczne są logicznie odizolowane od pozostałej infrastruktury sieciowej przez segmentację VLAN uniemożliwiającą niekontrolowane przemieszczanie się potencjalnego atakującego między segmentami (lateral movement). Polityki firewalla wymuszają kontrolę ruchu wschód-zachód między segmentami. Użytkownicy rozumieją cel izolacji systemów, co świadczy o skuteczności komunikacji wewnętrznej działu IT.

Zarządzanie certyfikatami TLS (DORA art. 9, NIS2 art. 21 lit. h): organizacja prowadzi inwentarz certyfikatów TLS z datami wygasania i wdrożonym procesem automatycznego odnawiania. Stosowane narzędzie monitorujące generuje alerty z wyprzedzeniem co najmniej 30 dni przed wygaśnięciem certyfikatu. Użytkownicy nie odnotowali przypadków ostrzeżeń przeglądarki o wygasłym certyfikacie na systemach banku.

Pełna zgodność we wszystkich ośmiu obszarach technicznych, potwierdzona spójnie przez wszystkie trzy perspektywy, świadczy o wysokiej kulturze bezpieczeństwa technicznego w organizacji. Szczególnie istotny jest wynik w obszarze szkoleń i świadomości: użytkownicy końcowi wykazali praktyczną wiedzę z zakresu cyberbezpieczeństwa, co bezpośrednio przekłada się na ograniczenie ryzyka ataków socjotechnicznych (phishing, vishing) jako najczęstszego wektora inicjalnego kompromitacji systemów finansowych.

7.6.10 Wyniki sekcji bezpieczeństwo fizyczne

Sekcja bezpieczeństwo fizyczne obejmuje osiem obszarów dotyczących ochrony fizycznej obiektów, infrastruktury serwerowej i nośników danych, wymaganych przez regulacje NIS2, DORA oraz RODO. Spośród ośmiu obszarów sześć zostało ocenionych pozytywnie przez wszystkie trzy perspektywy (compliance, IT, użytkownicy). Dwa obszary sklasyfikowane jako zalecane ujawniły nieprawidłowości o wspólnej przyczynie, omówione

szczegółowo poniżej.

Bezpieczeństwo fizyczne centrów danych (DORA art. 9, NIS2 art. 21): polityki bezpieczeństwa fizycznego centrum danych spełniają wymogi w zakresie poufności, integralności i ochrony dostępu. Stosowana jest kontrola dostępu (karty dostępu) z rejestrowaniem każdego wejścia, monitoring środowiskowy oraz CCTV. Użytkownicy potwierdzili, że wejście do serwerowni wymaga autoryzacji i jest każdorazowo rejestrowane.

Kontrola dostępu fizycznego do obiektów (DORA art. 9, NIS2 art. 21): organizacja posiada formalną politykę kontroli dostępu fizycznego do pomieszczeń przetwarzających dane. Dostęp do serwerowni jest logowany elektronicznie, bez możliwości wejścia wyłącznie na podstawie klucza mechanicznego. Wynik potwierdzony zgodnie przez wszystkie trzy perspektywy.

Monitoring CCTV i rejestracja wideo (RODO art. 5 ust. 1 lit. e, NIS2 art. 21): obszary krytyczne są objęte monitoringiem kamer z retencją nagrań zgodną z polityką bezpieczeństwa i wymogami RODO. Kamery obejmują punkty wejścia do stref krytycznych, a nagrania są chronione przed modyfikacją.

Zasilanie i redundancja energetyczna (DORA art. 11, NIS2 art. 21): obiekty krytyczne posiadają redundantne zasilanie z niezależnych źródeł oraz zasilacze UPS. Urządzenia zasilające są regularnie testowane pod obciążeniem.

Wynoszenie i transport urządzeń (RODO art. 32, NIS2 art. 21): organizacja posiada procedurę wynoszenia urządzeń poza siedzibę z rejestrem wydanych sprzętów. Urządzenia przenośne mają aktywowane szyfrowanie całego dysku oraz możliwość zdalnego wyczyszczenia w przypadku utraty lub kradzieży.

Niszczenie i utylizacja nośników danych (RODO art. 5, NIS2 art. 21): bank posiada procedurę bezpiecznego niszczenia nośników danych, obejmującą dyski twarde, nośniki przenośne oraz wydruki. Dyski są niszczone fizycznie lub nadpisywane skuteczną metodą przed utylizacją.

Strefy bezpieczeństwa i segmentacja fizyczna (NIS2 art. 21, ISO 27001 A.11): w tym obszarze stwierdzono niezgodność. Obiekty nie są w wystarczającym stopniu podzielone na odrębne strefy bezpieczeństwa z różnymi poziomami kontroli dostępu. W trakcie audytu z perspektywy użytkownika ustalono, że gość lub dostawca wchodzący do biura ma możliwość swobodnego poruszania się po budynku bez dodatkowej autoryzacji na kolejnych granicach stref. Oznacza to, że osoba posiadająca dostęp do przestrzeni biurowej może potencjalnie zbliżyć się do obszarów technicznych bez skutecznej przeszkody fizycznej lub proceduralnej.

Ochrona przed kradzieżą i sabotażem fizycznym (NIS2 art. 21, ISO 27001 A.11): stwierdzono niezgodność powiązaną przyczynowo z poprzednim obszarem. Podczas audytu zidentyfikowano niewystarczający nadzór nad osobami wizytującymi, które potencjalnie uzyskiwały nadmierny dostęp fizyczny do pomieszczeń zawierających sprzęt IT. Weryfikacja techniczna wykazała, że szafy rack z serwerami są zamknięte na klucz, a porty USB zablokowane, jednak brak segmentacji stref sprawia, że sam dostęp do szafy pozostaje fizycznie możliwy dla osoby nieupoważnionej, jeśli nie jest ona nadzorowana przez pracownika.

Oba zidentyfikowane ryzyka mają charakter zaleceń (nie wymagań obowiązkowych w rozumieniu NIS2 i DORA) i wynikają z tej samej luki: braku formalnej procedury nadzoru nad gośćmi oraz braku fizycznej segmentacji stref o różnym poziomie wrażliwości. Jako działania naprawcze wskazano wdrożenie rejestru gości z obowiązkowym eskortowaniem poza strefą publiczną, wprowadzenie bramek lub drzwi z osobną autoryzacją na granicy strefy biurowej i technicznej oraz rozważenie instalacji systemu zarządzania gośćmi (visitor

management system) rejestrującego każde wejście i wyjście w czasie rzeczywistym.

7.6.11 Wyniki sekcji system informatyczny

Sekcja system informatyczny obejmuje dziewięć obszarów dotyczących bezpieczeństwa warstwy aplikacyjnej systemu CTN, w tym zarządzania dostępem, szyfrowania, kopii zapasowych, logowania i zarządzania podatnościami, wymaganych przez NIS2, DORA i RODO. Spośród dziewięciu obszarów sześć zostało ocenionych pozytywnie przez wszystkie trzy perspektywy. Trzy obszary ujawniły nieprawidłowości o zróżnicowanym charakterze: jedno dotyczyło wyłącznie luki w wiedzy użytkowników (uzupełnionej na miejscu), jedno stanowiło pytanie blokujące (usunięte przed zakończeniem audytu), a jedno wskazuje na brak technicznego wymuszenia polityki haseł.

Uprawnienia i dostęp aplikacji dostawcy (DORA art. 9, NIS2 art. 21): konta serwisowe aplikacji dostawcy posiadają ograniczony zakres uprawnień w usłudze katalogowej, bez dostępu do systemów niezwiązanych z obsługą CTN, i są regularnie przeglądane.

Dostęp zdalny dostawcy (DORA art. 28): zdalny dostęp dostawcy do systemu jest kontrolowany, logowany i ograniczony czasowo. Sesje serwisowe wymagają jawnej akceptacji po stronie organizacji, co wyklucza możliwość nieautoryzowanego dostępu przez dostawcę bez wiedzy banku.

Rejestr zasobów ICT (DORA art. 8): system CTN figuruje w oficjalnym rejestrze zasobów ICT z przypisaną klasyfikacją krytyczności, właścicielem biznesowym i właścicielem technicznym. Użytkownicy potwierdzili wiedzę o tym, kto odpowiada za bezpieczeństwo aplikacji.

Retencja i ochrona logów aplikacji (DORA art. 10, NIS2 art. 21): logi aplikacji są centralnie agregowane i przechowywane przez wymagany okres, chronione przed modyfikacją w magazynie immutable. W trakcie audytu perspektywa użytkownika nie była w stanie samodzielnie potwierdzić faktu przechowywania logów, co wskazuje na lukę w komunikacji wewnętrznej na temat procedur retencji. Podczas sesji audytowej mechanizm logowania został zademonstrowany przez dział IT i zweryfikowany przez audytorów bezpośrednio w systemie. Uchybienie zostało ocenione jako formalne (brak wiedzy użytkownika, nie brak technicznej implementacji) i nie skutkuje obniżeniem oceny technicznej obszaru.

Szyfrowanie komunikacji (DORA art. 9, NIS2 art. 21 lit. h, RODO art. 32): cała komunikacja aplikacji jest szyfrowana przy użyciu protokołu TLS 1.2 lub nowszego. Skanowanie konfiguracji potwierdziło brak przestarzałych protokołów (TLS 1.0/1.1, SSL). Interfejs użytkownika jest dostępny wyłącznie przez HTTPS.

MFA dla wszystkich użytkowników (DORA art. 9, NIS2 art. 21): w momencie rozpoczęcia audytu stwierdzono brak obowiązkowego uwierzytelnienia wieloskładnikowego (MFA) dla kont użytkowników systemu CTN, w tym kont uprzywilejowanych. Pytanie to zostało sklasyfikowane przez metodologię ORION jako **pytanie blokujące** (wymóg obowiązkowy), co oznacza, że jego niespełnienie automatycznie obniża wynik sekcji niezależnie od wyników pozostałych pytań. Uchybienie zostało niezwłocznie zgłoszone producentowi systemu. W trakcie trwania audytu dostawca wdrożył stosowną zmianę konfiguracyjną, a audytorzy zweryfikowali jej działanie technicznie. Wynik obszaru został skorygowany do pozytywnego po potwierdzeniu wdrożenia.

Zarządzanie hasłami i polityką haseł (NIS2 art. 21, DORA art. 9): organizacja posiada formalną politykę haseł określającą minimalną długość, złożoność oraz zakaz ponownego użycia poprzednich haseł. Polityka jest wymuszana technicznie przez dostawcę

tożsamości. Stwierdzono jednak, że system nie wymusza zmiany hasła po upływie określonego czasu (brak mechanizmu wygasania hasła). Jest to niezgodność o charakterze wymagania obowiązkowego: brak cyklicznej rotacji hasła zwiększa ryzyko długotrwałego wykorzystywania przejętych poświadczeń bez wiedzy organizacji. Jako działanie naprawcze wskazano konfigurację polityki wygasania hasła po maksymalnie 90 dniach z obowiązkową zmianą przy kolejnym logowaniu.

Backup (DORA art. 12, NIS2 art. 21 ust. 2 lit. c): kopie zapasowe są przechowywane w geograficznie odrębnej lokalizacji, retencja spełnia wymogi regulacyjne, a procedura odtwarzania była regularnie testowana z udokumentowanymi wynikami. Użytkownicy wykazali świadomość procedur odtwarzania systemu po awarii.

Zarządzanie podatnościami (NIS2 art. 21 ust. 2 lit. m, DORA art. 9): organizacja posiada formalny proces skanowania podatności CVE i zarządzania aktualizacjami z udokumentowanymi terminami naprawy przypisanymi do właścicieli. Skanowanie systemów krytycznych jest przeprowadzane co najmniej raz w miesiącu.

Najistotniejszym ustaleniem sekcji jest wykrycie braku MFA jako pytania blokującego. Fakt jego usunięcia w trakcie audytu dokumentuje jedną z kluczowych właściwości metodologii ORION: identyfikacja konkretnego, weryfikowalnego uchybienia i jego naprawa w czasie rzeczywistym jest bardziej wartościowym wynikiem audytu niż brak niezgodności wynikający z powierzchownej oceny. Otwartą kwestią pozostaje brak wymuszania rotacji hasła, wymagający działania naprawczego po stronie organizacji.

7.6.12 Wyniki sekcji usługi chmurowe

Sekcja usługi chmurowe obejmuje sześć obszarów dotyczących zgodności wynikającej ze specyfiki przetwarzania danych w środowisku zewnętrznym, w tym wymagań RODO, DORA i NIS2 wobec relacji z dostawcą usługi chmurowej. Sekcja została aktywowana z uwagi na klasyfikację systemu CTN jako **CHMURA_EOG**. Wszystkie sześć obszarów uzyskało wyniki pozytywne. Dostawca infrastruktury jest polskim centrum danych działającym wyłącznie w jurysdykcji EOG, co w istotny sposób upraszcza część wymagań w porównaniu z dostawcami podlegającymi prawu państw trzecich.

Charakterystycznym ustaleniem tej sekcji był niski poziom wiedzy użytkowników o obowiązkach wynikających z modelu chmurowego, przy jednoczesnej pełnej zgodności po stronie technicznej i prawnocompliance. Perspektywa użytkownika ujawniła, że pracownicy banku nie byli świadomi, jakie obowiązki w zakresie bezpieczeństwa spoczywają na organizacji jako administratorze danych, a jakie przejmie dostawca chmury jako podmiot przetwarzający. Luka ta nie skutkuje niezgodnością formalną, jednak wskazuje na potrzebę przeprowadzenia dedykowanego szkolenia z zakresu modelu współodpowiedzialności (shared responsibility model) obowiązującego w środowiskach chmurowych.

Dokumentacja DPIA dla przetwarzania w chmurze (RODO art. 35): przed uruchomieniem systemu CTN przeprowadzono i udokumentowano ocenę skutków dla ochrony danych (DPIA), obejmującą opis przepływów danych osobowych, zidentyfikowane ryzyka i zastosowane środki techniczne. Dokument jest aktualny i był aktualizowany po ostatniej istotnej zmianie infrastruktury.

Szyfrowanie at-rest (DORA art. 9, RODO art. 32): dane organizacji przechowywane w systemie są szyfrowane w spoczynku. Obszar ten, sklasyfikowany jako zalecenie (nie wymóg obowiązkowy), dotyczy modelu zarządzania kluczami szyfrującymi. Organizacja potwierdziła wdrożenie szyfrowania po stronie dostawcy, ze świadomością, że pełna kontrola nad kluczami po stronie organizacji (model HYOK) pozostaje dobrą praktyką

wartą rozważenia przy kolejnym przeglądzie architektury.

Kary umowne dla dostawcy (NIS2 art. 34, DORA art. 30): umowa z dostawcą zawiera klauzulę odpowiedzialności i regresu, umożliwiającą organizacji dochodzenie zwrotu kar administracyjnych nałożonych przez regulatora (KNF, UODO) w przypadku, gdy ich przyczyną był błąd lub zaniedbanie po stronie dostawcy. Użytkownicy nie byli świadomi tej klauzuli, co jest typowym zjawiskiem dla postanowień umownych o charakterze prawno-regulacyjnym, których znajomość nie jest wymagana operacyjnie od personelu liniowego.

Prawo do audytu dostawcy (DORA art. 30 ust. 2 lit. f, RODO art. 28 ust. 3 lit. h): umowa z dostawcą gwarantuje organizacji prawo do przeprowadzenia audytu, w tym audytu na miejscu (onsite), bez możliwości zastąpienia go wyłącznie raportem własnym dostawcy. Polskie centrum danych jako podmiot działający w jurysdykcji krajowej nie zgłasza w tym zakresie ograniczeń proceduralnych ani prawnych, charakterystycznych dla dostawców z krajów trzecich, gdzie realizacja audytu onsite bywa utrudniona lub niemożliwa. Użytkownicy zostali podczas audytu poinformowani o przysługującym organizacji prawie do weryfikacji dostawcy.

Procedura reagowania na incydenty po stronie dostawcy (DORA art. 19 ust. 3, NIS2 art. 23 ust. 4): umowa z dostawcą określa maksymalny czas powiadomienia organizacji o incydencie bezpieczeństwa, umożliwiającą dotrzymanie ustawowego obowiązku zgłoszenia do CSIRT lub KNF w ciągu 24 godzin. Powiadomienie trafia do wyznaczonego punktu kontaktowego i zawiera wymagany zakres informacji o zdarzeniu. Użytkownicy nie znali szczegółów procedury, jednak znajomość ta nie leży w zakresie ich obowiązków operacyjnych.

Izolacja danych między klientami (DORA art. 9, RODO art. 32, ISO 27017): dostawca zapewnia pełną logiczną izolację danych organizacji od danych innych klientów (tenantów). Dane systemu CTN są przechowywane w dedykowanej przestrzeni przypisanej wyłącznie do banku. Organizacja posiada dokumentację potwierdzającą mechanizmy izolacji. Użytkownicy zostali zapoznani z ryzykiem wynikającym z modelu multi-tenancy i znaczeniem technicznej izolacji danych w środowiskach współdzielonych.

Wyniki sekcji CHMURA potwierdzają, że wybór krajowego dostawcy działającego w jurysdykcji EOG istotnie ogranicza ryzyko regulacyjne związane z przetwarzaniem w chmurze. Brak ekspozycji na przepisy o ekstraterytorialnym dostępie do danych (US CLOUD Act, FISA Section 702) eliminuje potrzebę przeprowadzenia TIA, a dostępność audytu onsite u dostawcy jest gwarantowana umownie i nieobarczona ograniczeniami prawnymi. Główną rekomendacją wynikającą z tej sekcji jest uzupełnienie wiedzy użytkowników na temat modelu współodpowiedzialności w środowiskach chmurowych, tak aby personel operacyjny rozumiał granicę między obowiązkami banku a obowiązkami dostawcy w przypadku incydentu lub kontroli regulatora.

7.6.13 Wyniki sekcji dane poufne

Sekcja dane poufne obejmuje cztery obszary dotyczące ochrony danych osobowych i tajemnicy bankowej, wymaganych przez RODO. Sekcja została aktywowana z uwagi na klasyfikację systemu CTN jako przetwarzającego dane kategorii TAJEMNICA (D_3). We wszystkich czterech obszarach organizacja uzyskała wyniki pozytywne, a odpowiedzi były spójne we wszystkich trzech perspektywach. Bank wykazał się pełną wiedzą proceduralną i techniczną w zakresie ochrony danych szczególnie wrażliwych, co jest wynikiem różniącym się na tle typowych obserwacji audytowych w sektorze finansowym, gdzie

formalne polityki są często niedostatecznie internalizowane przez personel operacyjny.

Zgłaszanie naruszeń danych osobowych do UODO (RODO art. 33): organizacja posiada odrębną procedurę zgłaszania naruszeń ochrony danych osobowych do Prezesa UODO w ciągu 72 godzin, wyraźnie rozróżnioną od procedury zgłoszeń ICT do CSIRT i KNF. Istnieją oddzielne ścieżki eskalacji dla obu typów zdarzeń, co eliminuje ryzyko błędnego zakwalifikowania naruszenia danych osobowych wyłącznie jako incydentu technicznego i pominięcia obowiązku zgłoszenia do organu ochrony danych. Użytkownicy wykazali świadomość obowiązku powiadamiania poszkodowanych osób i znali procedurę jego realizacji.

Inspektor Ochrony Danych (RODO art. 37–39): organizacja powołała Inspektora Ochrony Danych, zarejestrowała go w UODO i udostępniła jego dane kontaktowe klientom oraz pracownikom. IOD posiada bezpośredni dostęp do zarządu i działa niezależnie, bez podlegania instrukcjom w zakresie wykonywania swoich zadań ustawowych. Użytkownicy wiedzieli, kto pełni funkcję IOD i jak można się z nim skontaktować, co świadczy o skutecznej komunikacji wewnętrznej w tym obszarze.

Rejestr Czynności Przetwarzania (RODO art. 30): organizacja prowadzi aktualny rejestr czynności przetwarzania (RCP) w formie elektronicznej, obejmujący cele przetwarzania, podstawy prawne, kategorie danych i odbiorców oraz okresy retencji i stosowane środki bezpieczeństwa dla każdej czynności. Rejestr jest aktualizowany w ramach procesu zarządzania zmianami, dzięki czemu odzwierciedla aktualny stan systemu. Użytkownicy potwierdzili znajomość jego istnienia i rozumieli cel jego prowadzenia.

Harmonogram retencji i usuwania danych osobowych (RODO art. 5): organizacja posiada formalny harmonogram retencji z określonymi maksymalnymi okresami przechowywania danych osobowych i mechanizmem ich automatycznego usuwania lub anonimizacji po upływie tych okresów. Proces jest logowany, co umożliwia jego weryfikację przez audytorów. Użytkownicy rozumieli, że dane klientów nie mogą być przechowywane bezterminowo i znali ogólne zasady obowiązującej polityki retencji.

Pełna zgodność we wszystkich czterech obszarach, z wysokim poziomem świadomości we wszystkich trzech perspektywach, potwierdza dojrzałość organizacji w zakresie ochrony danych osobowych. Szczególnie istotna jest spójność między procedurami zgłaszania naruszeń do UODO i do CSIRT (oddzielne ścieżki eskalacji), która eliminuje jedno z najczęstszych uchybień proceduralnych obserwowanych w audytach sektora finansowego, polegające na myleniu incydentu ICT z naruszeniem ochrony danych osobowych w rozumieniu RODO.

7.6.14 Wyniki sekcji dostawcy ICT

Sekcja dostawcy ICT obejmuje siedem obszarów dotyczących zarządzania ryzykiem zewnętrznymi dostawcami ICT, wymaganych przez DORA, NIS2 i wytyczne EBA. Sekcja została aktywowana z uwagi na klasyfikację systemu CTN jako utrzymywanego w trybie CHMURA_EOG. W toku audytu zidentyfikowano jednego zewnętrznego dostawcę ICT, krajową spółkę świadczącą usługę utrzymania i wdrożenia systemu. Weryfikacja umów i dokumentacji dostawcy nie wykazała żadnych niezgodności. Wszystkie siedem obszarów uzyskało ocenę pozytywną.

Retencja i ochrona logów systemów krytycznych (DORA art. 10, NIS2 art. 21): logi systemów krytycznych są przechowywane przez wymagany okres i chronione przed modyfikacją. Centralna agregacja logów oraz retencja w magazynie immutable zostały zweryfikowane przez audytorów bezpośrednio w środowisku dostawcy.

Due diligence i ocena ryzyka dostawcy (DORA art. 28, EBA/GL/2019/02): przed zawarciem umowy z dostawcą systemu CTN przeprowadzono due diligence obejmujące weryfikację posiadanych certyfikatów bezpieczeństwa, lokalizacji przetwarzania danych, listy sub-procesorów oraz wyników testów penetracyjnych środowiska dostawcy. Użytkownicy rozumieli zasadność weryfikacji nowych dostawców ICT przed nawiązaniem współpracy.

Prawa audytu dostawcy (DORA art. 30 ust. 2 lit. f, EBA/GL/2019/02): umowa z dostawcą zawiera zapis gwarantujący organizacji prawo do przeprowadzenia audytu, w tym audytu na miejscu (onsite), bez możliwości zastąpienia go wyłącznie raportem własnym dostawcy. Organizacja posiada dostęp do logów infrastrukturalnych i konfiguracji bezpieczeństwa środowiska dostawcy, a ostatni raport z audytu był dostępny do wglądu audytorów z potwierdzeniem zaadresowania wszystkich obserwacji.

Transfer Impact Assessment (DORA art. 28, Komunikat UKNF 2020): dostawca jest podmiotem krajowym działającym w jurysdykcji EOG, wobec czego ocena skutków transferu (TIA) w rozumieniu przepisów o transferze danych do państw trzecich nie jest wymagana. Dokumentacja dostawcy potwierdza, że żaden etap przetwarzania nie angażuje podmiotów spoza EOG, w tym na poziomie sub-procesorów.

Klauzule SLA i gwarantowana dostępność (DORA art. 30 ust. 2): umowa z dostawcą zawiera mierzalne i egzekwowalne wskaźniki poziomu usług (SLA) z gwarantowaną dostępnością dostosowaną do krytyczności systemu CTN, wraz z sankcjami umownymi za niedotrzymanie uzgodnionych parametrów. Użytkownicy wykazali znajomość dopuszczalnych okien niedostępności systemu wynikających z umowy.

Klauzule powiadomień o zmianach u dostawcy (DORA art. 30 ust. 2 lit. e): umowa zobowiązuje dostawcę do uprzedniego informowania organizacji o istotnych zmianach, w tym zmianach w sub-procesorach, lokalizacji danych, architekturze bezpieczeństwa i strukturze właścicielskiej, z zachowaniem minimalnego okresu wyprzedzenia. Brak powiadomienia w wymaganym terminie uprawnia organizację do rozwiązania umowy bez kary.

Klauzule odpowiedzialności i regres od dostawcy (DORA art. 30 ust. 2 lit. d, NIS2 art. 34): umowa zawiera klauzulę umożliwiającą organizacji dochodzenie regresem kosztów kar regulacyjnych nałożonych na bank przez KNF lub UODO w przypadku, gdy ich przyczyną był błąd lub zaniedbanie po stronie dostawcy. Zakres klauzuli odpowiedzialności nie jest ograniczony wyłącznie do wartości ostatniej faktury.

Wyniki sekcji dostawcy ICT potwierdzają, że bank prowadzi relację z dostawcą systemu CTN zgodnie z wymaganiami DORA w zakresie zarządzania ryzykiem stron trzecich. Krajowy charakter dostawcy i jego działalność wyłącznie w jurysdykcji EOG istotnie upraszcza zarządzanie ryzykiem w łańcuchu dostaw: brak sub-procesorów z krajów trzecich eliminuje konieczność prowadzenia rozbudowanego monitoringu na poziomie poddostawców, który jest typowym źródłem niezgodności w przypadku dostawców korzystających z infrastruktury globalnych hiperskalerów.

7.6.15 Wyniki sekcji plan wyjścia z usługi (exit plan)

Sekcja exit plan obejmuje sześć obszarów dotyczących gotowości organizacji do zakończenia współpracy z dostawcą systemu CTN w sposób kontrolowany, bez utraty danych i bez zakłócenia ciągłości działania, wymaganych przez DORA art. 28. Sekcja została aktywowana z uwagi na klasyfikację audytowanego podmiotu jako FINANSOWY i obecność zewnętrznego dostawcy ICT. Pięć spośród sześciu obszarów uzyskało ocenę pozytywną.

Zidentyfikowano jedno uchybienie w obszarze testowania planu, omówione poniżej. Bank wykazał się wysoką świadomością proceduralną i prawną, natomiast audyt ujawnił lukę w wiedzy użytkowników o tym, czym jest exit plan i jakie uprawnienia organizacji z niego wynikają, którą uzupełniono w toku sesji audytowej.

Istnienie i zatwierdzenie exit planu (DORA art. 28 ust. 2 lit. f): organizacja posiada formalny exit plan zatwierdzony przez zarząd, traktowany jako dokument żywy i aktualizowany przy każdej istotnej zmianie systemu lub dostawcy. Dokument zawiera konkretne kroki techniczne, narzędzia migracyjne i sekwencje wyłączeń, a nie jedynie deklaracyjny opis intencji. Użytkownicy potwierdzili wiedzę o istnieniu planu i jego ogólnym zakresie.

Kompletność i możliwość eksportu danych (DORA art. 30 ust. 2 lit. h): dla systemu CTN zdefiniowano i przetestowano procedurę pełnego eksportu danych do formatu niezależnego od narzędzi własnościowych dostawcy. Czas i kompletność eksportu są udokumentowane w ramach testów ciągłości działania. Użytkownicy początkowo nie byli pewni, czy dane można pobrać w formacie standardowym, jednak kwestia ta została wyjaśniona i zademonstrowana podczas sesji audytowej jako element podnoszenia wiedzy o uprawnieniach przysługujących organizacji wobec dostawcy.

Czas i koszty wyjścia (DORA art. 28): exit plan zawiera udokumentowaną analizę czasu pełnej migracji (RTE) oraz kosztów wyjścia zatwierdzoną przez zarząd, obejmującą czas migracji danych, koszt wdrożenia alternatywnego systemu, koszty równoległego utrzymania obu środowisk oraz ryzyko utraty ciągłości działania. Użytkownicy nie posiadali szczegółowej wiedzy o szacowanych czasach migracji, co jest akceptowalne, ponieważ informacje te są adresowane do zarządu i działu IT, a nie do personelu operacyjnego.

Alternatywny dostawca i przenośność usługi (DORA art. 28): organizacja zidentyfikowała co najmniej jednego alternatywnego dostawcę zdolnego do przejęcia funkcji systemu CTN i oceniła jego zdolność do onboardingu. Architektura systemu opiera się na otwartych standardach, bez uzależnienia od własnościowych formatów danych lub interfejsów API uniemożliwiających migrację. Użytkownicy zostali poinformowani o istnieniu zidentyfikowanego dostawcy alternatywnego, co wzmacnia ich poczucie ciągłości obsługi.

Bezpieczne usunięcie danych u dostawcy po wyjściu (RODO art. 28 ust. 3 lit. g, DORA art. 30): umowa z dostawcą zawiera klauzulę zobowiązującą go do wydania certyfikatu zniszczenia danych po zakończeniu współpracy, obejmującego kopie zapasowe, logi i dane archiwalne. Procedura bezpiecznego usunięcia danych jest opisana w exit planie z przypisaną odpowiedzialnością i terminami. Użytkownicy zostali zapoznani z obowiązkiem uzyskania takiego certyfikatu jako elementem ochrony danych klientów po zakończeniu umowy.

Testowanie exit planu (DORA art. 28): stwierdzono niezgodność. Exit plan nie był dotychczas testowany w żadnej formie, ani jako rzeczywiste przełączenie środowiska, ani jako ćwiczenie stołowe (tabletop exercise). DORA art. 28 wymaga regularnego testowania planów wyjścia z udokumentowanymi wynikami dostępnymi dla audytorów. Brak testów oznacza, że poprawność procedur migracyjnych, kompletność eksportu danych i realność zadeklarowanych parametrów RTE pozostają niezweryfikowane empirycznie. Jako działanie naprawcze wskazano przeprowadzenie w najbliższym cyklu rocznym testu eksportu danych do formatu niezależnego od dostawcy, z udokumentowaniem czasu i kompletności eksportu, oraz opracowanie harmonogramu regularnych ćwiczeń z exit planu.

Wyniki sekcji exit plan wskazują na wysoką dojrzałość organizacji w zakresie dokumentacji i struktury planu wyjścia, z jednym istotnym uchybieniem: brakiem jakiegokolwiek testowania planu. Pozostałe pięć obszarów (istnienie i zatwierdzenie planu, możliwość

eksportu danych, analiza czasu i kosztów wyjścia, identyfikacja alternatywnego dostawcy, procedura bezpiecznego usunięcia danych) było kompletnych i zgodnych z wymogami DORA. Priorytetowym działaniem naprawczym jest przeprowadzenie pierwszego testu exit planu we współpracy z dostawcą, obejmującego rzeczywisty eksport danych, tak aby plan przestał być wyłącznie dokumentem, a stał się zweryfikowaną procedurą operacyjną. Rekomendowanym działaniem uzupełniającym jest podniesienie świadomości personelu operacyjnego o tym, czym jest exit plan i jakie uprawnienia (prawo do eksportu danych, prawo do certyfikatu zniszczenia, prawo do audytu) przysługują organizacji wobec dostawcy.

7.6.16 Wyniki sekcji plan ciągłości działania (BCP)

Sekcja plan ciągłości działania obejmuje pięć obszarów dotyczących gotowości organizacji do utrzymania ciągłości działania i odtworzenia funkcji krytycznych po poważnym incydencie ICT, wymaganych przez DORA art. 11 i NIS2 art. 21. Sekcja została aktywowana z uwagi na klasyfikację systemu CTN jako WAŻNY i klasyfikację podmiotu jako FINANSOWY. Wszystkie pięć obszarów uzyskało ocenę pozytywną. Podobnie jak w sekcjach Usługi w chmurze i exit plan, wyniki wymagały uzupełnienia wiedzy użytkowników, którzy nie zawsze rozumieli czym jest plan ciągłości działania i jakie uprawnienia oraz obowiązki się z nim wiąże. Dział compliance i dział IT wykazały się wysoką świadomością i znajomością dokumentacji.

Istnienie i zatwierdzenie planów BCP i DRP (DORA art. 11, NIS2 art. 21 ust. 2 lit. c): organizacja posiada formalne plany ciągłości działania (BCP) i odtwarzania po awarii (DRP) zatwierdzone przez zarząd, obejmujące funkcje krytyczne ICT. Dokumenty zawierają konkretne kroki techniczne, sekwencje przełączeń i drzewa decyzyjne dla poszczególnych scenariuszy, nie zaś ogólne deklaracje intencji. Użytkownicy potwierdzili ogólną wiedzę o procedurach awaryjnych, w tym o zastępczym trybie pracy w przypadku niedostępności systemu CTN.

Scenariusze zagrożeń w BCP i DRP (DORA art. 11, NIS2 art. 21): plany obejmują konkretne scenariusze zagrożeń, w tym atak ransomware, utratę centrum danych, niedostępność dostawcy chmury i awarię kaskadową w łańcuchu dostaw. Dla każdego scenariusza zdefiniowano odrębną ścieżkę odtwarzania z konkretnymi krokami technicznymi i przypisanymi odpowiedzialnościami. Użytkownicy zostali zapoznani z podstawowymi scenariuszami w trakcie sesji audytowej, co pozwoliło uzupełnić wiedzę operacyjną personelu niezbędną do skutecznego reagowania na zdarzenia.

Testowanie BCP i DRP (DORA art. 11 ust. 6): plany były testowane w wymaganym cyklu rocznym, z udokumentowanymi wynikami dostępnymi dla audytorów. Testy obejmowały rzeczywiste przełączenie na środowisko zapasowe z mierzonym RTO i RPO, a nie jedynie ćwiczenie stołowe (tabletop exercise). Użytkownicy w większości nie uczestniczyli bezpośrednio w ćwiczeniach awaryjnych, co wskazuje na potrzebę włączenia szerszego grona pracowników operacyjnych w kolejne testy, tak by posiadali praktyczną znajomość procedur przełączenia.

Komunikacja kryzysowa (NIS2 art. 23, DORA art. 14): BCP zawiera plan komunikacji kryzysowej z gotowymi szablonami i upoważnieniami do komunikowania się na zewnątrz. Organizacja dysponuje alternatywnym kanałem komunikacji działającym niezależnie od głównej infrastruktury IT, umożliwiającym koordynację działań w przypadku niedostępności poczty elektronicznej i systemów komunikacji wewnętrznej. Użytkownicy nie zawsze posiadali numery kontaktowe kluczowych osób poza środowiskami cyfrowymi,

co zostało wskazane jako obszar wymagający uzupełnienia w ramach szkoleń z procedur kryzysowych.

Scenariusz awarii kaskadowej w łańcuchu dostaw (DORA art. 11, art. 29 ust. 1): organizacja opracowała scenariusz awarii kaskadowej uwzględniający drzewo zależności między dostawcami różnych poziomów i potencjalny wpływ awarii jednego węzła na dostępność funkcji krytycznych. Scenariusz był symulowany w ramach testów BCP. Użytkownicy zostali zapoznani z koncepcją ryzyka kaskadowego podczas sesji audytowej, uzyskując praktyczne zrozumienie tego, w jaki sposób awaria jednego systemu lub dostawcy może propagować się na inne elementy infrastruktury banku.

Wyniki sekcji plan ciągłości działania potwierdzają dojrzałość organizacyjną banku w zakresie zarządzania ciągłością działania. Szczególnie istotne jest przeprowadzenie testów z rzeczywistym przełączeniem środowiska, a nie jedynie ćwiczeń stołowych, co odpowiada wzorcowi empirycznej weryfikacji obserwowanemu w sekcji Exit Plan. Wspólnym mianownikiem rekomendacji dla obu tych sekcji jest potrzeba systematycznego włączania personelu operacyjnego w ćwiczenia i szkolenia, tak aby procedury kryzysowe były znane i zrozumiałe nie tylko na poziomie zarządu i działu IT, ale również przez pracowników bezpośrednio obsługujących audytowane systemy.

7.6.17 Podsumowanie wyników audytu i obliczenie S_{total}

Krok 1: Zestawienie wszystkich odpowiedzi

Audyt systemu CTN objął łącznie 62 pytania rozmieszczone w 9 aktywnych sekcjach. Spośród nich 58 uzyskało odpowiedź twierdzącą (TAK), a 4 odpowiedź negatywną (NIE). Jedno pytanie blokujące (brak MFA) zostało rozwiązane w trakcie audytu i ujęte jako pozytywne w wyniku końcowym.

Tabela 7.11: Zestawienie odpowiedzi audytowych systemu CTN według sekcji

Sekcja	Pytań	TAK	NIE	Niezgodność
Organizacja	9	9	0	brak
Bezpieczeństwo fizyczne	8	6	2	zalecane
Bezpieczeństwo techniczne	8	8	0	brak
System informatyczny	9	8	1	obowiązkowe
Usługi w chmurze	6	6	0	brak
Dane poufne	4	4	0	brak
Dostawcy ICT	7	7	0	brak
Exit Plan	6	5	1	obowiązkowe
Plan ciągłości działania	5	5	0	brak
Łącznie	62	58	4	

Zidentyfikowane niezgodności:

- **Strefy bezpieczeństwa i segmentacja fizyczna** (zalecane) oraz **Ochrona przed kradzieżą i sabotażem fizycznym** (zalecane): brak segmentacji stref i niewystarczający nadzór nad gośćmi.
- **Zarządzanie hasłami: wymuszanie rotacji** (obowiązkowe): brak technicznego mechanizmu cyklicznej zmiany haseł.
- **Testowanie exit planu** (obowiązkowe): plan wyjścia nie był dotychczas testowany.

Krok 2: Wagi pytań i wzór na wynik sekcji

Zgodnie z równaniem (7.6), każdemu pytaniu przypisywana jest waga $\omega(q_j)$ wynikająca z jego obligatoryjności:

$$\omega(q_j) = \begin{cases} 2,0 & \text{pytanie obowiązkowe} \\ 1,0 & \text{pytanie zalecane} \\ 0,5 & \text{pytanie informacyjne} \end{cases}$$

Wynik sekcji wyznaczany jest jako ważona średnia wyników pytań (równanie (7.5)), przy założeniu pełnej jakości dowodu ($d_{ij} = 1,0$) dla wszystkich odpowiedzi twierdzących i zerowej ($d_{ij} = 0$) dla negatywnych:

$$S(\mathcal{S}_k) = \frac{\sum_{q_j \in \mathcal{S}_k} S(q_j) \cdot \omega(q_j)}{\sum_{q_j \in \mathcal{S}_k} \omega(q_j)}$$

Krok 3: Obliczenie wyników poszczególnych sekcji

ORGANIZACJA: 9 pytań obowiązkowych, wszystkie TAK.

$$S(\text{ORG}) = \frac{9 \times 2,0 \times 1,0}{9 \times 2,0} = \frac{18}{18} = 1,000$$

BEZPIECZENSTWO_FIZYCZNE: 5 obowiązkowych TAK, 1 zalecane TAK (CCTV), 2 zalecane NIE (strefy, ochrona).

$$S(\text{BF}) = \frac{5 \times 2,0 \times 1,0 + 1 \times 1,0 \times 1,0 + 2 \times 1,0 \times 0,0}{5 \times 2,0 + 1 \times 1,0 + 2 \times 1,0} = \frac{10 + 1 + 0}{10 + 1 + 2} = \frac{11}{13} \approx 0,846$$

BEZPIECZENSTWO_TECHNICZNE: 5 obowiązkowych TAK, 3 zalecane TAK.

$$S(\text{BT}) = \frac{5 \times 2,0 \times 1,0 + 3 \times 1,0 \times 1,0}{5 \times 2,0 + 3 \times 1,0} = \frac{10 + 3}{10 + 3} = \frac{13}{13} = 1,000$$

APLIKACJA: 9 obowiązkowych, 8 TAK, 1 NIE (rotacja haseł). Pytanie MFA zostało rozwiązane w trakcie audytu i wliczone jako TAK.

$$S(\text{APP}) = \frac{8 \times 2,0 \times 1,0 + 1 \times 2,0 \times 0,0}{9 \times 2,0} = \frac{16}{18} \approx 0,889$$

CHMURA: 4 obowiązkowe TAK, 2 zalecane TAK.

$$S(\text{CHM}) = \frac{4 \times 2,0 \times 1,0 + 2 \times 1,0 \times 1,0}{4 \times 2,0 + 2 \times 1,0} = \frac{8 + 2}{8 + 2} = \frac{10}{10} = 1,000$$

DANE_POUFNE: 1 obowiązkowe TAK, 3 zalecane TAK.

$$S(DP) = \frac{1 \times 2,0 \times 1,0 + 3 \times 1,0 \times 1,0}{1 \times 2,0 + 3 \times 1,0} = \frac{2 + 3}{2 + 3} = \frac{5}{5} = 1,000$$

DOSTAWCY: 6 obowiązkowych TAK, 1 zalecane TAK.

$$S(DOS) = \frac{6 \times 2,0 \times 1,0 + 1 \times 1,0 \times 1,0}{6 \times 2,0 + 1 \times 1,0} = \frac{12 + 1}{12 + 1} = \frac{13}{13} = 1,000$$

EXIT_PLAN: 4 obowiązkowe TAK, 1 zalecane TAK, 1 informacyjne TAK, 1 obowiązkowe NIE (brak testu).

$$S(EP) = \frac{4 \times 2,0 \times 1,0 + 1 \times 1,0 \times 1,0 + 1 \times 0,5 \times 1,0 + 1 \times 2,0 \times 0,0}{4 \times 2,0 + 1 \times 1,0 + 1 \times 0,5 + 1 \times 2,0} =$$

$$S \frac{8 + 1 + 0,5 + 0}{8 + 1 + 0,5 + 2} = \frac{9,5}{11,5} \approx 0,826$$

PLAN_CIAGLOSCI_DZIALANIA: 4 obowiązkowe TAK, 1 zalecane TAK.

$$S(BCP) = \frac{4 \times 2,0 \times 1,0 + 1 \times 1,0 \times 1,0}{4 \times 2,0 + 1 \times 1,0} = \frac{8 + 1}{8 + 1} = \frac{9}{9} = 1,000$$

Krok 4: Obliczenie S_{total} systemu CTN

Zgodnie z równaniem (7.7), wynik obiektu jest średnią arytmetyczną wyników wszystkich aktywnych sekcji ($|\mathcal{S}(v)| = 9$):

$$S_{total}(CTN) = \frac{1}{9} \sum_{\mathcal{S}_k} S(\mathcal{S}_k)$$

$$= \frac{1,000 + 0,846 + 1,000 + 0,889 + 1,000 + 1,000 + 1,000 + 0,826 + 1,000}{9} = \frac{8,561}{9} \approx \mathbf{0,951}$$

Tabela 7.12: Wyniki sekcji i końcowy wynik systemu CTN

Sekcja	$S(\mathcal{S}_k)$	Niezgodności	Charakter
Organizacja	1,000	0	
Bezpieczeństwo fizyczne	0,846	2	zalecane
Bezpieczeństwo techniczna	1,000	0	
System informatyczny	0,889	1	obowiązkowe
Usługi w chmurze	1,000	0	
Dane poufne	1,000	0	
Dostawcy ICT	1,000	0	
Plan wyjścia	0,826	1	obowiązkowe
Plan ciągłości działania (BCP)	1,000	0	
S_{total}	0,951	4	

Krok 5: Klasyfikacja końcowa

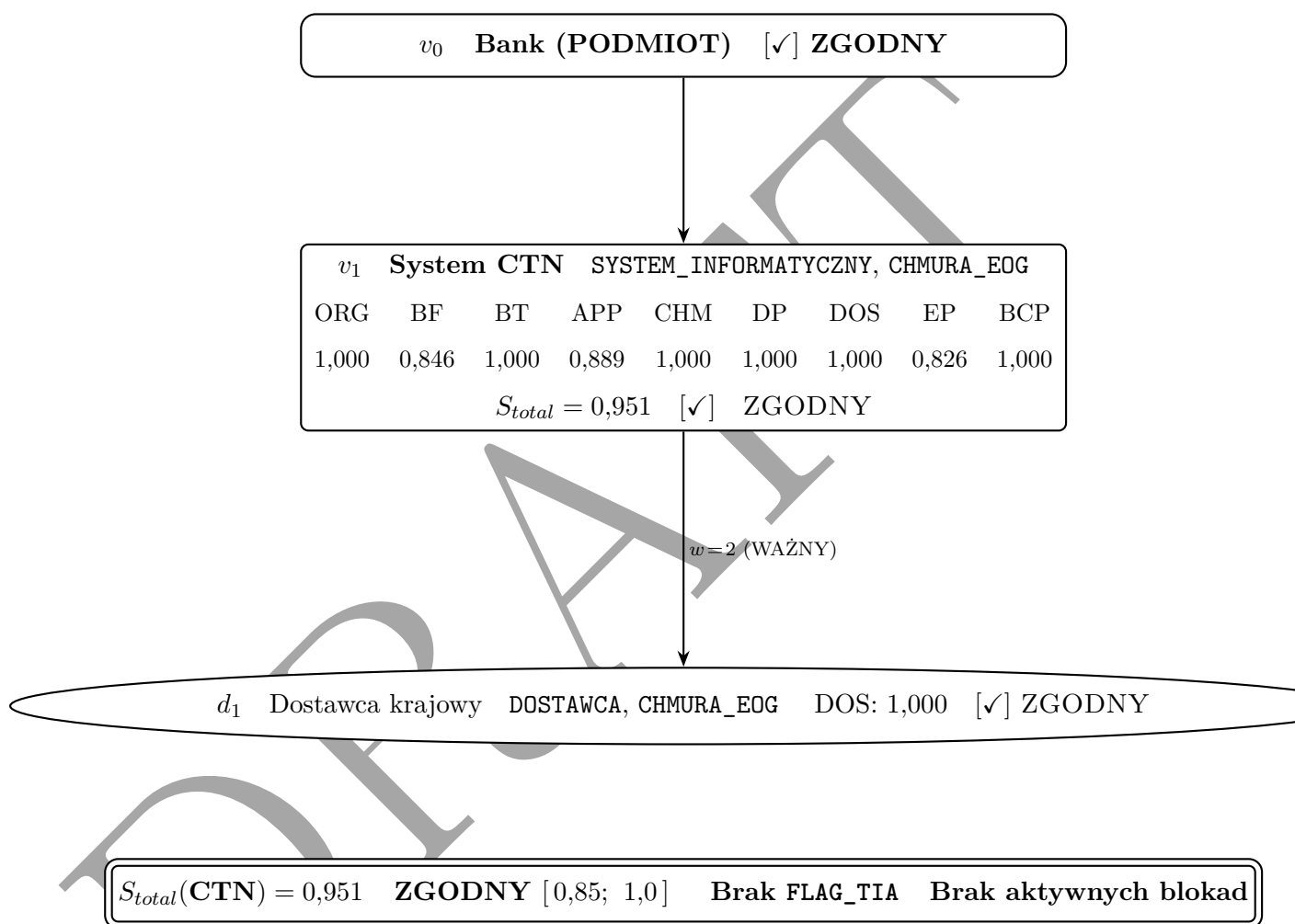
Wynik $S_{total}(CTN) = 0,951$ mieści się w przedziale $[0,85; 1,0]$, co odpowiada klasyfikacji **ZGODNY** według skali interpretacyjnej metodologii ORION (tabela 7.5).

Żadna z aktywnych sekcji nie uzyskała wyniku zerowego spowodowanego flagą blokującą (pytanie MFA zostało rozwiązane przed zamknięciem audytu). Nie aktywowano flagi TIA, ponieważ dostawca działa w jurysdykcji EOG. Wynik końcowy nie jest nadpisywany przez żaden mechanizm korekcyjny opisany w równaniach (7.4) i (7.8).

Dwie spośród czterech niezgodności dotyczą pytań zalecanych (nie obowiązkowych), wobec czego ich wpływ na wynik jest ograniczony przez niższe wagi ($\omega = 1,0$ wobec $\omega = 2,0$). Dwie niezgodności w pytaniach obowiązkowych (rotacja hasła, brak testowania exit planu) obniżają wyniki odpowiednich sekcji, lecz nie zmieniają klasyfikacji końcowej. Ich usunięcie w ramach działań naprawczych podniosłoby S_{total} do wartości 1,000.

Graf ICT systemu CTN

Poniższy graf ICT przedstawia topologię audytowanego środowiska oraz wyniki poszczególnych sekcji w odwzorowaniu na obiekty audytowe. Każdy węzeł zawiera identyfikator obiektu, jego typ i atrybuty klasyfikacyjne oraz wyniki aktywnych sekcji. Krawędź z etykietą wagi w prowadzi od systemu informatycznego do obsługującego go dostawcy; brak linii przerywanej potwierdza, że nie aktywowano triggera TIA.



Rysunek 7.3: Graf ICT audytowanego systemu CTN. Skróty sekcji: ORG (Organizacja), BF (Bezpieczeństwo fizyczne), BT (Bezpieczeństwo techniczne), APP (Aplikacja), CHM (Chmura), DP (Dane poufne), DOS (Dostawcy), EP (Exit Plan), BCP (Plan ciągłości działania). Waga $w=2$ odpowiada klasyfikacji WAŻNY obsługiwanego systemu.

8. Zakończenie

Rosnąca złożoność środowisk ICT w organizacjach nadzorowanych, wzmocniona przez wejście w życie rozporządzenia DORA i implementację dyrektywy NIS2, stworzyła wyraźną lukę pomiędzy wymaganiami regulacyjnymi a dostępnymi narzędziami ich weryfikacji. Istniejące metodyki audytu (ISO 27001, COBIT, NIST CSF) dostarczają ogólnych ram kontrolnych, lecz nie oferują skwantyfikowanego, powtarzalnego mechanizmu oceny ryzyka uwzględniającego jednocześnie strukturę łańcucha dostaw ICT, klasyfikację przetwarzanych danych, specyfikę jurysdykcji dostawców chmurowych oraz wagę poszczególnych wymagań regulacyjnych. Niniejsza praca odpowiada na ten deficyt, proponując metodologię ORION (Ocena Ryzyka Informatycznego Organizacji Nadzorowanych), zaprojektowaną z myślą o organizacjach objętych regulacjami sektorowymi i unikną legislacją z zakresu cyfrowej odporności operacyjnej.

Centralnym elementem ORION jest model grafu ważonego $G = (V, E, W)$, w którym wierzchołki reprezentują obiekty audytowe trzech typów (PODMIOT, SYSTEM INFORMATYCZNY, DOSTAWCA), a krawędzie kierowane odzwierciedlają zależności usługowe z wagami odpowiadającymi krytyczności obsługiwanych systemów. Model ten umożliwia propagację ryzyka wzdłuż łańcucha dostaw i automatyczne rozszerzanie zakresu audytu o poddostawców w przypadku aktywacji triggera TIA (Third-party Impact Analysis), co bezpośrednio adresuje wymogi art. 28 DORA dotyczące mapowania zależności zewnętrznych. Mechanizm walidacji krzyżowej (każde pytanie zadawane niezależnie trzem perspektywom: compliance/prawnej, IT oraz użytkownika) ogranicza ryzyko konfabulacji i formalnego spełniania wymagań bez ich realnego wdrożenia. Wynik końcowy S_{total} jest wielkością skwantyfikowaną, wyznaczaną na podstawie jednolitego wzoru ważonego z jasno zdefiniowaną skalą pięciostopniową, co czyni ocenę porównywalną między audytami i organizacjami.

Przeprowadzony audyt pilotażowy systemu CTN w instytucji bankowej potwierdził wykonalność i spójność metodologii w warunkach rzeczywistych. Spośród 62 pytań kwalifikacyjnych 58 uzyskało odpowiedź pozytywną. Cztery niezgodności (dwie obowiązkowe dotyczące rotacji haseł i braku testu exit planu, dwie zalecane z zakresu bezpieczeństwa fizycznego) przełożyły się na wynik $S_{total} = 0,951$, klasyfikowany jako ZGODNY w przedziale $[0,85; 1,0]$. Żadna sekcja nie aktywowała flagi blokującej. Trigger TIA nie został wyzwolony, ponieważ dostawca systemu działa w jurysdykcji EOG, a wszystkie umowy spełniały wymagania DORA w zakresie klauzul audytowych i prawa do wypowiedzenia. Wynik wskazuje, że organizacja prowadzi zarządzanie ryzykiem ICT na dojrzałym poziomie, jednocześnie precyzyjnie wskazując dwa obszary wymagające korekty w ramach działań naprawczych.

Jedną z celowych właściwości projektowych ORION jest jego adaptowalność. Choć poniższy przypadek użycia dotyczy sektora finansowego (banku nadzorowanego przez KNF), architektura metodologii nie zakłada żadnych elementów specyficznych wyłącznie dla bankowości. Biblioteka sekcji (bezpieczeństwo techniczne, chmura, dane poufne, ciągłość działania, zarządzanie dostawcami) stanowi zbiór bloków, które mogą być selektywnie włączane lub wyłączane na podstawie atrybutów obiektu audytowego i katalogu regulacji mającego zastosowanie do danej branży. Szpital przetwarzający dane medyczne

klasy D3 aktywuje sekcje dotyczące ochrony danych poufnych z inną wagą niż operator logistyczny, lecz korzysta z tego samego aparatu formalnego i tych samych procedur zbierania dowodów. Dostawca energii objęty NIS2 jako podmiot kluczowy, podmiot administracji publicznej prowadzący rejestr ludności, platforma przetwarzania danych medycznych, czy firma fintech objęta DORA, wszystkie te organizacje mają odmienną specyfikę ryzyka, lecz wspólny mianownik: konieczność wykazania organom nadzoru, że ryzyko ICT jest zarządzane w sposób mierzalny i udokumentowany. ORION dostarcza do tego celu jednolity język.

Żaden system oceny ryzyka nie może być lepszy niż jakość danych, na których operuje, a ta zależy przede wszystkim od kompetencji i rzetelności audytora. Kluczowe znaczenie ma konsekwentne przestrzeganie zasady niezależności perspektyw w walidacji krzyżowej: zbyt swobodna interpretacja odpowiedzi jednej perspektywy jako potwierdzenia dla pozostałych wypacza wynik i podważa sens całego mechanizmu. Równie istotna jest wytrwałość w dążeniu do weryfikacji dowodów (logi, konfiguracje, umowy, wyniki testów) zamiast poprzestania na deklaracjach słownych. Przypadek wykrycia braku MFA w trakcie audytu CTN, niezgodności naprawionej jeszcze przed zamknięciem kwestionariusza, ilustruje, jak rzetelna inspekcja może mieć bezpośredni, pozytywny wpływ na bezpieczeństwo systemu. Metodologia ORION tworzy ramy do przeprowadzenia takiej inspekcji, lecz jej realna wartość zależy od gotowości audytora do konfrontowania się z trudnymi obserwacjami i formułowania wniosków bez ulegania presji organizacyjnej.

Autor identyfikuje kilka kierunków dalszego rozwoju metodologii. Po pierwsze, automatyzacja zbierania i walidacji dowodów technicznych (logi SIEM, wyniki skanerów podatności, raporty certyfikatów TLS) może istotnie skrócić czas trwania fazy kwestionariuszowej i ograniczyć ryzyko błędów ludzkich. Po drugie, mechanizm propagacji ryzyka w grafie ICT może zostać rozszerzony o modele probabilistyczne uwzględniające historyczne dane o incydentach, co pozwoliłoby na szacowanie oczekiwanej straty operacyjnej powiązanej z konkretnym poddostawcą. Po trzecie, opracowanie branżowych szablonów pytań (dla sektora zdrowotnego, energetycznego, administracji publicznej) pozwoliłoby skrócić etap konfiguracji audytu przy zachowaniu wspólnego aparatu obliczeniowego. Po czwarte, integracja z rejestrami CMDB i systemami GRC (Governance, Risk and Compliance) umożliwiłaby ciągłą, automatyczną aktualizację grafu ICT bez konieczności inicjowania pełnego audytu przy każdej zmianie w środowisku.

Metodologia ORION nie pretenduje do bycia jedynym ani wyczerpującym narzędziem oceny ryzyka ICT w organizacjach nadzorowanych. Jest natomiast propozycją wypełnienia konkretnej luki: braku ustrukturyzowanej, skwantyfikowanej i regulacyjnie zakorzenionej metody łączącej audyt organizacyjny z analizą łańcucha dostaw w jednolitym modelu grafowym. Zaprezentowany przypadek użycia potwierdza, że taki model jest wykonalny w praktyce i generuje wnioski działające dwukierunkowo: dając organom nadzoru czytelny wskaźnik zgodności, a organizacji audytowanej precyzyjny priorytet działań naprawczych. Dalszy rozwój metodologii, jej walidacja na większej próbie organizacji i ewentualna standaryzacja w postaci normy branżowej lub wytycznych regulatora, pozostają zadaniami otwartymi i stanowią naturalny kierunek kontynuacji niniejszych badań.

9. Słownik pojęć

AI Act (Artificial Intelligence Act)

Unijne rozporządzenie dotyczące sztucznej inteligencji, wskazane jako przyszły obszar wpływu na sektory regulowane.

API (Application Programming Interface)

Interfejs programistyczny umożliwiający komunikację między systemami i usługami.

ASVS (Application Security Verification Standard)

Standard OWASP służący do weryfikacji wymagań bezpieczeństwa aplikacji.

BCP (Business Continuity Plan)

Plan ciągłości działania określający sposób utrzymania kluczowych procesów po incydencie lub awarii.

BION (Badanie i Ocena Nadzorcza)

Mechanizm oceny nadzorczej stosowany przez KNF wobec podmiotów rynku finansowego.

CLOUD Act (Clarifying Lawful Overseas Use of Data Act)

Ustawa USA dotycząca dostępu organów amerykańskich do danych przechowywanych przez dostawców usług.

CSF (Cybersecurity Framework)

Framework cyberbezpieczeństwa, do którego tekst odnosi się przy porównaniu z innymi standardami oceny.

CSIRT (Computer Security Incident Response Team)

Zespół reagowania na incydenty bezpieczeństwa komputerowego właściwy do przyjmowania zgłoszeń i koordynacji reakcji.

CTPP (Critical ICT Third-Party Providers)

Krytyczni zewnętrzni dostawcy ICT objęci nadzorem w ramach DORA.

DAST (Dynamic Application Security Testing)

Dynamiczna analiza bezpieczeństwa aplikacji wykonywana podczas działania systemu.

DORA (Digital Operational Resilience Act)

Rozporządzenie UE ustanawiające zasady operacyjnej odporności cyfrowej sektora finansowego.

DPF (Data Privacy Framework)

Ramy transferu danych między UE a USA omawiane w kontekście legalności przekazywania danych.

DPIA (Data Protection Impact Assessment)

Ocena skutków dla ochrony danych stosowana przy przetwarzaniu mogącym powodować wysokie ryzyko dla praw i wolności osób. [web:9]

DRP (Disaster Recovery Plan)

Plan odtwarzania po awarii określający sposób przywrócenia systemów i usług po zakłóceniu.

DUC (Dostawca Usług Cyfrowych)

Kategoria podmiotów występująca w ustawie o krajowym systemie cyberbezpieczeństwa.

EBA (European Banking Authority)

Europejski Urząd Nadzoru Bankowego, wskazany przy standardach technicznych związanych z DORA.

EEHRxF (European Electronic Health Record Exchange Format)

Europejski format wymiany elektronicznej dokumentacji zdrowotnej.

EHDS (European Health Data Space)

Europejska Przestrzeń Danych Zdrowotnych, istotna dla regulacji przetwarzania danych medycznych.

EIOPA (European Insurance and Occupational Pensions Authority)

Europejski organ nadzoru dla sektora ubezpieczeń i pracowniczych programów emerytalnych.

EOG (Europejski Obszar Gospodarczy)

Obszar istotny dla oceny transferu danych i klasyfikacji jurysdykcyjnej.

ESMA (European Securities and Markets Authority)

Europejski organ nadzoru nad rynkami papierów wartościowych i rynkiem kapitałowym.

FISA 702 (Foreign Intelligence Surveillance Act Section 702)

Przepis prawa USA wskazywany w pracy jako źródło ryzyka dostępu do danych przez służby amerykańskie.

GDPR (General Data Protection Regulation)

Angielska nazwa RODO, używana także w tytule dokumentu.

GRC (Governance Risk and Compliance)

Obszar zarządzania obejmujący ład organizacyjny, ryzyko i zgodność.

ICT (Information and Communications Technology)

Technologie informacyjno-komunikacyjne stanowiące podstawowy obszar analizy w pracy.

IOD (Inspektor Ochrony Danych)

Osoba odpowiedzialna za nadzór nad zgodnością przetwarzania danych osobowych.

ITS (Implementing Technical Standards)

Wykonawcze standardy techniczne towarzyszące regulacjom unijnym, w tym DORA.

JIT (Just-in-Time)

Model przyznawania uprawnień tylko na niezbędny czas.

KNF (Komisja Nadzoru Finansowego)

Polski organ nadzoru nad rynkiem finansowym.

KSC (Krajowy System Cyberbezpieczeństwa)

System krajowych ram organizacyjnych i prawnych cyberbezpieczeństwa.

MFA (Multi-Factor Authentication)

Uwierzytelnianie wieloskładnikowe wymagające użycia co najmniej dwóch różnych składników.

mTLS (Mutual Transport Layer Security)

Mechanizm wzajemnego uwierzytelniania stron połączenia szyfrowanego TLS.

NIS2 (Network and Information Security Directive 2)

Dyrektywa UE ustanawiająca nowy model obowiązków cyberbezpieczeństwa dla podmiotów kluczowych i ważnych.

OChK (Operator Chmury Krajowej)

Polski dostawca i integrator usług chmurowych wspomniany w kontekście suwerenności danych.

OPA (Open Policy Agent)

Narzędzie do egzekwowania polityk w modelu governance as code.

ORSN (Ocena Ryzyka Systemów Nadzorowanych)

Autorska metodyka oceny zgodności systemów ICT i ich łańcucha dostaw opisana w monografii.

OUK (Operator Usług Kluczowych)

Kategoria podmiotów objętych obowiązkami ustawy o KSC w wcześniejszym modelu regulacyjnym.

OWASP (Open Worldwide Application Security Project)

Organizacja opracowująca praktyki i standardy bezpieczeństwa aplikacji.

PAM (Privileged Access Management)

Zarządzanie dostępem uprzywilejowanym do kont i zasobów o podwyższonych uprawnieniach.

PQC (Post-Quantum Cryptography)

Kryptografia postkwantowa wskazana w pracy jako nadchodzące wyzwanie technologiczne.

PUODO (Prezes Urzędu Ochrony Danych Osobowych)

Krajowy organ nadzorczy właściwy w sprawach ochrony danych osobowych.

RBAC (Role-Based Access Control)

Model kontroli dostępu oparty na rolach przypisanych użytkownikom.

RODO (Rozporządzenie o Ochronie Danych Osobowych)

Unijne ogólne rozporządzenie regulujące zasady przetwarzania danych osobowych.

RTS (Regulatory Technical Standards)

Regulacyjne standardy techniczne uszczegóławiające wymagania aktów unijnych.

SAST (Static Application Security Testing)

Statyczna analiza bezpieczeństwa aplikacji prowadzona na kodzie lub artefaktach przed uruchomieniem.

SBOM (Software Bill of Materials)

Wykaz komponentów programistycznych tworzących dane oprogramowanie.

SCC (Standard Contractual Clauses)

Standardowe klauzule umowne wykorzystywane przy transferze danych poza EOG.

STRIDE (Spoofing Tampering Repudiation Information Disclosure Denial of Service Elevation of Privilege)

Metodologia modelowania zagrożeń wykorzystywana na etapie projektowania systemów.

TEE (Trusted Execution Environment)

Zaufane środowisko wykonawcze stosowane m.in. w poufnym przetwarzaniu danych.

TIA (Transfer Impact Assessment)

Ocena skutków transferu danych do państw trzecich pod kątem ryzyka prawnego i operacyjnego.

TLPT (Threat-Led Penetration Testing)

Zaawansowane testy penetracyjne sterowane scenariuszami zagrożeń.

TPRM (Third-Party Risk Management)

Zarządzanie ryzykiem związanym z dostawcami i innymi stronami trzecimi.

UODO (Urząd Ochrony Danych Osobowych)

Urząd wspierający krajowy nadzór nad ochroną danych osobowych.

UKSC (Ustawa o Krajowym Systemie Cyberbezpieczeństwa)

Polska ustawa określająca obowiązki podmiotów w obszarze cyberbezpieczeństwa.

ZTA (Zero Trust Architecture)

Architektura bezpieczeństwa oparta na zasadzie ciągłej weryfikacji i braku domyślnego zaufania.

Bibliografia

- Ustawa z dnia 5 lipca 2018 r. o krajowym systemie cyberbezpieczeństwa*. Weszła w życie 28 sierpnia 2018 r. 2018.
- Parlament Europejski i Rada Unii Europejskiej. *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*. Dz.Urz. UE L 333/1. Grudzień 2022. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX%3A32022R2554>.
- Dyrektywa Parlamentu Europejskiego i Rady (UE) 2016/1148 z dnia 6 lipca 2016 r. w sprawie środków na rzecz wysokiego wspólnego poziomu bezpieczeństwa sieci i systemów informatycznych na terytorium Unii*. 19 lipca 2016.
- Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw*. 2026.
- Dyrektywa Parlamentu Europejskiego i Rady (UE) 2022/2555 z dnia 14 grudnia 2022 r. w sprawie środków na rzecz wysokiego wspólnego poziomu cyberbezpieczeństwa na terytorium Unii (NIS2)*. 27 grudnia 2022.
- Ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych*. Weszła w życie 25 maja 2018 r. 2018.
- Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (ogólne rozporządzenie o ochronie danych)*. Stosowane od 25 maja 2018 r. 4 maja 2016.
- Ustawa z dnia 16 kwietnia 1993 r. o zwalczaniu nieuczciwej konkurencji*. Tekst jednolity: Dz.U. z 2003 r. Nr 153, poz. 1503 z późn. zm. 1993.
- Ustawa z dnia 23 kwietnia 1964 r. – Kodeks cywilny*. Tekst jednolity: Dz.U. z 2023 r. poz. 1610 z późn. zm. 1964.
- Ustawa z dnia 6 czerwca 1997 r. – Kodeks karny*. Tekst jednolity: Dz.U. z 2024 r. poz. 17 z późn. zm. 1997.
- Ustawa z dnia 6 marca 2018 r. – Prawo przedsiębiorców*. Dz.U. 2018 poz. 646. art. 7; ELI: <https://eli.gov.pl/eli/DU/2018/646/ogl>. 2018. URL: <https://eli.gov.pl/eli/DU/2018/646/ogl>.
- Komisja Nadzoru Finansowego. *Rekomendacja D dotycząca zarządzania obszarami technologii informacyjnej i bezpieczeństwa środowiska teleinformatycznego w bankach*. Załącznik do uchwały nr 7/2013 Komisji Nadzoru Finansowego z dnia 8 stycznia 2013 r., Dz. Urz. KNF z 2013 r. poz. 5. Ogłoszona 27 lutego 2013 r. 2013. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/rekomendacja_d_8_01_13_uchwala_7_33016.pdf.
- Urząd Komisji Nadzoru Finansowego. *Metodyka badania i oceny nadzorczej banków komercyjnych, zrzeszających oraz spółdzielczych (Metodyka BION)*. Urząd Komisji Nadzoru Finansowego, Warszawa, 12 lutego 2024 r. Dokument opisujący proces BION stosowany przez KNF. 2024. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/Metodyka_BION_2024.pdf.
- Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2022/2554 z dnia 14 grudnia 2022 r. w sprawie operacyjnej odporności cyfrowej sektora finansowego i zmieniające*

- rozporządzenia (WE) nr 1060/2009, (UE) nr 648/2012, (UE) nr 600/2014, (UE) nr 909/2014 oraz (UE) 2016/1011 (DORA). 27 grudnia 2022. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32022R2554>.
- European Insurance and Occupational Pensions Authority (EIOPA). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna EIOPA. Informacje dotyczące wymogów DORA w zakresie zarządzania ryzykiem ICT, raportowania incydentów oraz wymiany informacji o zagrożeniach cybernetycznych. 2024. URL: https://www.eiopa.europa.eu/digital-operational-resilience-act-dora_en (dostęp 10.03.2025).
- Komisja Nadzoru Finansowego (KNF). *Rozporządzenie DORA – strona tematyczna*. Serwis instytucjonalny KNF. Zbiór materiałów nadzorczych KNF dotyczących wdrożenia rozporządzenia (UE) 2022/2554 (DORA). 2024. URL: https://www.knf.gov.pl/dla_ryнку/dora (dostęp 10.03.2025).
- Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (Ogólne rozporządzenie o ochronie danych, RODO)*. W szczególności art. 9 dotyczący szczególnych kategorii danych osobowych (w tym danych zdrowotnych). 27 kwietnia 2016. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679>.
- Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. (RODO)*. W szczególności art. 37–39 RODO regulujące obowiązek wyznaczenia, zadania i pozycję Inspektora Ochrony Danych (IOD). 27 kwietnia 2016. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679>.
- Ustawa z dnia 6 listopada 2008 r. o prawach pacjenta i Rzeczniku Praw Pacjenta*. W szczególności art. 23–29 regulujące prawo pacjenta do dokumentacji medycznej oraz obowiązki podmiotów leczniczych w zakresie jej prowadzenia, przechowywania i udostępniania. 6 listopada 2008. URL: <https://isap.sejm.gov.pl/isap.nsf/download.xsp/WDU20240000581/0/D20240581.pdf>.
- Centrum e-Zdrowia. *Systemy informacyjne w ochronie zdrowia – P1 (e-recepta, e-skierowanie) i krajowa infrastruktura elektronicznej dokumentacji medycznej*. Serwis instytucjonalny Centrum e-Zdrowia. Informacje o systemach P1, P2 oraz standardach informatycznych elektronicznej dokumentacji medycznej zarządzanych przez Centrum e-Zdrowia. 2024. URL: <https://www.cez.gov.pl> (dostęp 10.03.2025).
- Rozporządzenia EHDS (UE) 2025/327, daty wejścia w życie (26.03.2025 r.) oraz harmonogramu wdrożenia do 26.03.2027 r.* Parlament Europejski. 2025. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/PDF/?uri=OJ:L_202500327 (dostęp 10.03.2025).
- Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2025/327 z dnia 11 lutego 2025 r. w sprawie Europejskiej Przestrzeni Danych Dotyczących Zdrowia i zmieniające rozporządzenie (UE) 2018/1724 i dyrektywę 2011/24/UE*. Weszło w życie 26 marca 2025 r.; ustanawia EHDS jako ogólnounijne ramy pierwotnego i wtórnego wykorzystania elektronicznych danych zdrowotnych. 5 marca 2025. URL: <https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32025R0327>.
- Putter, Johan i Sascha-Dominik Bachmann. „Russia and China Expected to Renew Their Espionage Vigour”. W: *Journal on Baltic Security* 9.1 (2023), s. 1–31. DOI: 10.2478/jobs-2023-0001. URL: <https://journalonbalticsecurity.com/journal/JOBS/article/113/text>.

- The White House. *Imposing Sanctions on the International Criminal Court*. Luty 2025. URL: <https://www.whitehouse.gov/presidential-actions/2025/02/imposing-sanctions-on-the-international-criminal-court/> (dostęp 7.03.2026).
- United States Congress. *Clarifying Lawful Overseas Use of Data Act (CLOUD Act)*. Pub. L. No. 115-141, div. V, 132 Stat. 348. 2018. URL: <https://www.congress.gov/115/plaws/publ141/PLAW-115publ141.pdf>.
- *Foreign Intelligence Surveillance Act, Section 702*. 50 U.S.C. §1881a; reauthorized most recently by the FISA Reform and Reauthorization Act of 2024. 1978. URL: <https://www.govinfo.gov/content/pkg/STATUTE-92/pdf/STATUTE-92-Pg1783.pdf>.
- Synergy Research Group. *European Cloud Providers' Local Market Share Holds Steady at 15%*. Market Report. 2023. URL: <https://www.srgresearch.com/articles/european-cloud-providers-local-market-share-now-holds-steady-at-15>.
- European Data Protection Board i European Data Protection Supervisor. *Initial Legal Assessment of the Impact of the US CLOUD Act on the European Union Legal Framework for Personal Data Protection*. Joint Response Annex. 2019. URL: https://www.edpb.europa.eu/sites/default/files/files/file2/edpb_edps_joint_response_us_cloudact_annex.pdf.
- Braud, Tristan i in. „Scaling the Gaia-X Lighthouse: An Analysis of European Data Infrastructure”. W: *Proceedings of the 2021 IEEE International Conference on Cloud Engineering (IC2E)*. IEEE, 2021. URL: <https://publikationen.bibliothek.kit.edu/1000139020>.
- Operator Chmury Krajowej. *OChK osiągnął pełną suwerenność cyfrową zgodnie z Cloud Sovereignty Framework Komisji Europejskiej*. Komunikat prasowy. Październik 2025. URL: <https://chmura.gov.pl>.
- Almutairi, Sulaiman i in. „Confidential Computing Using Trusted Execution Environments”. W: *International Journal of Advances in Internet of Big Data and Cloud Management System 3.1* (2024). URL: <https://ijaibdcms.org/index.php/ijaibdcms/article/view/240>.
- Urząd Komisji Nadzoru Finansowego. *Komunikat UKNF w sprawie przetwarzania przez podmioty nadzorowane informacji w chmurze obliczeniowej publicznej i hybrydowej*. Komunikat UKNF. Styczeń 2020. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/Komunikat_UKNF_Chmura_Obliczeniowa_68669.pdf.
- Komisja Europejska. *Commission Delegated Regulation (EU) 2024/1532 — RTS on ICT Risk Management Tools, Methods, Processes and Policies (DORA Article 15)*. Dz.Urz. UE. 2024. URL: https://ec.europa.eu/finance/docs/level-2-measures/dora-regulation-rtss--2024-1532_en.pdf.
- *Decyzja Komisji 2000/520/WE z dnia 26 lipca 2000 r. wydana na podstawie dyrektywy 95/46/WE Parlamentu Europejskiego i Rady w sprawie adekwatności ochrony przewidzianej przez zasady „bezpiecznej przystani” oraz związane z nimi najczęściej zadawane pytania, wydane przez Departament Handlu Stanów Zjednoczonych*. Dz.U. L 215 z 25.08.2000, s. 7–47. 2000.
- Trybunał Sprawiedliwości Unii Europejskiej. *Wyrok z dnia 6 października 2015 r., Maximilian Schrems przeciwko Data Protection Commissioner, C-362/14*. ECLI: EU:C:2015:650. Schrems I. 2015.
- *Wyrok z dnia 16 lipca 2020 r., Data Protection Commissioner przeciwko Facebook Ireland Ltd i Maximilian Schrems, C-311/18*. ECLI: EU:C:2020:559. Schrems II. 2020.
- Komisja Europejska. *Decyzja wykonawcza Komisji (UE) 2023/1795 z dnia 10 lipca 2023 r. wydana na podstawie rozporządzenia (UE) 2016/679 Parlamentu Europejskiego i*

- Rady w sprawie odpowiedniego poziomu ochrony danych osobowych na podstawie ram ochrony danych UE–USA*. Dz.U. UE L 231 z 20.09.2023. dokument C(2023) 4745. 2023.
- Parlament Europejski i Rada Unii Europejskiej. *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2023/2854 z dnia 13 grudnia 2023 r. w sprawie zharmonizowanych przepisów dotyczących sprawiedliwego dostępu do danych i ich wykorzystywania oraz w sprawie ich zmiany*. Stosowane od 12 września 2025 r. 22 grudnia 2023. URL: <https://data.europa.eu/eli/reg/2023/2854/oj> (dostęp 21.03.2026).
- European Union Agency for Cybersecurity (ENISA). *EUCS – Cloud Services Scheme: Draft Candidate Scheme for the European Cybersecurity Certification of Cloud Services*. Draft Candidate Scheme. ENISA, 2022. URL: <https://www.enisa.europa.eu/publications/eucs-cloud-service-scheme> (dostęp 21.03.2026).
- Komisja Europejska. *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*. Czerwiec 2026. URL: <https://digital-strategy.ec.europa.eu/pl/library/proposal-cloud-and-ai-development-act-cada> (dostęp 11.06.2026).
- *Commission Work Programme 2026*. Inicjatywa Cloud and AI Development Act (CADA) zapowiedziana na I kwartał 2026 r.; wniosek złożony 3 czerwca 2026 jako COM(2026) 502; podstawa prawna: art. 114 TFUE. 2025. URL: https://commission.europa.eu/document/09579818-64a6-4dd5-9577-446ab6219113_en (dostęp 21.03.2026).
- European Parliamentary Research Service (EPRS). *Cloud and AI Development Act*. Sprawozdanie techniczne EPRS_BRI(2025)779251. Europejski Parlament – EPRS, grudzień 2025. URL: [https://www.europarl.europa.eu/thinktank/en/document/EPRS_BRI\(2025\)779251](https://www.europarl.europa.eu/thinktank/en/document/EPRS_BRI(2025)779251) (dostęp 21.03.2026).
- Draghi, Mario. *The Future of European Competitiveness. A Competitiveness Strategy for Europe*. Bruksela: Komisja Europejska, wrzesień 2024. URL: https://commission.europa.eu/topics/strengthening-european-competitiveness/eu-competitiveness-looking-ahead_en (dostęp 21.03.2026).
- Microsoft Corporation. *Configure Windows diagnostic data in your organization*. Microsoft Learn. Dostęp: 2026-04-07. 2023. URL: <https://learn.microsoft.com/en-us/windows/privacy/configure-windows-diagnostic-data-in-your-organization>.
- Privacy Guides. *macOS Overview — Privacy and Telemetry*. Privacy Guides. Dostęp: 2026-04-07. 2025. URL: <https://www.privacyguides.org/en/os/macOS-overview/>.
- Fedora Project. *Changes/Telemetry — Fedora Project Wiki*. Fedora Project Wiki. Dostęp: 2026-04-07. 2024. URL: <https://fedoraproject.org/wiki/Changes/Telemetry>.
- Swimlane. *GRC Chaos: The High Price of Audits and Non-Compliance*. Sprawozdanie techniczne. Survey conducted by Sapio Research among 500 IT and cybersecurity decision-makers in the US and UK, March 2025. Swimlane, Inc., kwiecień 2025. URL: <https://swimlane.com/news/grc-audit-research/> (dostęp 10.03.2026).
- Henry, Brandon. „The Next Generation Cybersecurity Auditor: Technical Competency Gaps in 151,000 IT Auditors in the Audit Industry”. W: *Security Magazine* (październik 2022). Dotyczy luki kompetencyjnej między wiedzą deklaratywną a proceduralną u audytorów IT w firmach Big Four; wykazano 17% spadek poziomu wiedzy praktycznej względem teoretycznej. URL: <https://www.securitymagazine.com/articles/98555-technical-competency-gaps-in-151-000-it-auditors-in-the-audit-industry> (dostęp 10.03.2026).

- Friesen, Lana. „Designing Self-Reporting Regimes to Encourage Truth Telling”. W: *Journal of Economic Behavior & Organization* 95 (2013). DOI: 10.1016/j.jebo.2013.08.007. URL: <https://www.sciencedirect.com/science/article/abs/pii/S0167268113002072>.
- Peer, Eyal, Thomas Vanhoof i in. „Commitment to honesty oaths decreases dishonesty, but commitment to another individual does not”. W: *Communications Psychology* 1.1 (2023). DOI: 10.1038/s44271-023-00028-7. URL: <https://www.nature.com/articles/s44271-023-00028-7>.
- IBM. *What Is Shadow IT?* Dostęp: 2026. 2022. URL: <https://www.ibm.com/think/topics/shadow-it>.
- JumpCloud. *What Is Shadow IT? 2024 Statistics & Solutions*. Dostęp: 2026. 2024. URL: <https://jumpcloud.com/blog/shadow-it>.
- Capterra. *Shadow IT Report 2023*. Cytowane w: Auvik (2024), dostęp: 2026. 2023. URL: <https://www.capterra.com>.
- Josys. *Shadow IT Definition: 2024 Statistics and Solutions*. Dostęp: 2026. 2024. URL: <https://josys.com/article/article-shadow-it-shadow-it-definition-2024-statistics-and-solutions>.
- Kaspersky. *IT Security Economics Report 2023*. Cytowane w: ISACA Journal (2024), dostęp: 2026. 2023. URL: <https://www.kaspersky.com>.
- ISACA. „Risk in the Shadows”. W: *ISACA Journal* 6 (2024). Dostęp: 2026. URL: <https://www.isaca.org/resources/isaca-journal/issues/2024/volume-6/risk-in-the-shadows>.
- Grip Security. *How to Detect and Manage Shadow IT in 5 Steps*. Dostęp: 2026. 2025. URL: <https://www.grip.security/blog/5-steps-to-detect-and-control-shadow-it>.
- Gartner, Inc. *Gartner Predicts Forty Percent of AI Data Breaches Will Arise from Cross-Border GenAI Misuse by 2027*. Gartner Newsroom Press Release. Accessed: June 2026. Luty 2025. URL: <https://www.gartner.com/en/newsroom/press-releases/2025-02-17-gartner-predicts-forty-percent-of-ai-data-breaches-will-arise-from-cross-border-genai-misuse-by-2027>.
- LayerX Security. *Enterprise AI and SaaS Data Security Report 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. LayerX Security Ltd., 2025. URL: <https://www.cybersecurity-insiders.com/research-says-over-77-percent-of-data-is-shared-to-chatgpt-by-employees/>.
- Cyberhaven Labs. *11% of data employees paste into ChatGPT is confidential*. Dostęp: 10 marca 2026. 2023. URL: <https://www.cyberhaven.com/blog/4-2-of-workers-have-pasted-company-data-into-chatgpt>.
- Microsoft i LinkedIn. *2024 Work Trend Index Annual Report: AI at Work Is Here. Now Comes the Hard Part*. Sprawozdanie techniczne. Based on a survey of 31,000 professionals across 31 countries. Accessed: June 2026. Microsoft Corporation, maj 2024. URL: <https://www.microsoft.com/en-us/worklab/work-trend-index/ai-at-work-is-here-now-comes-the-hard-part>.
- European Parliament i Council of the European Union. *Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act)*. Entered into force: 1 August 2024. Accessed: June 2026. Lipiec 2024. URL: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689>.

- ISOQAR CEE. *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. ISOQAR CEE Sp. z o.o., 2024. URL: <https://www.isoqar.pl/pl/aktualnosci/bezpieczenstwo-informacji/blad-ludzki-cichy-sprawca-naruszen-bezpieczenstwa-informacji>.
- Verizon Business. *2024 Data Breach Investigations Report*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Verizon Communications Inc., 2024. URL: <https://www.verizon.com/business/resources/reports/dbir/>.
- BrandsIT. *Im mniej szkoleń, tym więcej ataków. Jak brak edukacji wpływa na cyberbezpieczeństwo firm*. Dostęp: 10 marca 2026. 2025. URL: <https://brandsit.pl/im-mniej-szkolen-tym-wiecej-atakow-jak-brak-edukacji-wplywa-na-cyberbezpieczenstwo-firm/>.
- CERT Polska / NASK. *Analiza bezpieczeństwa polskiego internetu w 2024 roku*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Ministerstwo Cyfryzacji / NASK PIB, 2025. URL: <https://www.gov.pl/web/baza-wiedzy/analiza-bezpieczenstwa-polskiego-internetu-w-2024-roku>.
- Keepnet Labs. *Security Awareness Training Statistics [Updated 2026]*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Keepnet Labs Ltd., 2026. URL: <https://keepnetlabs.com/blog/security-awareness-training-statistics>.
- PAP Biznes. *Cyberbezpieczeństwo najszybciej rosnącym segmentem rynku IT w Polsce*. Dostęp: 10 marca 2026. 2026. URL: <https://biznes.pap.pl/wiadomosci/gry-i-technologie/cyberbezpieczenstwo-najszybciej-rosnacym-segmentem-ryнку-it-w-polsce-w>.
- Autoriteit Financiële Markten (AFM). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna AFM. Informacje nt. wymogów DORA, w tym zarządzania ryzykiem ICT i obowiązków raportowania incydentów dla podmiotów finansowych. 2025. URL: <https://www.afm.nl/en/sector/themas/digitalisering/dora> (dostęp 10.03.2025).
- WifiTalents. *Shadow IT Statistics: Reports 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. WifiTalents, 2025. URL: <https://wifitalents.com/shadow-it-statistics/>.
- Data Protection People. *GDPR Data Breaches & Human Error: How Bad Is It?* Dostęp: 10 marca 2026. 2026. URL: <https://dataprotectionpeople.com/resource-centre/gdpr-data-breaches-human-error-how-bad-is-it/>.
- Agencia Española de Protección de Datos (AEPD). *Personal Data Breaches: Development and Pre-Production Environments*. Dostęp: 10 marca 2026. 2022. URL: <https://www.aepd.es/en/prensa-y-comunicacion/blog/data-breaches-development-and-pre-production-environments>.
- Preuveneers, Davy i in. „Re-pseudonymization Strategies for Smart Meter Data Are Not Robust to Deep Learning Profiling Attacks”. W: *arXiv preprint* (2024). DOI: 10.48550/arXiv.2404.03948. URL: <https://arxiv.org/abs/2404.03948>.
- Legal.io / Bloomberg Law. *AI Meeting Tools Raise Privacy, Privilege, and Discovery Risks for Employers*. Dostęp: 10 marca 2026. 2025. URL: <https://www.legal.io/articles/5767845/AI-Meeting-Tools-Raise-Privacy-Privilege-And-Discovery-Risks-For-Employers>.
- Privacy Partnership. *Why AI Transcription Bots Pose a Data Privacy Risk*. Dostęp: 10 marca 2026. 2025. URL: https://www.linkedin.com/posts/privacy-partnership_ai-bots-gdpr-activity-7387443108201787396-3dRL.

- MailIntelligence. *Human Error Cases in Enterprise Email Security 2024*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. MailIntelligence AI, 2024. URL: <https://mailintelligence.ai/reports/human-error-cases-2024>.
- Najwyższa Izba Kontroli. *RODO w szpitalu – wyniki kontroli*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Najwyższa Izba Kontroli, 2019. URL: <https://www.nik.gov.pl/najnowsze-informacje-o-wynikach-kontroli/rodo-w-szpitalu.html>.
- Gazeta Prawna. „Raport: w 2025 r. padły rekordowe kary za naruszenia RODO – najwyższa dla Poczty Polskiej”. W: *Gazeta Prawna* (2026). Dostęp: 10 marca 2026. URL: <https://www.gazetaprawna.pl/firma-i-prawo/artykuly/10648769,raport-w-2025-r-padly-rekordowe-kary-za-naruszenia-rodo-najwyzsza-.html>.
- ODO 24. *Naruszenia ochrony danych – jakie są zgłaszane najczęściej i jak można im zapobiegać*. Dostęp: 10 marca 2026. 2020. URL: <https://odo24.pl/blog-post-naruszenia-ochrony-danych-jakie-sa-zglaszane-najczesciej-i-w-jaki-sposob-mozna-im-zapobiegac>.
- Fidelis Security. *Shadow IT Risks, Examples, and Detection*. Dostęp: 10 marca 2026. 2026. URL: <https://fidelissecurity.com/cybersecurity-101/cloud-security/shadow-it-risks-examples-and-detection/>.
- Krosnick, Jon A. i in. „The Impact of “No Opinion” Response Options on Data Quality: Non-Attitude Reduction or an Invitation to Satisfice?” W: *Public Opinion Quarterly* 66.3 (2002), s. 371–403. DOI: 10.1086/341394.
- Dolnicar, Sara, Bettina Grün i Friedrich Leisch. „Quick, simple and reliable: forced binary survey questions”. W: *International Journal of Market Research* 53.2 (2011), s. 231–252. DOI: 10.2501/IJMR-53-2-231-252.
- Waters, Erika A. i in. „Dismissing “don’t know” responses to perceived risk survey questions”. W: *Sage Journals* (2021). DOI: 10.1177/17456916211017860.